Daily Debian

CompTIA Security+ SY0-701 Exam Practice Questions

611 Questions

Questions With Answers & Explanations

More PDFs: www.dailydebian.com

YouTube www.youtube.com/@DailyDebian

Instagram www.instagram.com/dailydebian

Question #1

Which of the following threat actors is the most likely to be hired by a foreign government to attack critical systems located in other countries?

A. Hacktivist
B. Whistleblower
C. Organized crime
D. Unskilled attacker

Correct Answer: C — Organized crime

Organized crime groups have the resources, capability, and profit motive to be hired by foreign governments for sophisticated cyberattacks on critical infrastructure. They operate as professional entities with established business relationships and can be contracted for high-value operations. Hacktivists are ideologically motivated rather than mercenary, whistleblowers leak information rather than attack systems, and unskilled attackers lack the sophistication required for critical infrastructure targeting.

Why The Other Options Are Incorrect

A. Hacktivists are ideologically motivated, not hired for profit by governments.
B. Whistleblowers disclose information rather than conduct attacks.
D. Unskilled attackers lack the sophistication to target critical systems effectively.

Question #2

Which of the following is used to add extra complexity before using a one-way data transformation algorithm?

A. Key stretching
B. Data masking
C. Steganography
D. Salting

Correct Answer: D — Salting

Salting adds random data to input before applying a one-way hash function, increasing complexity and preventing rainbow table attacks. It is specifically designed to add extra complexity before hashing. Key stretching is a related but distinct technique that applies hashing multiple times, data masking obscures sensitive data visibility, and steganography hides information within other media.

Why The Other Options Are Incorrect

A. Key stretching applies the algorithm repeatedly, not adding complexity before transformation.

B. Data masking obscures data visibility rather than adding cryptographic complexity.

C. Steganography hides information within media, unrelated to hash algorithms.

Question #3

An employee clicked a link in an email from a payment website that asked the employee to update contact information. The employee entered the log-in information but received a “page not found” error message.

Which of the following types of social engineering attacks occurred?

A. Brand impersonation

B. Pretexting

C. Typosquatting

D. Phishing

Correct Answer: D — Phishing

This scenario describes a classic phishing attack where an employee received a deceptive email from what appeared to be a payment website, clicked a link, and entered credentials on a fraudulent page. The 'page not found' error is typical when the phishing site has captured the credentials. Brand impersonation is the technique used but phishing is the attack type; pretexting involves creating false scenarios verbally; typosquatting involves domain name mimicry.

Why The Other Options Are Incorrect

A. Brand impersonation is the technique used within the phishing attack, not the attack type itself.

B. Pretexting typically involves direct communication and building false relationships, not fake websites.

C. Typosquatting involves slightly misspelled domain names, not exact impersonation in emails.

Question #4

An enterprise is trying to limit outbound DNS traffic originating from its internal network. Outbound DNS requests will only be allowed from one device with the IP address 10.50.10.25.

Which of the following firewall ACLs will accomplish this goal?

A. Access list outbound permit 0.0.0.0/0 0.0.0.0/0 port 53 Access list outbound deny 10.50.10.25/32 0.0.0.0/0 port 53

B. Access list outbound permit 0.0.0.0/0 10.50.10.25/32 port 53 Access list outbound deny 0.0.0.0/0 0.0.0.0/0 port 53

C. Access list outbound permit 0.0.0.0/0 0.0.0.0/0 port 53 Access list outbound deny 0.0.0.0/0 10.50.10.25/32 port 53

D. Access list outbound permit 10.50.10.25/32 0.0.0.0/0 port 53 Access list outbound deny 0.0.0.0/0 0.0.0.0/0 port 53

✅ Correct Answer: D — Access list outbound permit 10.50.10.25/32 0.0.0.0/0 port 53 Access list outbound deny 0.0.0.0/0 0.0.0.0/0 port 53

ACLs are processed top-to-bottom with first match wins. Option D permits DNS traffic only from 10.50.10.25 to any destination on port 53, then denies all other outbound DNS traffic. This correctly restricts DNS to the single authorized device. Options A and C deny the authorized device or permit then deny the same traffic illogically. Option B reverses source/destination incorrectly.

Why The Other Options Are Incorrect

A. This denies the authorized device (10.50.10.25) after permitting all others, opposite of the requirement.

B. This reverses source and destination in the first line, allowing all devices to send to 10.50.10.25.

C. This permits all outbound DNS first, making the second deny statement unreachable.

Question #5

A data administrator is configuring authentication for a SaaS application and would like to reduce the number of credentials employees need to maintain. The company prefers to use domain credentials to access new SaaS applications.

Which of the following methods would allow this functionality?

A. SSO

B. LEAP

C. MFA

D. PEAP

✅ Correct Answer: A — SSO

Single Sign-On (SSO) allows employees to use a single set of credentials (domain credentials) to authenticate to multiple applications, eliminating the need to maintain separate credentials for each SaaS application. LEAP and PEAP are wireless authentication protocols, not identity management solutions; MFA adds authentication factors but doesn't reduce credential management.

Why The Other Options Are Incorrect

B. LEAP is a wireless authentication protocol, not applicable to SaaS credential management.

C. MFA adds authentication factors but doesn't reduce the number of credential sets required.

D. PEAP is a wireless authentication protocol, not a SaaS credential management solution.

Question #6

Which of the following scenarios describes a possible business email compromise attack?

A. An employee receives a gift card request in an email that has an executive's name in the display field of the email.

B. Employees who open an email attachment receive messages demanding payment in order to access files.

C. A service desk employee receives an email from the HR director asking for log-in credentials to a cloud administrator account.

D. An employee receives an email with a link to a phishing site that is designed to look like the company's email portal.

✅ Correct Answer: C — A service desk employee receives an email from the HR director asking for log-in credentials to a cloud administrator account.

Business Email Compromise (BEC) attacks target employees with authority or access by impersonating executives or trusted contacts to request sensitive actions. Option C describes a classic BEC scenario where someone impersonating an HR director requests cloud administrator credentials from a service desk employee. Option A is gift card phishing, option B is ransomware, and option D is standard phishing to the email portal.

Why The Other Options Are Incorrect

A. Gift card requests represent basic phishing, not the sophisticated impersonation characteristic of BEC.

B. Email attachments causing ransomware describes malware delivery, not BEC social engineering.

D. Phishing links to company portals are standard phishing, not the account compromise targeting of BEC.

Question #7

A company prevented direct access from the database administrators' workstations to the network segment that contains database servers.

Which of the following should a database administrator use to access the database servers?

A. Jump server
B. RADIUS
C. HSM
D. Load balancer

Correct Answer: A — Jump server

A jump server (bastion host) is a hardened, monitored intermediary system that allows administrators to access restricted network segments without direct connectivity. It enforces access control and logging for administrative activities. RADIUS is an authentication protocol, HSM is for key management, and load balancers distribute traffic, none addressing the access restriction requirement.

Why The Other Options Are Incorrect

B. RADIUS is an authentication protocol, not a mechanism for accessing restricted network segments.

C. HSM (Hardware Security Module) manages cryptographic keys, not administrative access routing.

D. Load balancers distribute network traffic, not provide restricted access for administrators.

Question #8

An organization's internet-facing website was compromised when an attacker exploited a buffer overflow.

Which of the following should the organization deploy to best protect against similar attacks in the future?

A. NGFW
B. WAF
C. TLS
D. SD-WAN

Correct Answer: B — WAF

A Web Application Firewall (WAF) is specifically designed to protect web applications by analyzing HTTP/HTTPS traffic and detecting/blocking attacks like buffer overflows, SQL injection, and XSS at the application layer. NGFW operates at network layer, TLS provides encryption, and SD-WAN manages network connectivity; none specifically protect against application-level exploits.

Why The Other Options Are Incorrect

A. NGFW protects at the network layer and cannot detect application-level buffer overflow exploits.

C. TLS provides encryption in transit but cannot prevent buffer overflow exploitation.

D. SD-WAN manages network routing and connectivity, not application security threats.

Question #9

An administrator notices that several users are logging in from suspicious IP addresses. After speaking with the users, the administrator determines that the employees were not logging in from those IP addresses and resets the affected users' passwords.

Which of the following should the administrator implement to prevent this type of attack from succeeding in the future?

A. Multifactor authentication
B. Permissions assignment
C. Access management
D. Password complexity

✅ Correct Answer: A — Multifactor authentication

Multifactor authentication (MFA) would prevent unauthorized access even if credentials are compromised, since attackers would need a second authentication factor (such as a code from the user's phone) that only the legitimate user possesses. This directly addresses the scenario where passwords were stolen and used from suspicious locations.

Why The Other Options Are Incorrect

B. Permissions assignment controls what authenticated users can do, not who can authenticate.

C. Access management is too broad and doesn't specifically prevent credential-based attacks.

D. Password complexity alone doesn't prevent compromised passwords from being used by attackers.

Question #10

An employee receives a text message that appears to have been sent by the payroll department and is asking for credential verification.

Which of the following social engineering techniques are being attempted? (Choose two.)

A. Typosquatting
B. Phishing
C. Impersonation
D. Vishing

E. Smishing
F. Misinformation

Correct Answer: C, E

C. Impersonation
E. Smishing

Impersonation (C) is occurring because someone is pretending to be the payroll department, and smishing (E) is the specific technique of conducting phishing attacks via SMS text messages. These two elements combine to describe this attack scenario.

Why The Other Options Are Incorrect

A. Typosquatting involves creating fake websites with similar URLs, not text message impersonation.

B. Phishing is the broader category, but smishing is the specific technique used for text-based phishing.

D. Vishing is voice-based phishing, not text message-based.

F. Misinformation spreads false information, but this attack is specifically attempting credential theft through impersonation.

Question #11

Several employees received a fraudulent text message from someone claiming to be the Chief Executive Officer (CEO). The message stated:

“I’m in an airport right now with no access to email. I need you to buy gift cards for employee recognition awards. Please send the gift cards to following email address.”

Which of the following are the best responses to this situation? (Choose two).

A. Cancel current employee recognition gift cards.
B. Add a smishing exercise to the annual company training.
C. Issue a general email warning to the company.
D. Have the CEO change phone numbers.
E. Conduct a forensic investigation on the CEO’s phone.
F. Implement mobile device management.

Correct Answer: B, C

B. Add a smishing exercise to the annual company training.
C. Issue a general email warning to the company.

Adding a smishing exercise to annual training (B) educates employees to recognize and avoid similar attacks in the future, and issuing a general email warning (C) alerts the entire organization to the threat and prevents others from falling victim. These are appropriate

immediate and long-term preventive measures for this smishing attack.

Why The Other Options Are Incorrect

A. Canceling gift cards doesn't address the root cause or prevent future attacks.

D. Changing the CEO's phone number is reactive but doesn't prevent impersonation attacks since attackers can spoof numbers.

E. A forensic investigation on the CEO's phone won't prevent future smishing attacks against employees.

F. Mobile device management helps secure devices but doesn't specifically address or prevent smishing social engineering attacks.

Question #12

A company is required to use certified hardware when building networks.

Which of the following best addresses the risks associated with procuring counterfeit hardware?

A. A thorough analysis of the supply chain
B. A legally enforceable corporate acquisition policy
C. A right to audit clause in vendor contracts and SOWs
D. An in-depth penetration test of all suppliers and vendors

Correct Answer: A — A thorough analysis of the supply chain

A thorough analysis of the supply chain directly addresses counterfeit hardware risks by identifying vulnerabilities in procurement processes, verifying authenticity of suppliers, and ensuring products come from legitimate sources. This comprehensive approach is the best way to mitigate counterfeit hardware procurement risks.

Why The Other Options Are Incorrect

B. While a corporate acquisition policy is important, it doesn't specifically address the technical verification needed to identify counterfeits.

C. A right to audit clause helps verify compliance but is less comprehensive than full supply chain analysis for detecting counterfeit products.

D. Penetration testing evaluates security controls, not the authenticity or legitimacy of hardware products from suppliers.

Question #13

Which of the following provides the details about the terms of a test with a third-party penetration tester?

A. Rules of engagement

B. Supply chain analysis
C. Right to audit clause
D. Due diligence

✅ Correct Answer: A — Rules of engagement

Rules of engagement specifically document the terms, scope, timeline, authorized targets, and limitations of a penetration testing engagement with a third-party tester. This document defines what the tester can and cannot do during the assessment.

Why The Other Options Are Incorrect

B. Supply chain analysis reviews vendor procurement processes, not testing engagement terms.

C. A right to audit clause grants audit permissions but doesn't detail specific test terms and conditions.

D. Due diligence is a broader assessment process, not a specific document detailing engagement terms.

Question #14

A penetration tester begins an engagement by performing port and service scans against the client environment according to the rules of engagement.

Which of the following reconnaissance types is the tester performing?

A. Active
B. Passive
C. Defensive
D. Offensive

✅ Correct Answer: A — Active

Active reconnaissance involves direct engagement with target systems to gather information, such as performing port scans and service enumeration. These activities generate network traffic and are detectable, distinguishing them from passive reconnaissance which observes without direct interaction.

Why The Other Options Are Incorrect

B. Passive reconnaissance involves gathering information without directly interacting with systems, like reviewing public records.

C. Defensive reconnaissance is not a standard penetration testing term.

D. Offensive describes attacks, but the scanning phase is reconnaissance, not the offensive exploitation phase.

Question #15

Which of the following is required for an organization to properly manage its restore process in the event of system failure?

A. IRP
B. DRP
C. RPO
D. SDLC

Correct Answer: B — DRP

A Disaster Recovery Plan (DRP) is required to manage the restore process and recovery procedures following system failures. It defines recovery steps, timelines, and responsibilities. RPO relates to data loss tolerance, IRP to incident response, and SDLC to development, none of which specifically manage restoration processes.

Why The Other Options Are Incorrect

A. IRP (Incident Response Plan) addresses incident handling, not system restoration after failure.

C. RPO (Recovery Point Objective) defines acceptable data loss but doesn't manage the actual restore process.

D. SDLC (Software Development Life Cycle) governs software development, not disaster recovery and restoration.

Question #16

Which of the following vulnerabilities is associated with installing software outside of a manufacturer's approved software repository?

A. Jailbreaking
B. Memory injection
C. Resource reuse
D. Side loading

Correct Answer: D — Side loading

Side loading refers to installing software from sources outside the manufacturer's official repository, such as third-party app stores or directly from files. This practice bypasses the manufacturer's security reviews and vetting processes, introducing vulnerabilities and malware risks.

Why The Other Options Are Incorrect

A. Jailbreaking is the process of removing device restrictions, which may enable side loading but is not itself the vulnerability of installing from unapproved sources.

B. Memory injection involves code being inserted into memory at runtime, not related to software installation sources.

C. Resource reuse involves reusing computing resources with residual data, not software installation practices.

Question #17

A security analyst is reviewing the following logs:

```
[10:00:00 AM] Login rejected - username administrator - password Spring2023
[10:00:01 AM] Login rejected - username jsmith - password Spring2023
[10:00:01 AM] Login rejected - username guest - password Spring2023
[10:00:02 AM] Login rejected - username cpolk - password Spring2023
[10:00:03 AM] Login rejected - username fmartin - password Spring2023
```

Which of the following attacks is most likely occurring?

A. Password spraying
B. Account forgery
C. Pass-the-hash
D. Brute-force

Correct Answer: A — Password spraying

The logs show multiple failed login attempts using different usernames (administrator, jsmith, guest, cpolk, fmartin) with the SAME password (Spring2023) across a short time period. This is the defining characteristic of password spraying—an attacker tries a single password against many different accounts rather than trying many passwords against one account. The attacker is systematically testing whether the common password 'Spring2023' works across various user accounts in the system.

Why The Other Options Are Incorrect

B. Account forgery involves creating fake accounts or impersonating accounts, not attempting logins with wrong credentials.

C. Pass-the-hash is a technique that uses stolen password hashes to authenticate without knowing the plaintext password, not visible in login attempt logs.

D. Brute-force attacks involve repeatedly trying many different passwords against one or a few accounts, not trying one password against many accounts.

Question #18

An analyst is evaluating the implementation of Zero Trust principles within the data plane.

Which of the following would be most relevant for the analyst to evaluate?

A. Secured zones
B. Subject role
C. Adaptive identity
D. Threat scope reduction

Correct Answer: C — Adaptive identity

Adaptive identity is the most relevant evaluation criterion for Zero Trust in the data plane because it focuses on continuously verifying and reassessing user/device credentials and characteristics in real-time, which is fundamental to Zero Trust's verify-always approach. This enables dynamic access decisions based on current context rather than static permissions.

Why The Other Options Are Incorrect

A. Secured zones represent network segmentation, which is more relevant to the control plane than data plane evaluation.

B. Subject role is relevant to identity but doesn't capture the continuous, adaptive verification essential to Zero Trust data plane security.

D. Threat scope reduction is a general risk management concept, not specifically focused on data plane implementation details.

Question #19

An engineer needs to find a solution that creates an added layer of security by preventing unauthorized access to internal company resources.

Which of the following would be the best solution?

A. RDP server
B. Jump server
C. Proxy server
D. Hypervisor

Correct Answer: B — Jump server

A jump server (bastion host) is a hardened, monitored intermediary system that adds a security layer by requiring administrators to connect through it before accessing internal resources, enabling centralized logging, auditing, and control of administrative access.

Why The Other Options Are Incorrect

A. RDP servers are remote access tools but don't inherently add security layers or prevent unauthorized access to internal resources.

C. Proxy servers manage application-level traffic but are not specifically designed as access control barriers for internal resource protection.

D. Hypervisors are virtualization platforms with no direct role in preventing unauthorized access to company resources.

Question #20

A company's web filter is configured to scan the URL for strings and deny access when matches are found.

Which of the following search strings should an analyst employ to prohibit access to non-encrypted websites?

A. encryption=off
B. http://
C. www.*.com
D. :443

Correct Answer: B — http://

The search string 'http://' matches unencrypted web protocol URLs, allowing the filter to deny access to non-encrypted websites. HTTP traffic uses port 80 and lacks encryption, whereas HTTPS uses port 443 with encryption, making this the correct identifier for non-encrypted traffic.

Why The Other Options Are Incorrect

A. The string 'encryption=off' is not a standard component of URLs and would not reliably match non-encrypted websites.

C. The pattern 'www.*.com' matches domain names but does not distinguish between encrypted (HTTPS) and non-encrypted (HTTP) protocols.

D. The port ':443' is used by HTTPS, which is encrypted, making it the opposite of what needs to be blocked.

Question #21

During a security incident, the security operations team identified sustained network traffic from a malicious IP address: 10.1.4.9. A security analyst is creating an inbound firewall rule to block the IP address from accessing the organization's network.

Which of the following fulfills this request?

A. access-list inbound deny ip source 0.0.0.0/0 destination 10.1.4.9/32
B. access-list inbound deny ip source 10.1.4.9/32 destination 0.0.0.0/0
C. access-list inbound permit ip source 10.1.4.9/32 destination 0.0.0.0/0
D. access-list inbound permit ip source 0.0.0.0/0 destination 10.1.4.9/32

✅ **Correct Answer: B — access-list inbound deny ip source 10.1.4.9/32 destination 0.0.0.0/0**

Option B correctly denies inbound traffic from the malicious source IP (10.1.4.9/32) to any destination (0.0.0.0/0). It uses 'deny' to block the traffic and specifies the attacker's IP as the source, which is the proper direction for blocking inbound attacks.

Why The Other Options Are Incorrect

A. This rule denies traffic from all sources to the specific IP, which is backwards and doesn't block the malicious IP from attacking.

C. This rule permits (allows) traffic from the malicious IP, the opposite of what is needed to block it.

D. This rule permits traffic from all sources to the malicious IP, which both allows the attack and has incorrect permit logic.

Question #22

A company needs to provide administrative access to internal resources while minimizing the traffic allowed through the security boundary.

Which of the following methods is most secure?

A. Implementing a bastion host
B. Deploying a perimeter network
C. Installing a WAF
D. Utilizing single sign-on

Daily Debian

✅ **Correct Answer: A — Implementing a bastion host**

A bastion host (jump server) is the most secure method for providing administrative access while minimizing traffic through the security boundary because it acts as a hardened, monitored gateway that enforces strict access controls and centralized logging of all administrative activities.

Why The Other Options Are Incorrect

B. A perimeter network provides segmentation but doesn't specifically minimize administrative traffic or provide the centralized access control of a bastion host.

C. A WAF protects web applications but is not designed for securing administrative access to internal resources.

D. Single sign-on addresses authentication convenience but does not minimize traffic through security boundaries or provide the access control mechanisms of a bastion host.

Question #23

A security analyst is reviewing alerts in the SIEM related to potential malicious network traffic coming from an employee's corporate laptop. The security analyst has determined that additional data about the executable running on the machine is necessary to continue the investigation.

Which of the following logs should the analyst use as a data source?

A. Application
B. IPS/IDS
C. Network
D. Endpoint

Correct Answer: D — Endpoint

Endpoint logs are the appropriate data source because they contain detailed information about executables running on the laptop, including process names, file hashes, execution paths, and behavior artifacts necessary to identify and analyze malicious executable activity.

Why The Other Options Are Incorrect

A. Application logs record application-specific events but typically don't provide detailed executable process information needed for malware analysis.

B. IPS/IDS logs capture network-level signatures and anomalies but don't contain information about specific executables running on local systems.

C. Network logs show traffic patterns but lack visibility into which executables are running and their behavior on the endpoint itself.

Question #24

A cyber operations team informs a security analyst about a new tactic malicious actors are using to compromise networks.

SIEM alerts have not yet been configured.

Which of the following best describes what the security analyst should do to identify this behavior?

A. Digital forensics
B. E-discovery
C. Incident response
D. Threat hunting

Correct Answer: D — Threat hunting

Threat hunting is the best approach when new malicious tactics have not yet triggered

SIEM alerts. It involves proactive searching through network and system data to find indicators of compromise and new attack patterns before automated detection rules are configured.

Why The Other Options Are Incorrect

A. Digital forensics is a reactive technique used after incidents are detected, not for proactively identifying new attack behaviors.

B. E-discovery focuses on locating and retrieving data for legal proceedings, not on identifying new security threats.

C. Incident response is triggered by detected incidents, but threat hunting precedes that by seeking to find threats before they trigger alerts.

Question #25

A company purchased cyber insurance to address items listed on the risk register.

Which of the following strategies does this represent?

A. Accept
B. Transfer
C. Mitigate
D. Avoid

Correct Answer: B — Transfer

Purchasing cyber insurance represents the 'transfer' strategy because the organization is shifting the financial risk of potential breaches to an insurance company rather than mitigating, avoiding, or accepting the risk internally.

Why The Other Options Are Incorrect

A. Accept would mean acknowledging the risk and absorbing potential losses without purchasing insurance.

C. Mitigate involves implementing security controls to reduce risk, not transferring financial responsibility to insurers.

D. Avoid means eliminating the activity or asset that creates the risk, not purchasing insurance coverage for it.

Question #26

A security administrator would like to protect data on employees' laptops.

Which of the following encryption techniques should the security administrator use?

A. Partition
B. Asymmetric

C. Full disk
D. Database

Correct Answer: C — Full disk

Full disk encryption is the appropriate technique to protect data on laptops because it encrypts the entire storage device, protecting data at rest whether the laptop is powered on or off. This ensures that if a laptop is lost or stolen, the data remains protected. Partition is not an encryption technique, asymmetric encryption is not suitable for transparent data protection on entire disks, and database encryption only protects specific databases rather than all data on the device.

Why The Other Options Are Incorrect

A. Partition refers to dividing storage space, not an encryption technique.

B. Asymmetric encryption is impractical for transparent full-disk protection and uses key pairs rather than single encryption.

D. Database encryption only protects data within databases, not all data on the laptop.

Question #27

Which of the following security control types does an acceptable use policy best represent?

A. Detective
B. Compensating
C. Corrective
D. Preventive

Correct Answer: D — Preventive

An acceptable use policy is a preventive control because it establishes rules and guidelines designed to prevent employees from misusing company resources or violating security policies before violations occur. It sets expectations and boundaries to deter unwanted behavior. Detective controls identify violations after they occur, corrective controls remediate issues after detection, and compensating controls provide alternative protections when primary controls fail.

Why The Other Options Are Incorrect

A. Detective controls identify violations after they happen, not prevent them beforehand.

B. Compensating controls provide alternatives when primary controls are inadequate.

C. Corrective controls fix or remediate issues after they have already occurred.

Question #28

An IT manager informs the entire help desk staff that only the IT manager and the help desk lead will have access to the administrator console of the help desk software.

Which of the following security techniques is the IT manager setting up?

A. Hardening
B. Employee monitoring
C. Configuration enforcement
D. Least privilege

Correct Answer: D — Least privilege

The IT manager is implementing the principle of least privilege by restricting administrator console access to only the IT manager and help desk lead—the minimum number of individuals who require this level of access to perform their job duties. This limits potential damage from unauthorized access or misuse. Hardening involves securing systems through multiple methods, employee monitoring tracks user activities, and configuration enforcement ensures systems maintain desired settings.

Why The Other Options Are Incorrect

A. Hardening is a broader concept involving multiple security measures beyond access restrictions.

B. Employee monitoring tracks and records user activities rather than restricting access.

C. Configuration enforcement ensures systems maintain desired security settings, not about limiting who can access tools.

Question #29

Which of the following is the most likely to be used to document risks, responsible parties, and thresholds?

A. Risk tolerance
B. Risk transfer
C. Risk register
D. Risk analysis

Correct Answer: C — Risk register

A risk register is the formal document used to record identified risks, assign responsible parties, define risk thresholds, and track risk mitigation efforts throughout an organization. It serves as the central repository for risk management information. Risk tolerance defines an organization's willingness to accept risk, risk transfer involves shifting risk to another party, and risk analysis is the process of evaluating risks rather than documenting them in

a structured format.

Why The Other Options Are Incorrect

A. Risk tolerance refers to acceptable risk levels, not a document for recording specific risks and parties.

B. Risk transfer involves shifting risk responsibility, not documenting risks and thresholds.

D. Risk analysis is a process of evaluating risks, not a document for recording risks and responsible parties.

Question #30

Which of the following should a security administrator adhere to when setting up a new set of firewall rules?

A. Disaster recovery plan
B. Incident response procedure
C. Business continuity plan
D. Change management procedure

Correct Answer: D — Change management procedure

A change management procedure should be adhered to when setting up new firewall rules to ensure changes are documented, reviewed, approved, tested, and implemented in a controlled manner that minimizes disruption and security risks. This process prevents unauthorized or untested changes from affecting network security. A disaster recovery plan addresses recovery after incidents, incident response procedures handle active security events, and business continuity plans ensure operations continue during disruptions.

Why The Other Options Are Incorrect

A. A disaster recovery plan addresses recovery procedures after major incidents occur.

B. Incident response procedures address how to handle active security incidents, not routine configuration changes.

C. A business continuity plan ensures operations continue during disruptions, not specific to firewall rule implementation.

Question #31

A company is expanding its threat surface program and allowing individuals to security test the company's internet-facing application. The company will compensate researchers based on the vulnerabilities discovered.

Which of the following best describes the program the company is setting up?

A. Open-source intelligence
B. Bug bounty
C. Red team
D. Penetration testing

Correct Answer: B — Bug bounty

A bug bounty program compensates external researchers and security professionals for discovering and reporting vulnerabilities in a company's systems. This crowdsourced approach expands the scope of security testing beyond traditional methods. Open-source intelligence involves gathering public information, red team exercises simulate adversarial attacks in a controlled manner, and penetration testing is typically conducted by hired professionals under contract rather than a public compensation program.

Why The Other Options Are Incorrect

A. Open-source intelligence involves collecting and analyzing publicly available information, not testing systems.

C. Red team exercises are internal or contracted adversarial simulations, not crowdsourced public programs.

D. Penetration testing is typically contracted work, not a public compensation-based program for outside researchers.

Question #32

Which of the following threat actors is the most likely to use large financial resources to attack critical systems located in other countries?

A. Insider
B. Unskilled attacker
C. Nation-state
D. Hacktivist

Correct Answer: C — Nation-state

Nation-states possess the largest financial and technical resources, making them most likely to target critical infrastructure in other countries through sophisticated, well-funded cyber operations. They conduct campaigns aligned with geopolitical interests and have capabilities far exceeding other threat actors. Insiders lack external resources, unskilled attackers lack both resources and sophistication, and hacktivists are motivated by ideology rather than having substantial financial backing.

Why The Other Options Are Incorrect

A. Insiders lack access to large financial resources for sustained international attacks.

B. Unskilled attackers lack both financial resources and technical capability.

D. Hacktivists are typically motivated by ideology rather than possessing large financial resources.

Question #33

Which of the following enables the use of an input field to run commands that can view or manipulate data?

A. Cross-site scripting
B. Side loading
C. Buffer overflow
D. SQL injection

Correct Answer: D — SQL injection

SQL injection enables attackers to manipulate input fields to execute arbitrary SQL commands against databases, allowing them to view, modify, or delete data. The vulnerability occurs when user input is improperly validated before being included in SQL queries. Cross-site scripting injects malicious scripts into web pages, side loading refers to installing applications outside official channels, and buffer overflow exploits memory vulnerabilities rather than database query manipulation.

Why The Other Options Are Incorrect

A. Cross-site scripting injects malicious scripts into web pages viewed by other users.

B. Side loading involves installing applications from unofficial sources, not executing database commands.

C. Buffer overflow exploits memory management vulnerabilities, not input fields executing data queries.

Question #34

Employees in the research and development business unit receive extensive training to ensure they understand how to best protect company data.

Which of the following is the type of data these employees are most likely to use in day-to-day work activities?

A. Encrypted
B. Intellectual property
C. Critical
D. Data in transit

Correct Answer: B — Intellectual property

R&D employees work with proprietary research, trade secrets, and confidential innovations—all forms of intellectual property. This is the core asset they protect through their specialized training, making it the most likely type of data they use daily in their roles.

Why The Other Options Are Incorrect

A. Encryption is a security control/mechanism, not a data type.

C. Critical data is a classification level, but not specifically tied to R&D work.

D. Data in transit describes data movement, not a classification type R&D employees specifically handle.

Question #35

A company has begun labeling all laptops with asset inventory stickers and associating them with employee IDs.

Which of the following security benefits do these actions provide? (Choose two.)

A. If a security incident occurs on the device, the correct employee can be notified.

B. The security team will be able to send user awareness training to the appropriate device.

C. Users can be mapped to their devices when configuring software MFA tokens.

D. User-based firewall policies can be correctly targeted to the appropriate laptops.

E. When conducting penetration testing, the security team will be able to target the desired laptops.

F. Company data can be accounted for when the employee leaves the organization.

Correct Answer: A, F

A. If a security incident occurs on the device, the correct employee can be notified.

F. Company data can be accounted for when the employee leaves the organization.

Asset inventory stickers with employee ID associations enable two key security functions: notifying the correct employee when their device experiences a security incident (option A), and accounting for company data when an employee leaves the organization (option F). These directly support incident response and data accountability in the asset lifecycle.

Why The Other Options Are Incorrect

B. User awareness training is sent to employees, not devices; the mapping doesn't enable this benefit.

C. MFA token configuration uses identity management systems, not asset inventory stickers.

D. User-based firewall policies rely on identity/authentication systems, not physical

asset labels.

E. Penetration testing target selection uses network reconnaissance and scoping, not asset inventory stickers.

Question #36

A technician wants to improve the situational and environmental awareness of existing users as they transition from remote to in-office work.

Which of the following is the best option?

A. Send out periodic security reminders.
B. Update the content of new hire documentation.
C. Modify the content of recurring training.
D. Implement a phishing campaign.

Correct Answer: C — Modify the content of recurring training.

To improve situational and environmental awareness during a specific transition (remote to in-office), modifying recurring training content ensures the message reaches all users regularly with contextually relevant information about their changing work environment. This is more targeted and sustainable than one-time reminders and directly addresses the transition period.

Why The Other Options Are Incorrect

A. Periodic reminders are less formal and structured than training for behavioral change.

B. New hire documentation doesn't address existing users already in the workforce.

D. Phishing campaigns test awareness but don't proactively educate users about environmental changes.

Question #37

A newly appointed board member with cybersecurity knowledge wants the board of directors to receive a quarterly report detailing the number of incidents that impacted the organization. The systems administrator is creating a way to present the data to the board of directors.

Which of the following should the systems administrator use?

A. Packet captures
B. Vulnerability scans
C. Metadata
D. Dashboard

Correct Answer: D — Dashboard

A dashboard is the appropriate tool for presenting quarterly incident metrics to executive leadership. It provides visual, digestible summaries of key performance indicators—exactly what a board of directors needs for strategic decision-making, whereas the other options are technical data sources unsuitable for executive reporting.

Why The Other Options Are Incorrect

A. Packet captures are granular technical data, not executive summaries.

B. Vulnerability scans show vulnerabilities, not incident counts.

C. Metadata is raw technical information, not a presentation format for board reporting.

Question #38

A systems administrator receives the following alert from a file integrity monitoring tool:

The hash of the cmd.exe file has changed.

The systems administrator checks the OS logs and notices that no patches were applied in the last two months.

Which of the following most likely occurred?

A. The end user changed the file permissions.
B. A cryptographic collision was detected.
C. A snapshot of the file system was taken.
D. A rootkit was deployed.

Daily Debian

Correct Answer: D — A rootkit was deployed.

A changed hash on cmd.exe with no patches applied indicates unauthorized modification of a critical system file. This is a classic indicator of rootkit installation, which modifies system executables to maintain persistence and hide malicious activity. The lack of legitimate patching rules out other explanations.

Why The Other Options Are Incorrect

A. Permission changes don't alter file content or hashes.

B. Cryptographic collisions are theoretically possible but extremely rare and unrelated to patch history.

C. File system snapshots don't change the actual hash of the monitored file.

Question #39

Which of the following roles, according to the shared responsibility model, is responsible for securing the company's database in an IaaS model for a cloud environment?

A. Client
B. Third-party vendor
C. Cloud provider
D. DBA

Correct Answer: A — Client

In IaaS (Infrastructure as a Service), the cloud provider manages infrastructure while the client is responsible for securing applications and data, including databases. The client must implement database security controls, access management, encryption, and patches —making the client responsible for database security.

Why The Other Options Are Incorrect

B. Third-party vendors are not part of the standard shared responsibility model.

C. The cloud provider handles infrastructure; database security is the client's responsibility in IaaS.

D. DBAs are staff roles that work for the client organization implementing security controls.

Question #40

A client asked a security company to provide a document outlining the project, the cost, and the completion time frame.

Which of the following documents should the company provide to the client?

A. MSA
B. SLA
C. BPA
D. SOW

Correct Answer: D — SOW

A Statement of Work (SOW) is the appropriate document to outline project scope, deliverables, costs, and completion timeframes. It establishes the specific agreement between the security company and client for a defined engagement, making it the correct choice for this scenario.

Why The Other Options Are Incorrect

A. Master Service Agreement (MSA) covers general terms and conditions for ongoing relationships, not specific project details.

B. Service Level Agreement (SLA) defines performance metrics and uptime guarantees, not project scope and cost.

C. Business Partnership Agreement (BPA) establishes long-term partnership terms, not

individual project parameters.

Question #41

A security team is reviewing the findings in a report that was delivered after a third party performed a penetration test. One of the findings indicated that a web application form field is vulnerable to cross-site scripting.

Which of the following application security techniques should the security analyst recommend the developer implement to prevent this vulnerability?

A. Secure cookies
B. Version control
C. Input validation
D. Code signing

Correct Answer: C — Input validation

Input validation prevents cross-site scripting (XSS) by filtering, sanitizing, or rejecting malicious script input before it's processed by the application. This is the fundamental defense against XSS vulnerabilities in web forms, ensuring user-supplied data cannot execute malicious code.

Why The Other Options Are Incorrect

A. Secure cookies protect session tokens but don't prevent XSS injection in form fields.

B. Version control manages code changes but doesn't prevent XSS vulnerabilities.

D. Code signing verifies code authenticity but doesn't validate user input to prevent XSS.

Question #42

Which of the following must be considered when designing a high-availability network? (Choose two).

A. Ease of recovery
B. Ability to patch
C. Physical isolation
D. Responsiveness
E. Attack surface
F. Extensible authentication

Correct Answer: A, D

A. Ease of recovery

D. Responsiveness

When designing a high-availability network, ease of recovery (A) is essential because systems must be restored quickly to minimize downtime. Responsiveness (D) is critical because HA networks must respond rapidly to failures and maintain service continuity. Physical isolation relates to security segmentation rather than availability design, ability to patch is an operational concern not a core HA design principle, attack surface is a security consideration, and extensible authentication is an identity management feature—none directly address the core availability requirements.

Why The Other Options Are Incorrect

B. Ability to patch is an operational concern but not a core design consideration for high availability.

C. Physical isolation relates to security segmentation, not HA network design principles.

E. Attack surface is a security metric, not a design consideration for high availability.

F. Extensible authentication is an identity management feature unrelated to HA design.

Question #43

A technician needs to apply a high-priority patch to a production system.

Which of the following steps should be taken first?

A. Air gap the system.

B. Move the system to a different network segment.

C. Create a change control request.

D. Apply the patch to the system.

Correct Answer: C — Create a change control request.

Creating a change control request must be the first step before applying any patch to production systems. This ensures proper documentation, risk assessment, approval workflows, and stakeholder notification occur before making changes. Air-gapping or moving systems are responses to security incidents, not standard patch procedures. Applying the patch without change control violates established change management practices and could cause unforeseen issues.

Why The Other Options Are Incorrect

A. Air-gapping is a response to active security threats, not a step for routine patching.

B. Moving the system is not necessary for patch deployment if change control is followed.

D. Applying the patch immediately skips required change management approval and documentation.

Question #44

Which of the following describes the reason root cause analysis should be conducted as part of incident response?

A. To gather IoCs for the investigation
B. To discover which systems have been affected
C. To eradicate any trace of malware on the network
D. To prevent future incidents of the same nature

Correct Answer: D — To prevent future incidents of the same nature

Root cause analysis identifies the underlying factors that led to the incident, which is essential for preventing similar incidents from occurring in the future. This forward-looking approach addresses systemic issues, security gaps, and process improvements. While IoC gathering, affected systems discovery, and malware eradication are all part of incident response, they address immediate containment and investigation rather than the specific purpose of root cause analysis.

Why The Other Options Are Incorrect

A. Gathering IoCs is part of investigation but not the primary purpose of root cause analysis.

B. Discovering affected systems is part of scoping but not the purpose of root cause analysis.

C. Eradicating malware is remediation; root cause analysis explains why the infection occurred.

Daily Debian

Question #45

Which of the following is the most likely outcome if a large bank fails an internal PCI DSS compliance assessment?

A. Fines
B. Audit findings
C. Sanctions
D. Reputation damage

Correct Answer: B — Audit findings

An internal compliance assessment failure results in audit findings that document non-compliance issues. These findings form the basis for remediation efforts. While external assessments can lead to fines, and failures may eventually impact reputation and result in regulatory sanctions, the immediate direct outcome of a failed internal assessment is documented audit findings that the organization uses to track and address compliance

gaps.

Why The Other Options Are Incorrect

A. Fines are typically imposed by external auditors or regulatory bodies, not from internal assessments.

C. Sanctions are formal regulatory penalties, not the primary outcome of internal assessment failures.

D. Reputation damage is a potential long-term consequence but not the direct outcome of the assessment.

Question #46

A company is developing a business continuity strategy and needs to determine how many staff members would be required to sustain the business in the case of a disruption.

Which of the following best describes this step?

A. Capacity planning
B. Redundancy
C. Geographic dispersion
D. Tabletop exercise

Daily Debian

Correct Answer: A — Capacity planning

Capacity planning is the process of determining the resources—including staffing levels—needed to maintain business operations during a disruption. This directly addresses the question of how many staff members are required to sustain the business. Redundancy refers to backup systems, geographic dispersion addresses location-based resilience, and tabletop exercises are simulation activities for testing plans, none of which specifically address staffing capacity requirements.

Why The Other Options Are Incorrect

B. Redundancy involves backup systems and components, not workforce capacity planning.

C. Geographic dispersion addresses distributing operations across locations, not staffing capacity.

D. Tabletop exercises test BC plans but do not determine staffing requirements.

Question #47

A company's legal department drafted sensitive documents in a SaaS application and wants to ensure the documents cannot be accessed by individuals in high-risk countries.

Which of the following is the most effective way to limit this access?

A. Data masking
B. Encryption
C. Geolocation policy
D. Data sovereignty regulation

Correct Answer: C — Geolocation policy

A geolocation policy directly restricts access based on geographic location, preventing users in high-risk countries from accessing the documents. This is the most effective and straightforward method to enforce location-based access restrictions. Data masking obscures data content but doesn't prevent access, encryption protects data in transit/rest but doesn't restrict who can decrypt it, and data sovereignty regulations are compliance frameworks rather than access control mechanisms.

Why The Other Options Are Incorrect

A. Data masking obscures sensitive content but does not prevent access from restricted locations.

B. Encryption protects data confidentiality but does not inherently restrict access by geography.

D. Regulations provide compliance requirements but are not technical controls that enforce access restrictions.

Question #48

Which of the following is a hardware-specific vulnerability?

A. Firmware version
B. Buffer overflow
C. SQL injection
D. Cross-site scripting

Correct Answer: A — Firmware version

Firmware version is hardware-specific because firmware is the low-level software programmed into hardware devices that controls their operation. Outdated or vulnerable firmware versions represent hardware-level security weaknesses. Buffer overflow, SQL injection, and cross-site scripting are all software-level vulnerabilities that can exist across different platforms and are not specific to hardware.

Why The Other Options Are Incorrect

B. Buffer overflow is a software coding vulnerability, not hardware-specific.

C. SQL injection is a database/application-level vulnerability, not hardware-specific.

D. Cross-site scripting is a web application vulnerability, not hardware-specific.

Question #49

While troubleshooting a firewall configuration, a technician determines that a “deny any” policy should be added to the bottom of the ACL. The technician updates the policy, but the new policy causes several company servers to become unreachable.

Which of the following actions would prevent this issue?

A. Documenting the new policy in a change request and submitting the request to change management

B. Testing the policy in a non-production environment before enabling the policy in the production network

C. Disabling any intrusion prevention signatures on the “deny any” policy prior to enabling the new policy

D. Including an “allow any” policy above the “deny any” policy

✅ Correct Answer: B — Testing the policy in a non-production environment before enabling the policy in the production network

Testing the policy in a non-production environment first would have identified the issue before it impacted production servers. This preventive approach catches unintended consequences before they affect business operations. While documentation and change management are important, they don't prevent the issue from occurring. Including an "allow any" policy would defeat the security purpose of the deny rule. Disabling IPS signatures is a security risk and doesn't address the underlying ACL logic problem.

Why The Other Options Are Incorrect

A. Change management documentation doesn't prevent the policy from causing server unreachability.

C. Disabling IPS signatures reduces security and does not address the ACL configuration issue.

D. Adding an "allow any" above "deny any" defeats the security purpose of implementing the deny rule.

Question #50

An organization is building a new backup data center with cost-benefit as the primary requirement and RTO and RPO values around two days.

Which of the following types of sites is the best for this scenario?

A. Real-time recovery

B. Hot

C. Cold
D. Warm

Correct Answer: C — Cold

A cold site is the most cost-effective backup data center option, which aligns with the organization's primary requirement of cost-benefit. With RTO and RPO values around two days, the organization can tolerate the extended recovery time required to activate and configure a cold site, making it the optimal choice when cost is the primary driver.

Why The Other Options Are Incorrect

A. Real-time recovery requires active mirroring and is the most expensive option.

B. Hot sites are fully operational and immediately available, but they are significantly more costly than cold sites.

D. Warm sites are a middle ground between hot and cold, providing faster recovery than cold but at higher cost than necessary for two-day RTO/RPO requirements.

Question #51

A company requires hard drives to be securely wiped before sending decommissioned systems to recycling.

Which of the following best describes this policy?

A. Enumeration
B. Sanitization
C. Destruction
D. Inventory

Correct Answer: B — Sanitization

Sanitization is the process of securely wiping, erasing, or overwriting data on storage devices before they are decommissioned or recycled. This policy ensures that sensitive data cannot be recovered from hard drives that are sent to recycling, which is exactly what the scenario describes.

Why The Other Options Are Incorrect

A. Enumeration is the process of discovering and listing systems and assets, not related to secure data removal.

C. Destruction involves physically destroying the media itself, which is more extreme than sanitization and would prevent recycling.

D. Inventory is the process of tracking and cataloging assets, not related to secure data removal.

Question #52

A systems administrator works for a local hospital and needs to ensure patient data is protected and secure.

Which of the following data classifications should be used to secure patient data?

A. Private
B. Critical
C. Sensitive
D. Public

Correct Answer: C — Sensitive

Patient data in a hospital setting, such as Protected Health Information (PHI), should be classified as Sensitive. Sensitive data classification indicates information that requires strong protections and controlled access, which is the appropriate level for healthcare data subject to regulations like HIPAA.

Why The Other Options Are Incorrect

A. Private is a less stringent classification than Sensitive and does not adequately reflect the regulatory requirements of patient data.

B. Critical typically refers to systems and operations essential for business continuity, not a primary data classification for patient information.

D. Public indicates data with no restriction on access or disclosure, which is completely inappropriate for patient data.

Daily Debian

Question #53

A U.S.-based cloud-hosting provider wants to expand its data centers to new international locations.

Which of the following should the hosting provider consider first?

A. Local data protection regulations
B. Risks from hackers residing in other countries
C. Impacts to existing contractual obligations
D. Time zone differences in log correlation

Correct Answer: A — Local data protection regulations

When expanding to international locations, the hosting provider must first consider local data protection regulations such as GDPR, CCPA, and other regional privacy laws. These legal and compliance requirements directly impact how data can be stored, processed, and transferred, making them the primary consideration before any other factors.

Why The Other Options Are Incorrect

B. While cybersecurity threats are important, they are not the primary first consideration compared to legal compliance requirements.

C. Contractual obligations are important but follow from understanding the regulatory landscape that governs the new locations.

D. Time zone differences are operational considerations that come later in the planning process, not a primary first consideration.

Question #54

Which of the following would be the best way to block unknown programs from executing?

A. Access control list
B. Application allow list
C. Host-based firewall
D. DLP solution

Correct Answer: B — Application allow list

An application allow list (also called application whitelisting) is a security control that explicitly defines which programs are permitted to execute on a system. Any program not on the allow list is blocked from running, which directly prevents unknown and potentially malicious programs from executing.

Why The Other Options Are Incorrect

A. Access control lists regulate file and resource permissions but do not control which programs can execute.

C. A host-based firewall controls network traffic to and from a system but does not block unknown program execution.

D. DLP (Data Loss Prevention) solutions monitor and protect data but do not prevent unknown programs from executing.

Question #55

A company hired a consultant to perform an offensive security assessment covering penetration testing and social engineering.

Which of the following teams will conduct this assessment activity?

A. White
B. Purple
C. Blue

D. Red

✅ Correct Answer: D — Red

The Red Team conducts offensive security assessments, including penetration testing and social engineering attacks. Their role is to simulate adversary behavior and identify vulnerabilities from an attacker's perspective, which is exactly what the scenario describes.

Why The Other Options Are Incorrect

A. The White Team typically acts as a neutral referee or judge in security exercises.

B. The Purple Team is a hybrid approach combining red and blue team activities for collaborative improvement.

C. The Blue Team is defensive in nature, focusing on protecting systems and responding to attacks rather than conducting offensive assessments.

Question #56

A software development manager wants to ensure the authenticity of the code created by the company.

Which of the following options is the most appropriate?

A. Testing input validation on the user input fields
B. Performing code signing on company-developed software
C. Performing static code analysis on the software
D. Ensuring secure cookies are use

✅ Correct Answer: B — Performing code signing on company-developed software

Code signing involves digitally signing company-developed software with a cryptographic signature, which proves the code's authenticity and origin. This ensures that the code has not been tampered with and that it genuinely comes from the company, addressing the requirement to ensure code authenticity.

Why The Other Options Are Incorrect

A. Input validation testing focuses on security vulnerabilities, not on verifying code authenticity and origin.

C. Static code analysis identifies bugs and vulnerabilities but does not establish the authenticity or origin of the code.

D. Secure cookies protect session data but have no relationship to proving the authenticity of company-developed software.

Question #57

Which of the following can be used to identify potential attacker activities without affecting production servers?

A. Honeypot
B. Video surveillance
C. Zero Trust
D. Geofencing

Correct Answer: A — Honeypot

A honeypot is a decoy system designed to attract and detect attacker activities without affecting production systems. It logs all interactions with the honeypot, allowing security teams to identify potential attacker behavior and techniques while keeping actual production systems unimpacted.

Why The Other Options Are Incorrect

B. Video surveillance monitors physical access but does not specifically identify attacker activities on systems.

C. Zero Trust is an access control framework, not a tool for identifying attacker activities without affecting production.

D. Geofencing restricts access based on location but does not identify or detect attacker activities on systems.

Daily Debian

Question #58

During an investigation, an incident response team attempts to understand the source of an incident.

Which of the following incident response activities describes this process?

A. Analysis
B. Lessons learned
C. Detection
D. Containment

Correct Answer: A — Analysis

Analysis is the incident response phase where the team investigates and understands the source, cause, and nature of an incident. During analysis, responders examine evidence, logs, and artifacts to determine what happened and how the incident occurred. Detection is identifying that an incident occurred, Containment is stopping the spread, and Lessons Learned occurs after the incident is resolved.

Why The Other Options Are Incorrect

B. Lessons learned is the post-incident review phase, not the investigation phase.

C. Detection is the phase of discovering that an incident has occurred, not understanding its source.

D. Containment is the phase of stopping the spread of an incident, not investigating its source.

Question #59

A security practitioner completes a vulnerability assessment on a company's network and finds several vulnerabilities, which the operations team remediates.

Which of the following should be done next?

A. Conduct an audit.
B. Initiate a penetration test.
C. Rescan the network.
D. Submit a report.

✅ **Correct Answer: C — Rescan the network.**

After remediation efforts are completed, rescanning the network is the essential next step to verify that vulnerabilities have been successfully fixed and to ensure the remediation was effective. This validates that the security controls are working and closes the loop on the vulnerability management process. A report would come after verification, and a penetration test is a more advanced assessment typically done separately.

Why The Other Options Are Incorrect

A. An audit is a compliance check, not necessarily the next step after remediation verification.

B. A penetration test is typically scheduled separately and is not the immediate next step after vulnerability remediation.

D. A report should be submitted after verifying that remediation was successful through rescanning.

Question #60

An administrator was notified that a user logged in remotely after hours and copied large amounts of data to a personal device.

Which of the following best describes the user's activity?

A. Penetration testing
B. Phishing campaign
C. External audit

D. Insider threat

Correct Answer: D — Insider threat

An insider threat describes malicious or negligent activity by an authorized user with access to organizational systems and data. The scenario of a user logging in remotely after hours and copying large amounts of customer data to a personal device is a classic example of insider threat behavior—unauthorized data exfiltration by someone with legitimate credentials. This is not penetration testing, phishing, or an external audit.

Why The Other Options Are Incorrect

A. Penetration testing is authorized security testing, not unauthorized data copying by employees.

B. Phishing is a social engineering attack targeting users, not the exfiltration of data by an authenticated user.

C. An external audit is a legitimate, authorized review process, not unauthorized after-hours data copying.

Question #61

Which of the following allows for the attribution of messages to individuals?

A. Adaptive identity
B. Non-repudiation
C. Authentication
D. Access logs

Correct Answer: B — Non-repudiation

Non-repudiation is the security property that ensures a person cannot deny having sent a message or performed an action. Through digital signatures and other cryptographic mechanisms, non-repudiation attributes messages to specific individuals and proves they originated from that person. Authentication verifies identity but doesn't prevent denial, access logs record activity but aren't a security principle, and adaptive identity manages identity context but doesn't prevent repudiation.

Why The Other Options Are Incorrect

A. Adaptive identity manages identity verification based on context, not message attribution.

C. Authentication verifies who someone is but doesn't prevent them from denying they sent a message.

D. Access logs record activity but are not a security principle that ensures message attribution or prevents denial.

Question #62

Which of the following is the best way to consistently determine on a daily basis whether security settings on servers have been modified?

A. Automation
B. Compliance checklist
C. Attestation
D. Manual audit

Correct Answer: A — Automation

Automation is the best approach for consistently determining daily whether security settings have been modified because it can continuously monitor, scan, and report on configuration changes without human intervention. Automated tools can compare current settings against baselines and alert when deviations occur. A compliance checklist requires manual effort, attestation is a confirmation process, and manual audits are not scalable for daily consistency.

Why The Other Options Are Incorrect

B. A compliance checklist is a static tool that requires manual execution and is not suitable for consistent daily monitoring.

C. Attestation is a formal acknowledgment but does not actively detect configuration modifications.

D. Manual audits are labor-intensive and cannot provide the consistent daily monitoring needed for this purpose.

Question #63

Which of the following tools can assist with detecting an employee who has accidentally emailed a file containing a customer's PII?

A. SCAP
B. NetFlow
C. Antivirus
D. DLP

Correct Answer: D — DLP

Data Loss Prevention (DLP) tools are specifically designed to detect and prevent sensitive data from being transmitted outside the organization, including through email. DLP can identify personally identifiable information (PII) patterns and block or alert on emails containing such data. SCAP is for compliance assessment, NetFlow is for network traffic analysis, and antivirus focuses on malware, none of which are specifically designed to

detect accidental PII transmission.

Why The Other Options Are Incorrect

A. SCAP is a compliance framework for security configuration, not for detecting data in emails.

B. NetFlow analyzes network traffic patterns but is not designed to detect PII in email communications.

C. Antivirus detects malicious software, not sensitive data patterns in emails.

Question #64

An organization recently updated its security policy to include the following statement:

Regular expressions are included in source code to remove special characters such as $, |, ;. &, `, and ? from variables set by forms in a web application.

Which of the following best explains the security technique the organization adopted by making this addition to the policy?

A. Identify embedded keys
B. Code debugging
C. Input validation
D. Static code analysis

Daily Debian

Correct Answer: C — Input validation

Input validation is the security technique being described—using regular expressions to filter and remove potentially dangerous special characters from form input variables. This prevents attackers from injecting malicious code or commands through special characters that could be used in attacks like SQL injection or command injection. The other options describe different security activities unrelated to filtering user input.

Why The Other Options Are Incorrect

A. Identifying embedded keys is about finding hardcoded credentials, not about filtering special characters from input.

B. Code debugging is about finding and fixing software bugs, not implementing security filtering controls.

D. Static code analysis examines code for vulnerabilities but is different from implementing input validation rules in policy.

Question #65

A security analyst and the management team are reviewing the organizational performance of a recent phishing campaign. The user click-through rate exceeded the

acceptable risk threshold, and the management team wants to reduce the impact when a user clicks on a link in a phishing message.

Which of the following should the analyst do?

A. Place posters around the office to raise awareness of common phishing activities.
B. Implement email security filters to prevent phishing emails from being delivered.
C. Update the EDR policies to block automatic execution of downloaded programs.
D. Create additional training for users to recognize the signs of phishing attempts.

✅ Correct Answer: C — Update the EDR policies to block automatic execution of downloaded programs.

Updating EDR (Endpoint Detection and Response) policies to block automatic execution of downloaded programs directly reduces the impact when a user clicks a malicious link. This technical control prevents the automatic execution of potentially malicious payloads that might be downloaded as a result of the click, effectively containing the damage. While awareness and email filters are preventive, the question specifically asks how to reduce impact when users click links, making technical mitigation through EDR the best approach.

Why The Other Options Are Incorrect

A. Posters raise awareness but do not reduce the impact of clicks that already occur.

B. Email security filters prevent delivery but do not address the scenario where users have already clicked links.

D. Additional training is preventive but does not reduce the impact of clicks that have already happened from users who missed the phishing attempts.

Question #66

Which of the following has been implemented when a host-based firewall on a legacy Linux system allows connections from only specific internal IP addresses?

A. Compensating control
B. Network segmentation
C. Transfer of risk
D. SNMP traps

✅ Correct Answer: A — Compensating control

A host-based firewall restricting connections to specific internal IP addresses is a compensating control—a security measure implemented to mitigate risk when standard controls are unavailable or inadequate. On a legacy Linux system where other security measures may be limited, the firewall serves as an alternative control to protect the system. This is not network segmentation (which is broader network architecture), risk transfer (which involves shifting risk to another party), or SNMP traps (which are

monitoring alerts).

Why The Other Options Are Incorrect

B. Network segmentation refers to dividing a network into subnets; a single host firewall rule is not network segmentation.

C. Transfer of risk involves shifting risk responsibility to another party, such as through insurance; a firewall implements risk mitigation, not transfer.

D. SNMP traps are network monitoring alerts used to send notifications about network conditions; they are not related to firewall access control.

Question #67

The management team notices that new accounts that are set up manually do not always have correct access or permissions.

Which of the following automation techniques should a systems administrator use to streamline account creation?

A. Guard rail script
B. Ticketing workflow
C. Escalation script
D. User provisioning script

Correct Answer: D — User provisioning script

A user provisioning script automates the account creation process, ensuring that new accounts are created with correct access and permissions consistently. This directly addresses the problem of manual account setup errors by standardizing the configuration and applying predefined permission templates. Guard rail scripts restrict user actions, ticketing workflows manage request processes, and escalation scripts handle approval chains—none of these specifically automate account creation with proper permissions.

Why The Other Options Are Incorrect

A. Guard rail scripts constrain or limit user actions rather than automate account creation with proper permissions.

B. Ticketing workflow manages the request process but does not automate the technical account creation and permission assignment.

C. Escalation scripts handle approval routing and notifications, not the actual account creation and permission configuration.

Question #68

A company is planning to set up a SIEM system and assign an analyst to review the logs on a weekly basis.

Which of the following types of controls is the company setting up?

A. Corrective
B. Preventive
C. Detective
D. Deterrent

✅ Correct Answer: C — Detective

A SIEM system that analyzes logs to detect security incidents is a detective control—it identifies and responds to events that have already occurred. The weekly analyst review represents the detection and investigation phase after malicious activity has happened. Preventive controls stop attacks before they occur, corrective controls fix damage after detection, and deterrent controls discourage attacks through visible security measures.

Why The Other Options Are Incorrect

A. Corrective controls address and remedy issues after they are detected; SIEM primarily detects rather than corrects.

B. Preventive controls stop attacks before they happen; SIEM operates after events have occurred.

D. Deterrent controls discourage attackers through visible security measures; SIEM is not a visible deterrent but an internal detection system.

Question #69

A systems administrator is looking for a low-cost application-hosting solution that is cloud-based.

Which of the following meets these requirements?

A. Serverless framework
B. Type 1 hypervisor
C. SD-WAN
D. SDN

✅ Correct Answer: A — Serverless framework

A serverless framework is a cloud-based application hosting solution that offers low cost because users pay only for actual code execution without provisioning or managing servers. This directly meets both requirements: it is cloud-based and cost-effective. Type 1 hypervisor is physical virtualization infrastructure (not cloud-hosted), SD-WAN and SDN are network technologies used for network management, not application hosting.

Why The Other Options Are Incorrect

B. Type 1 hypervisors run directly on hardware and require on-premises infrastructure;

they are not cloud-based solutions.

C. SD-WAN (Software-Defined WAN) manages wide-area networks, not application hosting.

D. SDN (Software-Defined Networking) is a networking architecture approach; it does not provide application hosting capabilities.

Question #70

A security operations center determines that the malicious activity detected on a server is normal.

Which of the following activities describes the act of ignoring detected activity in the future?

A. Tuning
B. Aggregating
C. Quarantining
D. Archiving

Correct Answer: A — Tuning

Tuning is the process of adjusting SIEM rules and thresholds to reduce false positives and alert fatigue by ignoring known benign activity in the future. When the SOC determines that detected activity is normal rather than malicious, tuning suppresses similar future alerts. Aggregating combines related events, quarantining isolates threats, and archiving stores historical data—none of these describe ignoring future detections of the same activity.

Why The Other Options Are Incorrect

B. Aggregating combines multiple related alerts or events into a single alert for easier analysis, not ignoring future activity.

C. Quarantining isolates affected systems to prevent spread of threats, not related to ignoring future alerts.

D. Archiving stores logs and data for retention and historical reference, not for suppressing future alert notifications.

Question #71

A security analyst reviews domain activity logs and notices the following:

```
UserID jsmith, password authentication: succeeded, MFA: failed (invalid code)
UserID jsmith, password authentication: succeeded, MFA: failed (invalid code)
UserID jsmith, password authentication: succeeded, MFA: failed (invalid code)
UserID jsmith, password authentication: succeeded, MFA: failed (invalid code)
```

Which of the following is the best explanation for what the security analyst has discovered?

A. The user jsmith's account has been locked out.
B. A keylogger is installed on jsmith's workstation.
C. An attacker is attempting to brute force jsmith's account.
D. Ransomware has been deployed in the domain.

✅ Correct Answer: C — An attacker is attempting to brute force jsmith's account.

The log shows multiple consecutive failed MFA attempts for the same user account (jsmith) after successful password authentication. This pattern is characteristic of a brute force attack where an attacker has obtained valid credentials and is systematically trying different MFA codes to gain access. The repetitive nature of identical failed authentication attempts within a short timeframe indicates an automated attack rather than a legitimate user making occasional mistakes.

Why The Other Options Are Incorrect

A. Account lockout would typically result in a different log message indicating the account is locked, not repeated failed MFA attempts.

B. A keylogger would capture credentials but wouldn't cause multiple failed MFA authentication attempts; the attacker would either succeed or have the correct codes.

D. Ransomware deployment would manifest as file encryption, network scanning, or privilege escalation attempts, not failed authentication logs.

Question #72

A company is concerned about weather events causing damage to the server room and downtime.

Which of the following should the company consider?

A. Clustering servers
B. Geographic dispersion
C. Load balancers
D. Off-site backups

✅ Correct Answer: B — Geographic dispersion

Geographic dispersion—distributing servers and infrastructure across multiple physical locations—directly mitigates the risk of weather events affecting a single server room. If one location experiences weather damage, the dispersed infrastructure remains operational at other sites. Clustering and load balancers improve availability and performance but do not protect against localized weather events, and off-site backups

address data recovery but not preventing downtime.

Why The Other Options Are Incorrect

A. Clustering servers in the same location provides failover capability but does not protect against weather damage affecting the entire clustered location.

C. Load balancers distribute traffic across servers but do not prevent downtime if all servers are in one location affected by weather.

D. Off-site backups ensure data recovery after an incident but do not prevent server room downtime during a weather event.

Question #73

Which of the following is a primary security concern for a company setting up a BYOD program?

A. End of life
B. Buffer overflow
C. VM escape
D. Jailbreaking

Correct Answer: D — Jailbreaking

Jailbreaking (removing OS restrictions on personal devices) is a primary security concern for BYOD programs because it bypasses security controls, allows installation of unauthorized software, disables device management capabilities, and increases malware vulnerability. Jailbroken devices cannot be properly secured or monitored by company security policies. End of life refers to product lifecycle management, buffer overflow is a code exploitation technique, and VM escape involves breaking out of virtual machines—none are primary BYOD-specific concerns.

Why The Other Options Are Incorrect

A. End of life refers to when products reach the end of support; while relevant to BYOD, it is not the primary security concern.

B. Buffer overflow is a code-level vulnerability exploitation technique unrelated to BYOD program risks.

C. VM escape is a hypervisor vulnerability; BYOD typically involves personal mobile devices, not virtual machines.

Question #74

A company decided to reduce the cost of its annual cyber insurance policy by removing the coverage for ransomware attacks.

Which of the following analysis elements did the company most likely use in making this decision?

A. MTTR
B. RTO
C. ARO
D. MTBF

✅ Correct Answer: C — ARO

ARO (Annual Rate of Occurrence) represents how frequently an event is expected to occur per year. By reducing ransomware coverage, the company implicitly determined that ransomware attacks have a low ARO for their organization, making the insurance premium not cost-effective. MTTR measures recovery time, RTO measures recovery time objective after disaster, and MTBF measures equipment reliability—none of these directly inform decisions about insurance coverage likelihood or frequency.

Why The Other Options Are Incorrect

A. MTTR (Mean Time To Repair) measures how long repairs typically take; it is not the basis for removing insurance coverage.

B. RTO (Recovery Time Objective) specifies the acceptable downtime after an incident; it informs recovery planning but not insurance premium decisions.

D. MTBF (Mean Time Between Failures) measures equipment reliability intervals; it does not inform decisions about ransomware attack probability.

Question #75

Which of the following is the most likely to be included as an element of communication in a security awareness program?

A. Reporting phishing attempts or other suspicious activities
B. Detecting insider threats using anomalous behavior recognition
C. Verifying information when modifying wire transfer data
D. Performing social engineering as part of third-party penetration testing

✅ Correct Answer: A — Reporting phishing attempts or other suspicious activities

Reporting phishing attempts and suspicious activities is a core communication element of security awareness programs. It encourages employees to recognize threats and report them to security teams, creating a human firewall. This is fundamental to awareness training and incident reporting procedures.

Why The Other Options Are Incorrect

B. Detecting insider threats via anomalous behavior is a technical detection capability,

not a communication element of awareness training.

C. Verifying wire transfer information is a specific control procedure, not part of general security awareness communication.

D. Social engineering by third parties is a testing activity, not an element of communication within the awareness program itself.

Question #76

HOTSPOT

Select the appropriate attack and remediation from each drop-down list to label the corresponding attack with its remediation.

INSTRUCTIONS

Not all attacks and remediation actions will be used.

If at any time you would like to bring back the initial state of the simulation, please click the Reset All button.

Daily Debian

Attack Description	Target	Attack Identified	BEST Preventative or Remediation Action
An attacker sends multiple SYN packets from multiple sources.	Web server	Botnet RAT Logic Bomb Backdoor Virus Spyware Worm Adware Ransomware Keylogger Phishing	Enable DDoS protection Patch vulnerable systems Disable vulnerable services Change the default system password Update the cryptographic algorithms Change the default application password Implement 2FA using push notification Conduct a code review Implement application fuzzing Implement a host-based IPS Disable remote access services
The attack establishes a connection, which allows remote commands to be executed.	User	Botnet RAT Logic Bomb Backdoor Virus Spyware Worm Adware Ransomware Keylogger Phishing	Enable DDoS protection Patch vulnerable systems Disable vulnerable services Change the default system password Update the cryptographic algorithms Change the default application password Implement 2FA using push notification Conduct a code review Implement application fuzzing Implement a host-based IPS Disable remote access services
The attack is self propagating and compromises a SQL database using well-known credentials as it moves through the network.	Database server	Botnet RAT Logic Bomb Backdoor Virus Spyware Worm Adware Ransomware Keylogger Phishing	Enable DDoS protection Patch vulnerable systems Disable vulnerable services Change the default system password Update the cryptographic algorithms Change the default application password Implement 2FA using push notification Conduct a code review Implement application fuzzing Implement a host-based IPS Disable remote access services
The attacker uses hardware to remotely monitor a user's input activity to harvest credentials.	Executive	Botnet RAT Logic Bomb Backdoor Virus Spyware Worm Adware Ransomware Keylogger Phishing	Enable DDoS protection Patch vulnerable systems Disable vulnerable services Change the default system password Update the cryptographic algorithms Change the default application password Implement 2FA using push notification Conduct a code review Implement application fuzzing Implement a host-based IPS Disable remote access services
The attacker embeds hidden access in an internally developed application that bypasses account login.	Application	Botnet RAT Logic Bomb Backdoor Virus Spyware Worm Adware Ransomware Keylogger Phishing	Enable DDoS protection Patch vulnerable systems Disable vulnerable services Change the default system password Update the cryptographic algorithms Change the default application password Implement 2FA using push notification Conduct a code review Implement application fuzzing Implement a host-based IPS Disable remote access services

✅ Completed Answer

Match each attack description with the correct attack type and select the best preventative or remediation action from the dropdown lists.

Web server attack → Botnet

Web server remediation → Enable DDoS protection

User attack → RAT

User remediation → Disable remote access services

Database server attack → Virus

Database server remediation → Patch vulnerable systems

Executive attack → Keylogger

Executive remediation → Implement 2FA using push notification

Application attack → Backdoor

Application remediation → Conduct a code review

How To Work It Out

1. Analyze the first attack description about multiple SYN packets from multiple sources against a web server, which is characteristic of a DDoS botnet attack.

2. Select Botnet as the attack type and Enable DDoS protection as the corresponding remediation for network-level distributed attack protection.

3. Identify the second attack involving remote command execution on a user system as a Remote Access Trojan (RAT).

4. Select Disable remote access services to prevent future remote command execution and lateral movement.

5. Recognize the third attack as a self-propagating malware targeting databases using default credentials, which describes a Virus.

6. Choose Patch vulnerable systems to close the credential exploitation vulnerability on the database server.

7. Identify the fourth attack using hardware keystroke monitoring to harvest credentials as a Keylogger.

8. Select Implement 2FA using push notification to prevent credential misuse even if keystroke monitoring succeeds.

9. Recognize the fifth attack as an embedded Backdoor that bypasses login authentication in the application.

10. Choose Conduct a code review to detect and remove the hidden access mechanism before deployment or further compromise.

Each attack description targets a specific system component and uses a particular malware type or technique. The SYN flood attack on the web server is a botnet-based DDoS, best countered by enabling DDoS protection at the network perimeter. Remote command execution on users indicates a RAT, requiring disabling of remote services. The self-propagating database attack is a virus exploiting default credentials, necessitating system patching. Hardware-based credential harvesting on an executive system is characteristic of a keylogger, which 2FA push notifications can mitigate. Finally, an embedded login-bypassing mechanism is a backdoor, requiring code review and remediation before it causes further compromise. Each pairing aligns the attack vector with targeted, appropriate security controls.

Daily Debian

Question #77

HOTSPOT

You are a security administrator investigating a potential infection on a network.

INSTRUCTIONS

Click on each host and firewall. Review all logs to determine which host originated the infection and then identify if each remaining host is clean or infected.

If at any time you would like to bring back the initial state of the simulation, please click the Reset All button.

Daily Debian

192.168.10.22

```
4/17/2019 14:30  Info   Scheduled scan initiated
4/17/2019 14:31  Info   Checking for update
4/17/2019 14:32  Info   No update available
4/17/2019 14:33  Info   Checking for definition update
4/17/2019 14:34  Info   No definition update available
4/17/2019 14:35  Info   Scan type = full
4/17/2019 14:36  Info   Scan start
4/17/2019 14:37  Info   Scanning system files
4/17/2019 14:38  Info   Scanning temporary files
4/17/2019 14:39  Info   Scanning services
4/17/2019 14:40  Info   Scanning boot sector
4/17/2019 14:41  Info   Scan complete
4/17/2019 14:42  Info   Files removed: 0
4/17/2019 14:43  Info   Files quarantined: 0
4/17/2019 14:44  Info   Boot sector: clean
4/17/2019 14:45  Info   Next scheduled scan: 4/18/2019 14:30
4/18/2019 2:31   Warn   Scheduled scan disabled by process svch0st.exe
4/18/2019 2:32   Warn   Scheduled update disabled by process scvh0st.exe
```

192.168.10.37

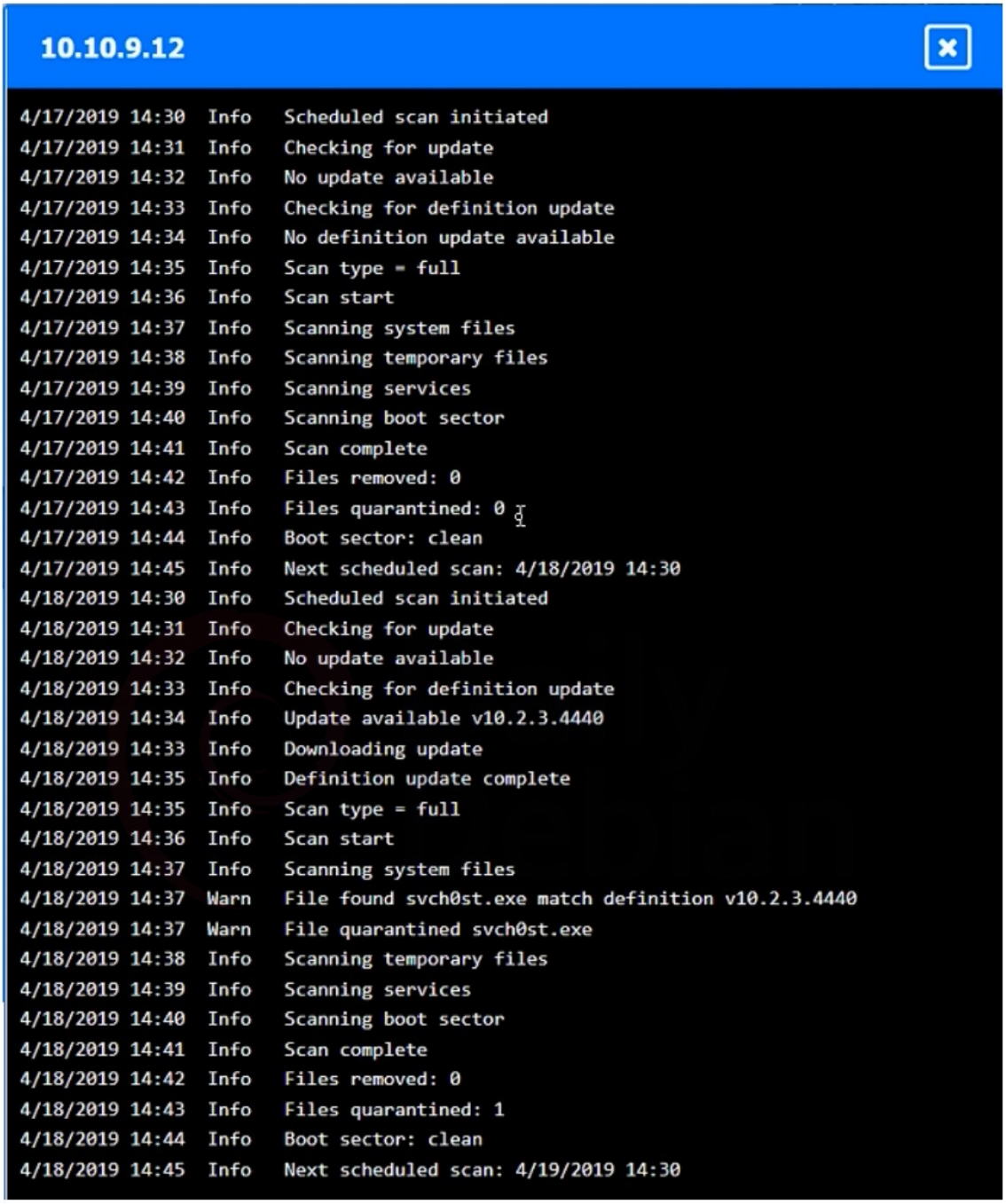
```
4/17/2019 14:30  Info   Scheduled scan initiated
4/17/2019 14:31  Info   Checking for update
4/17/2019 14:32  Info   No update available
4/17/2019 14:33  Info   Checking for definition update
4/17/2019 14:34  Info   No definition update available
4/17/2019 14:35  Info   Scan type = full
4/17/2019 14:36  Info   Scan start
4/17/2019 14:37  Info   Scanning system files
4/17/2019 14:38  Info   Scanning temporary files
4/17/2019 14:39  Info   Scanning services
4/17/2019 14:40  Info   Scanning boot sector
4/17/2019 14:41  Info   Scan complete
4/17/2019 14:42  Info   Files removed: 0
4/17/2019 14:43  Info   Files quarantined: 0
4/17/2019 14:44  Info   Boot sector: clean
4/17/2019 14:45  Info   Next scheduled scan: 4/18/2019 14:30
4/18/2019 14:30  Info   Scheduled scan initiated
4/18/2019 14:31  Info   Checking for update
4/18/2019 14:32  Info   No update available
4/18/2019 14:33  Info   Checking for definition update
4/18/2019 14:34  Info   Update available v10.2.3.4440
4/18/2019 14:33  Info   Downloading update
4/18/2019 14:35  Info   Definition update complete
4/18/2019 14:35  Info   Scan type = full
4/18/2019 14:36  Info   Scan start
4/18/2019 14:37  Info   Scanning system files
4/18/2019 14:37  Warn   File found svch0st.exe match definition v10.2.3.4440
4/18/2019 14:37  Warn   File quarantined svch0st.exe
4/18/2019 14:38  Info   Scanning temporary files
4/18/2019 14:39  Info   Scanning services
4/18/2019 14:40  Info   Scanning boot sector
4/18/2019 14:41  Info   Scan complete
4/18/2019 14:42  Info   Files removed: 0
4/18/2019 14:43  Info   Files quarantined: 1
4/18/2019 14:44  Info   Boot sector: clean
4/18/2019 14:45  Info   Next scheduled scan: 4/19/2019 14:30
```

192.168.10.41

```
4/17/2019 14:30  Info   Scheduled scan initiated
4/17/2019 14:31  Info   Checking for update
4/17/2019 14:32  Info   No update available
4/17/2019 14:33  Info   Checking for definition update
4/17/2019 14:34  Info   No definition update available
4/17/2019 14:35  Info   Scan type = full
4/17/2019 14:36  Info   Scan start
4/17/2019 14:37  Info   Scanning system files
4/17/2019 14:38  Info   Scanning temporary files
4/17/2019 14:39  Info   Scanning services
4/17/2019 14:40  Info   Scanning boot sector
4/17/2019 14:41  Info   Scan complete
4/17/2019 14:42  Info   Files removed: 0
4/17/2019 14:43  Info   Files quarantined: 0
4/17/2019 14:44  Info   Boot sector: clean
4/17/2019 14:45  Info   Next scheduled scan: 4/18/2019 14:30
4/18/2019 14:30  Info   Scheduled scan initiated
4/18/2019 14:31  Info   Checking for update
4/18/2019 14:32  Info   No update available
4/18/2019 14:33  Info   Checking for definition update
4/18/2019 14:34  Error  Unable to reach update server
4/18/2019 14:35  Info   Scan type = full
4/18/2019 14:36  Info   Scan start
4/18/2019 14:37  Info   Scanning system files
4/18/2019 14:37  Warn   File svch0st.exe match heuristic pattern 0c09488c08d0f3k
4/18/2019 14:37  Error  Unable to quarantine file svch0st.exe
4/18/2019 14:38  Info   Scanning temporary files
4/18/2019 14:39  Info   Scanning services
4/18/2019 14:40  Info   Scanning boot sector
4/18/2019 14:41  Info   Scan complete
4/18/2019 14:42  Info   Files removed: 0
4/18/2019 14:43  Info   Files quarantined: 0
4/18/2019 14:43  Warn   File quarantine file
4/18/2019 14:44  Info   Boot sector: clean
4/18/2019 14:45  Info   Next scheduled scan: 4/19/2019 14:30
```

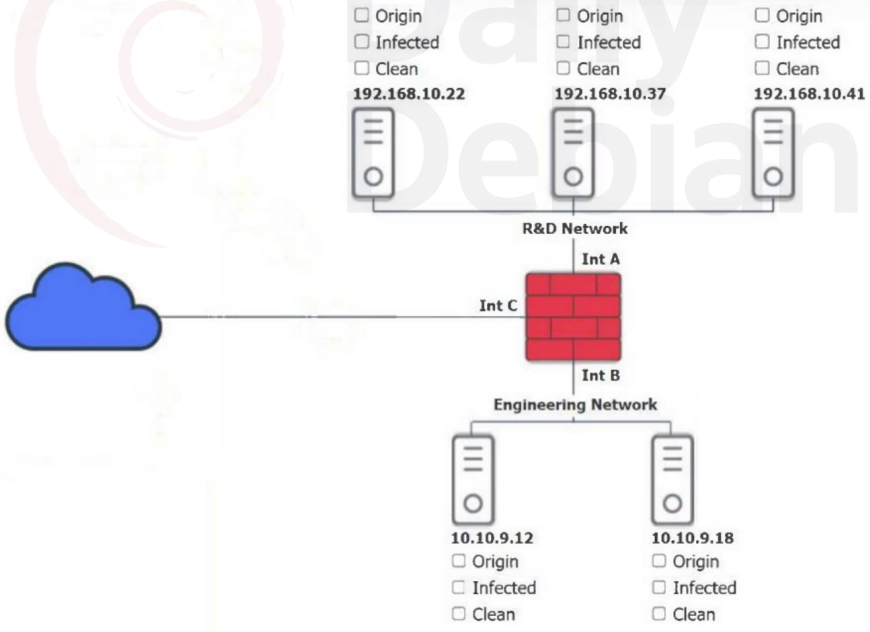
Firewall

Timestamp		Source	Destination	Destination Port	Application	Action	Client Bytes	Server Bytes
4/17/2019	16:01:44	10.10.9.18	57.203.54.183	443	ssl	Permit	6953	99427
4/17/2019	16:01:58	192.168.10.37	57.203.54.221	443	ssl	Permit	9301	199386
4/17/2019	16:17:06	192.168.10.22	10.10.9.12	135	rpc	Permit	175	1504
4/17/2019	16:27:36	192.168.10.41	10.10.9.12	445	smbv1	Permit	345	34757
4/17/2019	16:28:06	10.10.9.12	192.168.10.41	135	rpc	Permit	754	4771
4/17/2019	16:33:31	10.10.9.18	192.168.10.22	135	rpc	Permit	643	2355
4/17/2019	16:35:36	192.168.10.37	10.10.9.12	135	smbv2	Permit	649	5644
4/17/2019	23:58:36	10.10.9.12	192.168.10.41		icmp	Permit	128	128
4/17/2019	23:58:43	10.10.9.12	192.168.10.22		icmp	Permit	128	128
4/17/2019	23:58:45	10.10.9.12	192.168.10.37		icmp	Permit	128	128
4/18/2019	2:31:36	10.10.9.18	192.168.10.41	445	smbv2	Permit	1874	23874
4/18/2019	2:31:45	192.168.10.22	57.203.55.29	8080	http	Permit	7203	75997
4/18/2019	2:31:51	10.10.9.18	57.203.56.201	443	ssl	Permit	9953	199730
4/18/2019	2:31:02	192.168.10.22	57.203.55.234	443	http	Permit	4937	84937
4/18/2019	2:39:11	192.168.10.41	57.203.53.89	8080	http	Permit	8201	133183
4/18/2019	2:39:12	10.10.9.18	57.203.55.19	8080	ssl	Permit	1284	9102854
4/18/2019	2:39:32	192.168.10.37	57.203.56.113	443	ssl	Permit	9341	9938
4/18/2019	13:37:36	192.168.10.22	10.10.9.18	445	smbv3	Permit	1874	23874
4/18/2019	13:39:43	192.168.10.22	10.10.9.18	135	rpc	Permit	673	41358
4/18/2019	13:45:04	10.10.9.18	192.168.10.37	135	rpc	Permit	693	1952
4/18/2019	13:47:44	10.10.9.12	192.168.10.41	445	smbv3	Permit	482	3505
4/18/2019	13:52:57	10.10.9.18	192.168.10.22	135	rpc	Permit	545	9063
4/18/2019	13:53:01	192.168.10.37	10.10.9.12	335	smbv3	Permit	876	8068
4/18/2019	14:30:04	10.10.9.12	57.203.56.231	443	ssl	Permit	9901	199730
4/18/2019	14:30:04	192.168.10.37	57.203.56.143	443	ssl	Permit	10092	209938


10.10.9.12
4/17/2019 14:30 Info Scheduled scan initiated
4/17/2019 14:31 Info Checking for update
4/17/2019 14:32 Info No update available
4/17/2019 14:33 Info Checking for definition update
4/17/2019 14:34 Info No definition update available
4/17/2019 14:35 Info Scan type = full
4/17/2019 14:36 Info Scan start
4/17/2019 14:37 Info Scanning system files
4/17/2019 14:38 Info Scanning temporary files
4/17/2019 14:39 Info Scanning services
4/17/2019 14:40 Info Scanning boot sector
4/17/2019 14:41 Info Scan complete
4/17/2019 14:42 Info Files removed: 0
4/17/2019 14:43 Info Files quarantined: 0
4/17/2019 14:44 Info Boot sector: clean
4/17/2019 14:45 Info Next scheduled scan: 4/18/2019 14:30
4/18/2019 14:30 Info Scheduled scan initiated
4/18/2019 14:31 Info Checking for update
4/18/2019 14:32 Info No update available
4/18/2019 14:33 Info Checking for definition update
4/18/2019 14:34 Info Update available v10.2.3.4440
4/18/2019 14:33 Info Downloading update
4/18/2019 14:35 Info Definition update complete
4/18/2019 14:35 Info Scan type = full
4/18/2019 14:36 Info Scan start
4/18/2019 14:37 Info Scanning system files
4/18/2019 14:37 Warn File found svch0st.exe match definition v10.2.3.4440
4/18/2019 14:37 Warn File quarantined svch0st.exe
4/18/2019 14:38 Info Scanning temporary files
4/18/2019 14:39 Info Scanning services
4/18/2019 14:40 Info Scanning boot sector
4/18/2019 14:41 Info Scan complete
4/18/2019 14:42 Info Files removed: 0
4/18/2019 14:43 Info Files quarantined: 1
4/18/2019 14:44 Info Boot sector: clean
4/18/2019 14:45 Info Next scheduled scan: 4/19/2019 14:30

10.10.9.18

```
4/17/2019 14:30  Info   Scheduled scan initiated
4/17/2019 14:31  Info   Checking for update
4/17/2019 14:32  Info   No update available
4/17/2019 14:33  Info   Checking for definition update
4/17/2019 14:34  Info   No definition update available
4/17/2019 14:35  Info   Scan type = full
4/17/2019 14:36  Info   Scan start
4/17/2019 14:37  Info   Scanning system files
4/17/2019 14:38  Info   Scanning temporary files
4/17/2019 14:39  Info   Scanning services
4/17/2019 14:40  Info   Scanning boot sector
4/17/2019 14:41  Info   Scan complete
4/17/2019 14:42  Info   Files removed: 0
4/17/2019 14:43  Info   Files quarantined: 0
4/17/2019 14:44  Info   Boot sector: clean
4/17/2019 14:45  Info   Next scheduled scan: 4/18/2019 14:30
4/18/2019 14:30  Info   Scheduled scan initiated
4/18/2019 14:31  Info   Checking for update
4/18/2019 14:32  Info   No update available
4/18/2019 14:33  Info   Checking for definition update
4/18/2019 14:34  Error  Unable to reach update server
4/18/2019 14:35  Info   Scan type = full
4/18/2019 14:36  Info   Scan start
4/18/2019 14:37  Info   Scanning system files
4/18/2019 14:37  Warn   File svch0st.exe match heuristic pattern 0c09488c08d0f3k
4/18/2019 14:37  Error  Unable to quarantine file svch0st.exe
4/18/2019 14:38  Info   Scanning temporary files
4/18/2019 14:39  Info   Scanning services
4/18/2019 14:40  Info   Scanning boot sector
4/18/2019 14:41  Info   Scan complete
4/18/2019 14:42  Info   Files removed: 0
4/18/2019 14:43  Info   Files quarantined: 0
4/18/2019 14:43  Warn   File quarantine file
4/18/2019 14:44  Info   Boot sector: clean
4/18/2019 14:45  Info   Next scheduled scan: 4/19/2019 14:30
```



✅ Completed Answer

Review the host antivirus logs and the firewall log to mark which host was the origin of the infection and whether each of the other four hosts is infected or clean.

192.168.10.22 → Infected

192.168.10.37 → Infected
192.168.10.41 → Origin
10.10.9.12 → Infected
10.10.9.18 → Infected

How To Work It Out

1. Every host log references the same malicious file, svch0st.exe, so the whole set of five machines is involved in one outbreak.

2. 192.168.10.41 is the only host whose antivirus detected svch0st.exe by heuristic pattern rather than by a signature, could not reach the update server, and failed to quarantine the file — and the firewall log shows it as the earliest internal talker (SMB to 10.10.9.12 on 4/17 at 16:27), so it is the origin.

3. 192.168.10.22's log stops after warnings that its scheduled scan and update were disabled by the process svch0st.exe, proving the malware is running and suppressing defenses, so it is infected.

4. 192.168.10.37 and 10.10.9.12 both received the v10.2.3.4440 definition update, found svch0st.exe and quarantined it, so they were infected even though the file was contained.

5. 10.10.9.18 mirrors 192.168.10.41: no definition update, heuristic match on svch0st.exe and an error quarantining it, so it is still infected.

6. With malware present on all five machines and only 192.168.10.41 identified as the source, no host can be marked Clean.

All five systems show evidence of the same file, svch0st.exe, so none of them can be marked clean. The distinguishing detail is how each host encountered the file. 192.168.10.41 never got the new definitions (it could not reach the update server), matched the file only through a heuristic pattern, failed to quarantine it, and appears first in the firewall log initiating SMB and RPC traffic toward the Engineering hosts — the classic profile of the patient-zero machine spreading laterally, so it is the origin. 192.168.10.22 is infected because the malware itself disabled its scheduled scan and update, which is why its log simply stops. 192.168.10.37 and 10.10.9.12 successfully downloaded definition v10.2.3.4440, detected svch0st.exe by signature and quarantined it, confirming they had been compromised. 10.10.9.18 behaves like the origin host — no updated definitions, heuristic match, and an error quarantining the file — so it remains infected. The correct marking is therefore Origin on 192.168.10.41 and Infected on the other four hosts.

Question #78

Which of the following is the phase in the incident response process when a security analyst reviews roles and responsibilities?

A. Preparation
B. Recovery
C. Lessons learned

D. Analysis

Correct Answer: A — Preparation

The Preparation phase is when an organization establishes roles, responsibilities, tools, and procedures before incidents occur. This includes defining who does what during incident response. This foundational work happens before any incident is detected.

Why The Other Options Are Incorrect

B. Recovery is the phase focused on restoring systems to normal operation, not reviewing roles.

C. Lessons learned occurs after the incident to review what happened, not during preparation.

D. Analysis is when the incident itself is being investigated and analyzed, not when roles are initially defined.

Question #79

After a recent vulnerability scan, a security engineer needs to harden the routers within the corporate network.

Which of the following is the most appropriate to disable?

A. Console access
B. Routing protocols
C. VLANs
D. Web-based administration

Correct Answer: D — Web-based administration

Web-based administration interfaces are a significant attack vector and should be disabled when hardening routers. This eliminates unnecessary services and reduces the attack surface. Console access, routing protocols, and VLANs are typically necessary for router functionality and network operations.

Why The Other Options Are Incorrect

A. Console access is needed for legitimate administration and emergency recovery procedures.

B. Routing protocols are essential for the router to function and forward traffic properly.

C. VLANs are important security and segmentation features that should remain enabled.

Question #80

A security administrator needs a method to secure data in an environment that includes some form of checks so track any changes.

Which of the following should the administrator set up to achieve this goal?

A. SPF
B. GPO
C. NAC
D. FIM

Correct Answer: D — FIM

File Integrity Monitoring (FIM) is designed to track and monitor changes to files and data, detecting any unauthorized modifications. It provides the checks and audit trails needed to verify data hasn't been altered. This directly addresses the requirement to secure data while tracking changes.

Why The Other Options Are Incorrect

A. SPF (Sender Policy Framework) is for email authentication, not data integrity tracking.

B. GPO (Group Policy Object) manages Windows settings but doesn't provide file change tracking.

C. NAC (Network Access Control) manages device access to networks, not file integrity.

Daily Debian

Question #81

An administrator is reviewing a single server's security logs and discovers the following:

Keywords	Date and Time	Source	Event ID	Task Category
Audit Failure	09/16/2022 11:13:05 AM	Microsoft Windows security	4625	Logon
Audit Failure	09/16/2022 11:13:07 AM	Microsoft Windows security	4625	Logon
Audit Failure	09/16/2022 11:13:09 AM	Microsoft Windows security	4625	Logon
Audit Failure	09/16/2022 11:13:11 AM	Microsoft Windows security	4625	Logon
Audit Failure	09/16/2022 11:13:13 AM	Microsoft Windows security	4625	Logon
Audit Failure	09/16/2022 11:13:15 AM	Microsoft Windows security	4625	Logon
Audit Failure	09/16/2022 11:13:17 AM	Microsoft Windows security	4625	Logon
Audit Failure	09/16/2022 11:13:19 AM	Microsoft Windows security	4625	Logon
Audit Failure	09/16/2022 11:13:21 AM	Microsoft Windows security	4625	Logon
Audit Failure	09/16/2022 11:13:23 AM	Microsoft Windows security	4625	Logon
Audit Failure	09/16/2022 11:13:25 AM	Microsoft Windows security	4625	Logon
Audit Failure	09/16/2022 11:13:27 AM	Microsoft Windows security	4625	Logon

Which of the following best describes the action captured in this log file?

A. Brute-force attack
B. Privilege escalation
C. Failed password audit
D. Forgotten password by the user

Correct Answer: A — Brute-force attack

The log shows 13 consecutive failed logon attempts (Audit Failure events) occurring within a 14-second window (11:13:05 AM to 11:13:27 AM) on the same date from the same source (Microsoft Windows security). All failures are for the same Event ID 4625 (Logon Failure) and Task Category (Logon). This rapid succession of failed authentication attempts at regular 2-second intervals is the characteristic signature of a brute-force attack, where an attacker systematically tries multiple passwords or credentials in quick succession to gain unauthorized access.

Why The Other Options Are Incorrect

B. Privilege escalation involves gaining higher-level permissions after initial access;

these logs show failed login attempts before any access is granted.

C. A 'failed password audit' is not a security term; the entries are audit failures of logon attempts, not an audit event about passwords.

D. A forgotten password would typically result in a single failed attempt followed by a password reset, not 13 rapid successive attempts within seconds.

Question #82

A security engineer is implementing FDE for all laptops in an organization.

Which of the following are the most important for the engineer to consider as part of the planning process? (Choose two.)

A. Key escrow
B. TPM presence
C. Digital signatures
D. Data tokenization
E. Public key management
F. Certificate authority linking

Correct Answer: A, B

A. Key escrow
B. TPM presence

When implementing FDE, the engineer must consider TPM (Trusted Platform Module) presence for secure key storage and integration with the encryption system. Key escrow is critical for ensuring encrypted data can be recovered if users forget passphrases or leave the organization. These two elements directly support the practical deployment and management of FDE systems.

Why The Other Options Are Incorrect

C. Digital signatures are for authentication and non-repudiation, not FDE implementation.

D. Data tokenization is a separate data protection technique, not relevant to FDE planning.

E. Public key management relates to PKI systems, not the core FDE implementation concerns.

F. Certificate authority linking is a PKI concept, not essential to FDE planning.

Question #83

A security analyst scans a company's public network and discovers a host is running a remote desktop that can be used to access the production network.

Which of the following changes should the security analyst recommend?

A. Changing the remote desktop port to a non-standard number
B. Setting up a VPN and placing the jump server inside the firewall
C. Using a proxy for web connections from the remote desktop server
D. Connecting the remote server to the domain and increasing the password length

✅ Correct Answer: B — Setting up a VPN and placing the jump server inside the firewall

Setting up a VPN with a jump server behind the firewall is the best practice for securing remote access to production networks. This creates a hardened entry point and adds network segmentation. Simply changing ports is security through obscurity, proxies don't protect the production network from compromise, and domain joining with longer passwords don't address the fundamental exposure of RDP on public networks.

Why The Other Options Are Incorrect

A. Port obfuscation through non-standard ports is security through obscurity and doesn't adequately protect from determined attackers.

C. A proxy for web connections doesn't address the primary security concern of exposed RDP access.

D. Domain joining and password length increase are general hardening steps but don't eliminate the core vulnerability of public RDP exposure.

Question #84

An enterprise has been experiencing attacks focused on exploiting vulnerabilities in older browser versions with well-known exploits.

Which of the following security solutions should be configured to best provide the ability to monitor and block these known signature-based attacks?

A. ACL
B. DLP
C. IDS
D. IPS

✅ Correct Answer: D — IPS

IPS (Intrusion Prevention System) is designed to actively block known signature-based attacks in real-time. Since the question specifies well-known exploits with known

signatures, IPS is the appropriate choice as it can detect and prevent these attacks automatically. IDS only monitors and alerts, while ACL and DLP serve different purposes.

Why The Other Options Are Incorrect

A. ACL (Access Control Lists) control traffic flow but don't analyze payloads for known signatures.

B. DLP (Data Loss Prevention) focuses on preventing data exfiltration, not blocking exploit traffic.

C. IDS (Intrusion Detection System) can detect attacks but only alerts; it doesn't actively block like IPS does.

Question #85

Security controls in a data center are being reviewed to ensure data is properly protected and that human life considerations are included.

Which of the following best describes how the controls should be set up?

A. Remote access points should fail closed.
B. Logging controls should fail open.
C. Safety controls should fail open.
D. Logical security controls should fail closed.

✅ Correct Answer: C — Safety controls should fail open.

Safety controls, particularly those protecting human life in data centers (such as emergency exits, fire suppression, and physical safety systems), must fail open to ensure people can always escape or that life-safety systems activate. Denying access during an emergency could endanger lives. Logical security controls and remote access should fail closed for security, but human safety takes precedence.

Why The Other Options Are Incorrect

A. Remote access points failing closed is correct security practice but doesn't address the human life consideration mentioned in the question.

B. Logging controls failing open would lose audit trails and compromise security monitoring capabilities.

D. While logical security controls should generally fail closed, this doesn't address the human life protection priority stated in the question.

Question #86

Which of the following would be best suited for constantly changing environments?

A. RTOS

B. Containers
C. Embedded systems
D. SCADA

Correct Answer: B — Containers

Containers are best suited for constantly changing environments because they provide lightweight, portable, and easily deployable application instances that can be quickly scaled up or down. They enable rapid iteration and deployment cycles, making them ideal for dynamic environments where applications and infrastructure requirements change frequently.

Why The Other Options Are Incorrect

A. RTOS (Real-Time Operating Systems) are designed for deterministic, predictable environments with fixed real-time constraints, not constantly changing ones.

C. Embedded systems are typically designed for specific, fixed hardware and use cases with minimal changes.

D. SCADA systems are designed for industrial control with stable, long-running processes and fixed operational parameters.

Question #87

Which of the following incident response activities ensures evidence is properly handled?

A. E-discovery
B. Chain of custody
C. Legal hold
D. Preservation

Correct Answer: B — Chain of custody

Chain of custody is the specific process that ensures evidence is properly handled, documented, and tracked throughout the incident response process. It maintains a detailed record of who collected, handled, stored, and analyzed evidence, which is critical for maintaining integrity and admissibility in legal proceedings.

Why The Other Options Are Incorrect

A. E-discovery is about locating and retrieving digital data but does not specifically ensure proper evidence handling protocols.

C. Legal hold is a process to preserve data for litigation but does not address the chain of custody procedures.

D. Preservation is about keeping data intact but does not specifically document the handling and custody of evidence throughout the process.

Question #88

An accounting clerk sent money to an attacker's bank account after receiving fraudulent instructions to use a new account.

Which of the following would most likely prevent this activity in the future?

A. Standardizing security incident reporting
B. Executing regular phishing campaigns
C. Implementing insider threat detection measures
D. Updating processes for sending wire transfers

Correct Answer: D — Updating processes for sending wire transfers

Updating processes for sending wire transfers would most effectively prevent this type of fraud by implementing controls such as dual approval requirements, verification procedures, or mandatory callbacks to confirm changes in banking instructions. This addresses the root cause by requiring procedural safeguards rather than relying on user awareness or detection after the fact.

Why The Other Options Are Incorrect

A. Standardizing incident reporting helps document incidents but does not prevent fraudulent transactions from occurring in the first place.

B. While phishing campaigns improve awareness, they do not directly prevent an already-trained employee from being socially engineered.

C. Insider threat detection measures would detect suspicious behavior but may not prevent the initial transfer if the clerk appeared to follow existing procedures.

Question #89

A systems administrator is creating a script that would save time and prevent human error when performing account creation for a large number of end users.

Which of the following would be a good use case for this task?

A. Off-the-shelf software
B. Orchestration
C. Baseline
D. Policy enforcement

Correct Answer: B — Orchestration

Orchestration is the automated coordination and execution of multiple related tasks across systems to accomplish complex workflows. Creating a script to automate account creation

for multiple users is a classic orchestration use case, as it automates repetitive tasks and reduces human error.

Why The Other Options Are Incorrect

A. Off-the-shelf software refers to pre-built applications, not custom scripting for automation.

C. Baseline refers to a standard configuration or security starting point, not task automation.

D. Policy enforcement is about ensuring compliance with rules, not automating routine administrative tasks.

Question #90

A company's marketing department collects, modifies, and stores sensitive customer data. The infrastructure team is responsible for securing the data while in transit and at rest.

Which of the following data roles describes the customer?

A. Processor
B. Custodian
C. Subject
D. Owner

Correct Answer: C — Subject

The customer is the data subject—the individual whose personal information is being collected, modified, and stored. In data protection terminology, the subject is the person whose data is being processed, regardless of which department collects it or which department secures it.

Why The Other Options Are Incorrect

A. Processor is the entity that processes data on behalf of the owner (the marketing department in this case).

B. Custodian is the entity responsible for safeguarding the data (the infrastructure team in this case).

D. Owner is typically the organization or the individual with legal rights over the data; here the organization owns the customer data.

Question #91

Which of the following describes the maximum allowance of accepted risk?

A. Risk indicator

B. Risk level
C. Risk score
D. Risk threshold

✅ Correct Answer: D — Risk threshold

Risk threshold describes the maximum level or amount of risk that an organization is willing to accept. It represents the boundary between acceptable and unacceptable risk levels and is used to determine when risk mitigation actions must be taken.

Why The Other Options Are Incorrect

A. Risk indicator is a metric or signal that suggests the presence or level of risk but does not define maximum acceptance.

B. Risk level is a general classification of risk severity but is not specifically the maximum acceptable amount.

C. Risk score is a numerical rating of risk but does not define the maximum acceptable threshold.

Question #92

A security analyst receives alerts about an internal system sending a large amount of unusual DNS queries to systems on the internet over short periods of time during non-business hours.

Which of the following is most likely occurring?

A. A worm is propagating across the network.
B. Data is being exfiltrated.
C. A logic bomb is deleting data.
D. Ransomware is encrypting files.

✅ Correct Answer: B — Data is being exfiltrated.

Large amounts of unusual DNS queries to external systems during non-business hours are a strong indicator of data exfiltration. Attackers often use DNS tunneling or DNS-based communication to covertly extract data from the network while avoiding detection by traditional network monitoring.

Why The Other Options Are Incorrect

A. A worm would cause broad network propagation with different traffic patterns, not specifically DNS queries to external systems.

C. A logic bomb deletes data locally and would not generate outbound DNS queries to the internet.

D. Ransomware encrypts files locally and does not typically generate large amounts of

outbound DNS queries as a primary activity.

Question #93

A technician is opening ports on a firewall for a new system being deployed and supported by a SaaS provider.

Which of the following is a risk in the new system?

A. Default credentials
B. Non-segmented network
C. Supply chain vendor
D. Vulnerable software

Correct Answer: C — Supply chain vendor

A SaaS provider represents a supply chain vendor risk. When deploying systems supported by external vendors, organizations inherit risks related to the vendor's security practices, potential breaches of the vendor's infrastructure, and the vendor's access to the organization's systems and data.

Why The Other Options Are Incorrect

A. While default credentials are a risk, the question specifically asks about the risk introduced by using a SaaS provider, which is a vendor relationship.

B. Non-segmented networks are a general network architecture risk, not specific to the SaaS provider deployment context.

D. Vulnerable software is a general software risk but does not specifically characterize the risk introduced by the SaaS vendor relationship.

Question #94

A systems administrator is working on a solution with the following requirements:

- Provide a secure zone.
- Enforce a company-wide access control policy.
- Reduce the scope of threats.

Which of the following is the systems administrator setting up?

A. Zero Trust
B. AAA
C. Non-repudiation
D. CIA

Correct Answer: A — Zero Trust

Zero Trust is a security framework that requires continuous verification of all users and devices, regardless of location. It provides a secure zone by enforcing strict access control policies, reducing the attack surface by assuming breach, and minimizing the scope of threats through granular access controls and microsegmentation. This directly addresses all three requirements: secure zone, company-wide access policy enforcement, and reduced threat scope.

Why The Other Options Are Incorrect

B. AAA (Authentication, Authorization, Accounting) is a framework but doesn't specifically address creating a secure zone or reducing threat scope as comprehensively as Zero Trust.

C. Non-repudiation ensures accountability but doesn't provide secure zones or reduce threat scope.

D. CIA (Confidentiality, Integrity, Availability) is a model of security goals, not an implementation framework for access control and threat reduction.

Question #95

Which of the following involves an attempt to take advantage of database misconfigurations?

A. Buffer overflow
B. SQL injection
C. VM escape
D. Memory injection

Correct Answer: B — SQL injection

SQL injection exploits database misconfigurations and improper input validation by inserting malicious SQL code into input fields, allowing attackers to access, modify, or delete database contents. This directly involves taking advantage of how databases are configured to handle user input.

Why The Other Options Are Incorrect

A. Buffer overflow targets memory management vulnerabilities in applications or operating systems, not database misconfigurations.

C. VM escape involves breaking out of a virtual machine to access the host system, not exploiting database misconfigurations.

D. Memory injection targets running processes in memory, not database misconfigurations.

Question #96

Which of the following is used to validate a certificate when it is presented to a user?

A. OCSP
B. CSR
C. CA
D. CRC

Correct Answer: A — OCSP

OCSP (Online Certificate Status Protocol) is used to validate whether a digital certificate is still valid when it is presented to a user by checking the certificate's revocation status in real-time with a certificate authority.

Why The Other Options Are Incorrect

B. CSR (Certificate Signing Request) is used to request a certificate, not to validate one.

C. CA (Certificate Authority) is an entity that issues certificates but is not itself the validation mechanism.

D. CRC (Cyclic Redundancy Check) is used for data integrity in transmission, not certificate validation.

Question #97

One of a company's vendors sent an analyst a security bulletin that recommends a BIOS update.

Which of the following vulnerability types is being addressed by the patch?

A. Virtualization
B. Firmware
C. Application
D. Operating system

Correct Answer: B — Firmware

A BIOS update addresses firmware-level vulnerabilities. BIOS is low-level firmware that runs before the operating system, so vulnerabilities and patches at this level are classified as firmware vulnerabilities.

Why The Other Options Are Incorrect

A. Virtualization vulnerabilities relate to hypervisor and virtual machine security, not BIOS updates.

C. Application vulnerabilities are in software applications, not in system firmware.

D. Operating system vulnerabilities are in the OS layer, which loads after BIOS

firmware.

Question #98

Which of the following is used to quantitatively measure the criticality of a vulnerability?

A. CVE
B. CVSS
C. CIA
D. CERT

Correct Answer: B — CVSS

CVSS (Common Vulnerability Scoring System) is a standardized framework that quantitatively measures the severity and criticality of vulnerabilities on a numerical scale, allowing organizations to prioritize remediation efforts based on objective metrics.

Why The Other Options Are Incorrect

A. CVE (Common Vulnerabilities and Exposures) is an identifier for vulnerabilities, not a measurement system for criticality.

C. CIA (Confidentiality, Integrity, Availability) is a security model, not a quantitative measurement scale.

D. CERT is an organization that issues security advisories but is not itself a quantitative measurement system.

Daily Debian

Question #99

Which of the following actions could a security engineer take to ensure workstations and servers are properly monitored for unauthorized changes and software?

A. Configure all systems to log scheduled tasks.
B. Collect and monitor all traffic exiting the network.
C. Block traffic based on known malicious signatures.
D. Install endpoint management software on all systems

Correct Answer: D — Install endpoint management software on all systems

Endpoint management software provides comprehensive monitoring and control of workstations and servers, enabling detection of unauthorized changes, unauthorized software installations, policy violations, and configuration drift across all systems from a centralized point.

Why The Other Options Are Incorrect

A. Logging scheduled tasks helps monitor activity but doesn't directly detect

unauthorized software changes or provide the comprehensive monitoring needed.

B. Monitoring outbound network traffic detects data exfiltration but doesn't monitor for unauthorized changes or software on systems.

C. Blocking traffic based on signatures is a network defense measure but doesn't monitor systems themselves for unauthorized changes.

Question #100

An organization is leveraging a VPN between its headquarters and a branch location.

Which of the following is the VPN protecting?

A. Data in use
B. Data in transit
C. Geographic restrictions
D. Data sovereignty

Correct Answer: B — Data in transit

A VPN (Virtual Private Network) encrypts and protects data while it is in transit across the network between the headquarters and branch location, creating a secure tunnel for data transmission over potentially untrusted networks.

Why The Other Options Are Incorrect

A. Data in use refers to data being actively processed in memory, which VPN does not specifically protect.

C. VPN does not enforce geographic restrictions; it allows access from remote locations.

D. Data sovereignty concerns where data is stored and which jurisdiction's laws apply, not the encryption VPN provides during transmission.

Question #101

After reviewing the following vulnerability scanning report:

A security analyst performs the following test:

```
Server:192.168.14.6
Service: Telnet
Port: 23 Protocol: TCP
Status: Open Severity: High
Vulnerability: Use of an insecure network protocol
```

A security analyst performs the following test:

```
nmap -p 23 192.168.14.6 --script telnet-encryption

PORT     STATE SERVICE REASON
23/tcp   open  telnet  syn-ack
|  telnet encryption:
|_ Telnet server supports encryption
```

Which of the following would the security analyst conclude for this reported vulnerability?

A. It is a false positive.
B. A rescan is required.
C. It is considered noise.
D. Compensating controls exist.

Correct Answer: A — It is a false positive.

The vulnerability report flagged Telnet on port 23 as having 'High' severity due to use of an insecure network protocol. However, the nmap script scan with telnet-encryption explicitly confirms that 'Telnet server supports encryption.' This means the actual vulnerability (unencrypted Telnet) does not exist on this system, making the original finding a false positive—the vulnerability scanner reported a problem that is not actually present because the service has encryption enabled as a compensating measure that the initial scan did not detect.

Why The Other Options Are Incorrect

B. A rescan is not required; the nmap script has already definitively confirmed the encryption capability, resolving the discrepancy.

C. This is not merely noise; it represents a genuine scanning result that requires interpretation and validation.

D. While encryption could be considered a compensating control, the direct evidence shows the vulnerability itself does not exist, making this a false positive rather than a mitigated risk.

Question #102

An organization disabled unneeded services and placed a firewall in front of a business-critical legacy system.

Which of the following best describes the actions taken by the organization?

A. Exception
B. Segmentation
C. Risk transfer
D. Compensating controls

Correct Answer: D — Compensating controls

Compensating controls are alternative safeguards implemented when standard security measures cannot be applied. Disabling unneeded services and placing a firewall in front of a legacy system that cannot be updated or patched represents compensating controls—alternative security measures to reduce risk when the system itself cannot be fully secured.

Why The Other Options Are Incorrect

A. Exception refers to accepting risk temporarily, not implementing alternative controls.

B. Segmentation isolates systems but doesn't specifically describe compensating for legacy system limitations with firewalls.

C. Risk transfer involves shifting risk to another party through insurance or outsourcing, not implementing additional security controls.

Question #103

A security consultant needs secure, remote access to a client environment.

Which of the following should the security consultant most likely use to gain access?

A. EAP
B. DHCP
C. IPSec
D. NAT

Correct Answer: C — IPSec

IPSec is a cryptographic protocol suite used to secure Internet Protocol communications through authentication and encryption. It is the standard choice for establishing secure remote access connections for consultants and remote workers. EAP is an authentication framework, DHCP assigns IP addresses, and NAT translates addresses—none provide the end-to-end encryption and security needed for remote access.

Why The Other Options Are Incorrect

A. EAP is an authentication method, not a secure remote access protocol.

B. DHCP is used for IP address assignment, not secure remote connections.

D. NAT translates IP addresses but provides no encryption or authentication for secure access.

Question #104

Which of the following should a systems administrator use to ensure an easy deployment of resources within the cloud provider?

A. Software as a service
B. Infrastructure as code
C. Internet of Things
D. Software-defined networking

Correct Answer: B — Infrastructure as code

Infrastructure as Code (IaC) enables administrators to define and deploy cloud resources using code, templates, and automation tools, making deployment easy, repeatable, and scalable. SaaS is an application delivery model, IoT involves connected devices, and SDN relates to network management—none directly address easy resource deployment within cloud environments.

Why The Other Options Are Incorrect

A. SaaS is a software delivery model, not a deployment methodology for cloud resources.

C. IoT refers to connected devices and sensors, not cloud resource deployment.

D. SDN manages network behavior, not general cloud resource deployment.

Question #105

After a security awareness training session, a user called the IT help desk and reported a suspicious call. The suspicious caller stated that the Chief Financial Officer wanted credit card information in order to close an invoice.

Which of the following topics did the user recognize from the training?

A. Insider threat
B. Email phishing
C. Social engineering
D. Executive whaling

✅ Correct Answer: C — Social engineering

Social engineering is the manipulation of people into divulging confidential information through deception and trust exploitation. The scenario describes an attacker impersonating an executive and requesting sensitive information via phone call, which is a classic social engineering tactic. Insider threats involve current employees, email phishing uses email, and whaling specifically targets high-level executives (though this applies to any employee)—making social engineering the broadest and most accurate answer.

Why The Other Options Are Incorrect

A. Insider threat refers to harm from current employees, not external impersonation attacks.

B. Email phishing uses email, whereas this attack occurred via phone call.

D. Whaling targets senior executives specifically; this call targeted a general employee.

Question #106

A security administrator is deploying a DLP solution to prevent the exfiltration of sensitive customer data.

Which of the following should the administrator do first?

A. Block access to cloud storage websites.
B. Create a rule to block outgoing email attachments.
C. Apply classifications to the data.
D. Remove all user permissions from shares on the file server.

Daily Debian

✅ Correct Answer: C — Apply classifications to the data.

Before implementing DLP rules and blocks, the administrator must first classify sensitive customer data so the system knows what to protect. Classification establishes the foundation for all subsequent DLP policies—without knowing what data is sensitive, blocking cannot be properly targeted. Blocking websites, email attachments, or removing permissions without first identifying sensitive data would be ineffective and could disrupt legitimate business operations.

Why The Other Options Are Incorrect

A. Blocking cloud storage without data classification may harm business operations.

B. Creating blocking rules requires knowing which data is sensitive first.

D. Removing all permissions is premature without understanding data sensitivity levels.

Question #107

An administrator assists the legal and compliance team with ensuring information about customer transactions is archived for the proper time period.

Which of the following data policies is the administrator carrying out?

A. Compromise
B. Retention
C. Analysis
D. Transfer
E. Inventory

Correct Answer: B — Retention

Retention policy defines how long data must be kept based on legal, regulatory, and business requirements. The scenario explicitly describes archiving customer transaction information for the proper time period, which is the definition of data retention. Compromise refers to security breaches, analysis involves data examination, transfer relates to data movement, and inventory catalogs data assets—none address time-based archival requirements.

Why The Other Options Are Incorrect

A. Compromise relates to security breaches, not data archival periods.
C. Analysis involves examining data, not determining archival timeframes.
D. Transfer involves moving data between systems, not retention duration.
E. Inventory catalogs what data exists, not how long to keep it.

Question #108

A company is working with a vendor to perform a penetration test.

Which of the following includes an estimate about the number of hours required to complete the engagement?

A. SOW
B. BPA
C. SLA
D. NDA

Correct Answer: A — SOW

A Statement of Work (SOW) is a document that defines the scope, objectives, deliverables, timeline, and estimated hours/effort required for a project or engagement, including penetration testing. The SOW explicitly includes labor estimates and duration. A BPA (Blanket Purchase Agreement) is a procurement tool, an SLA (Service Level

Agreement) defines service standards, and an NDA (Non-Disclosure Agreement) protects confidential information—none include effort estimates.

Why The Other Options Are Incorrect

B. BPA is a purchasing agreement framework, not an engagement specification document.

C. SLA defines service performance standards and response times, not project effort estimates.

D. NDA protects confidentiality but does not include engagement hour estimates.

Question #109

A Chief Information Security Officer (CISO) wants to explicitly raise awareness about the increase of ransomware-as-a-service in a report to the management team.

Which of the following best describes the threat actor in the CISO's report?

A. Insider threat
B. Hacktivist
C. Nation-state
D. Organized crime

Correct Answer: D — Organized crime

Ransomware-as-a-Service (RaaS) is primarily associated with organized crime groups that develop and lease ransomware tools to other attackers for profit, creating a criminal business model. This profit-driven, sophisticated operation is characteristic of organized cybercrime rather than individual insiders, hacktivists motivated by ideology, or nation-states pursuing geopolitical objectives.

Why The Other Options Are Incorrect

A. Insider threats involve current employees, not external criminal service providers.

B. Hacktivists are motivated by political or social causes, not commercial profit.

C. Nation-states pursue strategic/political goals, not commercial ransomware-as-a-service.

Question #110

Which of the following practices would be best to prevent an insider from introducing malicious code into a company's development process?

A. Code scanning for vulnerabilities
B. Open-source component usage
C. Quality assurance testing

D. Peer review and approval

Correct Answer: D — Peer review and approval

Peer review and approval processes ensure that code changes are examined by other developers before integration, providing a human control to detect and prevent malicious code insertion by insiders. This multi-person authorization prevents a single compromised developer from introducing malicious code undetected. Code scanning finds vulnerabilities, open-source component usage relates to third-party dependencies, and QA testing may not catch intentional malicious logic designed to evade detection.

Why The Other Options Are Incorrect

A. Code scanning detects vulnerabilities but may miss intentional malicious logic designed to hide.

B. Open-source component usage relates to dependency management, not insider code introduction.

C. QA testing validates functionality but may not detect intentionally hidden malicious code.

Question #111

Which of the following can best protect against an employee inadvertently installing malware on a company system?

A. Host-based firewall
B. System isolation
C. Least privilege
D. Application allow list

Correct Answer: D — Application allow list

An application allow list (whitelist) prevents unauthorized software from executing by only permitting pre-approved applications. This directly prevents inadvertent malware installation by blocking any unapproved executable, including malware an employee might unknowingly download. This is more effective than the other options because it operates at the point of execution rather than just monitoring network traffic or restricting permissions after the fact.

Why The Other Options Are Incorrect

A. A host-based firewall filters network traffic but does not prevent local execution of malware binaries.

B. System isolation reduces spread but does not prevent initial installation on that system.

C. Least privilege restricts what an infected process can do, but does not prevent

malware installation itself.

Question #112

A company is adding a clause to its AUP that states employees are not allowed to modify the operating system on mobile devices.

Which of the following vulnerabilities is the organization addressing?

A. Cross-site scripting
B. Buffer overflow
C. Jailbreaking
D. Side loading

Correct Answer: C — Jailbreaking

Jailbreaking is the process of modifying an operating system on mobile devices to remove restrictions and gain elevated privileges. By prohibiting OS modifications in the AUP, the organization directly addresses the vulnerability that jailbreaking creates, which includes bypassing security controls and installing unauthorized software. Sideloading is a related concept but jailbreaking is the specific term for OS modification.

Why The Other Options Are Incorrect

A. Cross-site scripting is a web application vulnerability unrelated to OS modification.

B. Buffer overflow is a code-level vulnerability not specifically addressed by preventing OS modification.

D. Sideloading is installing apps outside official app stores, related to but distinct from OS modification.

Question #113

Which of the following would be the best ways to ensure only authorized personnel can access a secure facility? (Choose two.)

A. Fencing
B. Video surveillance
C. Badge access
D. Access control vestibule
E. Sign-in sheet
F. Sensor

Correct Answer: C, D

C. Badge access

D. Access control vestibule

Badge access systems provide authentication and authorization, ensuring only approved personnel can physically enter. An access control vestibule (mantrap) adds a second layer by requiring multi-factor physical authentication and preventing tailgating. Together, these provide strong identity verification and controlled access. Video surveillance records activity but does not prevent unauthorized access; fencing and sensors are perimeter controls; sign-in sheets are non-enforceable and lack real-time verification.

Why The Other Options Are Incorrect

A. Fencing is a perimeter deterrent but does not verify authorization of individuals.

B. Video surveillance records access but does not actively prevent unauthorized entry.

E. Sign-in sheets are easily circumvented and provide no real-time access control.

F. Sensors detect motion or presence but do not authenticate or authorize individuals.

Question #114

An organization would like to store customer data on a separate part of the network that is not accessible to users on the main corporate network.

Which of the following should the administrator use to accomplish this goal?

A. Segmentation
B. Isolation
C. Patching
D. Encryption

Correct Answer: A — Segmentation

Network segmentation divides a network into separate subnets or zones, allowing the customer data to reside on a distinct network segment physically or logically separated from the main corporate network. This is the standard architectural approach for separating network traffic and controlling access between different groups of systems. Isolation refers more to the outcome, segmentation is the method used to achieve it.

Why The Other Options Are Incorrect

B. Isolation describes the desired state but not the technical method used to create separation.

C. Patching addresses software vulnerabilities and does not create network separation.

D. Encryption protects data in transit or at rest but does not prevent network access to the data storage location.

Question #115

Which of the following is the most common data loss path for an air-gapped network?

A. Bastion host
B. Unsecured Bluetooth
C. Unpatched OS
D. Removable devices

Correct Answer: D — Removable devices

Removable devices (USB drives, external hard drives, SD cards) represent the most common data exfiltration path for air-gapped networks because they physically bridge the gap between isolated and connected systems. An employee can easily copy sensitive data to removable media and transport it off the network. This is why strict removable media policies are critical for maintaining air-gap integrity.

Why The Other Options Are Incorrect

A. A bastion host is an intentional connection point, not a data loss vector for properly managed air-gaps.

B. Unsecured Bluetooth would require proximity and specific device pairing, making it less practical than removable media.

C. An unpatched OS is a vulnerability for malware execution but not the primary data loss path from an air-gapped network.

Daily Debian

Question #116

Malware spread across a company's network after an employee visited a compromised industry blog.

Which of the following best describes this type of attack?

A. Impersonation
B. Disinformation
C. Watering-hole
D. Smishing

Correct Answer: C — Watering-hole

A watering-hole attack targets websites frequented by a specific group (in this case, industry professionals) by compromising the website and infecting visitors. The malware is delivered when trusted industry resources are visited, exploiting the assumption that these sites are safe. This is distinct from other social engineering attacks and represents a strategic supply-chain style attack.

Why The Other Options Are Incorrect

A. Impersonation involves pretending to be someone else, not compromising websites.

B. Disinformation involves spreading false information, not deploying malware.

D. Smishing is phishing via SMS text messages, not through compromised websites.

Question #117

An organization is struggling with scaling issues on its VPN concentrator and internet circuit due to remote work. The organization is looking for a software solution that will allow it to reduce traffic on the VPN and internet circuit, while still providing encrypted tunnel access to the data center and monitoring of remote employee internet traffic.

Which of the following will help achieve these objectives?

A. Deploying a SASE solution to remote employees
B. Building a load-balanced VPN solution with redundant internet
C. Purchasing a low-cost SD-WAN solution for VPN traffic
D. Using a cloud provider to create additional VPN concentrators

Correct Answer: A — Deploying a SASE solution to remote employees

A SASE (Secure Access Service Edge) solution addresses all stated requirements by reducing VPN and internet circuit load through intelligent traffic routing (non-critical traffic goes direct to internet), providing encrypted tunnels for sensitive data center access, and enabling monitoring of employee internet activity. SASE is a modern cloud-based architecture designed specifically to solve remote work scaling challenges while maintaining security.

Why The Other Options Are Incorrect

B. Load-balanced VPN with redundancy increases capacity but does not reduce traffic on existing circuits as requested.

C. SD-WAN optimizes routing but does not specifically address the encryption and monitoring requirements for data center access.

D. Additional cloud VPN concentrators increase capacity but do not reduce circuit load or provide traffic monitoring.

Question #118

Which of the following is the best reason to complete an audit in a banking environment?

A. Regulatory requirement
B. Organizational change
C. Self-assessment requirement
D. Service-level requirement

Correct Answer: A — Regulatory requirement

Banking environments are subject to strict regulatory requirements (such as those from the Federal Reserve, OCC, and FDIC, plus standards like PCI DSS) that mandate regular audits. Regulatory compliance is the primary driver for audits in this highly regulated industry, whereas organizational changes, self-assessments, and SLA requirements are secondary factors.

Why The Other Options Are Incorrect

B. Organizational change may trigger additional audits but is not the best reason for regular banking audits.

C. Self-assessment is part of the audit process but not the fundamental reason audits are conducted.

D. Service-level requirements apply to IT operations but are not the primary reason for financial audits in banking.

Question #119

Which of the following security concepts is the best reason for permissions on a human resources fileshare to follow the principle of least privilege?

A. Integrity
B. Availability
C. Confidentiality
D. Non-repudiation

Correct Answer: C — Confidentiality

The principle of least privilege restricts user access to only the minimum permissions necessary to perform their job functions. For a human resources fileshare containing sensitive employee data, this directly protects confidentiality by preventing unauthorized users from accessing sensitive information. While integrity, availability, and non-repudiation are security concepts, confidentiality is the primary concern when restricting access to sensitive HR data.

Why The Other Options Are Incorrect

A. Integrity relates to data accuracy and modification, not access restriction.

B. Availability concerns system uptime and accessibility, not data access control.

D. Non-repudiation ensures accountability for actions, not data confidentiality.

Question #120

Which of the following are cases in which an engineer should recommend the decommissioning of a network device? (Choose two.)

A. The device has been moved from a production environment to a test environment.
B. The device is configured to use cleartext passwords.
C. The device is moved to an isolated segment on the enterprise network.
D. The device is moved to a different location in the enterprise.
E. The device's encryption level cannot meet organizational standards.
F. The device is unable to receive authorized updates.

Correct Answer: E, F

E. The device's encryption level cannot meet organizational standards.
F. The device is unable to receive authorized updates.

Decommissioning should occur when devices cannot meet security standards (encryption requirements) or cannot be properly maintained (unable to receive authorized updates). Option E addresses a security vulnerability that cannot be remediated, and option F indicates the device cannot be kept current with security patches, both justifying removal from service. Options A, C, and D involve moving devices to different environments or locations but don't inherently require decommissioning. Option B, while a security concern, could be remediated through configuration changes rather than requiring decommissioning.

Why The Other Options Are Incorrect

A. Moving to test environment is a legitimate repurposing, not a decommissioning trigger.
B. Cleartext passwords can be reconfigured without decommissioning.
C. Network segmentation isolates the device, managing rather than eliminating risk.
D. Physical relocation doesn't inherently require decommissioning.

Question #121

A company is required to perform a risk assessment on an annual basis.

Which of the following types of risk assessments does this requirement describe?

A. Continuous
B. Ad hoc
C. Recurring
D. One time

Correct Answer: C — Recurring

A recurring risk assessment is one that occurs at regular, scheduled intervals. The requirement to perform risk assessments on an annual basis describes a recurring pattern—it happens every year as part of regular organizational procedures. This is distinct from one-time, ad hoc, or continuous assessments, which have different scheduling patterns.

Why The Other Options Are Incorrect

A. Continuous refers to ongoing real-time monitoring, not annual scheduling.

B. Ad hoc implies unplanned, irregular assessments as needed.

D. One-time describes a single assessment event, not an annual requirement.

Question #122

After a recent ransomware attack on a company's system, an administrator reviewed the log files.

Which of the following control types did the administrator use?

A. Compensating
B. Detective
C. Preventive
D. Corrective

Correct Answer: B — Detective

Reviewing log files after a ransomware attack is a detective control—it identifies and analyzes what has already occurred. Detective controls work after an incident happens to identify, detect, and document security events. The administrator examined logs to understand the attack that had already taken place, which is the core function of detective controls.

Why The Other Options Are Incorrect

A. Compensating controls substitute for primary controls that cannot be implemented.

C. Preventive controls stop incidents before they occur.

D. Corrective controls remediate damage after detection and involve active restoration.

Question #123

Which of the following exercises should an organization use to improve its incident response process?

A. Tabletop
B. Replication
C. Failover

D. Recovery

Correct Answer: A — Tabletop

A tabletop exercise is a structured walkthrough of an incident response scenario where teams discuss and simulate their response without activating systems. This exercise format is ideal for improving incident response processes by identifying gaps, testing procedures, and training personnel. Replication, failover, and recovery are technical operations related to systems and data, not incident response process improvement exercises.

Why The Other Options Are Incorrect

B. Replication is a technical data duplication process, not an exercise format.

C. Failover is a system operation for redundancy, not an incident response exercise.

D. Recovery is an operational procedure, not a process improvement exercise.

Question #124

Which of the following best ensures minimal downtime and data loss for organizations with critical computing equipment located in earthquake-prone areas?

A. Generators and UPS
B. Off-site replication
C. Redundant cold sites
D. High availability networking

Correct Answer: B — Off-site replication

Off-site replication provides the best protection against earthquake damage by maintaining real-time or near-real-time copies of critical data and systems at a geographically distant location. This ensures both minimal data loss (through continuous replication) and minimal downtime (data is available elsewhere). Generators and UPS address power concerns but not physical destruction. Cold sites provide recovery capability but involve significant downtime. High availability networking improves uptime but doesn't address geographic disaster protection.

Why The Other Options Are Incorrect

A. Generators and UPS only address power loss, not earthquake physical damage.

C. Cold sites require significant time to activate, resulting in substantial downtime.

D. High availability networking improves uptime but doesn't address geographic disasters.

Question #125

A newly identified network access vulnerability has been found in the OS of legacy IoT devices.

Which of the following would best mitigate this vulnerability quickly?

A. Insurance
B. Patching
C. Segmentation
D. Replacement

Correct Answer: C — Segmentation

Network segmentation is the best quick mitigation for a vulnerability in legacy IoT devices that cannot be patched. By isolating the vulnerable devices to a restricted network segment, the organization prevents attackers from accessing them via the primary network. This can be implemented immediately without waiting for patches, replacements, or device updates. Patching may not be available for legacy devices, replacement takes time, and insurance addresses financial risk but not the vulnerability itself.

Why The Other Options Are Incorrect

A. Insurance addresses financial risk, not vulnerability mitigation.
B. Patching may not be available for legacy devices with unpatched OS vulnerabilities.
D. Replacement takes considerable time and cost, not a quick mitigation.

Question #126

After an audit, an administrator discovers all users have access to confidential data on a file server.

Which of the following should the administrator use to restrict access to the data quickly?

A. Group Policy
B. Content filtering
C. Data loss prevention
D. Access control lists

Correct Answer: D — Access control lists

Access control lists (ACLs) are the direct mechanism for controlling file and resource permissions. ACLs restrict who can access specific files and folders by specifying exactly which users and groups have permission to access resources. This provides immediate, granular control over file server access. While Group Policy can enforce ACLs enterprise-wide, ACLs are the specific tool for restricting access to data. Content filtering and data loss prevention address different security concerns and are not the primary tools for

access restriction.

Why The Other Options Are Incorrect

A. Group Policy is an enterprise deployment tool, not the direct access control mechanism.

B. Content filtering restricts content types, not file access permissions.

C. Data loss prevention monitors and prevents data exfiltration, not access control.

Question #127

A client demands at least 99.99% uptime from a service provider's hosted security services.

Which of the following documents includes the information the service provider should return to the client?

A. MOA
B. SOW
C. MOU
D. SLA

Correct Answer: D — SLA

An SLA (Service Level Agreement) is the document that specifies measurable performance metrics and uptime guarantees between a service provider and client. It defines the specific service levels, including availability percentages like 99.99% uptime, along with remedies if those levels are not met. This is the standard contractual document for defining such technical requirements.

Why The Other Options Are Incorrect

A. MOA (Memorandum of Agreement) is a general agreement but does not typically contain specific technical performance metrics.

B. SOW (Statement of Work) describes the work to be performed but not the ongoing service level guarantees.

C. MOU (Memorandum of Understanding) is a preliminary agreement and lacks the binding technical specifications of an SLA.

Question #128

A company is discarding a classified storage array and hires an outside vendor to complete the disposal.

Which of the following should the company request from the vendor?

A. Certification

B. Inventory list
C. Classification
D. Proof of ownership

Correct Answer: A — Certification

When disposing of classified equipment, the company should request a Certification from the vendor proving that proper data destruction and disposal procedures were followed according to regulatory standards. This certification documents compliance with legal and regulatory requirements for handling classified materials and provides proof that the disposal was completed securely.

Why The Other Options Are Incorrect

B. An inventory list would be helpful for tracking but doesn't prove proper disposal procedures were followed.

C. Classification is already known; the company needs proof it was handled properly during disposal.

D. Proof of ownership is irrelevant; the company already owns the equipment being discarded.

Question #129

A company is planning a disaster recovery site and needs to ensure that a single natural disaster would not result in the complete loss of regulated backup data.

Which of the following should the company consider?

A. Geographic dispersion
B. Platform diversity
C. Hot site
D. Load balancing

Correct Answer: A — Geographic dispersion

Geographic dispersion ensures that backup data is stored in multiple physically separate locations so that a single natural disaster cannot destroy all copies of regulated backup data. This is a critical requirement for disaster recovery planning to protect against localized disasters affecting a single geographic area.

Why The Other Options Are Incorrect

B. Platform diversity refers to using different hardware/software types but does not protect against geographic disasters.

C. A hot site is a backup facility but without geographic dispersion, it could be affected by the same disaster.

D. Load balancing distributes traffic but does not protect backup data from geographic disasters.

Question #130

A security analyst locates a potentially malicious video file on a server and needs to identify both the creation date and the file's creator.

Which of the following actions would most likely give the security analyst the information required?

A. Obtain the file's SHA-256 hash.
B. Use hexdump on the file's contents.
C. Check endpoint logs.
D. Query the file's metadata.

Correct Answer: D — Query the file's metadata.

Querying file metadata is the most direct way to obtain creation date and creator information. Metadata contains file properties including timestamps (creation, modification, access dates) and often author/creator information embedded in the file's header and properties sections.

Why The Other Options Are Incorrect

A. SHA-256 hash identifies the file but provides no information about creation date or creator.

B. Hexdump shows raw binary content but requires manual interpretation and is inefficient for extracting metadata.

C. Endpoint logs might show file access events but are unlikely to contain file creation details or original creator information.

Question #131

Which of the following teams combines both offensive and defensive testing techniques to protect an organization's critical systems?

A. Red
B. Blue
C. Purple
D. Yellow

Correct Answer: C — Purple

A Purple team combines both red team (offensive/attack) and blue team

(defensive/security) techniques to comprehensively test and improve an organization's security posture. This hybrid approach uses offensive testing insights to strengthen defensive capabilities.

Why The Other Options Are Incorrect

A. Red team focuses only on offensive testing and attacks, not defensive measures.

B. Blue team focuses only on defensive security measures and response, not offensive testing.

D. Yellow team is not a standard security team classification in industry frameworks.

Question #132

A small business uses kiosks on the sales floor to display product information for customers. A security team discovers the kiosks use end-of-life operating systems.

Which of the following is the security team most likely to document as a security implication of the current architecture?

A. Patch availability
B. Product software compatibility
C. Ease of recovery
D. Cost of replacement

Correct Answer: A — Patch availability

The primary security implication of end-of-life operating systems is lack of patch availability. Once an OS reaches end-of-life, the vendor stops releasing security patches and updates, leaving the systems vulnerable to known exploits and new vulnerabilities that cannot be remediated.

Why The Other Options Are Incorrect

B. Product software compatibility is a functional concern, not the primary security implication.

C. Ease of recovery relates to disaster recovery, not the security risk of end-of-life systems.

D. Cost of replacement is a budgetary concern, not a direct security implication.

Question #133

Which of the following would help ensure a security analyst is able to accurately measure the overall risk to an organization when a new vulnerability is disclosed?

A. A full inventory of all hardware and software
B. Documentation of system classifications

C. A list of system owners and their departments

D. Third-party risk assessment documentation

✅ Correct Answer: A — A full inventory of all hardware and software

A full inventory of all hardware and software is essential to accurately measure organizational risk when a vulnerability is disclosed. Without knowing what systems and applications are deployed throughout the organization, the analyst cannot determine exposure scope, affected assets, or overall risk impact.

Why The Other Options Are Incorrect

B. System classification helps prioritize but doesn't tell you what systems exist to assess exposure.

C. System owners help with notification but don't provide the asset inventory needed for risk measurement.

D. Third-party assessments are external perspectives but don't replace the need for internal asset inventory.

Question #134

Which of the following best practices gives administrators a set period to perform changes to an operational system to ensure availability and minimize business impacts?

A. Impact analysis

B. Scheduled downtime

C. Backout plan

D. Change management boards

✅ Correct Answer: B — Scheduled downtime

Scheduled downtime is the best practice that designates a specific period when administrators can perform system changes while minimizing business impact. This pre-planned window allows the organization to prepare, notify stakeholders, and reduce disruption to operations.

Why The Other Options Are Incorrect

A. Impact analysis assesses risks but does not provide the scheduled period for performing changes.

C. Backout plan defines how to revert changes if problems occur but doesn't schedule the change window.

D. Change management boards approve changes but do not establish the specific scheduled period for execution.

Question #135

A company must ensure sensitive data at rest is rendered unreadable.

Which of the following will the company most likely use?

A. Hashing
B. Tokenization
C. Encryption
D. Segmentation

Correct Answer: C — Encryption

Encryption is the standard method for rendering sensitive data at rest unreadable. It converts plaintext data into ciphertext using cryptographic algorithms, ensuring that only those with the proper decryption key can access the original data. This is the most direct and widely accepted approach for protecting data confidentiality.

Why The Other Options Are Incorrect

A. Hashing is irreversible and used for integrity verification, not for rendering data readable again.

B. Tokenization replaces sensitive data with tokens but doesn't inherently render data unreadable in the same way encryption does.

D. Segmentation is a network security strategy that isolates systems but doesn't directly protect data at rest.

Daily Debian

Question #136

A legacy device is being decommissioned and is no longer receiving updates or patches.

Which of the following describes this scenario?

A. End of business
B. End of testing
C. End of support
D. End of life

Correct Answer: D — End of life

End of life (EOL) describes when a device is no longer receiving updates, patches, or support from the manufacturer or vendor. A legacy device being decommissioned that no longer receives updates is at the end of its life cycle. This is the standard industry terminology for this scenario.

Why The Other Options Are Incorrect

A. End of business refers to a company ceasing operations, not a device's support

status.

B. End of testing refers to completion of quality assurance phases during development, not device decommissioning.

C. End of support is related but less specific; EOL encompasses the full lifecycle end including hardware obsolescence.

Question #137

A bank insists all of its vendors must prevent data loss on stolen laptops.

Which of the following strategies is the bank requiring?

A. Encryption at rest
B. Masking
C. Data classification
D. Permission restrictions

Correct Answer: A — Encryption at rest

Encryption at rest is the primary strategy to prevent data loss on stolen laptops. By encrypting the data stored on the device, even if a laptop is physically stolen, the data remains unreadable and protected without the encryption key. This directly addresses the bank's concern about protecting sensitive data on mobile devices.

Why The Other Options Are Incorrect

B. Masking obscures data for display purposes but doesn't protect stolen devices.

C. Data classification organizes data by sensitivity level but doesn't actively prevent loss.

D. Permission restrictions control access in normal operation but are ineffective against stolen hardware.

Question #138

A company's end users are reporting that they are unable to reach external websites. After reviewing the performance data for the DNS severs, the analyst discovers that the CPU, disk, and memory usage are minimal, but the network interface is flooded with inbound traffic. Network logs show only a small number of DNS queries sent to this server.

Which of the following best describes what the security analyst is seeing?

A. Concurrent session usage
B. Secure DNS cryptographic downgrade
C. On-path resource consumption

D. Reflected denial of service

Correct Answer: D — Reflected denial of service

A reflected denial of service (DDoS) attack is occurring. The DNS server is being flooded with inbound traffic but showing minimal resource consumption internally (low CPU, disk, memory), and there are only a small number of actual DNS queries. This indicates the server is receiving spoofed responses from third-party servers that have been tricked into sending traffic to the victim, overwhelming the network interface without consuming server resources.

Why The Other Options Are Incorrect

A. Concurrent session usage would cause high CPU/memory consumption, not just network interface flooding.

B. Secure DNS cryptographic downgrade is a protocol manipulation attack, not related to network flooding.

C. On-path resource consumption would affect internal server resources, not just network interface traffic.

Question #139

A systems administrator wants to prevent users from being able to access data based on their responsibilities. The administrator also wants to apply the required access structure via a simplified format.

Which of the following should the administrator apply to the site recovery resource group?

A. RBAC
B. ACL
C. SAML
D. GPO

Correct Answer: A — RBAC

Role-Based Access Control (RBAC) is the access management approach that prevents users from accessing data based on their responsibilities and job roles. It applies access permissions based on assigned roles in a simplified, scalable format, making it ideal for managing access to resource groups like site recovery systems where permissions should align with user responsibilities.

Why The Other Options Are Incorrect

B. ACLs (Access Control Lists) specify individual object permissions but are more granular and less role-oriented.

C. SAML is a federated authentication protocol, not an access control model.

D. GPO (Group Policy Object) is a Windows management tool for enforcing policies but isn't primarily an access control framework.

Question #140

During the onboarding process, an employee needs to create a password for an intranet account. The password must include ten characters, numbers, and letters, and two special characters. Once the password is created, the company will grant the employee access to other company-owned websites based on the intranet profile.

Which of the following access management concepts is the company most likely using to safeguard intranet accounts and grant access to multiple sites based on a user's intranet account? (Choose two.)

A. Federation
B. Identity proofing
C. Password complexity
D. Default password changes
E. Password manager
F. Open authentication

Correct Answer: A, C

A. Federation
C. Password complexity

Password complexity (C) directly addresses the password requirements described (ten characters, numbers, letters, and special characters). Federation (A) describes the concept of using one intranet profile to grant access to multiple company-owned websites without separate authentication, enabling single sign-on across systems. Together, these concepts safeguard the intranet account through strong passwords while enabling streamlined multi-site access.

Why The Other Options Are Incorrect

B. Identity proofing verifies a user's real identity during onboarding but isn't about granting access to multiple sites.

D. Default password changes refer to forcing initial password modification, not the ongoing access management concept.

E. Password managers store credentials but don't directly address federation or multi-site access.

F. Open authentication (OAuth) is an authorization protocol but less commonly used for this intranet federation scenario.

Question #141

Which of the following describes a security alerting and monitoring tool that collects system, application, and network logs from multiple sources in a centralized system?

A. SIEM
B. DLP
C. IDS
D. SNMP

Correct Answer: A — SIEM

SIEM (Security Information and Event Management) is the primary tool that collects, aggregates, and analyzes logs from multiple sources (systems, applications, networks) in a centralized location. It provides alerting, monitoring, and correlation capabilities essential for comprehensive security monitoring and incident response.

Why The Other Options Are Incorrect

B. DLP (Data Loss Prevention) focuses on preventing data exfiltration, not log collection and monitoring.

C. IDS (Intrusion Detection System) detects network attacks but doesn't centralize logs from all sources.

D. SNMP (Simple Network Management Protocol) is used for network device management, not security log aggregation.

Daily Debian

Question #142

A network manager wants to protect the company's VPN by implementing multifactor authentication that uses:

- Something you know
- Something you have
- Something you are

Which of the following would accomplish the manager's goal?

A. Domain name, PKI, GeoIP lookup
B. VPN IP address, company ID, facial structure
C. Password, authentication token, thumbprint
D. Company URL, TLS certificate, home address

Correct Answer: C — Password, authentication token, thumbprint

Password (something you know), authentication token (something you have), and thumbprint (something you are) perfectly align with the three MFA factors required. A password is knowledge-based, an authentication token is a physical possession, and a

thumbprint is a biometric characteristic. This combination provides robust multifactor authentication for VPN protection.

Why The Other Options Are Incorrect

A. Domain name and TLS certificate aren't authentication factors; GeoIP is location-based, not a standard MFA factor.

B. VPN IP address isn't an authentication factor; company ID could be knowledge-based but GeoIP lookup isn't proper MFA.

D. Company URL and home address aren't authentication factors; TLS certificate is infrastructure-based, not user authentication.

Question #143

Which of the following would be the best way to handle a critical business application that is running on a legacy server?

A. Segmentation
B. Isolation
C. Hardening
D. Decommissioning

Correct Answer: B — Isolation

When a critical business application runs on a legacy server, isolation is the best approach to protect it from modern threats. Isolation involves separating the legacy system from the broader network, limiting its attack surface and preventing lateral movement if the system is compromised. While hardening and segmentation are defensive measures, isolation specifically addresses the unique risk of an outdated, potentially vulnerable system by containing it. Decommissioning is not viable since the application is critical to business operations.

Why The Other Options Are Incorrect

A. Segmentation divides the network but doesn't adequately contain the specific risks of a vulnerable legacy system like isolation does.

C. Hardening improves security posture but cannot fully address the inherent vulnerabilities in outdated software and systems.

D. Decommissioning is impossible if the application is critical to business operations.

Question #144

Which of the following vulnerabilities is exploited when an attacker overwrites a register with a malicious address?

A. VM escape

B. SQL injection

C. Buffer overflow

D. Race condition

✅ Correct Answer: C — Buffer overflow

A buffer overflow occurs when an attacker writes more data into a buffer than it can hold, causing the excess data to overwrite adjacent memory locations, including registers and return addresses. This allows an attacker to inject malicious code or redirect program execution to a malicious address. This is the classic definition and exploitation method of buffer overflow vulnerabilities.

Why The Other Options Are Incorrect

A. VM escape involves breaking out of virtual machine isolation, not overwriting registers with malicious addresses.

B. SQL injection manipulates database queries through unsanitized input, not register manipulation.

D. Race conditions exploit timing gaps in concurrent processes, not register overwrites.

Question #145

After a company was compromised, customers initiated a lawsuit. The company's attorneys have requested that the security team initiate a legal hold in response to the lawsuit.

Which of the following describes the action the security team will most likely be required to take?

A. Retain the emails between the security team and affected customers for 30 days.

B. Retain any communications related to the security breach until further notice.

C. Retain any communications between security members during the breach response.

D. Retain all emails from the company to affected customers for an indefinite period of time.

✅ Correct Answer: B — Retain any communications related to the security breach until further notice.

A legal hold requires preservation of all relevant evidence and communications related to the litigation. In this case, the company must retain any communications related to the security breach and the incident response until the legal matter is resolved. This is broader than just emails between specific parties and includes all relevant documentation, communications, logs, and evidence pertaining to the breach itself.

Why The Other Options Are Incorrect

A. A 30-day retention is too limited; legal holds extend until the litigation is resolved, and it's not limited to customer communications.

C. Internal security team communications are relevant but represent only a subset of what must be retained.

D. The requirement is indefinite duration until further notice, but it's specifically for communications related to the breach, not all customer emails.

Question #146

Which of the following describes the process of concealing code or text inside a graphical image?

A. Symmetric encryption
B. Hashing
C. Data masking
D. Steganography

Correct Answer: D — Steganography

Steganography is the practice of hiding information (text, code, messages) within other data, most commonly within graphical images. The hidden data is embedded in a way that is not obvious to an observer. This is distinct from encryption, which makes data unreadable, or hashing, which creates a unique fingerprint. Steganography aims for concealment rather than scrambling.

Why The Other Options Are Incorrect

A. Symmetric encryption scrambles data so it's unreadable without a key, rather than hiding it within another medium.

B. Hashing creates a one-way fingerprint of data for integrity verification, not concealment within images.

C. Data masking obscures sensitive data in databases or files, not specifically hiding content within images.

Question #147

An employee receives a text message from an unknown number claiming to be the company's Chief Executive Officer and asking the employee to purchase several gift cards.

Which of the following types of attacks does this describe?

A. Vishing
B. Smishing
C. Pretexting

D. Phishing

Correct Answer: B — Smishing

Smishing is a phishing attack conducted via SMS (text messages) rather than email. The attacker impersonates an authority figure (in this case, the CEO) and requests the victim take an action (purchase gift cards), which is a classic social engineering tactic adapted to text messaging. The key identifier is that the attack arrives via SMS/text message.

Why The Other Options Are Incorrect

A. Vishing is phishing conducted through voice calls, not text messages.

C. Pretexting creates a fabricated scenario to extract information, typically through conversation, but doesn't specifically describe SMS-based attacks.

D. Phishing generally refers to email-based attacks, though the term can be broader; smishing specifically identifies the SMS channel.

Question #148

Which of the following risk management strategies should an enterprise adopt first if a legacy application is critical to business operations and there are preventative controls that are not yet implemented?

A. Mitigate
B. Accept
C. Transfer
D. Avoid

Correct Answer: A — Mitigate

When a critical business application has known vulnerabilities and preventative controls are available but not yet implemented, mitigation is the appropriate first strategy. Mitigation involves implementing controls to reduce the risk to an acceptable level. This is more proactive than accepting risk, more practical than avoidance (which would require shutting down a critical system), and should precede transfer strategies. Implementing the available preventative controls directly addresses the risk.

Why The Other Options Are Incorrect

B. Accepting risk without implementing available controls is irresponsible when preventative measures exist.

C. Transferring risk through insurance is secondary to implementing available technical controls.

D. Avoidance would require decommissioning a critical system, which is not viable.

Question #149

Visitors to a secured facility are required to check in with a photo ID and enter the facility through an access control vestibule.

Which of the following best describes this form of security control?

A. Physical
B. Managerial
C. Technical
D. Operational

Correct Answer: A — Physical

Photo ID verification and access control vestibules are physical security controls. They involve tangible, hardware-based mechanisms to prevent unauthorized physical access to a facility. Physical controls are distinct from technical controls (software/systems), managerial controls (policies/procedures), and operational controls (day-to-day execution). These measures directly restrict physical movement through the facility.

Why The Other Options Are Incorrect

B. Managerial controls are policies and procedures, not the implementation of physical barriers and ID checks.

C. Technical controls involve systems and software, not physical access points and ID verification.

D. Operational controls involve day-to-day execution of security procedures, not the physical infrastructure itself.

Question #150

The local administrator account for a company's VPN appliance was unexpectedly used to log in to the remote management interface.

Which of the following would have most likely prevented this from happening?

A. Using least privilege
B. Changing the default password
C. Assigning individual user IDs
D. Reviewing logs more frequently

Correct Answer: B — Changing the default password

The unexpected use of the local administrator account indicates an unauthorized login, most likely because the default password remained unchanged. Changing the default password is the fundamental step to prevent unauthorized access using default credentials. This is a standard security practice for any system with pre-set credentials. If

the default password had been changed to a strong, unique password, an attacker would be unable to access the account without discovering the new credentials.

Why The Other Options Are Incorrect

A. Least privilege limits user permissions but doesn't prevent unauthorized login using valid credentials.

C. Assigning individual user IDs is good practice but doesn't prevent compromise of the administrator account itself.

D. Reviewing logs more frequently detects intrusions after they occur but doesn't prevent unauthorized access in the first place.

Question #151

Which of the following is the best way to secure an on-site data center against intrusion from an insider?

A. Bollards
B. Access badge
C. Motion sensor
D. Video surveillance

Correct Answer: B — Access badge

Access badges are the best control against insider intrusion because they authenticate and authorize individuals before granting entry, creating accountability through logged access records. While bollards prevent vehicle ramming, motion sensors detect movement, and video surveillance records events, only access badges actively control who can enter the data center and provide proof of identity.

Why The Other Options Are Incorrect

A. Bollards prevent vehicle intrusion but do not control personnel access.

C. Motion sensors detect movement but do not prevent unauthorized access.

D. Video surveillance records intrusions but does not prevent them from occurring.

Question #152

An engineer moved to another team and is unable to access the new team's shared folders while still being able to access the shared folders from the former team. After opening a ticket, the engineer discovers that the account was never moved to the new group.

Which of the following access controls is most likely causing the lack of access?

A. Role-based

B. Discretionary
C. Time of day
D. Least privilege

Correct Answer: A — Role-based

Role-based access control (RBAC) grants permissions based on group or role membership. The engineer's account was never moved to the new group, so the account lacks the role necessary to access the new team's shared folders. This is a classic RBAC scenario where access depends on role assignment rather than individual permissions.

Why The Other Options Are Incorrect

B. Discretionary access control is user-controlled and would not explain systematic group-based access denial.

C. Time-of-day restrictions would affect all access attempts regardless of group membership.

D. Least privilege principle would limit access but does not explain why group membership affects folder access.

Question #153

Which of the following factors are the most important to address when formulating a training curriculum plan for a security awareness program?

(Choose two.)

A. Channels by which the organization communicates with customers
B. The reporting mechanisms for ethics violations
C. Threat vectors based on the industry in which the organization operates
D. Secure software development training for all personnel
E. Cadence and duration of training events
F. Retraining requirements for individuals who fail phishing simulations

Correct Answer: C, E

C. Threat vectors based on the industry in which the organization operates
E. Cadence and duration of training events

When formulating a security awareness curriculum, threat vectors specific to the industry ensure training is relevant to actual organizational risks, while cadence and duration determine training effectiveness and reinforcement. These two factors directly address what to train (C) and how often/long to train (E), which are fundamental to curriculum planning. Options B, D, and F are important but secondary to establishing the core training program parameters.

Why The Other Options Are Incorrect

A. Customer communication channels are not directly relevant to employee security awareness training curriculum.

B. Ethics reporting mechanisms are important but are procedural implementation rather than curriculum planning factors.

D. Secure development training is valuable but not required for all personnel in every organization.

F. Phishing simulation retraining is a response mechanism, not a fundamental factor in initial curriculum formulation.

Question #154

A network administrator is working on a project to deploy a load balancer in the company's cloud environment.

Which of the following fundamental security requirements does this project fulfil?

A. Privacy
B. Integrity
C. Confidentiality
D. Availability

Correct Answer: D — Availability

A load balancer distributes traffic across multiple servers to prevent any single point of failure and ensure services remain available even if one server fails. This directly addresses availability—one of the three pillars of the CIA triad. While load balancers may indirectly support other security goals, availability is the fundamental requirement they fulfill.

Why The Other Options Are Incorrect

A. Privacy concerns data protection from unauthorized access, which load balancers do not directly address.

B. Integrity ensures data is not modified, which is not the primary function of load balancers.

C. Confidentiality protects data from disclosure, which load balancers do not primarily ensure.

Question #155

A systems administrator is changing the password policy within an enterprise environment and wants this update implemented on all systems as quickly as possible.

Which of the following operating system security measures will the administrator most likely use?

A. Deploying PowerShell scripts
B. Pushing GPO update
C. Enabling PAP
D. Updating EDR profiles

Correct Answer: B — Pushing GPO update

Group Policy Object (GPO) updates in enterprise Windows environments are the standard mechanism for rapidly deploying system configuration changes like password policies to all managed systems simultaneously. GPOs push changes centrally and apply them enterprise-wide with minimal latency. PowerShell scripts, PAP, and EDR are not designed for this specific purpose.

Why The Other Options Are Incorrect

A. PowerShell scripts require individual execution and are slower than GPO for enterprise-wide deployment.

C. PAP (Password Authentication Protocol) is an outdated authentication protocol, not a deployment mechanism.

D. EDR profiles manage endpoint detection and response, not password policy deployment.

Daily Debian

Question #156

Which of the following would be most useful in determining whether the long-term cost to transfer a risk is less than the impact of the risk?

A. ARO
B. RTO
C. RPO
D. ALE
E. SLE

Correct Answer: D — ALE

Annual Loss Expectancy (ALE) is calculated as SLE × ARO and represents the expected monetary loss per year if a risk occurs. ALE is the most useful metric for determining whether the cost of risk transfer (insurance, outsourcing) is less than the potential annual impact, enabling cost-benefit analysis of risk mitigation strategies.

Why The Other Options Are Incorrect

A. ARO (Annual Rate of Occurrence) is a component of ALE but does not itself

determine transfer costs versus impact.

B. RTO (Recovery Time Objective) measures restoration speed, not financial risk impact.

C. RPO (Recovery Point Objective) measures data loss tolerance, not financial impact.

E. SLE (Single Loss Expectancy) calculates one-time loss but does not annualize or compare transfer costs.

Question #157

In order to strengthen a password and prevent a hacker from cracking it, a random string of 36 characters was added to the password.

Which of the following best describes this technique?

A. Key stretching
B. Tokenization
C. Data masking
D. Salting

Correct Answer: D — Salting

Salting is the technique of adding a random string of characters to a password before hashing to prevent rainbow table attacks and ensure identical passwords produce different hashes. The 36-character random string added to the password is a salt, which strengthens password security by making precomputed hash attacks ineffective.

Why The Other Options Are Incorrect

A. Key stretching applies hash functions iteratively, not by appending a random string.

B. Tokenization replaces sensitive data with non-sensitive tokens, not related to password strengthening.

C. Data masking obscures sensitive data in displays, not a password security technique.

Question #158

A technician is deploying a new security camera.

Which of the following should the technician do?

A. Configure the correct VLAN.
B. Perform a vulnerability scan.
C. Disable unnecessary ports.
D. Conduct a site survey.

Correct Answer: D — Conduct a site survey.

A site survey is the fundamental first step before deploying security cameras, determining optimal camera placement, coverage areas, lighting conditions, network access points, and infrastructure requirements. This planning phase ensures effective deployment. While VLAN configuration, vulnerability scanning, and port disabling may follow, the site survey must occur first to inform all other deployment decisions.

Why The Other Options Are Incorrect

A. VLAN configuration is an implementation detail that follows site survey planning.

B. Vulnerability scanning applies to IT systems, not primarily to camera hardware selection and placement.

C. Disabling unnecessary ports is a hardening step that follows initial deployment and site planning.

Question #159

A company is experiencing a web services outage on the public network. The services are up and available but inaccessible. The network logs show a sudden increase in network traffic that is causing the outage.

Which of the following attacks is the organization experiencing?

A. ARP poisoning
B. Brute force
C. Buffer overflow
D. DDoS

Correct Answer: D — DDoS

A DDoS (Distributed Denial of Service) attack is characterized by a sudden surge in network traffic that overwhelms network resources and makes services inaccessible despite being operational. The scenario describes services that are up but unreachable due to excessive traffic, which is the hallmark of a DDoS attack.

Why The Other Options Are Incorrect

A. ARP poisoning redirects network traffic but doesn't cause widespread traffic floods or service outages in this manner.

B. Brute force attacks attempt repeated authentication attempts, not causing sudden network traffic spikes.

C. Buffer overflow exploits software vulnerabilities to execute code, not generate excessive network traffic.

Question #160

Which of the following threat actors is the most likely to be motivated by profit?

A. Hacktivist
B. Insider threat
C. Organized crime
D. Shadow IT

Correct Answer: C — Organized crime

Organized crime is primarily motivated by financial gain and profit. They engage in cybercriminal activities such as ransomware, theft, fraud, and extortion specifically to generate revenue, making profit their primary driver.

Why The Other Options Are Incorrect

A. Hacktivists are motivated by ideological or political causes, not financial profit.

B. Insider threats are motivated by various factors including revenge, disgruntlement, or espionage, not necessarily profit.

D. Shadow IT refers to unauthorized use of systems, not a specific threat actor type with profit motivation.

Daily Debian

Question #161

An organization experiences a cybersecurity incident involving a command-and-control server.

Which of the following logs should be analyzed to identify the impacted host? (Choose two.)

A. Application
B. Authentication
C. DHCP
D. Network
E. Firewall
F. Database

Correct Answer: D, E

D. Network
E. Firewall

Network logs and Firewall logs are essential for identifying command-and-control communications. Network logs capture traffic patterns and communication with external C2 servers, while firewall logs record attempted connections and blocked traffic to/from C2

infrastructure, both directly revealing which hosts communicated with malicious servers.

Why The Other Options Are Incorrect

A. Application logs typically record application-level events, not network connections to C2 servers.

B. Authentication logs track login attempts and credential usage, not C2 communication patterns.

C. DHCP logs show IP address assignments but don't identify C2 communication.

F. Database logs record database transactions, not external C2 communications.

Question #162

During a penetration test, a vendor attempts to enter an unauthorized area using an access badge.

Which of the following types of tests does this represent?

A. Defensive
B. Passive
C. Offensive
D. Physical

Correct Answer: D — Physical

This scenario describes a physical penetration test, where a tester attempts unauthorized physical access to a restricted area using an access badge. Physical security testing evaluates the effectiveness of physical security controls like badge readers, locks, and access restrictions.

Why The Other Options Are Incorrect

A. Defensive testing focuses on defending against attacks, not attempting unauthorized access.

B. Passive testing involves observation without interaction, whereas using a badge requires active engagement.

C. Offensive testing is too broad; this specifically tests physical security controls.

Question #163

A systems administrator uses a key to encrypt a message being sent to a peer in a different branch office. The peer then uses the same key to decrypt the message.

Which of the following describes this example?

A. Symmetric

B. Asymmetric
C. Hashing
D. Salting

Correct Answer: A — Symmetric

Symmetric encryption uses the same key for both encryption and decryption. The scenario explicitly states the sender uses a key to encrypt and the peer uses the same key to decrypt, which is the fundamental characteristic of symmetric cryptography.

Why The Other Options Are Incorrect

B. Asymmetric encryption uses a public key and private key pair, not the same key for both operations.

C. Hashing is a one-way function for integrity verification, not an encryption method.

D. Salting is a technique used with hashing to prevent rainbow table attacks, not an encryption method.

Question #164

A visitor plugs a laptop into a network jack in the lobby and is able to connect to the company's network.

Which of the following should be configured on the existing network infrastructure to best prevent this activity?

A. Port security
B. Web application firewall
C. Transport layer security
D. Virtual private network

Correct Answer: A — Port security

Port security controls which devices can connect to physical network ports, typically by limiting connections based on MAC addresses. This directly prevents unauthorized laptops from connecting to network jacks in public areas like lobbies.

Why The Other Options Are Incorrect

B. Web application firewalls filter HTTP/HTTPS traffic at the application layer, not physical network access.

C. Transport layer security encrypts data in transit but doesn't prevent initial network connection.

D. Virtual private networks provide secure remote access but don't restrict physical port connections.

Question #165

A security administrator is reissuing a former employee's laptop.

Which of the following is the best combination of data handling activities for the administrator to perform? (Choose two.)

A. Data retention
B. Certification
C. Destruction
D. Classification
E. Sanitization
F. Enumeration

Correct Answer: B, E

B. Certification
E. Sanitization

When reissuing a former employee's laptop, the administrator should perform Sanitization (secure data removal/wiping) and Certification (documenting that the device has been properly cleaned and is safe to reissue). These ensure data confidentiality and provide proof of proper handling.

Why The Other Options Are Incorrect

A. Data retention is inappropriate when reissuing a device; data should be removed.

C. Destruction applies when devices are being decommissioned, not reissued.

D. Classification organizes data sensitivity levels but doesn't handle the reissue requirement.

F. Enumeration documents assets but is not a data handling activity for device reissuance.

Question #166

A systems administrator would like to deploy a change to a production system.

Which of the following must the administrator submit to demonstrate that the system can be restored to a working state in the event of a performance issue?

A. Backout plan
B. Impact analysis
C. Test procedure
D. Approval procedure

Correct Answer: A — Backout plan

A backout plan documents the procedures to reverse or rollback a change if problems occur, demonstrating that the system can be restored to its previous working state. This is a critical change management requirement before deploying to production.

Why The Other Options Are Incorrect

B. Impact analysis assesses potential consequences but doesn't demonstrate restoration capability.

C. Test procedure validates changes work correctly but doesn't address rollback capability.

D. Approval procedure authorizes the change but doesn't document restoration procedures.

Question #167

A company is redesigning its infrastructure and wants to reduce the number of physical servers in use.

Which of the following architectures is best suited for this goal?

A. Serverless
B. Segmentation
C. Virtualization
D. Microservices

Daily Debian

Correct Answer: C — Virtualization

Virtualization directly addresses the goal of reducing physical servers by allowing multiple virtual machines to run on fewer physical hosts. This consolidation of hardware resources is the primary benefit of virtualization architecture. Serverless removes the need to manage servers but doesn't reduce existing physical infrastructure. Segmentation is a security practice unrelated to server reduction. Microservices is an application architecture pattern that doesn't inherently reduce physical servers.

Why The Other Options Are Incorrect

A. Serverless eliminates server management but doesn't reduce existing physical infrastructure

B. Segmentation is a security control, not an infrastructure consolidation strategy

D. Microservices is an application design pattern, not a physical infrastructure reduction approach

Question #168

A bank set up a new server that contains customers' PII.

Which of the following should the bank use to make sure the sensitive data is not modified?

A. Full disk encryption
B. Network access control
C. File integrity monitoring
D. User behavior analytics

Correct Answer: C — File integrity monitoring

File integrity monitoring (FIM) detects unauthorized modifications to files by tracking and alerting on changes to file attributes, content, and metadata. This directly addresses the requirement to ensure sensitive PII data is not modified. Full disk encryption protects data confidentiality but not integrity. Network access control manages who can connect but doesn't monitor file modifications. User behavior analytics detects anomalous activities but is not primarily designed for file integrity assurance.

Why The Other Options Are Incorrect

A. Full disk encryption protects confidentiality, not integrity against modifications
B. Network access control limits connections but doesn't monitor file changes
D. User behavior analytics detects unusual access patterns but not file modifications

Question #169

Users at a company are reporting they are unable to access the URL for a new retail website because it is flagged as gambling and is being blocked.

Which of the following changes would allow users to access the site?

A. Creating a firewall rule to allow HTTPS traffic
B. Configuring the IPS to allow shopping
C. Tuning the DLP rule that detects credit card data
D. Updating the categorization in the content filter

Correct Answer: D — Updating the categorization in the content filter

A content filter is categorizing the retail website incorrectly as gambling and blocking it. Updating the categorization in the content filter to correctly identify the site as a retail/shopping site will allow users to access it. Creating firewall rules for HTTPS doesn't address the categorization issue. Configuring the IPS for shopping is not a valid security control function. Tuning DLP rules for credit card data is unrelated to the gambling miscategorization.

Why The Other Options Are Incorrect

A. Firewall rules for HTTPS traffic won't override content filter categorization

B. IPS is for intrusion prevention, not content categorization adjustments

C. DLP tuning for credit card data is unrelated to the gambling categorization issue

Question #170

Which of the following most impacts an administrator's ability to address CVEs discovered on a server?

A. Rescanning requirements
B. Patch availability
C. Organizational impact
D. Risk tolerance

Correct Answer: B — Patch availability

Patch availability is the primary factor that determines whether an administrator can actually address a discovered CVE. Without an available patch from the vendor, the administrator cannot remediate the vulnerability regardless of other factors. Rescanning verifies the vulnerability but doesn't fix it. Organizational impact and risk tolerance influence prioritization of patching efforts but don't determine whether a patch can be applied at all.

Why The Other Options Are Incorrect

A. Rescanning requirements verify vulnerabilities but don't enable remediation

C. Organizational impact influences prioritization but not the ability to patch

D. Risk tolerance affects remediation decisions but not the existence of patches

Question #171

Which of the following describes effective change management procedures?

A. Approving the change after a successful deployment
B. Having a backout plan when a patch fails
C. Using a spreadsheet for tracking changes
D. Using an automatic change control bypass for security updates

Correct Answer: B — Having a backout plan when a patch fails

Having a backout plan (rollback procedure) when a patch fails is a critical component of effective change management, ensuring that failed deployments can be quickly reversed with minimal impact. Approving changes after deployment violates proper change control procedures. Using a spreadsheet for tracking is outdated and ineffective compared to proper change management systems. Automatic bypass of change control for security

updates circumvents the change management process and introduces risk.

Why The Other Options Are Incorrect

A. Approving changes after deployment violates change control procedures

C. Manual spreadsheet tracking is inefficient and lacks proper change control

D. Bypassing change control for security updates defeats the purpose of change management

Question #172

The CIRT is reviewing an incident that involved a human resources recruiter exfiltrating sensitive company data. The CIRT found that the recruiter was able to use HTTP over port 53 to upload documents to a web server.

Which of the following security infrastructure devices could have identified and blocked this activity?

A. WAF utilizing SSL decryption
B. NGFW utilizing application inspection
C. UTM utilizing a threat feed
D. SD-WAN utilizing IPSec

Correct Answer: B — NGFW utilizing application inspection

An NGFW (Next-Generation Firewall) utilizing application inspection can identify and block HTTP traffic over port 53 because it performs deep packet inspection and understands application protocols, recognizing that HTTP should not be running on the DNS port (53). This anomalous protocol-port combination violates normal network behavior. A WAF focuses on HTTP/HTTPS web application attacks. A UTM threat feed is signature-based and less likely to catch protocol anomalies. SD-WAN with IPSec is for network segmentation and encryption, not protocol anomaly detection.

Why The Other Options Are Incorrect

A. WAF is designed for web application attacks, not protocol-port anomalies

C. UTM threat feeds detect known threats but not necessarily protocol misuse patterns

D. SD-WAN with IPSec encrypts traffic but doesn't inspect for protocol anomalies

Question #173

An enterprise is working with a third party and needs to allow access between the internal networks of both parties for a secure file migration. The solution needs to ensure encryption is applied to all traffic that is traversing the networks.

Which of the following solutions should most likely be implemented?

A. EAP
B. IPSec
C. SD-WAN
D. TLS

Correct Answer: B — IPSec

IPSec is the appropriate solution for encrypting all traffic between two internal networks of different organizations during file migration. IPSec operates at the network layer and provides end-to-end encryption for all traffic, making it ideal for site-to-site connectivity. EAP is an authentication protocol for wireless networks. SD-WAN is a network management approach but requires underlying encryption protocols like IPSec. TLS is for application-layer encryption and wouldn't encrypt all network traffic.

Why The Other Options Are Incorrect

A. EAP is an authentication protocol for wireless access, not network-to-network encryption

C. SD-WAN is a management approach that requires underlying encryption like IPSec

D. TLS provides application-layer encryption, not comprehensive network traffic encryption

Question #174

An administrator has identified and fingerprinted specific files that will generate an alert if an attempt is made to email these files outside of the organization.

Which of the following best describes the tool the administrator is using?

A. DLP
B. SNMP traps
C. SCAP
D. IPS

Correct Answer: A — DLP

DLP (Data Loss Prevention) is specifically designed to fingerprint sensitive files and generate alerts when attempts are made to exfiltrate them via email or other channels. This capability of identifying specific files by content fingerprinting and controlling their movement is a core DLP function. SNMP traps are for network device monitoring and alerts. SCAP is for configuration and vulnerability scanning. IPS focuses on blocking malicious network activity, not file-specific exfiltration prevention.

Why The Other Options Are Incorrect

B. SNMP traps are for network device monitoring, not file fingerprinting and exfiltration alerts

C. SCAP is for configuration compliance and vulnerability assessment, not file DLP

D. IPS detects malicious activity but doesn't fingerprint specific files for exfiltration control

Question #175

A software developer released a new application and is distributing application files via the developer's website.

Which of the following should the developer post on the website to allow users to verify the integrity of the downloaded files?

A. Hashes
B. Certificates
C. Algorithms
D. Salting

Correct Answer: A — Hashes

Publishing cryptographic hash values (such as SHA-256 digests) alongside the download lets users compute the hash of the file they received and compare it to the posted value; if the two match, the file was not altered or corrupted in transit, which is exactly what integrity verification means.

Why The Other Options Are Incorrect

B. Certificates and code signing establish the publisher's identity and authenticity rather than providing a value users compare for integrity of a plain download.

C. An algorithm is only the method used to produce a digest; posting the algorithm name alone gives users nothing to compare against.

D. Salting adds random data to stored passwords before hashing to defeat rainbow tables and has no role in verifying downloaded files.

Question #176

An organization wants to limit potential impact to its log-in database in the event of a breach.

Which of the following options is the security team most likely to recommend?

A. Tokenization
B. Hashing
C. Obfuscation
D. Segmentation

Correct Answer: B — Hashing

Hashing converts passwords into one-way cryptographic values that cannot be reversed. If the login database is breached, attackers obtain hashes rather than plaintext passwords, significantly limiting the impact since hashes cannot be directly used to access accounts.

Why The Other Options Are Incorrect

A. Tokenization replaces sensitive data with tokens but is more commonly used for payment card data rather than password protection.

C. Obfuscation merely hides data but doesn't prevent access if the obfuscation method is discovered.

D. Segmentation separates networks but doesn't protect the passwords themselves once a database is breached.

Question #177

An administrator finds that all user workstations and servers are displaying a message that is associated with files containing an extension of .ryk.

Which of the following types of infections is present on the systems?

A. Virus
B. Trojan
C. Spyware
D. Ransomware

Daily Debian

Correct Answer: D — Ransomware

Ransomware typically encrypts files and changes their extensions (in this case .ryk) while displaying ransom messages demanding payment for decryption keys. The presence of a file extension change combined with a ransom-related message is the hallmark of ransomware infections.

Why The Other Options Are Incorrect

A. Viruses replicate and spread but typically don't display unified ransom messages with file extension changes.

B. Trojans are malicious programs disguised as legitimate software but don't characteristically encrypt files with new extensions.

C. Spyware monitors user activity and steals information but doesn't encrypt files or display ransom messages.

Question #178

A systems administrator is advised that an external web server is not functioning property. The administrator reviews the following firewall logs containing traffic going to the web server:

```
Date       |    Time     |  SourceIP   |SPort|Flag| DestIP | DPort
2023-01-25 01:45:09.102 98.123.45.100 4560 SYN 100.50.20.7 443
2023-01-25 01:45:09.102 95.123.45.101 3361 SYN 100.50.20.7 443
2023-01-25 01:45:09.102 99.123.45.102 3662 SYN 100.50.20.7 443
2023-01-25 01:45:09.102 89.123.45.103 5663 SYN 100.50.20.7 443
2023-01-25 01:45:09.102 98.123.45.104 4064 SYN 100.50.20.7 443
2023-01-25 01:45:09.102 80.123.45.105 4365 SYN 100.50.20.7 443
```

Which of the following attacks is likely occurring?

A. DDoS
B. Directory traversal
C. Brute-force
D. HTTPS downgrade

Correct Answer: A — DDoS

The firewall logs show multiple source IPs (98.123.45.100, 95.123.45.101, 99.123.45.102, 89.123.45.103, 98.123.45.104, 80.123.45.105) all sending traffic to the same destination IP (100.50.20.7) on the same port (443) at the exact same timestamp (01:45:09.102). This pattern of numerous distinct source addresses simultaneously flooding a single target with traffic is characteristic of a Distributed Denial of Service (DDoS) attack, where the goal is to overwhelm the server and render it unavailable.

Why The Other Options Are Incorrect

B. Directory traversal is an application-layer attack targeting file system access, not indicated by multiple simultaneous connections from different IPs in firewall logs.

C. Brute-force attacks attempt multiple authentication attempts, typically over time with varied credentials, not evidenced by this synchronized multi-source traffic pattern.

D. HTTPS downgrade attacks target protocol negotiation between client and server, not related to traffic patterns showing multiple source IPs flooding a destination.

Question #179

An organization would like to calculate the time needed to resolve a hardware issue with a server.

Which of the following risk management processes describes this example?

A. Recovery point objective
B. Mean time between failures

C. Recovery time objective

D. Mean time to repair

Correct Answer: D — Mean time to repair

Mean time to repair (MTTR) is the average duration required to fix a hardware failure and restore the system to operational status. This directly describes calculating the time needed to resolve a hardware issue with a server.

Why The Other Options Are Incorrect

A. Recovery point objective (RPO) measures the maximum tolerable data loss, not repair time.

B. Mean time between failures (MTBF) measures how long a system runs between failures, not repair duration.

C. Recovery time objective (RTO) measures how long systems can be down, not the actual time to repair.

Question #180

A security engineer is installing an IPS to block signature-based attacks in the environment.

Which of the following modes will best accomplish this task?

A. Monitor

B. Sensor

C. Audit

D. Active

Correct Answer: D — Active

Active mode (also called inline mode) allows an IPS to actively block and drop malicious traffic in real-time. This is the mode required to actually prevent signature-based attacks from reaching their targets, rather than just detecting or monitoring them.

Why The Other Options Are Incorrect

A. Monitor mode only observes traffic and logs threats without taking action to block them.

B. Sensor refers to the IPS hardware component, not an operational mode.

C. Audit mode logs events for review but doesn't actively block attacks.

Question #181

An IT manager is increasing the security capabilities of an organization after a data classification initiative determined that sensitive data could be exfiltrated from the environment.

Which of the following solutions would mitigate the risk?

A. XDR
B. SPF
C. DLP
D. DMARC

Correct Answer: C — DLP

Data Loss Prevention (DLP) solutions monitor, detect, and block unauthorized attempts to exfiltrate sensitive data from an organization's environment. DLP directly addresses the risk of sensitive data being removed from the network.

Why The Other Options Are Incorrect

A. XDR (Extended Detection and Response) is for detecting and responding to advanced threats, not preventing data exfiltration.

B. SPF (Sender Policy Framework) is an email authentication protocol, not relevant to data exfiltration prevention.

D. DMARC is an email authentication standard, not a data exfiltration prevention tool.

Question #182

Which of the following is used to protect a computer from viruses, malware, and Trojans being installed and moving laterally across the network?

A. IDS
B. ACL
C. EDR
D. NAC

Correct Answer: C — EDR

Endpoint Detection and Response (EDR) solutions protect individual computers by detecting malware, preventing installations, and monitoring for lateral movement across the network. EDR provides both preventive and detective capabilities at the endpoint level.

Why The Other Options Are Incorrect

A. IDS (Intrusion Detection System) monitors network traffic but doesn't prevent endpoint infections.

B. ACL (Access Control List) manages permissions but doesn't protect against malware

installation.

D. NAC (Network Access Control) controls device access to networks but doesn't prevent malware installation on endpoints.

Question #183

Client files can only be accessed by employees who need to know the information and have specified roles in the company.

Which of the following best describes this security concept?

A. Availability
B. Confidentiality
C. Integrity
D. Non-repudiation

Correct Answer: B — Confidentiality

Confidentiality ensures that sensitive information is accessible only to authorized individuals with legitimate need-to-know and appropriate roles. Role-based access control to client files is a direct application of the confidentiality principle.

Why The Other Options Are Incorrect

A. Availability ensures systems and data are accessible when needed, not about restricting access.

C. Integrity ensures data is accurate and hasn't been modified, not about access control.

D. Non-repudiation ensures actions cannot be denied, not about limiting access based on roles.

Question #184

Which of the following describes the category of data that is most impacted when it is lost?

A. Confidential
B. Public
C. Private
D. Critical

Correct Answer: D — Critical

Critical data is categorized by its business impact when lost. While confidential, public, and private are data classification types based on sensitivity, 'critical' specifically describes

data whose loss would most severely impact business operations, making it the correct answer for data most impacted when lost.

Why The Other Options Are Incorrect

A. Confidential data is sensitive but not necessarily the most impactful when lost.

B. Public data by definition has minimal impact when lost.

C. Private data is less critical to operations than critical data.

Question #185

A new employee logs in to the email system for the first time and notices a message from human resources about onboarding. The employee hovers over a few of the links within the email and discovers that the links do not correspond to links associated with the company.

Which of the following attack vectors is most likely being used?

A. Business email
B. Social engineering
C. Unsecured network
D. Default credentials

Correct Answer: B — Social engineering

Social engineering is the primary attack vector being used here. The attacker is manipulating the new employee by impersonating HR and using deceptive links to trick them into clicking malicious URLs. This is a classic phishing attack that exploits human psychology rather than technical vulnerabilities.

Why The Other Options Are Incorrect

A. Business email compromise is a related but more specific threat category that doesn't fully describe the manipulation tactic.

C. Unsecured network is not the vector; the attack uses deception regardless of network security.

D. Default credentials are irrelevant to this link-based phishing attack.

Question #186

Which of the following describes the understanding between a company and a client about what will be provided and the accepted time needed to provide the company with the resources?

A. SLA
B. MOU

C. MOA
D. BPA

Correct Answer: A — SLA

An SLA (Service Level Agreement) is a formal contract between a company and client that specifies what services will be provided and the agreed-upon timeframe for delivery, including performance metrics and response times. This directly matches the scenario described.

Why The Other Options Are Incorrect

B. An MOU (Memorandum of Understanding) is a preliminary agreement that lacks the specificity and binding nature of an SLA.

C. An MOA (Memorandum of Agreement) is similar to an MOU and also lacks the detail and commitment of an SLA.

D. A BPA (Business Partner Agreement) addresses partnership terms but not service provision timelines.

Question #187

A company that is located in an area prone to hurricanes is developing a disaster recovery plan and looking at site considerations that allow the company to immediately continue operations.

Which of the following is the best type of site for this company?

A. Cold
B. Tertiary
C. Warm
D. Hot

Correct Answer: D — Hot

A hot site is a fully equipped, operational backup facility that is constantly synchronized with the primary site and allows immediate failover with zero downtime. For a hurricane-prone area requiring immediate continuation of operations, this is the only appropriate choice among the options.

Why The Other Options Are Incorrect

A. A cold site has no equipment or data and requires significant time to become operational.

B. Tertiary is not a standard disaster recovery site classification.

C. A warm site has some equipment and periodic data synchronization but requires hours to become fully operational.

Question #188

Which of the following security controls is most likely being used when a critical legacy server is segmented into a private network?

A. Deterrent
B. Corrective
C. Compensating
D. Preventive

Correct Answer: C — Compensating

Network segmentation of a legacy server is a compensating control—an alternative security measure implemented because the legacy system cannot be easily updated or patched to meet modern security standards. It compensates for the system's inherent vulnerabilities by isolating it from general network access.

Why The Other Options Are Incorrect

A. A deterrent control discourages attacks; segmentation doesn't deter threats.

B. A corrective control remediates damage after an incident; segmentation prevents incidents.

D. A preventive control stops incidents before they occur, but compensating controls are specifically chosen when preventive measures aren't feasible.

Daily Debian

Question #189

Which of the following best describes the practice of researching laws and regulations related to information security operations within a specific industry?

A. Compliance reporting
B. GDPR
C. Due diligence
D. Attestation

Correct Answer: C — Due diligence

Due diligence is the practice of conducting thorough research and evaluation of laws, regulations, and compliance requirements relevant to an organization's industry and operations. This investigative process is fundamental to establishing information security operations that meet legal obligations.

Why The Other Options Are Incorrect

A. Compliance reporting is the documentation and communication of compliance status, not the research phase.

B. GDPR is a specific regulation, not a practice of researching regulations.

D. Attestation is formal verification of compliance, not the research and evaluation process itself.

Question #190

Which of the following considerations is the most important for an organization to evaluate as it establishes and maintains a data privacy program?

A. Reporting structure for the data privacy officer
B. Request process for data subject access
C. Role as controller or processor
D. Physical location of the company

Correct Answer: C — Role as controller or processor

Understanding whether an organization is a data controller (determines purposes/means of processing) or processor (processes data on behalf of a controller) is the most critical foundational consideration, as it fundamentally determines the organization's legal obligations, responsibilities, and the entire structure of the privacy program.

Why The Other Options Are Incorrect

A. The reporting structure is important but secondary to understanding core legal roles.

B. Data subject access request processes are specific procedures derived from the core role definition.

D. Physical location matters for jurisdiction but is less fundamental than the controller/processor distinction.

Question #191

A security analyst is investigating a workstation that is suspected of outbound communication to a command-and-control server. During the investigation, the analyst discovered that logs on the endpoint were deleted.

Which of the following logs would the analyst most likely look at next?

A. IPS
B. Firewall
C. ACL
D. Windows security

Correct Answer: B — Firewall

When endpoint logs have been deleted, a firewall log is the next best source to investigate outbound command-and-control communications. Firewall logs maintain network traffic

records on external devices and are not under the compromised endpoint's control, making them resistant to local deletion.

Why The Other Options Are Incorrect

A. IPS (Intrusion Prevention System) logs may be helpful but are less reliable than firewall logs for this scenario.

C. ACL (Access Control List) logs relate to access permissions, not network traffic patterns.

D. Windows security logs are on the endpoint itself and were already deleted by the attacker.

Question #192

An IT manager is putting together a documented plan describing how the organization will keep operating in the event of a global incident.

Which of the following plans is the IT manager creating?

A. Business continuity
B. Physical security
C. Change management
D. Disaster recovery

Correct Answer: A — Business continuity

Business continuity planning describes how an organization will maintain operations during and after a global incident or disruption. It focuses on keeping the business running with minimal interruption. While disaster recovery is related, it specifically addresses recovery after an incident; business continuity is the broader plan for ongoing operations during emergencies.

Why The Other Options Are Incorrect

B. Physical security addresses building access and protection of physical assets, not operational continuity.

C. Change management governs how modifications to systems and processes are implemented, not emergency operations.

D. Disaster recovery focuses on restoring systems after failure, not maintaining ongoing operations during an incident.

Question #193

A business needs a recovery site but does not require immediate failover. The business also wants to reduce the workload required to recover from an outage.

Which of the following recovery sites is the best option?

A. Hot
B. Cold
C. Warm
D. Geographically dispersed

✅ Correct Answer: C — Warm

A warm site is the best fit when immediate failover is not required but reduced recovery effort is desired. It maintains some infrastructure and data synchronization without the full expense of a hot site, allowing for faster recovery than a cold site while minimizing costs. It balances recovery time objectives (RTO) and recovery point objectives (RPO) appropriately for this scenario.

Why The Other Options Are Incorrect

A. A hot site provides immediate failover but is expensive and unnecessary when immediate failover is not required.

B. A cold site requires significant time to recover and would not reduce the workload required for recovery.

D. Geographic dispersion is a location strategy, not a type of recovery site with specific operational characteristics.

Question #194

A security team is setting up a new environment for hosting the organization's on-premises software application as a cloud-based service.

Which of the following should the team ensure is in place in order for the organization to follow security best practices?

A. Virtualization and isolation of resources
B. Network segmentation
C. Data encryption
D. Strong authentication policies

✅ Correct Answer: A — Virtualization and isolation of resources

Virtualization and isolation of resources is fundamental to cloud security best practices, ensuring that on-premises applications deployed as cloud services are properly separated and protected from other tenants and resources. This is the foundational security control that enables secure multi-tenancy and resource protection in cloud environments.

Why The Other Options Are Incorrect

B. Network segmentation is important but is a supporting practice rather than the

primary best practice for cloud deployment.

C. Data encryption is important but applies across deployment models and is not specific to cloud-based services.

D. Strong authentication is important but is one component of security rather than the overarching best practice for cloud hosting.

Question #195

A manager receives an email that contains a link to receive a refund. After hovering over the link, the manager notices that the domain's URL points to a suspicious link.

Which of the following security practices helped the manager to identify the attack?

A. End user training
B. Policy review
C. URL scanning
D. Plain text email

Correct Answer: A — End user training

End user training enabled the manager to recognize phishing indicators by teaching users to verify URLs and look for suspicious links. The manager's ability to hover over and inspect the link domain demonstrates security awareness training in action. This is a direct result of education on recognizing phishing attacks.

Why The Other Options Are Incorrect

B. Policy review addresses organizational rules but doesn't explain the manager's ability to inspect and identify the suspicious URL.

C. URL scanning is a technical tool, but the scenario describes manual user inspection, not automated scanning.

D. Plain text email is a technical characteristic; user training is what allowed the manager to identify the malicious intent.

Question #196

A company wants to verify that the software the company is deploying came from the vendor the company purchased the software from.

Which of the following is the best way for the company to confirm this information?

A. Validate the code signature.
B. Execute the code in a sandbox.
C. Search the executable for ASCII strings.
D. Generate a hash of the files.

Correct Answer: A — Validate the code signature.

Code signing validation is the best method to verify that software came from the intended vendor. Digital signatures cryptographically prove the software's origin and integrity using the vendor's private key, ensuring authenticity and that the code has not been tampered with after release.

Why The Other Options Are Incorrect

B. Sandbox execution tests behavior but does not verify the software's origin or vendor authenticity.

C. Searching for ASCII strings provides information about software contents but does not prove vendor identity.

D. Hashing verifies file integrity but cannot confirm the software came from the specific vendor without a trusted hash database.

Question #197

A systems administrator notices that one of the systems critical for processing customer transactions is running an end-of-life operating system.

Which of the following techniques would increase enterprise security?

A. Installing HIDS on the system
B. Placing the system in an isolated VLAN
C. Decommissioning the system
D. Encrypting the system's hard drive

Correct Answer: B — Placing the system in an isolated VLAN

Placing an end-of-life system in an isolated VLAN increases enterprise security by limiting network access and containing potential compromises. This network segmentation prevents lateral movement and limits exposure to modern threats that the unpatched system cannot defend against, while maintaining availability of critical transaction processing.

Why The Other Options Are Incorrect

A. HIDS monitoring detects intrusions but does not prevent them; an end-of-life system remains vulnerable regardless.

C. Decommissioning may not be feasible if the system is critical for customer transactions.

D. Drive encryption protects data at rest but does not prevent exploitation of the unpatched operating system vulnerabilities.

Question #198

The Chief Information Security Officer (CISO) at a large company would like to gain an understanding of how the company's security policies compare to the requirements imposed by external regulators.

Which of the following should the CISO use?

A. Penetration test
B. Internal audit
C. Attestation
D. External examination

Correct Answer: B — Internal audit

An internal audit is the appropriate tool for comparing company security policies against external regulatory requirements. Internal audits systematically review controls and policies against established standards and regulations, providing the CISO with a comprehensive understanding of compliance gaps.

Why The Other Options Are Incorrect

A. A penetration test identifies vulnerabilities through active exploitation but does not assess policy compliance.

C. Attestation is a formal statement of compliance but does not provide the analysis needed to understand policy gaps.

D. An external examination could provide an outside perspective but an internal audit is the standard approach for this policy comparison work.

Question #199

A systems administrator notices that the research and development department is not using the company VPN when accessing various company-related services and systems.

Which of the following scenarios describes this activity?

A. Espionage
B. Data exfiltration
C. Nation-state attack
D. Shadow IT

Correct Answer: D — Shadow IT

Shadow IT describes the use of unauthorized or unmanaged IT resources and services outside official IT channels. The R&D department bypassing the company VPN to access company services represents unsanctioned technology use that circumvents established

security controls and IT governance.

Why The Other Options Are Incorrect

A. Espionage involves stealing secrets for external parties, not simply bypassing internal security controls.

B. Data exfiltration is the unauthorized removal of data, which may result from shadow IT but is not the activity itself.

C. Nation-state attacks are sophisticated threats by state actors, not departmental use of unauthorized access methods.

Question #200

The marketing department set up its own project management software without telling the appropriate departments.

Which of the following describes this scenario?

A. Shadow IT
B. Insider threat
C. Data exfiltration
D. Service disruption

Correct Answer: A — Shadow IT

Shadow IT refers to IT systems, software, or hardware deployed and used within an organization without explicit approval from IT departments or management. The marketing department independently setting up project management software without notifying appropriate departments is the classic definition of shadow IT—unapproved technology adoption that circumvents governance.

Why The Other Options Are Incorrect

B. Insider threat is malicious activity by authorized users, but this scenario describes unauthorized deployment, not necessarily malicious intent.

C. Data exfiltration is the unauthorized transfer of data out of an organization, which is not described in this scenario.

D. Service disruption refers to interruption of services, not the unauthorized adoption of new software.

Question #201

Which of the following would best explain why a security analyst is running daily vulnerability scans on all corporate endpoints?

A. To track the status of patching installations

B. To find shadow IT cloud deployments
C. To continuously the monitor hardware inventory
D. To hunt for active attackers in the network

✅ Correct Answer: A — To track the status of patching installations

Daily vulnerability scans on corporate endpoints are primarily used to track the status of patching installations and ensure systems remain secure as patches are deployed. By scanning regularly, analysts can verify which patches have been successfully applied and identify systems that still require updates, making it an essential component of patch management and compliance tracking.

Why The Other Options Are Incorrect

B. Finding shadow IT cloud deployments requires different detection methods like network traffic analysis and cloud API monitoring, not endpoint vulnerability scans.

C. Hardware inventory tracking typically uses asset management tools and CMDB systems rather than vulnerability scanning.

D. Hunting for active attackers requires behavioral analysis, log analysis, and threat hunting methodologies beyond standard vulnerability scanning.

Question #202

Which of the following is classified as high availability in a cloud environment?

A. Access broker
B. Cloud HSM
C. WAF
D. Load balancer

✅ Correct Answer: D — Load balancer

A load balancer distributes incoming traffic across multiple servers or resources, ensuring no single point of failure and maintaining service availability even if individual resources fail. This is a core component of high availability architecture. Load balancers directly enable redundancy and fault tolerance, which are essential characteristics of highly available systems.

Why The Other Options Are Incorrect

A. Access broker handles authentication/authorization but doesn't directly address service availability.

B. Cloud HSM (Hardware Security Module) provides cryptographic security, not availability.

C. WAF (Web Application Firewall) provides security protection but not high availability.

Question #203

Which of the following security measures is required when using a cloud-based platform for IoT management?

A. Encrypted connection
B. Federated identity
C. Firewall
D. Single sign-on

Correct Answer: A — Encrypted connection

Encrypted connections are the fundamental security requirement for IoT devices connecting to cloud-based management platforms. This protects data in transit from interception and is essential for securing communication between IoT devices and cloud infrastructure, making it a non-negotiable baseline security measure.

Why The Other Options Are Incorrect

B. Federated identity is an advanced authentication mechanism that is not universally required for basic IoT cloud management.

C. Firewalls are network security tools but not specifically required at the platform level for IoT management.

D. Single sign-on is an authentication convenience feature, not a fundamental security requirement for IoT platforms.

Daily Debian

Question #204

Which of the following threat vectors is most commonly utilized by insider threat actors attempting data exfiltration?

A. Unidentified removable devices
B. Default network device credentials
C. Spear phishing emails
D. Impersonation of business units through typosquatting

Correct Answer: A — Unidentified removable devices

Unidentified removable devices (USB drives, external hard drives) are the most commonly exploited vector by insider threat actors for data exfiltration because they provide a simple, untraceable method to physically remove large amounts of data from the network. These devices are portable, difficult to track, and bypass many network-based security controls.

Why The Other Options Are Incorrect

B. Default network device credentials are exploited for network access, not data exfiltration by insiders.

C. Spear phishing is an external attack vector, not a typical insider threat method for data exfiltration.

D. Typosquatting is an external social engineering technique, not a common insider threat vector for data exfiltration.

Question #205

Which of the following methods to secure credit card data is best to use when a requirement is to see only the last four numbers on a credit card?

A. Encryption
B. Hashing
C. Masking
D. Tokenization

Correct Answer: C — Masking

Masking is the appropriate technique when the requirement is to display only specific data elements (like the last four digits of a credit card) while obscuring the rest. Masking hides sensitive portions of data while keeping other parts visible for operational purposes, making it ideal for this use case.

Why The Other Options Are Incorrect

A. Encryption secures data but doesn't allow selective visibility of specific digits without decryption.

B. Hashing is one-way and irreversible, preventing display of the last four digits.

D. Tokenization replaces data with surrogates but doesn't preserve visible portions like the last four digits in the intended way.

Question #206

The Chief Information Security Officer (CISO) has determined the company is non-compliant with local data privacy regulations. The CISO needs to justify the budget request for more resources.

Which of the following should the CISO present to the board as the direct consequence of non-compliance?

A. Fines
B. Reputational damage
C. Sanctions
D. Contractual implications

Correct Answer: A — Fines

Fines are the direct financial consequences imposed by regulatory bodies for non-compliance with data privacy regulations. They represent immediate, measurable financial impact that directly justifies budget requests. Fines are specific, quantifiable penalties mandated by law, making them the strongest justification for resource allocation.

Why The Other Options Are Incorrect

B. Reputational damage is a consequential effect but is indirect and harder to quantify for budget justification.

C. Sanctions are regulatory consequences but are less common and specific than fines for data privacy violations.

D. Contractual implications are consequences but are secondary to the direct penalties imposed by regulators.

Question #207

Which of the following alert types is the most likely to be ignored over time?

A. True positive
B. True negative
C. False positive
D. False negative

Correct Answer: C — False positive

False positives are the most likely to be ignored over time due to alert fatigue. When security tools generate many alerts that turn out to be benign, analysts become desensitized and start dismissing alerts without thorough investigation. This reduces detection effectiveness as genuine threats may be overlooked among the noise of false alarms.

Why The Other Options Are Incorrect

A. True positives indicate actual security issues and should not be ignored.

B. True negatives indicate no threat present, so ignoring them is appropriate behavior.

D. False negatives involve missed detections, but analysts cannot ignore what they don't see.

Question #208

A security analyst is investigating an application server and discovers that software on the server is behaving abnormally. The software normally runs batch jobs locally and does not generate traffic, but the process is now generating outbound traffic over random high ports.

Which of the following vulnerabilities has likely been exploited in this software?

A. Memory injection
B. Race condition
C. Side loading
D. SQL injection

✅ Correct Answer: A — Memory injection

Memory injection allows attackers to inject malicious code into a running process's memory space, causing the legitimate application to execute unauthorized commands. In this scenario, the compromised process is generating unexpected outbound traffic, which is characteristic of injected malicious code hijacking the application's execution flow. The abnormal behavior of a normally local batch job suddenly creating network traffic strongly indicates code has been injected and is controlling the process.

Why The Other Options Are Incorrect

B. Race conditions cause unpredictable behavior from timing issues, not typically the targeted injection of remote communication capabilities.

C. Side loading involves installing unauthorized apps, not injecting code into running processes to cause network traffic.

D. SQL injection targets database queries, not application processes running batch jobs that don't interact with databases.

Daily Debian

Question #209

An important patch for a critical application has just been released, and a systems administrator is identifying all of the systems requiring the patch.

Which of the following must be maintained in order to ensure that all systems requiring the patch are updated?

A. Asset inventory
B. Network enumeration
C. Data certification
D. Procurement process

✅ Correct Answer: A — Asset inventory

An asset inventory is a comprehensive record of all hardware and software assets within an organization. To ensure all systems requiring a patch are identified and updated, the administrator must maintain accurate knowledge of what systems exist, their locations, configurations, and installed applications. Without a maintained asset inventory, it is impossible to reliably identify which systems need the patch.

Why The Other Options Are Incorrect

B. Network enumeration discovers active systems at a point in time but doesn't maintain persistent records needed for patch management tracking.

C. Data certification validates data integrity and compliance, not system identification for patching.

D. The procurement process handles vendor and asset acquisition, not ongoing tracking of systems requiring patches.

Question #210

Which of the following should a security operations center use to improve its incident response procedure?

A. Playbooks
B. Frameworks
C. Baselines
D. Benchmarks

Correct Answer: A — Playbooks

Playbooks are step-by-step guides that document specific procedures and actions to take during incident response. They provide clear, actionable instructions for SOC teams to follow when specific incident types occur, directly improving response efficiency and consistency. Playbooks translate frameworks and standards into operational procedures that teams can execute.

Why The Other Options Are Incorrect

B. Frameworks provide overall structures and guidance but are not the detailed procedural documents used directly during incident response.

C. Baselines establish baseline configurations for systems, not incident response procedures.

D. Benchmarks are standards for comparison and measurement, not operational guides for improving incident response.

Question #211

Which of the following describes an executive team that is meeting in a board room and testing the company's incident response plan?

A. Continuity of operations
B. Capacity planning
C. Tabletop exercise
D. Parallel processing

Correct Answer: C — Tabletop exercise

A tabletop exercise is a discussion-based assessment where participants (including executives) walk through an incident response scenario in a controlled meeting environment. It tests the plan without actually implementing it, allowing teams to identify gaps and improve procedures. The executive team meeting in a board room to test the incident response plan is the classic definition of a tabletop exercise.

Why The Other Options Are Incorrect

A. Continuity of operations refers to maintaining business functions during disruptions, not a specific testing methodology.

B. Capacity planning involves determining resource requirements, not testing incident response plans.

D. Parallel processing runs systems simultaneously but does not describe a meeting-based testing scenario.

Question #212

A healthcare organization wants to provide a web application that allows individuals to digitally report health emergencies.

Which of the following is the most important consideration during development?

A. Scalability
B. Availability
C. Cost
D. Ease of deployment

Correct Answer: B — Availability

For a healthcare emergency reporting application, availability is the most critical consideration. Emergency health services require the application to be operational and accessible at all times—downtime could cost lives. While scalability, cost, and ease of deployment are important, they are secondary to ensuring the system is reliably available 24/7 for individuals reporting health emergencies.

Why The Other Options Are Incorrect

A. Scalability is important but secondary to availability in a life-critical emergency reporting system.

C. Cost is a business consideration but should not compromise the availability of a life-critical system.

D. Ease of deployment is a development advantage but is less critical than ensuring the system remains available during emergencies.

Question #213

Which of the following agreement types defines the time frame in which a vendor needs to respond?

A. SOW
B. SLA
C. MOA
D. MOU

Correct Answer: B — SLA

A Service Level Agreement (SLA) is a contract that defines the expected service levels, including response times and resolution times. It specifically establishes the time frame within which a vendor must respond to issues and resolve them. SLAs are the standard tool for documenting these response and resolution commitments.

Why The Other Options Are Incorrect

A. A Statement of Work (SOW) describes what work will be performed, not response time commitments.

C. A Memorandum of Agreement (MOA) outlines general understandings but doesn't specify response time frames.

D. A Memorandum of Understanding (MOU) is a preliminary agreement indicating intent, not a binding contract with specific response times.

Daily Debian

Question #214

Which of the following is a feature of a next-generation SIEM system?

A. Virus signatures
B. Automated response actions
C. Security agent deployment
D. Vulnerability scanning

Correct Answer: B — Automated response actions

Next-generation SIEM systems include automated response actions that can automatically execute predefined actions (such as isolating systems, blocking IPs, or terminating sessions) when specific threats are detected. This automated response capability is a defining feature of modern SIEM solutions, enabling faster threat mitigation without requiring manual human intervention.

Why The Other Options Are Incorrect

A. Virus signatures are traditional antivirus features, not a defining characteristic of next-generation SIEM.

C. Security agent deployment is a function of endpoint management or security orchestration, not SIEM.

D. Vulnerability scanning is a separate security tool function, not a core next-generation SIEM feature.

Question #215

To improve the security at a data center, a security administrator implements a CCTV system and posts several signs about the possibility of being filmed.

Which of the following best describe these types of controls? (Choose two.)

A. Preventive
B. Deterrent
C. Corrective
D. Directive
E. Compensating
F. Detective

Correct Answer: B, F

B. Deterrent
F. Detective

The CCTV system is a detective control because it records and identifies security incidents after they occur through video footage. The posted signs about being filmed serve as a deterrent control by discouraging malicious behavior through the threat of being caught on camera. Together, these controls address both the prevention of incidents through deterrence and the identification of incidents through detection.

Why The Other Options Are Incorrect

A. Preventive controls stop incidents before they occur; neither CCTV nor warning signs prevent unauthorized access.

C. Corrective controls fix damage after an incident; these controls don't restore systems or correct damage.

D. Directive controls guide or mandate behavior; while signs provide information, they are primarily deterrents rather than directives.

E. Compensating controls provide alternative security when primary controls fail; these are primary controls, not compensating measures.

Question #216

Which of the following examples would be best mitigated by input sanitization?

A. A command prompt input: <script>alert('xss')</script>

B. nmap - 10.11.1.130

C. Email message: "Click this link to get your free gift card."

D. Browser message: "Your connection is not private."

✅ Correct Answer: A — A command prompt input: <script>alert('xss')</script>

Input sanitization is designed to neutralize malicious code embedded in user inputs before processing. Option A shows a script injection attempt that would be mitigated by sanitizing the input to strip or escape HTML/JavaScript tags, preventing the malicious script from executing. This is a classic example of where input validation and sanitization directly prevents the attack vector from succeeding.

Why The Other Options Are Incorrect

B. nmap is a network scanning tool; this represents network reconnaissance that requires network segmentation and firewall rules, not input sanitization.

C. A phishing email is a social engineering attack best mitigated by user awareness training and email filtering, not input sanitization.

D. A browser security warning about connection privacy is a TLS/SSL certificate validation issue, mitigated by proper certificate management, not input sanitization.

Question #217

An attacker posing as the Chief Executive Officer calls an employee and instructs the employee to buy gift cards.

Which of the following techniques is the attacker using?

A. Smishing

B. Disinformation

C. Impersonating

D. Whaling

✅ Correct Answer: D — Whaling

Whaling is a targeted phishing attack directed at high-value targets, typically executives like a CEO. The attacker impersonates someone in authority to manipulate the employee into performing an action (buying gift cards). While impersonation is occurring, the specific technique name for this type of attack targeting executives is whaling.

Why The Other Options Are Incorrect

A. Smishing uses SMS text messages, not phone calls.

B. Disinformation involves spreading false information to large audiences, not direct

manipulation.

C. Impersonating is the general method used, but whaling is the specific social engineering technique for CEO-level targets.

Question #218

After conducting a vulnerability scan, a systems administrator notices that one of the identified vulnerabilities is not present on the systems that were scanned.

Which of the following describes this example?

A. False positive
B. False negative
C. True positive
D. True negative

Correct Answer: A — False positive

A false positive occurs when a vulnerability scanner reports a vulnerability that does not actually exist on the scanned systems. The vulnerability was identified by the scan but is not present in reality, making this a false positive result.

Why The Other Options Are Incorrect

B. A false negative is when a real vulnerability exists but the scanner fails to detect it.

C. A true positive is when a vulnerability is correctly identified and actually exists.

D. A true negative is when the scanner correctly identifies that a vulnerability does not exist.

Question #219

A recent penetration test identified that an attacker could flood the MAC address table of network switches.

Which of the following would best mitigate this type of attack?

A. Load balancer
B. Port security
C. IPS
D. NGFW

Correct Answer: B — Port security

Port security is a switch feature that limits and controls MAC addresses allowed on specific ports. It prevents MAC address table flooding attacks by restricting the number of MAC addresses that can be learned on a port and taking action when the limit is

exceeded, making it the best mitigation for this attack.

Why The Other Options Are Incorrect

A. A load balancer distributes traffic across multiple servers and does not prevent MAC table flooding.

C. An IPS monitors traffic patterns but is not the primary defense against MAC table flooding at the switch level.

D. An NGFW focuses on application-layer filtering and threats, not MAC layer attacks.

Question #220

A user would like to install software and features that are not available with a smartphone's default software.

Which of the following would allow the user to install unauthorized software and enable new features?

A. SQLi
B. Cross-site scripting
C. Jailbreaking
D. Side loading

Correct Answer: C — Jailbreaking

Jailbreaking removes restrictions imposed by the device manufacturer, allowing installation of unauthorized software and enabling features not available in the default software. It bypasses the device's security restrictions to provide administrative access.

Why The Other Options Are Incorrect

A. SQLi is a database injection attack, not related to installing unauthorized software.

B. Cross-site scripting is a web application attack, not related to smartphone software installation.

D. Side loading is installing apps from sources other than the official app store, but jailbreaking specifically removes OS restrictions.

Question #221

Which of the following phases of an incident response involves generating reports?

A. Recovery
B. Preparation
C. Lessons learned
D. Containment

Correct Answer: C — Lessons learned

The Lessons Learned phase is the final phase of incident response where teams analyze what occurred, document findings, and generate reports on the incident, response effectiveness, and recommendations for improvement. Report generation is a primary activity of this phase.

Why The Other Options Are Incorrect

A. Recovery focuses on restoring systems to normal operations, not generating reports.

B. Preparation involves readiness activities before an incident occurs.

D. Containment focuses on stopping the spread of an active incident.

Question #222

Which of the following methods would most likely be used to identify legacy systems?

A. Bug bounty program
B. Vulnerability scan
C. Package monitoring
D. Dynamic analysis

Correct Answer: B — Vulnerability scan

A vulnerability scan can identify legacy systems by detecting outdated software versions, unsupported operating systems, and old service versions that are characteristic of legacy systems. Scanners report software versions and configurations that reveal aging infrastructure.

Why The Other Options Are Incorrect

A. A bug bounty program relies on external researchers finding vulnerabilities, not on systematic identification of legacy systems.

C. Package monitoring tracks updates to installed software but does not specifically identify legacy systems.

D. Dynamic analysis tests application behavior at runtime but is not the primary method for identifying legacy systems.

Question #223

Employees located off-site must have access to company resources in order to complete their assigned tasks. These employees utilize a solution that allows remote access without interception concerns.

Which of the following best describes this solution?

A. Proxy server

B. NGFW
C. VPN
D. Security zone

✅ Correct Answer: C — VPN

A VPN (Virtual Private Network) provides secure remote access to company resources by encrypting all traffic between the user and the company network, preventing interception. It is the standard solution for allowing off-site employees secure access to internal resources.

Why The Other Options Are Incorrect

A. A proxy server forwards requests but does not provide the encryption and security needed for safe remote access.

B. An NGFW protects internal networks but is not the primary solution for remote employee access.

D. A security zone is a network segmentation concept, not a remote access solution.

Question #224

A company allows customers to upload PDF documents to its public e-commerce website.

Which of the following would a security analyst most likely recommend?

A. Utilizing attack signatures in an IDS
B. Enabling malware detection through a UTM
C. Limiting the affected servers with a load balancer
D. Blocking command injections via a WAF

✅ Correct Answer: B — Enabling malware detection through a UTM

Enabling malware detection through a UTM (Unified Threat Management) is the most appropriate recommendation for a public upload service. A UTM can scan uploaded files for malware before they are stored or processed, protecting against malicious PDF documents containing embedded threats.

Why The Other Options Are Incorrect

A. Attack signatures in an IDS monitor network traffic but do not directly scan uploaded files for malware.

C. A load balancer distributes traffic but does not protect against malicious file uploads.

D. A WAF blocks command injection attacks but is not the primary defense against malware in uploaded files.

Question #225

A security analyst developed a script to automate a trivial and repeatable task.

Which of the following best describes the benefits of ensuring other team members understand how the script works?

A. To reduce implementation cost
B. To identify complexity
C. To remediate technical debt
D. To prevent a single point of failure

Correct Answer: D — To prevent a single point of failure

When only one person understands how a critical script works, that person becomes a single point of failure. If they leave, become unavailable, or something happens to them, the organization loses the ability to maintain, troubleshoot, or modify that script. Ensuring other team members understand the script mitigates this risk by distributing knowledge across the team.

Why The Other Options Are Incorrect

A. Script documentation does not directly reduce implementation costs; it may add initial effort.

B. Identifying complexity is a byproduct, not the primary benefit of knowledge sharing.

C. Remediating technical debt involves improving code quality and design, not just understanding existing scripts.

Question #226

A company is decommissioning its physical servers and replacing them with an architecture that will reduce the number of individual operating systems.

Which of the following strategies should the company use to achieve this security requirement?

A. Microservices
B. Containerization
C. Virtualization
D. Infrastructure as code

Correct Answer: B — Containerization

Containerization is the strategy that allows multiple applications and services to run in isolated containers on fewer operating systems, significantly reducing the number of individual OS instances required. Containers are lightweight, portable, and share the host

OS kernel, enabling high density application deployment on minimal infrastructure.

Why The Other Options Are Incorrect

A. Microservices is an architectural pattern, not a deployment technology that reduces the number of operating systems.

C. Virtualization creates multiple full operating systems, which does not reduce the number of individual OS instances—it may increase them.

D. Infrastructure as code is a management approach that automates provisioning but does not inherently reduce the number of operating systems.

Question #227

An administrator needs to perform server hardening before deployment.

Which of the following steps should the administrator take? (Choose two.)

A. Disable default accounts.
B. Add the server to the asset inventory.
C. Remove unnecessary services.
D. Document default passwords.
E. Send server logs to the SIEM.
F. Join the server to the corporate domain.

Daily Debian

Correct Answer: A, C

A. Disable default accounts.
C. Remove unnecessary services.

Server hardening involves reducing the attack surface by disabling default accounts (which are commonly targeted and known) and removing unnecessary services (which eliminates potential vulnerabilities). Both steps directly reduce security exposure. Adding to inventory, documenting passwords, sending logs to SIEM, and domain joining are important post-hardening or operational tasks but are not hardening steps themselves.

Why The Other Options Are Incorrect

B. Asset inventory tracking is a management function, not a hardening activity.

D. Documenting default passwords is a security risk and violates hardening principles.

E. Sending logs to SIEM is a monitoring and detection activity, not a hardening step.

F. Joining the domain is a configuration step, not a hardening activity.

Question #228

A Chief Information Security Officer would like to conduct frequent, detailed reviews of systems and procedures to track compliance objectives.

Which of the following will be the best method to achieve this objective?

A. Third-party attestation
B. Penetration testing
C. Internal auditing
D. Vulnerability scans

✅ Correct Answer: C — Internal auditing

Internal auditing is the process of conducting frequent, detailed reviews of systems, procedures, and controls to verify compliance with objectives and identify areas for improvement. It is continuous, detailed, and focuses specifically on tracking compliance against established standards and requirements.

Why The Other Options Are Incorrect

A. Third-party attestation provides external validation but is typically less frequent and detailed than internal audits.

B. Penetration testing focuses on identifying vulnerabilities through simulated attacks, not tracking compliance objectives.

D. Vulnerability scans identify technical weaknesses but do not provide the comprehensive review of systems and procedures needed for compliance tracking.

Question #229

Which of the following security concepts is accomplished with the installation of a RADIUS server?

A. CIA
B. AAA
C. ACL
D. PEM

✅ Correct Answer: B — AAA

RADIUS (Remote Authentication Dial-In User Service) is a network protocol that implements the AAA security concept: Authentication (verifying user identity), Authorization (determining what resources the user can access), and Accounting (logging and tracking user activities). RADIUS is a foundational AAA server technology.

Why The Other Options Are Incorrect

A. CIA refers to Confidentiality, Integrity, and Availability—security properties, not directly implemented by RADIUS.

C. ACL (Access Control List) is a security mechanism for controlling resource access, not specifically what RADIUS implements.

D. PEM (Privacy Enhanced Mail) is a file format for cryptographic keys and certificates, unrelated to RADIUS functionality.

Question #230

After creating a contract for IT contractors, the human resources department changed several clauses. The contract has gone through three revisions.

Which of the following processes should the human resources department follow to track revisions?

A. Version validation
B. Version changes
C. Version updates
D. Version control

Correct Answer: D — Version control

Version control is the formal process of tracking and managing changes to documents through multiple revisions, maintaining a history of modifications, and ensuring all stakeholders are working with the correct version. This is the standard terminology and best practice for managing document revisions.

Why The Other Options Are Incorrect

A. Version validation refers to verifying the correctness of a version, not tracking revisions.

B. Version changes is vague and not the formal term for the revision tracking process.

C. Version updates is informal and does not encompass the full tracking and management process.

Question #231

The executive management team is mandating the company develop a disaster recovery plan. The cost must be kept to a minimum, and the money to fund additional internet connections is not available.

Which of the following would be the best option?

A. Hot site
B. Cold site
C. Failover site
D. Warm site

Correct Answer: B — Cold site

A cold site is a disaster recovery facility with basic infrastructure (power, HVAC, connectivity) but no active systems or data, requiring manual setup and data restoration when deployed. It offers the lowest cost option since no redundant systems or continuous synchronization is maintained, making it ideal when budget is severely constrained and internet connections cannot be added.

Why The Other Options Are Incorrect

A. Hot site maintains active, fully operational systems and current data replicas—very expensive and requires robust connectivity.

C. Failover site is not a standard DR terminology; it implies active failover capability requiring significant infrastructure.

D. Warm site maintains some systems and partial data replication, providing faster recovery than cold but at higher cost than the minimal budget allows.

Question #232

An administrator at a small business notices an increase in support calls from employees who receive a blocked page message after trying to navigate to a spoofed website.

Which of the following should the administrator do?

A. Deploy multifactor authentication.
B. Decrease the level of the web filter settings.
C. Implement security awareness training.
D. Update the acceptable use policy.

Daily Debian

Correct Answer: C — Implement security awareness training.

The core issue is that employees are attempting to navigate to spoofed websites, indicating a lack of awareness about phishing and social engineering threats. Security awareness training educates employees on recognizing and avoiding these threats, reducing their susceptibility to spoofing attacks. This addresses the root cause rather than just the symptom.

Why The Other Options Are Incorrect

A. Multifactor authentication protects accounts but does not prevent employees from clicking links to spoofed sites.

B. Decreasing web filter settings would allow more blocked content through, worsening security rather than improving it.

D. Updating the acceptable use policy documents rules but does not educate employees on how to recognize threats.

Question #233

Which of the following teams is best suited to determine whether a company has systems that can be exploited by a potential, identified vulnerability?

A. Purple team
B. Blue team
C. Red team
D. White team

Correct Answer: C — Red team

The Red team is responsible for simulating attacks and identifying vulnerabilities that can be exploited in a company's systems. They conduct offensive security assessments to determine what vulnerabilities exist and how they could be exploited, which directly answers the question of determining whether systems can be exploited by identified vulnerabilities.

Why The Other Options Are Incorrect

A. Purple teams coordinate between red and blue teams but don't specifically conduct vulnerability exploitation testing.

B. Blue teams focus on defensive measures and protecting systems, not identifying exploitable vulnerabilities.

D. White teams are typically referees or observers in security exercises, not the ones performing vulnerability assessments.

Daily Debian

Question #234

A company is reviewing options to enforce user logins after several account takeovers. The following conditions must be met as part of the solution:

- Allow employees to work remotely or from assigned offices around the world.
- Provide a seamless login experience.
- Limit the amount of equipment required.

Which of the following best meets these conditions?

A. Trusted devices
B. Geotagging
C. Smart cards
D. Time-based logins

Correct Answer: A — Trusted devices

Trusted devices allow employees to work remotely from anywhere globally while maintaining security through device recognition rather than physical hardware. This

provides seamless login experience since authenticated devices are recognized automatically, requires minimal additional equipment compared to smart cards, and works across different locations without geographic restrictions.

Why The Other Options Are Incorrect

B. Geotagging restricts login by location, which conflicts with the requirement to work from anywhere around the world.

C. Smart cards require physical hardware that is difficult to manage for global distributed teams and adds equipment requirements.

D. Time-based logins do not provide meaningful security enhancement and don't address account takeover prevention.

Question #235

Which of the following methods can be used to detect attackers who have successfully infiltrated a network? (Choose two.)

A. Tokenization
B. CI/CD
C. Honeypots
D. Threat modeling
E. DNS sinkhole
F. Data obfuscation

Daily Debian

Correct Answer: C, E

C. Honeypots
E. DNS sinkhole

Honeypots are decoy systems designed to attract and detect attackers who have infiltrated the network, while DNS sinkholes redirect malicious DNS queries and reveal compromised systems attempting to communicate with command-and-control servers. Both methods actively detect successful infiltration, whereas tokenization and obfuscation protect data, CI/CD automates development, and threat modeling is a planning technique.

Why The Other Options Are Incorrect

A. Tokenization replaces sensitive data with tokens for protection, not for detecting attackers.

B. CI/CD is a development pipeline automation practice, not an intrusion detection mechanism.

D. Threat modeling identifies potential threats during planning, not detecting actual infiltration.

F. Data obfuscation hides data from view but does not detect attackers within the network.

Question #236

A company wants to ensure that the software it develops will not be tampered with after the final version is completed.

Which of the following should the company most likely use?

A. Hashing
B. Encryption
C. Baselines
D. Tokenization

Correct Answer: A — Hashing

Hashing creates a unique fingerprint of software that can be compared later to detect any tampering or changes. If the software is modified after release, its hash will change, immediately revealing tampering. This ensures integrity verification without preventing use of the software, unlike encryption which would prevent execution.

Why The Other Options Are Incorrect

B. Encryption protects data confidentiality but doesn't detect tampering and would prevent the software from running.

C. Baselines establish reference points for comparison but are a framework, not a technical method for detecting tampering.

D. Tokenization replaces sensitive data with tokens and is unrelated to detecting software tampering.

Question #237

An organization completed a project to deploy SSO across all business applications last year. Recently, the finance department selected a new cloud-based accounting software vendor.

Which of the following should most likely be configured during the new software deployment?

A. RADIUS
B. SAML
C. EAP
D. OpenID

Correct Answer: B — SAML

SAML (Security Assertion Markup Language) is the standard protocol for federating Single

Sign-On across business applications and cloud services. Since the organization already deployed SSO, the new cloud-based accounting software should be configured to use SAML to integrate seamlessly with the existing SSO infrastructure.

Why The Other Options Are Incorrect

A. RADIUS is primarily used for network access authentication, not cloud application SSO integration.

C. EAP is used for wireless and PPP authentication, not for cloud application federation.

D. OpenID is an authentication protocol but SAML is the enterprise standard for SSO federation across multiple applications.

Question #238

A user, who is waiting for a flight at an airport, logs in to the airline website using the public Wi-Fi, ignores a security warning and purchases an upgraded seat.

When the flight lands, the user finds unauthorized credit card charges.

Which of the following attacks most likely occurred?

A. Replay attack
B. Memory leak
C. Buffer overflow attack
D. On-path attack

Daily Debian

Correct Answer: D — On-path attack

An on-path attack (formerly known as man-in-the-middle) occurs when an attacker intercepts unencrypted communications on public Wi-Fi. The attacker captured the user's login credentials and credit card information during the transaction, then used this intercepted data to make unauthorized charges.

Why The Other Options Are Incorrect

A. Replay attacks involve resending captured valid data packets, but this scenario describes credential interception.

B. Memory leaks are programming vulnerabilities that expose data in memory, not related to Wi-Fi interception.

C. Buffer overflow attacks exploit memory management in applications, not related to Wi-Fi eavesdropping.

Question #239

A network engineer deployed a redundant switch stack to increase system availability. However, the budget can only cover the cost of one ISP connection.

Which of the following best describes the potential risk factor?

A. The equipment MTBF is unknown.
B. The ISP has no SLA.
C. An RPO has not been determined.
D. There is a single point of failure.

Correct Answer: D — There is a single point of failure.

Although the network team deployed redundant switches for high availability, relying on a single ISP connection creates a single point of failure. If that one ISP connection fails, all network traffic is lost regardless of the redundant switch stack, eliminating the benefits of the redundancy and causing complete unavailability.

Why The Other Options Are Incorrect

A. MTBF (Mean Time Between Failures) being unknown is not the primary risk factor when a single ISP connection exists.

B. An ISP SLA is important but the lack of one doesn't create the immediate risk that a single connection does.

C. RPO (Recovery Point Objective) relates to data recovery, not the network connectivity risk described here.

Question #240

A network team segmented a critical, end-of-life server to a VLAN that can only be reached by specific devices but cannot be reached by the perimeter network.

Which of the following best describe the controls the team implemented? (Choose two.)

A. Managerial
B. Physical
C. Corrective
D. Detective
E. Compensating
F. Technical
G. Deterrent

Correct Answer: E, F

E. Compensating
F. Technical

Compensating controls are alternative controls implemented when primary controls cannot be used, and segmenting the legacy server to a restricted VLAN compensates for its end-of-life status. Technical controls are the specific implementation of network segmentation

via VLAN configuration and access restrictions that directly prevent unauthorized access to the vulnerable server.

Why The Other Options Are Incorrect

A. Managerial controls involve policies and procedures, not technical network configurations.

B. Physical controls involve tangible security like locks and surveillance, not network segmentation.

C. Corrective controls remediate security incidents after they occur, while segmentation is preventive.

D. Detective controls identify security incidents, but segmentation primarily prevents access rather than detecting breaches.

G. Deterrent controls discourage attacks through visible security measures, not through network isolation.

Question #241

A threat actor was able to use a username and password to log in to a stolen company mobile device.

Which of the following provides the best solution to increase mobile data security on all employees' company mobile devices?

A. Application management
B. Full disk encryption
C. Remote wipe
D. Containerization

Correct Answer: B — Full disk encryption

Full disk encryption protects all data on the mobile device by encrypting the entire storage, making it unreadable if the device is stolen or accessed without authorization. While remote wipe can erase data after theft, full disk encryption prevents unauthorized access in the first place and is the best proactive security measure. The question asks for a solution that increases security on all devices against the demonstrated threat (unauthorized login access to stolen device).

Why The Other Options Are Incorrect

A. Application management controls which apps can run but doesn't prevent data access from stolen devices.

C. Remote wipe only helps after the device is reported stolen; it doesn't prevent initial unauthorized access.

D. Containerization separates work and personal data but doesn't encrypt data or prevent access on stolen devices.

Question #242

Which of the following best describes the risk present after controls and mitigating factors have been applied?

A. Residual
B. Avoided
C. Inherent
D. Operational

Correct Answer: A — Residual

Residual risk is the risk that remains after controls and mitigating factors have been applied. It represents the actual risk level an organization faces after implementing security measures. This is distinct from inherent risk (risk before controls) and avoided risk (completely eliminated). Operational risk refers to risks from business operations, not control effectiveness.

Why The Other Options Are Incorrect

B. Avoided risk means the risk was completely eliminated or not pursued; residual risk is what remains despite controls.

C. Inherent risk is the original risk before any controls are applied, not after.

D. Operational risk relates to risks from day-to-day operations, not the outcome of applying controls.

Question #243

A software development team asked a security administrator to recommend techniques that should be used to reduce the chances of the software being reverse engineered.

Which of the following should the security administrator recommend?

A. Digitally signing the software
B. Performing code obfuscation
C. Limiting the use of third-party libraries
D. Using compile flags

Correct Answer: B — Performing code obfuscation

Code obfuscation deliberately makes source code difficult to understand and analyze, directly preventing reverse engineering by obscuring logic, variable names, and program flow. This is the primary technique used to protect against reverse engineering attacks. Digital signatures verify authenticity but don't prevent analysis, library restrictions don't

prevent reverse engineering, and compile flags optimize but don't obfuscate code.

Why The Other Options Are Incorrect

A. Digital signing verifies code authenticity and integrity but does not prevent reverse engineering.

C. Limiting third-party libraries doesn't address reverse engineering vulnerability; attackers can reverse engineer either way.

D. Compile flags may optimize performance but don't obfuscate code or prevent reverse engineering.

Question #244

Which of the following is a possible factor for MFA?

A. Something you exhibit
B. Something you have
C. Somewhere you are
D. Someone you know

Correct Answer: B — Something you have

MFA typically uses factors in these categories: something you know (password), something you have (token, phone, hardware key), something you are (biometric), and somewhere you are (location). 'Something you have' is a recognized and commonly used MFA factor including hardware tokens, authenticator apps, and smart cards. The other options don't represent standard MFA factor categories.

Why The Other Options Are Incorrect

A. Something you exhibit is not a standard MFA factor category; behavior-based authentication exists but isn't foundational.

C. Somewhere you are (geolocation) is not a primary MFA factor; it may be used for risk assessment but not core MFA.

D. Someone you know is a social engineering vector, not a security factor for MFA.

Question #245

Easy-to-guess passwords led to an account compromise. The current password policy requires at least 12 alphanumeric characters, one uppercase character, one lowercase character, a password history of two passwords, a minimum password age of one day, and a maximum password age of 90 days.

Which of the following would reduce the risk of this incident from happening again? (Choose two.)

A. Increasing the minimum password length to 14 characters.
B. Upgrading the password hashing algorithm from MD5 to SHA-512.
C. Increasing the maximum password age to 120 days.
D. Reducing the minimum password length to ten characters.
E. Reducing the minimum password age to zero days.
F. Including a requirement for at least one special character.

Correct Answer: A, F

A. Increasing the minimum password length to 14 characters.
F. Including a requirement for at least one special character.

Option A (increase minimum length to 14 characters) increases password complexity and entropy, making guessing harder. Option F (require special characters) adds a character class requirement that significantly increases the password space and prevents simple alphanumeric guessing. Together these address the root cause of easy-to-guess passwords. Options B, C, D, and E either don't address password guessing difficulty (B, C, E) or weaken it (D).

Why The Other Options Are Incorrect

B. Hashing algorithm improvements don't prevent initial password guessing; they help only if the hash is already compromised.

C. Increasing maximum age to 120 days allows weaker passwords to remain in use longer, worsening the problem.

D. Reducing minimum length to 10 characters directly weakens password strength and increases guessing vulnerability.

E. Reducing minimum password age to zero allows immediate password changes, enabling rapid reuse and defeating history protections.

Daily Debian

Question #246

A user downloaded software from an online forum. After the user installed the software, the security team observed external network traffic connecting to the user's computer on an uncommon port.

Which of the following is the most likely explanation of this unauthorized connection?

A. The software had a hidden keylogger.
B. The software was ransomware.
C. The user's computer had a fileless virus.
D. The software contained a backdoor.

Correct Answer: D — The software contained a backdoor.

A backdoor is a hidden entry point installed by malware that allows attackers to remotely

access and control a compromised system. External network traffic connecting to the user's computer on an uncommon port after software installation is the classic indicator of a backdoor establishing command-and-control communication. Keyloggers don't establish incoming connections, ransomware focuses on encryption not remote access, and fileless viruses don't require traditional installation.

Why The Other Options Are Incorrect

A. Keyloggers capture keyboard input but typically don't initiate external network connections to the infected machine.

B. Ransomware encrypts files and extorts users; it doesn't characteristically establish inbound remote access connections.

C. Fileless viruses run in memory without installation and don't match the download-then-connection pattern described.

Question #247

A utility company is designing a new platform that will host all the virtual machines used by business applications. The requirements include:

- A starting baseline of 50% memory utilization
- Storage scalability
- Single circuit failure resilience

Which of the following best meets all of these requirements?

A. Connecting dual PDUs to redundant power supplies
B. Transitioning the platform to an IaaS provider
C. Configuring network load balancing for multiple paths
D. Deploying multiple large NAS devices for each host

Correct Answer: B — Transitioning the platform to an IaaS provider

Transitioning to an IaaS provider best meets all three requirements: IaaS providers maintain 50%+ baseline utilization through resource sharing across customers, offer built-in storage scalability through cloud infrastructure, and provide single circuit failure resilience through redundant data centers and multiple network paths by design. On-premises options like dual PDUs and NAS devices don't inherently achieve 50% baseline utilization or automatic geographic resilience.

Why The Other Options Are Incorrect

A. Dual PDUs with redundant power supplies address power resilience but don't achieve baseline memory utilization targets or storage scalability requirements.

C. Network load balancing handles traffic distribution but doesn't address the 50% baseline memory utilization or storage scalability requirements.

D. Multiple NAS devices provide storage but don't achieve memory utilization baselines

or single circuit failure resilience across the entire platform.

Question #248

Which of the following best describes a use case for a DNS sinkhole?

A. Attackers can see a DNS sinkhole as a highly valuable resource to identify a company's domain structure.

B. A DNS sinkhole can be used to draw employees away from known-good websites to malicious ones owned by the attacker.

C. A DNS sinkhole can be used to capture traffic to known-malicious domains used by attackers.

D. A DNS sinkhole can be set up to attract potential attackers away from a company's network resources.

✅ Correct Answer: C — A DNS sinkhole can be used to capture traffic to known-malicious domains used by attackers.

A DNS sinkhole is a security control that intercepts DNS requests for known-malicious domains and redirects them to a controlled IP address (often a local honeypot or monitoring server). This captures traffic destined for malicious domains, preventing users from reaching them and allowing security teams to monitor and analyze attack attempts. It's a defensive monitoring technique against known threats.

Why The Other Options Are Incorrect

A. DNS sinkholes are security defensive tools; attackers don't view them as valuable resources for reconnaissance.

B. DNS sinkholes redirect away from malicious sites, not toward them; they protect employees rather than deceive them.

D. DNS sinkholes target known-malicious domains, not act as honeypots to attract attackers to company networks.

Question #249

An incident analyst finds several image files on a hard disk. The image files may contain geolocation coordinates.

Which of the following best describes the type of information the analyst is trying to extract from the image files?

A. Log data

B. Metadata

C. Encrypted data

D. Sensitive data

Correct Answer: B — Metadata

Geolocation coordinates embedded in image files are examples of metadata—data about data that describes properties of the files themselves. Metadata in images typically includes EXIF data, GPS coordinates, timestamps, camera information, and other embedded information separate from the image content itself.

Why The Other Options Are Incorrect

A. Log data refers to system or application event records, not embedded information within files.

C. Encrypted data is scrambled content requiring decryption, not embedded geolocation information.

D. Sensitive data is a broad category; metadata is the specific technical term for this type of embedded file information.

Question #250

Which of the following most likely describes why a security engineer would configure all outbound emails to use S/MIME digital signatures?

A. To meet compliance standards
B. To increase delivery rates
C. To block phishing attacks
D. To ensure non-repudiation

Correct Answer: D — To ensure non-repudiation

S/MIME digital signatures provide non-repudiation, meaning the sender cannot deny having sent the email because their private key created the signature. This cryptographic proof establishes authenticity and prevents senders from denying responsibility for messages they signed.

Why The Other Options Are Incorrect

A. While compliance may be achieved through signatures, non-repudiation is the primary security purpose.

B. Digital signatures do not affect email delivery rates.

C. Signatures authenticate the sender but do not directly block phishing attacks; email filtering addresses that.

Question #251

During a recent company safety stand-down, the cyber-awareness team gave a presentation on the importance of cyber hygiene. One topic the team covered was best practices for printing centers.

Which of the following describes an attack method that relates to printing centers?

A. Whaling
B. Credential harvesting
C. Prepending
D. Dumpster diving

Correct Answer: D — Dumpster diving

Dumpster diving is a physical security attack where attackers retrieve discarded documents from printing centers and trash to obtain sensitive information. Printing centers are high-value targets because they handle large volumes of physical documents containing confidential data.

Why The Other Options Are Incorrect

A. Whaling is a spear-phishing attack targeting executives, not specifically related to printing centers.

B. Credential harvesting involves collecting login credentials through digital means, not printing center operations.

C. Prepending is a technical attack involving adding false information to network packets, unrelated to printing.

Question #252

Which of the following considerations is the most important regarding cryptography used in an IoT device?

A. Resource constraints
B. Available bandwidth
C. The use of block ciphers
D. The compatibility of the TLS version

Correct Answer: A — Resource constraints

Resource constraints—including limited processing power, memory, and battery capacity—are the most critical consideration for cryptography in IoT devices. These constraints directly impact which cryptographic algorithms can be implemented, necessitating lightweight cryptography rather than computationally intensive solutions.

Why The Other Options Are Incorrect

B. Bandwidth availability affects data transmission but is less fundamental than the device's ability to perform cryptographic operations.

C. Block cipher selection is important but derives from resource constraint considerations.

D. TLS version compatibility is relevant but secondary to whether the device can perform any cryptographic operations at all.

Question #253

A coffee shop owner wants to restrict internet access to only paying customers by prompting them for a receipt number.

Which of the following is the best method to use given this requirement?

A. WPA3
B. Captive portal
C. PSK
D. IEEE 802.1X

Correct Answer: B — Captive portal

A captive portal is the best method for this scenario. It redirects unauthenticated users to a login/verification page where they can enter their receipt number before gaining internet access. This provides the necessary control over who accesses the network based on payment.

Why The Other Options Are Incorrect

A. WPA3 is a wireless encryption standard that protects network traffic but doesn't restrict access based on receipt numbers.

C. PSK (Pre-Shared Key) requires all users to know the same password; it cannot differentiate between paying and non-paying customers.

D. IEEE 802.1X is an enterprise authentication framework requiring complex infrastructure; captive portal is simpler for this use case.

Question #254

While performing digital forensics, which of the following is considered the most volatile and should have the contents collected first?

A. Hard drive
B. RAM
C. SSD
D. Temporary files

Correct Answer: B — RAM

RAM is the most volatile form of storage and loses all data when power is removed. In digital forensics, volatile data collection must occur first because once the system is powered down or loses power, this evidence is permanently destroyed. Other storage types retain data longer.

Why The Other Options Are Incorrect

A. Hard drives retain data even when powered off and are less volatile than RAM.

C. SSDs retain data after power loss, making them less volatile than RAM.

D. Temporary files, while volatile, reside on storage media that persists longer than RAM without power.

Question #255

A hosting provider needs to prove that its security controls have been in place over the last six months and have sufficiently protected customer data.

Which of the following would provide the best proof that the hosting provider has met the requirements?

A. NIST CSF
B. SOC 2 Type 2 report
C. CIS Top 20 compliance reports
D. Vulnerability report

Daily Debian

Correct Answer: B — SOC 2 Type 2 report

A SOC 2 Type 2 report provides audit evidence that security controls have been implemented and operating effectively over a specific period (typically six months or more). Type 2 specifically demonstrates control effectiveness over time, which directly proves that controls were in place and functioning to protect customer data.

Why The Other Options Are Incorrect

A. NIST CSF is a framework for developing controls, not an attestation report proving their historical effectiveness.

C. CIS Top 20 compliance reports assess current compliance status but don't provide third-party attestation of control effectiveness over time.

D. Vulnerability reports identify weaknesses but don't prove historical control implementation and effectiveness.

Question #256

A city municipality lost its primary data center when a tornado hit the facility.

Which of the following should the city staff use immediately after the disaster to handle essential public services?

A. BCP
B. Communication plan
C. DRP
D. IRP

Correct Answer: C — DRP

The Disaster Recovery Plan (DRP) is immediately activated after the disaster occurs to restore IT systems and critical data processing capabilities. DRP focuses on restoring technology and data, which is essential for a municipality to resume essential public services. BCP is broader and includes DRP as a component, but DRP is the specific tool for this scenario.

Why The Other Options Are Incorrect

A. BCP (Business Continuity Plan) is broader and includes multiple components; DRP is the specific plan for this IT infrastructure failure.

B. Communication plan addresses stakeholder notification but doesn't directly restore technology services needed for public services.

D. IRP (Incident Response Plan) focuses on detecting and responding to security incidents, not restoring facilities destroyed by natural disasters.

Question #257

Which of the following is considered a preventive control?

A. Configuration auditing
B. Log correlation
C. Incident alerts
D. Segregation of duties

Correct Answer: D — Segregation of duties

Segregation of duties is a preventive control that stops errors or fraud before they occur by ensuring no single person can complete a critical transaction alone. Configuration auditing, log correlation, and incident alerts are all detective controls that identify issues after they happen.

Why The Other Options Are Incorrect

A. Configuration auditing detects unauthorized changes after they occur, making it

detective.

B. Log correlation identifies suspicious patterns after events have been logged, making it detective.

C. Incident alerts notify of problems already occurring, making them reactive/detective controls.

Question #258

A systems administrator notices that a testing system is down. While investigating, the systems administrator finds that the servers are online and accessible from any device on the server network. The administrator reviews the following information from the monitoring system:

Server name	IP	Traffic sent	Traffic received	Status
File01	10.12.14.13	2654812	23185	Up
DC01	10.12.15.2	168741	65481	Up
Test01	10.25.1.3	14872	654123168	Down
Test02	10.25.1.4	16941	651321685	Down
DC02	10.12.15.3	32145	32158	Up
Finance01	10.18.1.14	12374	6548	Up

Which of the following is the most likely cause of the outage?

A. Denial of service
B. ARP poisoning
C. Jamming
D. Kerberoasting

Correct Answer: A — Denial of service

The monitoring data shows that Test01 and Test02 are down despite being online and accessible from the server network. The key indicator is the dramatically high traffic received (654123168 and 651321685 bytes respectively) compared to traffic sent (14872 and 16941 bytes), showing an extremely asymmetrical traffic pattern. This characteristic imbalance of incoming traffic overwhelming outgoing traffic is typical of a Denial of Service (DoS) attack, where the systems are flooded with requests, consuming resources and making them unable to respond normally. The servers being accessible from other devices rules out physical jamming or routing issues.

Why The Other Options Are Incorrect

B. ARP poisoning would redirect traffic but wouldn't create this specific pattern of

massive incoming traffic with minimal outgoing responses.

C. Jamming is a physical layer attack affecting wireless signals and wouldn't allow the servers to remain accessible from the network as described.

D. Kerberoasting is a credential-based attack targeting Kerberos authentication and would not cause this type of traffic anomaly or general outage.

Question #259

A security team has been alerted to a flood of incoming emails that have various subject lines and are addressed to multiple email inboxes. Each email contains a URL shortener link that is redirecting to a dead domain.

Which of the following is the best step for the security team to take?

A. Create a blocklist for all subject lines.
B. Send the dead domain to a DNS sinkhole.
C. Quarantine all emails received and notify all employees.
D. Block the URL shortener domain in the web proxy.

Correct Answer: D — Block the URL shortener domain in the web proxy.

Blocking the URL shortener domain at the web proxy prevents access to the malicious links at the source, stopping the threat before users can click them. This is the most efficient and effective control that addresses the root vector of attack. Creating subject line blocklists is ineffective due to varied subject lines, DNS sinkholes don't address email delivery, and mass quarantine without targeting the specific threat vector is inefficient.

Why The Other Options Are Incorrect

A. Subject lines vary in the attack, making blocklisting ineffective.

B. A DNS sinkhole doesn't prevent emails from being sent or accessed via web proxy.

C. Quarantining all emails is an overreaction and doesn't address the specific threat vector of the URL shortener.

Question #260

A security administrator is working to secure company data on corporate laptops in case the laptops are stolen.

Which of the following solutions should the administrator consider?

A. Disk encryption
B. Data loss prevention
C. Operating system hardening
D. Boot security

Correct Answer: A — Disk encryption

Disk encryption directly protects data on stolen laptops by rendering the data unreadable without the encryption key, which is the primary concern stated in the scenario. Data loss prevention, OS hardening, and boot security address different security aspects but don't specifically protect data if a device is physically stolen.

Why The Other Options Are Incorrect

B. Data loss prevention prevents unauthorized data exfiltration but doesn't protect data if the physical device is stolen.

C. OS hardening reduces attack surface but doesn't protect data if the device itself is stolen.

D. Boot security prevents unauthorized system access but doesn't encrypt data on the disk itself.

Question #261

A company needs to keep the fewest records possible, meet compliance needs, and ensure destruction of records that are no longer needed.

Which of the following best describes the policy that meets these requirements?

A. Security policy
B. Classification policy
C. Retention policy
D. Access control policy

Correct Answer: C — Retention policy

A retention policy specifies how long records must be kept to meet compliance requirements and when they should be destroyed, directly addressing the need to keep the fewest records possible while meeting compliance and ensuring proper destruction. Security, classification, and access control policies serve different purposes in data management.

Why The Other Options Are Incorrect

A. Security policy protects data but doesn't govern how long records are kept.

B. Classification policy categorizes data sensitivity but doesn't address retention duration.

D. Access control policy determines who can access data but doesn't specify retention periods.

Question #262

Which of the following is a common source of unintentional corporate credential leakage in cloud environments?

A. Code repositories
B. Dark web
C. Threat feeds
D. State actors
E. Vulnerability databases

✅ Correct Answer: A — Code repositories

Code repositories are a common unintentional source of credential leakage in cloud environments because developers frequently commit API keys, passwords, and tokens into source control systems, especially in public repositories. The dark web, threat feeds, and vulnerability databases are external sources, not sources of leakage, and state actors are not a source but rather threat actors.

Why The Other Options Are Incorrect

B. Dark web is where leaked credentials are sold, not a source of organizational leakage.

C. Threat feeds provide intelligence about threats but are not sources of credential leakage.

D. State actors are threats that exploit credentials but do not serve as sources of leakage.

E. Vulnerability databases catalog known vulnerabilities but are not sources of credential leakage.

Question #263

Which of the following is the best reason an organization should enforce a data classification policy to help protect its most sensitive information?

A. End users will be required to consider the classification of data that can be used in documents.
B. The policy will result in the creation of access levels for each level of classification.
C. The organization will have the ability to create security requirements based on classification levels.
D. Security analysts will be able to see the classification of data within a document before opening it.

✅ Correct Answer: C — The organization will have the ability to create

security requirements based on classification levels.

Data classification enables organizations to create differentiated security requirements and controls based on sensitivity levels, ensuring appropriate protection mechanisms for each classification tier. While end users benefit from awareness and access levels may be created, the fundamental purpose of classification policy is to establish risk-based security requirements that match the value and sensitivity of data.

Why The Other Options Are Incorrect

A. User awareness of classification is a benefit but not the primary purpose of the policy.

B. Access levels are a result, but classification itself is about determining what controls are needed.

D. Security analysts' ability to see classifications is a tool benefit, not the primary purpose.

Question #264

An analyst is performing a vulnerability scan against the web servers exposed to the internet without a system account.

Which of the following is most likely being performed?

A. Non-credentialed scan
B. Packet capture
C. Privilege escalation
D. System enumeration
E. Passive scan

Daily Debian

Correct Answer: A — Non-credentialed scan

A non-credentialed scan is performed without system account credentials, attempting to find vulnerabilities from an external, unprivileged perspective, which matches the scenario description. Packet capture captures network traffic, privilege escalation is a post-exploitation technique, system enumeration is part of scanning but not the name, and passive scans don't actively probe systems.

Why The Other Options Are Incorrect

B. Packet capture collects network traffic data, not a vulnerability scanning method.

C. Privilege escalation is exploiting vulnerabilities after discovery, not the scanning method itself.

D. System enumeration is a component of scanning but not the specific scanning type being described.

E. Passive scans gather information without active probing, whereas this scan probes servers.

Question #265

A security administrator is hardening corporate systems and applying appropriate mitigations by consulting a real-world knowledge base for adversary behavior.

Which of the following would be best for the administrator to reference?

A. MITRE ATT&CK
B. CSIRT
C. CVSS
D. SOAR

Correct Answer: A — MITRE ATT&CK

MITRE ATT&CK is a real-world knowledge base documenting adversary tactics, techniques, and procedures (TTPs) based on threat intelligence, making it the ideal reference for hardening systems against actual adversary behaviors. CSIRT handles incident response, CVSS scores vulnerabilities, and SOAR automates incident response.

Why The Other Options Are Incorrect

B. CSIRT is a team that responds to incidents, not a knowledge base for adversary behavior.

C. CVSS provides vulnerability severity scores, not adversary behavior information.

D. SOAR is a platform for automating security workflows, not a knowledge base for adversary tactics.

Question #266

An architect has a request to increase the speed of data transfer using JSON requests externally. Currently, the organization uses SFTP to transfer data files.

Which of the following will most likely meet the requirements?

A. A website-hosted solution
B. Cloud shared storage
C. A secure email solution
D. Microservices using API

Correct Answer: D — Microservices using API

Microservices using APIs provide the modern, efficient way to transfer data using JSON requests over HTTPS. This directly addresses the requirement for faster data transfer using JSON externally while maintaining security. APIs are the standard approach for programmatic data exchange and are significantly faster than SFTP for high-volume transfers.

Why The Other Options Are Incorrect

A. A website-hosted solution does not specifically enable JSON-based data transfer or improve speed over SFTP.

B. Cloud shared storage is not designed for fast JSON request-based transfers and doesn't address the speed requirement.

C. Secure email is unsuitable for data transfer and would be slower than current SFTP solution.

Question #267

Which of the following addresses individual rights such as the right to be informed, the right of access, and the right to be forgotten?

A. GDPR
B. PCI DSS
C. NIST
D. ISO

Correct Answer: A — GDPR

GDPR (General Data Protection Regulation) specifically addresses individual rights including the right to be informed about data processing, the right of access to personal data, and the right to be forgotten (right to erasure). These are core principles of GDPR that do not appear as primary focuses in the other frameworks.

Why The Other Options Are Incorrect

B. PCI DSS focuses on payment card security, not individual data rights.

C. NIST is a cybersecurity framework focused on risk management, not individual privacy rights.

D. ISO is a general standards organization; while ISO 27001 addresses data protection, GDPR specifically enshrines these individual rights.

Question #268

An administrator is installing an LDAP browser tool in order to view objects in the corporate LDAP directory. Secure connections to the LDAP server are required.

When the browser connects to the server, certificate errors are being displayed, and then the connection is terminated.

Which of the following is the most likely solution?

A. The administrator should allow SAN certificates in the browser configuration.
B. The administrator needs to install the server certificate into the local truststore.

C. The administrator should request that the secure LDAP port be opened to the server.

D. The administrator needs to increase the TLS version on the organization's RA.

✅ Correct Answer: B — The administrator needs to install the server certificate into the local truststore.

Certificate errors during secure LDAP connection indicate the server's certificate is not trusted by the client. Installing the server certificate into the local truststore will establish trust and allow the secure connection to complete successfully. This is the standard solution for certificate validation errors.

Why The Other Options Are Incorrect

A. SANs are already supported in modern browsers and this wouldn't resolve certificate validation errors.

C. Port access for LDAPS is not the issue; the connection is being established but rejected due to certificate validation.

D. Increasing TLS version on the RA would not resolve trust issues with the server certificate itself.

Daily Debian

Question #269

Which of the following is the most important security concern when using legacy systems to provide production service?

A. Instability

B. Lack of vendor support

C. Loss of availability

D. Use of insecure protocols

✅ Correct Answer: B — Lack of vendor support

Lack of vendor support is the most critical security concern for legacy systems. Without vendor support, security patches are unavailable, leaving the system vulnerable to known exploits indefinitely. This creates an ongoing and unmitigatable security exposure that organizations cannot address through their own efforts.

Why The Other Options Are Incorrect

A. While instability is a concern, it affects availability rather than security directly.

C. Loss of availability is an operational concern but less critical than the ongoing security vulnerability from lack of patches.

D. Insecure protocols can be mitigated with network controls; lack of vendor support cannot be worked around.

Question #270

A security investigation revealed that malicious software was installed on a server using a server administrator's credentials. During the investigation, the server administrator explained that Telnet was regularly used to log in.

Which of the following most likely occurred?

A. A spraying attack was used to determine which credentials to use.
B. A packet capture tool was used to steal the password.
C. A remote-access Trojan was used to install the malware.
D. A dictionary attack was used to log in as the server administrator.

Correct Answer: B — A packet capture tool was used to steal the password.

Telnet transmits all traffic, including credentials, in cleartext over the network. A packet capture tool can easily intercept and extract the administrator's password from the network traffic. This is the classic vulnerability of Telnet and the most likely attack vector given the context of regular Telnet use.

Why The Other Options Are Incorrect

A. Spraying attacks require knowledge of valid usernames and don't apply to a specific known administrator account.

C. A RAT would not be necessary when credentials can be easily captured from Telnet traffic.

D. Dictionary attacks require login attempts which would be detectable; passive packet capture is more stealthy and likely.

Question #271

A user is requesting Telnet access to manage a remote development web server. Insecure protocols are not allowed for use within any environment.

Which of the following should be configured to allow remote access to this server?

A. HTTPS
B. SNMPv3
C. SSH
D. RDP
E. SMTP

Correct Answer: C — SSH

SSH (Secure Shell) is the secure replacement for Telnet, providing encrypted remote command-line access to servers. It is the industry standard for secure terminal access and

is compliant with the requirement that insecure protocols not be used.

Why The Other Options Are Incorrect

A. HTTPS is for web traffic, not terminal/shell access.

B. SNMPv3 is for network management, not server administration shell access.

D. RDP is for graphical desktop access, not typical for web server command-line management.

E. SMTP is for email, not remote server access.

Question #272

A security administrator is working to find a cost-effective solution to implement certificates for a large number of domains and subdomains owned by the company.

Which of the following types of certificates should the administrator implement?

A. Wildcard
B. Client certificate
C. Self-signed
D. Code signing

Correct Answer: A — Wildcard

Wildcard certificates cover a domain and all its subdomains (e.g., *.example.com) with a single certificate purchase, making them the most cost-effective solution for protecting multiple subdomains. This single certificate can be deployed across numerous servers, significantly reducing costs compared to individual certificates per domain.

Why The Other Options Are Incorrect

B. Client certificates are for authenticating users/devices, not for securing domains.

C. Self-signed certificates are not suitable for production external use and don't solve the multi-domain problem.

D. Code signing certificates are for signing code/executables, not for securing web domains.

Question #273

An auditor discovered multiple insecure ports on some servers. Other servers were found to have legacy protocols enabled.

Which of the following tools did the auditor use to discover these issues?

A. Nessus
B. curl

C. Wireshark

D. netcat

Correct Answer: A — Nessus

Nessus is a comprehensive vulnerability scanner that identifies open ports and insecure protocols running on servers. It performs active scanning to detect security configuration issues, including enabled legacy protocols and exposed insecure ports, making it the appropriate tool for this type of audit.

Why The Other Options Are Incorrect

B. curl is a command-line tool for transferring data, not for vulnerability scanning.

C. Wireshark is a packet analyzer for capturing and inspecting network traffic, not for port/protocol discovery.

D. netcat is a simple networking utility for connections, not a comprehensive vulnerability assessment tool.

Question #274

A security analyst received a tip that sensitive proprietary information was leaked to the public. The analyst is reviewing the PCAP and notices traffic between an internal server and an external host that includes the following:

...

12:47:22.327233 PPPoE [ses 0x8122] IP (tos 0x0, ttl 64, id 0, offset 0, flags [DF], proto IPv6 (41), length 331) 10.5.1.1 > 52.165.16.154: IP6 (hlim

E3, next-header TCP (6) paylcad length:

271) 2001:67c:2158:a019::ace.53104 > 2001:0:5ef5:79fd:380c:dddd:a601:24fa.13788: Flags [P.], cksum 0xd7ee (correct), seq 97:348, ack 102, win 16444, length 251 ...

Which of the following was most likely used to exfiltrate the data?

A. Encapsulation

B. MAC address spoofing

C. Steganography

D. Broken encryption

E. Sniffing via on-path position

Correct Answer: A — Encapsulation

The PCAP shows IPv6 traffic encapsulated within IPv4 (proto IPv6 (41)), which is IPv6-in-IPv4 tunneling. This encapsulation technique allows an attacker to hide IPv6 traffic within standard IPv4 packets to bypass security controls and exfiltrate data to an external host without detection. The unusual protocol combination and external destination indicate

deliberate use of encapsulation for data exfiltration.

Why The Other Options Are Incorrect

B. MAC address spoofing would not be visible in the IP layer packet analysis shown and would not facilitate exfiltration to external hosts.

C. Steganography hides data within other media; there is no indication of hidden data within the payload itself.

D. The presence of encryption or lack thereof doesn't explain the exfiltration method; the data is being actively sent out.

E. Sniffing via on-path position captures traffic but doesn't explain how data was exfiltrated from the internal server.

Question #275

A company wants to reduce the time and expense associated with code deployment.

Which of the following technologies should the company utilize?

A. Serverless architecture
B. Thin clients
C. Private cloud
D. Virtual machines

Correct Answer: A — Serverless architecture

Serverless architecture (such as AWS Lambda, Azure Functions) reduces deployment time and expense by eliminating the need to manage underlying infrastructure, provision servers, or handle scalability. The cloud provider manages all operational aspects, allowing developers to focus solely on code deployment and execution. This directly addresses the company's goal of reducing both time and cost.

Why The Other Options Are Incorrect

B. Thin clients reduce client-side resource needs but don't address code deployment efficiency or expense.

C. Private cloud still requires infrastructure management and deployment processes, not reducing deployment time/expense as much as serverless.

D. Virtual machines require provisioning, configuration, and management overhead, still incurring deployment time and expense.

Question #276

A security administrator is performing an audit on a stand-alone UNIX server, and the following message is immediately displayed:

(Error 13):

```
/etc/shadow: Permission denied.
```

Which of the following best describes the type of tool that is being used?

A. Pass-the-hash monitor
B. File integrity monitor
C. Forensic analysis
D. Password cracker

Correct Answer: D — Password cracker

The error message 'Permission denied' when attempting to access /etc/shadow indicates a password cracking tool is being used. Password crackers attempt to read the shadow file (which contains password hashes) to conduct offline attacks. The permission error occurs because the tool is running without sufficient privileges to access this restricted file. This is characteristic behavior of password cracking tools encountering permission barriers.

Why The Other Options Are Incorrect

A. Pass-the-hash monitors would not generate permission errors when reading files; they monitor for pass-the-hash attacks.

B. File integrity monitors check file changes/hashes but wouldn't attempt to read shadow files or generate this specific error.

C. Forensic analysis tools typically run with elevated privileges and would not encounter basic permission errors on shadow files.

Question #277

A security administrator needs to create firewall rules for the following protocols: RTP, SIP, H.323. and SRTP.

Which of the following does this rule set support?

A. RTOS
B. VoIP
C. SoC
D. HVAC

Correct Answer: B — VoIP

RTP (Real-time Transport Protocol), SIP (Session Initiation Protocol), H.323, and SRTP (Secure Real-time Transport Protocol) are all protocols used for Voice over IP (VoIP) communication. SIP and H.323 handle call signaling and setup, while RTP and SRTP transport the actual voice data (encrypted in SRTP's case). These protocols are the

foundational technologies for VoIP systems.

Why The Other Options Are Incorrect

A. RTOS (Real-Time Operating System) is not related to these communication protocols.

C. SoC (System-on-Chip) is a hardware architecture concept, not related to these protocols.

D. HVAC (Heating, Ventilation, Air Conditioning) is a building management system unrelated to VoIP.

Question #278

Which of the following best describes a social engineering attack that uses a targeted electronic messaging campaign aimed at a Chief Executive Officer?

A. Whaling
B. Spear phishing
C. Impersonation
D. Identity fraud

Correct Answer: A — Whaling

Whaling is specifically defined as targeted social engineering attacks against high-level executives (C-level individuals like CEOs). It is a variant of phishing that uses tailored electronic messaging aimed at senior leadership. The term 'whale' refers to high-value targets. This matches the scenario of a targeted campaign against a Chief Executive Officer.

Why The Other Options Are Incorrect

B. Spear phishing is targeted phishing but is not specifically defined for executive-level targets; it applies to any targeted individual.

C. Impersonation is a technique that could be used within whaling but doesn't describe the overall attack category.

D. Identity fraud involves assuming another's identity for personal gain, not sending targeted messaging campaigns to executives.

Question #279

During a penetration test, a flaw in the internal PKI was exploited to gain domain administrator rights using specially crafted certificates.

Which of the following remediation tasks should be completed as part of the cleanup phase?

A. Updating the CRL
B. Patching the CA
C. Changing passwords
D. Implementing SOAR

Correct Answer: B — Patching the CA

After exploiting a flaw in the internal PKI to gain domain administrator rights, the primary remediation task is patching the CA (Certificate Authority). This addresses the root vulnerability that was exploited and prevents future similar attacks. Patching the CA closes the specific flaw that allowed specially crafted certificates to elevate privileges.

Why The Other Options Are Incorrect

A. Updating the CRL (Certificate Revocation List) would revoke certificates but doesn't fix the underlying PKI flaw.

C. While password changes are good practice, they don't address the PKI vulnerability that was exploited.

D. SOAR (Security Orchestration, Automation and Response) is a tool platform, not a remediation task for PKI flaws.

Question #280

A company wants to implement MFA.

Which of the following enables the additional factor while using a smart card?

A. PIN
B. Hardware token
C. User ID
D. SMS

Correct Answer: A — PIN

When implementing MFA with a smart card as the first factor, a PIN (Personal Identification Number) serves as the second authentication factor. The smart card itself (something you have) is one factor, and the PIN (something you know) is the additional factor. Together they satisfy the MFA requirement of two different authentication types.

Why The Other Options Are Incorrect

B. A hardware token is itself a physical factor similar to a smart card, not an additional factor to use with it.

C. User ID is typically username/identification, not an authentication factor—it identifies but doesn't authenticate.

D. SMS sends a one-time code but requires a phone; it's not the enabling factor

specifically when using a smart card.

Question #281

A company hired an external consultant to assist with required system upgrades to a critical business application. A systems administrator needs to secure the consultant's access without sharing passwords to critical systems.

Which of the following solutions should most likely be utilized?

A. TACACS+
B. SAML
C. An SSO platform
D. Role-based access control
E. PAM software

Correct Answer: E — PAM software

PAM (Privileged Access Management) software is the ideal solution for granting secure temporary access to critical systems without sharing passwords. PAM provides credential management, session recording, access logging, and just-in-time privilege elevation. It allows the consultant to access systems through controlled sessions while maintaining security and audit trails, perfectly addressing the requirement to secure access without sharing credentials.

Why The Other Options Are Incorrect

A. TACACS+ is an authentication protocol but doesn't provide the credential management and privileged access control needed.

B. SAML is a federation and SSO protocol for authentication, not specifically for managing privileged access without sharing passwords.

C. SSO provides unified authentication but doesn't address the secure delegation of privileged access to external consultants.

D. RBAC defines what users can do after authentication but doesn't solve the problem of securely granting temporary privileged access without password sharing.

Question #282

A newly implemented wireless network is designed so that visitors can connect to the wireless network for business activities. The legal department is concerned that visitors might connect to the network and perform illicit activities.

Which of me following should the security team implement to address this concern?

A. Configure a RADIUS server to manage device authentication.
B. Use 802.1X on all devices connecting to wireless.

C. Add a guest captive portal requiring visitors to accept terms and conditions.
D. Allow for new devices to be connected via WPS.

✅ Correct Answer: C — Add a guest captive portal requiring visitors to accept terms and conditions.

A captive portal with terms and conditions acceptance directly addresses the legal department's concern by creating a documented acknowledgment that visitors understand acceptable use policies and potential legal consequences for illicit activities. This provides both a deterrent and a legal record of user acknowledgment. While RADIUS, 802.1X, and WPS address authentication mechanisms, they do not specifically address the concern about visitors performing illicit activities or create the legal documentation needed.

Why The Other Options Are Incorrect

A. RADIUS manages authentication but does not create accountability or legal acknowledgment for acceptable use.

B. 802.1X requires credentials but doesn't address the legal concern or create terms of service acknowledgment.

D. WPS weakens security rather than addressing concerns about illicit activities on the network.

Question #283

Which of the following data roles is responsible for identifying risks and appropriate access to data?

A. Owner
B. Custodian
C. Steward
D. Controller

✅ Correct Answer: A — Owner

The Data Owner is responsible for identifying risks associated with their data and determining appropriate access controls and permissions. This is a fundamental responsibility of data ownership. A custodian manages and maintains data, a steward ensures quality and proper use, and a controller determines how data is processed, but the owner specifically identifies risks and defines access policies.

Why The Other Options Are Incorrect

B. Custodian manages and maintains data but does not determine access policies.

C. Steward ensures data quality and proper use but is not responsible for identifying risks and defining access.

D. Controller (in GDPR context) determines processing but is not the primary role for

identifying access risks.

Question #284

Which of the following physical controls can be used to both detect and deter? (Choose two.)

A. Lighting
B. Fencing
C. Signage
D. Sensor
E. Bollard
F. Lock

Correct Answer: A, D

A. Lighting
D. Sensor

Lighting can both detect intruders through visibility and deter them by eliminating shadows and concealment. Sensors can both detect unauthorized access through triggering alarms and deter through visible notification. Fencing deters but primarily contains rather than detects; signage only deters; bollards only deter; locks only control access but do not detect.

Why The Other Options Are Incorrect

B. Fencing primarily deters and contains but does not actively detect intrusions.
C. Signage only deters potential intruders; it does not detect anything.
E. Bollards deter vehicle access but do not detect unauthorized presence.
F. Locks control access but do not independently detect unauthorized attempts.

Question #285

A multinational bank hosts several servers in its data center. These servers run a business-critical application used by customers to access their account information.

Which of the following should the bank use to ensure accessibility during peak usage times?

A. Load balancer
B. Cloud backups
C. Geographic dispersal
D. Disk multipathing

Correct Answer: A — Load balancer

A load balancer distributes incoming traffic across multiple servers, ensuring that no single server becomes overwhelmed during peak usage times, directly addressing accessibility during high demand. Cloud backups provide recovery but not real-time availability; geographic dispersal addresses disaster recovery but not peak load management; disk multipathing addresses storage redundancy, not web traffic distribution.

Why The Other Options Are Incorrect

B. Cloud backups ensure data recovery but do not help handle peak usage traffic.

C. Geographic dispersal is for disaster recovery and redundancy, not peak load distribution.

D. Disk multipathing provides storage redundancy but does not address web server capacity during peak times.

Question #286

The author of a software package is concerned about bad actors repackaging and inserting malware into the software. The software download is hosted on a website, and the author exclusively controls the website's contents.

Which of the following techniques would best ensure the software's integrity?

A. Input validation
B. Code signing
C. Secure cookies
D. Fuzzing

Daily Debian

Correct Answer: B — Code signing

Code signing allows users to cryptographically verify that the software has not been modified and originates from the legitimate author. This prevents bad actors from repackaging malware-infected versions while maintaining the legitimate signature. Input validation protects against attacks but doesn't verify package integrity; secure cookies relate to web sessions; fuzzing tests for vulnerabilities but doesn't prevent tampering.

Why The Other Options Are Incorrect

A. Input validation protects applications but does not verify the integrity of the downloaded package itself.

C. Secure cookies protect web session data but are irrelevant to software package integrity.

D. Fuzzing identifies vulnerabilities but does not prevent or detect malware injection into repackaged software.

Question #287

A third-party vendor is moving a particular application to the end-of-life stage at the end of the current year.

Which of the following is the most critical risk if the company chooses to continue running the application?

A. Lack of security updates
B. Lack of new features
C. Lack of support
D. Lack of source code access

Correct Answer: A — Lack of security updates

The lack of security updates is the most critical risk when running end-of-life software. As vulnerabilities are discovered and exploited in the wild, the application becomes increasingly vulnerable without patches. While lack of support, features, and source code access are concerns, security vulnerabilities directly threaten system and data integrity, making this the most critical risk.

Why The Other Options Are Incorrect

B. Lack of new features is a functionality issue but not a critical security risk.
C. Lack of support is problematic but less critical than unpatched security vulnerabilities.
D. Lack of source code access is rarely a primary concern for end-of-life applications.

Question #288

A security analyst recently read a report about a flaw in several of the organization's printer models that causes credentials to be sent over the network in cleartext, regardless of the encryption settings.

Which of the following would be best to use to validate this finding?

A. Wireshark
B. netcat
C. Nessus
D. Nmap

Correct Answer: A — Wireshark

Wireshark is a network packet analyzer that captures and displays network traffic at a detailed level, allowing verification that credentials are indeed being sent in cleartext over the network. This directly validates the reported vulnerability by inspecting the actual network packets. Netcat is a network utility but not designed for detailed packet inspection; Nessus is a vulnerability scanner but may not capture actual cleartext transmission; Nmap

performs port scanning and service discovery but doesn't analyze packet contents.

Why The Other Options Are Incorrect

B. Netcat is a networking utility but not designed to inspect detailed packet contents for credential cleartext.

C. Nessus scans for vulnerabilities but doesn't directly capture and display cleartext credential transmission.

D. Nmap identifies open ports and services but does not analyze packet contents for cleartext data.

Question #289

A development team is launching a new public-facing web product. The Chief Information Security Officer has asked that the product be protected from attackers who use malformed or invalid inputs to destabilize the system.

Which of the following practices should the development team implement?

A. Fuzzing
B. Continuous deployment
C. Static code analysis
D. Manual peer review

Daily Debian

Correct Answer: A — Fuzzing

Fuzzing (fuzz testing) deliberately feeds an application large volumes of malformed, unexpected, or random input to see whether it crashes, hangs, or behaves insecurely. That is precisely the threat described—attackers destabilizing the system with invalid inputs—so fuzzing is the practice that discovers and lets developers fix those weaknesses before release.

Why The Other Options Are Incorrect

B. Continuous deployment is a release automation practice; it speeds delivery of code but does not test how the application handles malformed input.

C. Static code analysis inspects source code without executing it, so it cannot observe runtime instability caused by malformed input the way dynamic fuzzing can.

D. Manual peer review relies on human inspection of code and would not systematically exercise the application with thousands of invalid input combinations.

Question #290

During an annual review of the system design, an engineer identified a few issues with the currently released design.

Which of the following should be performed next according to best practices?

A. Risk management process
B. Product design process
C. Design review process
D. Change control process

Correct Answer: D — Change control process

When issues are identified in a system design during review, the appropriate next step is the change control process. This formal process ensures that identified issues are documented, evaluated, approved, and implemented in a controlled manner with proper authorization and documentation. While risk management and design review are related processes, change control is the specific mechanism for managing and implementing improvements to existing released designs.

Why The Other Options Are Incorrect

A. Risk management would assess risks but doesn't directly implement solutions to identified design issues.

B. Product design process is for creating new designs, not for addressing issues in released systems.

C. Design review process identifies issues but doesn't implement changes; change control is needed to formally manage the corrections.

Question #291

Which of the following is best to use when determining the severity of a vulnerability?

A. CVE
B. OSINT
C. SOAR
D. CVSS

Correct Answer: D — CVSS

CVSS (Common Vulnerability Scoring System) is specifically designed to provide a standardized numerical rating of vulnerability severity, ranging from 0-10. It accounts for attack vector, complexity, privileges required, user interaction, and impact metrics. CVE is just an identifier, OSINT is intelligence gathering, and SOAR is for orchestration—none of these directly measure severity like CVSS does.

Why The Other Options Are Incorrect

A. CVE is only an identifier/catalog number for vulnerabilities, not a severity rating system.

B. OSINT is open-source intelligence gathering, not a severity measurement tool.

C. SOAR is for security orchestration and automation, not for determining vulnerability severity.

Question #292

An organization experienced a security breach that allowed an attacker to send fraudulent wire transfers from a hardened PC exclusively to the attacker's bank through remote connections. A security analyst is creating a timeline of events and has found a different PC on the network containing malware. Upon reviewing the command history, the analyst finds the following:

```
PS>.\mimikatz.exe "sekurlsa::pth /user:localadmin /domain:corp-
domain.com /ntlm:B4B9B02E1F29A3CF193EAB28C8D617D3F327
```

Which of the following best describes how the attacker gained access to the hardened PC?

A. The attacker created fileless malware that was hosted by the banking platform.

B. The attacker performed a pass-the-hash attack using a shared support account.

C. The attacker utilized living-off-the-land binaries to evade endpoint detection and response software.

D. The attacker socially engineered the accountant into performing bad transfers.

✅ Correct Answer: B — The attacker performed a pass-the-hash attack using a shared support account.

The command shown is mimikatz with the 'sekurlsa::pth' function, which executes a pass-the-hash attack. The attacker is using the NTLM hash of the 'localadmin' account (B4B9B02E...) to authenticate to the hardened PC without needing the plaintext password. This is a credential-based attack leveraging a compromised account hash from another system on the network.

Why The Other Options Are Incorrect

A. Fileless malware and banking platform hosting are not indicated by the mimikatz command history shown.

C. Living-off-the-land binaries involve using legitimate system tools, but mimikatz is a dedicated hacking tool, not a LOLBin.

D. Social engineering of the accountant is not supported by the technical evidence of the mimikatz hash attack command.

Question #293

Which of the following is the best resource to consult for information on the most common application exploitation methods?

A. OWASP
B. STIX
C. OVAL
D. Threat intelligence feed
E. Common Vulnerabilities and Exposures

Correct Answer: A — OWASP

OWASP (Open Web Application Security Project) is the authoritative resource for documenting the most common web application exploitation methods and vulnerabilities, particularly through publications like the OWASP Top 10. STIX is for threat intelligence sharing, OVAL is for vulnerability definitions, CVE is an identifier system, and threat feeds provide current intelligence but not the foundational methodology reference.

Why The Other Options Are Incorrect

B. STIX is a data model for sharing threat intelligence, not a guide to exploitation methods.

C. OVAL is used for vulnerability assessment and detection, not documentation of exploitation methods.

D. Threat intelligence feeds provide current threat data but not comprehensive documentation of common exploitation techniques.

E. CVE is an identifier catalog, not an educational resource on exploitation methods.

Question #294

A security analyst is reviewing the logs on an organization's DNS server and notices the following unusual snippet:

```
Log from named: post-processed 20230102 0045L
...
qry_source: 124.22.158.37 TCP/53
qry_dest: 52.165.16.154 TCP/53
qry_dest: 10.100.50.5 TCP/53
qry_type: AXFR
| zone int.comptia.org
------------------| www A 10.100.50.21
------------------| dns A 10.100.5.5
------------------| adds A 10.101.10.10
------------------| fshare A 10.101.10.20
------------------| sip A 10.100.5.11
...
```

Which of the following attack techniques was most likely used?

A. Determining the organization's ISP-assigned address space
B. Bypassing the organization's DNS sinkholing
C. Footprinting the internal network
D. Attempting to achieve initial access to the DNS server
E. Exfiltrating data from fshare.int.complia.org

Correct Answer: C — Footprinting the internal network

The log shows a DNS zone transfer (AXFR query) from an external IP (124.22.158.37) attempting to retrieve the complete zone file for int.comptia.org. The response reveals multiple internal DNS records (www, dns, adds, fshare, sip) with internal IP addresses (10.x.x.x range). This is a classic footprinting technique used to map an organization's internal network structure, DNS records, and IP addressing scheme. Zone transfers should be restricted to authorized secondary nameservers only, and this unrestricted transfer exposes internal network topology.

Why The Other Options Are Incorrect

A. The log reveals internal private IP addresses (10.x.x.x), not ISP-assigned public address space.

B. DNS sinkholing is irrelevant here; this is about zone transfer enumeration, not malware detection or blocking.

D. There is no evidence of an attack against the DNS server itself; the attacker successfully completed the zone transfer, indicating no defensive measure stopped them.

E. While fshare data could theoretically be exfiltrated, the log shows only DNS

reconnaissance/footprinting, not actual data exfiltration activity.

Question #295

A security analyst at an organization observed several user logins from outside the organization's network. The analyst determined that these logins were not performed by individuals within the organization.

Which of the following recommendations would reduce the likelihood of future attacks? (Choose two.)

A. Disciplinary actions for users
B. Conditional access policies
C. More regular account audits
D. Implementation of additional authentication factors
E. Enforcement of content filtering policies
F. A review of user account permissions

Correct Answer: B, D

B. Conditional access policies
D. Implementation of additional authentication factors

Conditional access policies (B) can restrict logins based on geographic location, device compliance, and risk factors, directly preventing unauthorized external logins. Implementation of additional authentication factors (D) such as MFA makes it significantly harder for attackers to gain access even with compromised credentials. Together, these provide both preventive controls (preventing unauthorized access) and detective controls (requiring stronger authentication).

Why The Other Options Are Incorrect

A. Disciplinary actions don't prevent future attacks; these logins weren't from actual users within the organization.

C. More regular account audits detect issues after the fact but don't prevent unauthorized access from occurring.

E. Content filtering is irrelevant to preventing unauthorized user logins from external networks.

F. Reviewing permissions doesn't prevent attackers from logging in with compromised credentials in the first place.

Question #296

A security team is addressing a risk associated with the attack surface of the organization's web application over port 443. Currently, no advanced network security capabilities are in place.

Which of the following would be best to set up? (Choose two.)

A. NIDS
B. Honeypot
C. Certificate revocation list
D. HIPS
E. WAF
F. SIEM

Correct Answer: A, E

A. NIDS
E. WAF

NIDS (A) provides network-level detection of malicious traffic on port 443, monitoring for attack patterns. WAF (E) is specifically designed to protect web applications by filtering and monitoring HTTP/HTTPS traffic for application-layer attacks. Both address the web application attack surface—NIDS provides network detection while WAF provides application-layer protection. These two complementary controls directly address the stated concern.

Why The Other Options Are Incorrect

B. Honeypots are deceptive tools for threat research, not primary defenses for production attack surfaces.

C. Certificate revocation lists manage certificate validity, not application attack surface protection.

D. HIPS (host-based) protects individual endpoints but doesn't address network-level web application threats.

F. SIEM is for log aggregation and analysis, not a preventive control for web application attacks.

Question #297

A systems administrator would like to create a point-in-time backup of a virtual machine.

Which of the following should the administrator use?

A. Replication
B. Simulation
C. Snapshot

D. Containerization

Correct Answer: C — Snapshot

A snapshot is the appropriate tool for creating a point-in-time backup of a virtual machine. It captures the exact state of the VM at a specific moment, including disk, memory, and configuration, allowing administrators to revert to that state if needed. Replication is for redundancy, simulation is for testing, and containerization is for application packaging—none provide point-in-time backup functionality.

Why The Other Options Are Incorrect

A. Replication creates copies for disaster recovery but doesn't provide point-in-time restore capability.

B. Simulation is for testing scenarios, not creating backups.

D. Containerization packages applications, not VM backups.

Question #298

A security administrator notices numerous unused, non-compliant desktops are connected to the network.

Which of the following actions would the administrator most likely recommend to the management team?

A. Monitoring
B. Decommissioning
C. Patching
D. Isolating

Correct Answer: B — Decommissioning

Decommissioning is the most appropriate action for unused, non-compliant desktops. These systems pose a security risk because they cannot be updated or maintained, making them vulnerable to exploits. Removing them from the network eliminates the attack surface they represent. While isolation, patching, and monitoring might temporarily mitigate risk, decommissioning permanently removes non-functional, liability-creating assets.

Why The Other Options Are Incorrect

A. Monitoring doesn't solve the compliance issue or reduce the risk of non-compliant systems.

C. Patching unused systems that may not be updatable doesn't address fundamental non-compliance.

D. Isolating unused desktops leaves them on the network as potential liabilities; decommissioning is the proper lifecycle action.

Question #299

Which of the following is a common data removal option for companies that want to wipe sensitive data from hard drives in a repeatable manner but allow the hard drives to be reused?

A. Sanitization
B. Formatting
C. Degaussing
D. Defragmentation

Correct Answer: A — Sanitization

Sanitization is the process of securely removing sensitive data from storage media while maintaining the ability to reuse the hardware. It overwrites data in a repeatable manner using standards like DOD 5220.22-M, making recovery impossible while preserving drive functionality. This distinguishes it from degaussing (which destroys the drive) and simple formatting (which doesn't securely erase data).

Why The Other Options Are Incorrect

B. Formatting does not securely erase data; deleted files can be recovered with forensic tools.

C. Degaussing destroys the hard drive with magnetic fields, making it unreusable for future purposes.

D. Defragmentation is a performance optimization technique unrelated to data removal.

Question #300

An organization wants to improve the company's security authentication method for remote employees. Given the following requirements:

- Must work across SaaS and internal network applications
- Must be device manufacturer agnostic
- Must have offline capabilities

Which of the following would be the most appropriate authentication method?

A. Username and password
B. Biometrics
C. SMS verification
D. Time-based tokens

Correct Answer: D — Time-based tokens

Time-based tokens (TOTP/HOTP) meet all requirements: they work across SaaS and internal applications, are device manufacturer agnostic (any TOTP-compatible authenticator works), and function offline without network connectivity. Username/password lacks multi-factor strength, biometrics require specific hardware, and SMS requires connectivity.

Why The Other Options Are Incorrect

A. Username and password alone doesn't meet the multi-factor security requirement for remote access.

B. Biometrics require specific device hardware, violating the manufacturer-agnostic requirement.

C. SMS verification requires network connectivity and cannot work offline as required.

Question #301

A security officer is implementing a security awareness program and has placed security-themed posters around the building and assigned online user training.

Which of the following will the security officer most likely implement?

A. Password policy
B. Access badges
C. Phishing campaign
D. Risk assessment

Daily Debian

Correct Answer: C — Phishing campaign

A phishing campaign is a practical security awareness training tool that tests employee response to social engineering attacks. Combined with posters and online training, it demonstrates real-world threats and measures user compliance. The other options are security controls, not awareness program components.

Why The Other Options Are Incorrect

A. Password policy is an administrative control, not part of awareness training implementation.

B. Access badges are physical security controls, not awareness program elements.

D. Risk assessment is an evaluation methodology, not an awareness program activity.

Question #302

A malicious update was distributed to a common software platform and disabled services at many organizations.

Which of the following best describes this type of vulnerability?

A. DDoS attack
B. Rogue employee
C. Insider threat
D. Supply chain

✅ Correct Answer: D — Supply chain

A malicious update distributed through a legitimate software platform represents a supply chain attack, where the attacker compromises a trusted vendor to distribute malware to multiple organizations downstream. This affects the security of all organizations using that platform.

Why The Other Options Are Incorrect

A. DDoS attacks target availability through traffic flooding, not software updates.

B. Rogue employees are individuals acting maliciously within an organization, not external supply chain compromises.

C. Insider threat requires a person within the target organization, whereas this originates from a software vendor.

Question #303

A company web server is initiating outbound traffic to a low-reputation, public IP on non-standard pat. The web server is used to present an unauthenticated page to clients who upload images the company. An analyst notices a suspicious process running on the server hat was not created by the company development team.

Which of the following is the most likely explanation for his security incident?

A. A web shell has been deployed to the server through the page.
B. A vulnerability has been exploited to deploy a worm to the server.
C. Malicious insiders are using the server to mine cryptocurrency.
D. Attackers have deployed a rootkit Trojan to the server over an exposed RDP port.

✅ Correct Answer: A — A web shell has been deployed to the server through the page.

A web shell deployed through the unauthenticated image upload functionality best explains the observed indicators: suspicious process, outbound traffic, and non-standard ports. Web shells are small scripts placed on web servers that provide attackers remote code execution and persistence. This attack vector specifically targets upload functionality.

Why The Other Options Are Incorrect

B. A worm self-replicates across systems; the scenario describes compromise of a single server through targeted upload.

C. Cryptocurrency mining doesn't typically cause outbound connections to low-

reputation IPs or match this attack pattern.

D. Rootkit Trojans require RDP access, but the attack vector described is the public-facing upload functionality.

Question #304

An organization requests a third-party full-spectrum analysis of its supply chain.

Which of the following would the analysis team use to meet this requirement?

A. Vulnerability scanner
B. Penetration test
C. SCAP
D. Illumination tool

Correct Answer: D — Illumination tool

An illumination tool provides comprehensive supply chain analysis and visibility into vendor risk, dependencies, and potential vulnerabilities across the entire supply chain ecosystem. It maps relationships and identifies security risks throughout interconnected suppliers.

Why The Other Options Are Incorrect

A. Vulnerability scanners identify technical weaknesses in systems but lack supply chain scope.

B. Penetration testing assesses security through active exploitation, not comprehensive supply chain analysis.

C. SCAP (Security Content Automation Protocol) is for vulnerability and compliance reporting, not supply chain analysis.

Question #305

A systems administrator deployed a monitoring solution that does not require installation on the endpoints that the solution is monitoring.

Which of the following is described in this scenario?

A. Agentless solution
B. Client-based soon
C. Open port
D. File-based solution

Correct Answer: A — Agentless solution

An agentless solution performs monitoring without requiring software installation on

monitored endpoints. It typically uses API queries, SNMP, WMI, or other remote protocols to gather data, reducing deployment complexity and maintenance overhead.

Why The Other Options Are Incorrect

B. Client-based solutions require installation on endpoints, contradicting the stated requirement.

C. Open ports refer to network accessibility, not monitoring architecture deployment models.

D. File-based solutions require local file access, implying agent or direct system interaction.

Question #306

A security analyst is reviewing the source code of an application in order to identify misconfigurations and vulnerabilities.

Which of the following kinds of analysis best describes this review?

A. Dynamic
B. Static
C. Gap
D. Impact

Correct Answer: B — Static

Static analysis examines application source code without executing it to identify vulnerabilities, misconfigurations, and coding flaws. Code review is a primary static analysis method. This contrasts with dynamic analysis which requires runtime execution.

Why The Other Options Are Incorrect

A. Dynamic analysis requires running the application to identify issues, not reviewing source code.

C. Gap analysis compares current state to desired state, unrelated to vulnerability identification in code.

D. Impact analysis assesses consequences of changes or incidents, not source code review for vulnerabilities.

Question #307

Which of the following agreement types is used to limit external discussions?

A. BPA
B. NDA
C. SLA

D. MSA

Correct Answer: B — NDA

An NDA (Non-Disclosure Agreement) is specifically designed to limit external discussions and protect confidential information by legally restricting what parties can disclose about the relationship or information shared. BPA is a Blanket Purchase Agreement for procurement, SLA defines service levels, and MSA is a Master Service Agreement covering general terms—none of these are primarily used to restrict external discussions.

Why The Other Options Are Incorrect

A. BPA is a procurement agreement, not designed to restrict discussions.

C. SLA defines service level commitments and metrics, not discussion limitations.

D. MSA covers general terms and conditions of service, not external discussion restrictions.

Question #308

A security analyst is evaluating a SaaS application that the human resources department would like to implement. The analyst requests a SOC 2 report from the SaaS vendor.

Which of the following processes is the analyst most likely conducting?

A. Internal audit
B. Penetration testing
C. Attestation
D. Due diligence

Correct Answer: D — Due diligence

Requesting a SOC 2 report from a vendor is a due diligence process where the organization evaluates the vendor's security controls and compliance posture before implementing their service. Due diligence is the systematic investigation and verification of a third party's security and operational capabilities. While attestation relates to the SOC 2 report itself, the process of requesting and reviewing it for decision-making is due diligence.

Why The Other Options Are Incorrect

A. Internal audit evaluates the organization's own controls, not vendor evaluation.

B. Penetration testing is active exploitation testing, not vendor evaluation methodology.

C. Attestation is the auditor's assurance statement within the report itself, not the evaluation process.

Question #309

Which of the following is used to conceal credit card information in a database log file?

A. Tokenization
B. Masking
C. Hashing
D. Obfuscation

Correct Answer: B — Masking

Masking is the technique used to conceal sensitive data like credit card information in logs and other outputs by replacing characters with symbols or redacting portions of the data while maintaining the data structure. Tokenization replaces data with tokens for processing, hashing is one-way cryptographic transformation, and obfuscation is a general term for making data unclear—masking is the specific technique for concealing PII in logs.

Why The Other Options Are Incorrect

A. Tokenization replaces sensitive data with tokens but is typically used in payment processing, not log concealment.

C. Hashing is a one-way function unsuitable for logs that need to display partial information.

D. Obfuscation is too general; masking is the specific, standard technique for this purpose.

Daily Debian

Question #310

SIMULATION

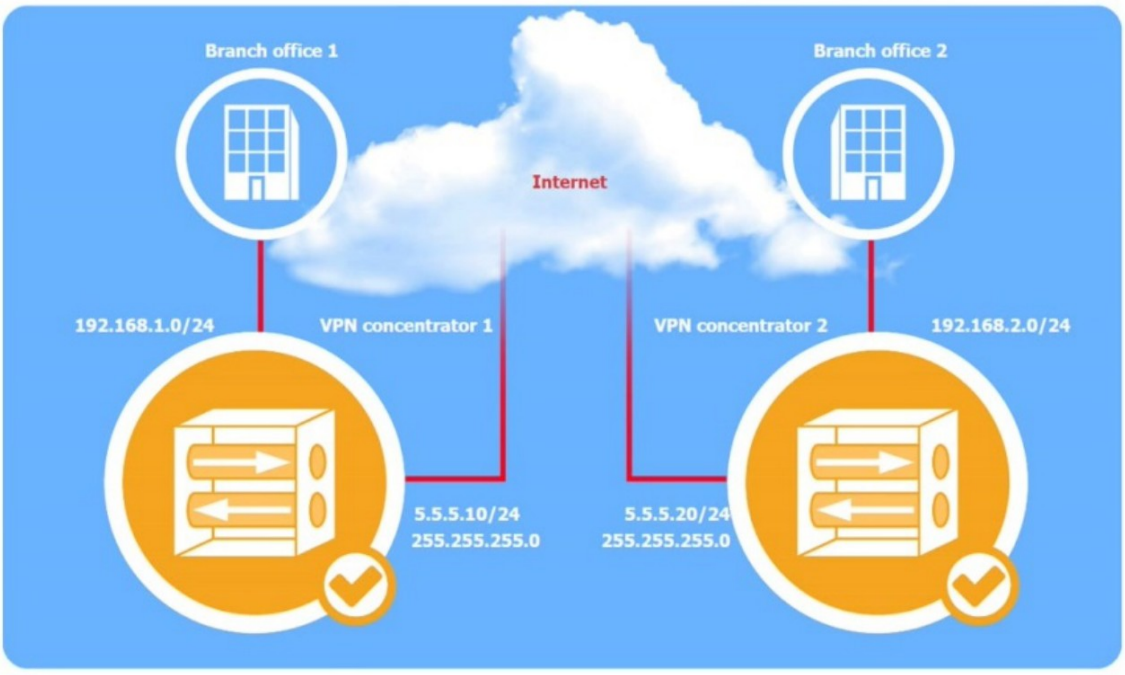
A systems administrator is configuring a site-to-site VPN between two branch offices. Some of the settings have already been configured correctly. The systems administrator has been provided the following requirements as part of completing the configuration:

- Most secure algorithms should be selected
- All traffic should be encrypted over the VPN
- A secret password will be used to authenticate the two VPN concentrators

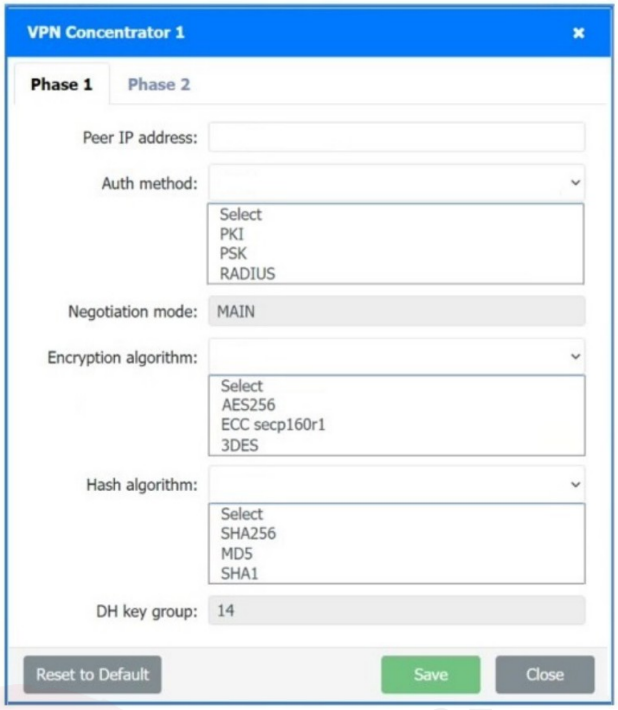
INSTRUCTIONS

Click on the two VPN Concentrators to configure the appropriate settings.

If at any time you would like to bring back the initial state of the simulation, please click the Reset All button.



Daily Debian


VPN Concentrator 1
Phase 1
Phase 2
Peer IP address:
Auth method:
Select
PKI
PSK
RADIUS
Negotiation mode:
MAIN
Encryption algorithm:
Select
AES256
ECC secp160r1
3DES
Hash algorithm:
Select
SHA256
MD5
SHA1
DH key group:
14
Reset to Default
Save
Close


VPN Concentrator 1
Phase 1
Phase 2
Mode:
Tunnel
Protocol:
Select
ESP
AH
Encryption algorithm:
Select
3DES
AES256
BLOWFISH
Hash algorithm:
Select
SHA256
MD5
SHA1
Local network/mask:
Remote network/mask:
Reset to Default
Save
Close



Completed Answer

Configure the Phase 1 and Phase 2 settings on both VPN concentrators so the site-to-site tunnel comes up with the strongest available algorithms and encrypts all traffic between the branch offices.

Concentrator 1, Phase 1, Peer IP address → 5.5.5.20
Concentrator 1, Phase 1, Auth method → PKI
Concentrator 1, Phase 1, Encryption algorithm → AES256
Concentrator 1, Phase 1, Hash algorithm → SHA256
Concentrator 1, Phase 1, DH key group → 14
Concentrator 1, Phase 2, Protocol → ESP
Concentrator 1, Phase 2, Encryption algorithm → AES256
Concentrator 1, Phase 2, Hash algorithm → SHA256
Concentrator 1, Phase 2, Local network/mask → 255.255.255.0
Concentrator 1, Phase 2, Remote network/mask → 255.255.255.0
Concentrator 2, Phase 1, Peer IP address → 5.5.5.10
Concentrator 2, Phase 1, Auth method → PKI
Concentrator 2, Phase 1, Encryption algorithm → AES256
Concentrator 2, Phase 1, Hash algorithm → SHA256
Concentrator 2, Phase 1, DH key group → 14

How To Work It Out

1. Each concentrator must point at the other one's public address, so Concentrator 1 gets a peer IP of 5.5.5.20 and Concentrator 2 gets a peer IP of 5.5.5.10.

2. For the authentication method the answer key selects PKI on both devices, and the same method must be configured identically on each end or Phase 1 will fail.

3. Of the encryption choices offered, AES256 is the strongest (3DES is deprecated, BLOWFISH is weak, and ECC secp160r1 is not a symmetric cipher), so AES256 is chosen for both Phase 1 and Phase 2.

4. MD5 and SHA1 are both considered broken for integrity, leaving SHA256 as the most secure hash on every tab, and DH key group 14 is kept as the pre-set 2048-bit group.

5. Phase 2 must use ESP rather than AH because only ESP encrypts the payload; AH only authenticates it, which would not meet the requirement that all traffic be encrypted.

6. The local and remote network masks are entered as 255.255.255.0 to match the /24 networks (192.168.1.0/24 and 192.168.2.0/24) being carried through the tunnel, and the mirror-image values are configured on the other concentrator.

A site-to-site IPSec tunnel only forms when both ends agree on every parameter, so the two concentrators are configured as mirror images of one another: Concentrator 1 lists 5.5.5.20 as its peer and Concentrator 2 lists 5.5.5.10. The authentication method is set the same on both sides (PKI in the published answer). Where a choice of cryptography exists, the strongest option is picked - AES256 for encryption instead of 3DES or BLOWFISH, SHA256 for hashing instead of MD5 or SHA1 - and DH group 14 is retained for the key exchange. In Phase 2 the protocol must be ESP, since ESP provides confidentiality for the encapsulated packets whereas AH only provides integrity and authentication and would leave traffic in the clear. Finally the tunnel selectors are given the 255.255.255.0 mask so the full 192.168.1.0/24 and 192.168.2.0/24 branch subnets are routed through and protected by the VPN, satisfying the requirement that all traffic be encrypted.

Question #311

An organization recently started hosting a new service that customers access through a web portal. A security engineer needs to add to the existing security devices a new solution to protect this new service.

Which of the following is the engineer most likely to deploy?

A. Layer 4 firewall
B. NGFW
C. WAF
D. UTM

Correct Answer: C — WAF

A WAF (Web Application Firewall) is specifically designed to protect web applications and services accessed through a web portal by filtering and monitoring HTTP/HTTPS traffic for malicious requests. While firewalls and UTM devices exist, a WAF is the specialized solution for protecting web-based services. Layer 4 firewalls operate at the transport layer and NGFW are general network firewalls, neither specifically designed for application layer web protection.

Why The Other Options Are Incorrect

A. Layer 4 firewalls operate at the transport layer and lack application-level web protection.

B. NGFW provides network-level protection but lacks the specialized web application filtering of a WAF.

D. UTM is a general security appliance; WAF is the specialized solution for web service protection.

Question #312

Which of the following topics would most likely be included within an organization's SDLC?

A. Service-level agreements
B. Information security policy
C. Penetration testing methodology
D. Branch protection requirements

Correct Answer: D — Branch protection requirements

Branch protection requirements are security controls implemented during the software

development process to ensure code integrity and governance, making them a direct component of SDLC. Service-level agreements relate to operational services, information security policy is organizational policy rather than SDLC-specific, and penetration testing methodology is a testing approach but not typically a core SDLC topic like branch protection which governs how code changes are managed.

Why The Other Options Are Incorrect

A. SLAs define service performance expectations, not development lifecycle processes.

B. Information security policy is organizational governance, separate from SDLC specifics.

C. Penetration testing is a security testing methodology, not a core SDLC component.

Question #313

Which of the following control types is AUP an example of?

A. Physical
B. Managerial
C. Technical
D. Operational

Correct Answer: B — Managerial

AUP (Acceptable Use Policy) is a managerial/administrative control that establishes rules and expectations for how employees and users should behave with organizational resources. It is policy-based governance rather than a physical barrier, technical mechanism, or operational procedure. Managerial controls include policies, procedures, and administrative directives that manage risk through governance.

Why The Other Options Are Incorrect

A. Physical controls are tangible barriers like locks or access cards, not policies.

C. Technical controls are technology-based like firewalls or encryption, not written policies.

D. Operational controls are day-to-day implementation procedures; AUP is a managerial policy.

Question #314

An organization is adopting cloud services at a rapid pace and now has multiple SaaS applications in use. Each application has a separate log-in, so the security team wants to reduce the number of credentials each employee must maintain.

Which of the following is the first step the security team should take?

A. Enable SAML.
B. Create OAuth tokens.
C. Use password vaulting.
D. Select an IdP.

Correct Answer: D — Select an IdP.

Selecting an IdP (Identity Provider) is the first foundational step before implementing single sign-on solutions like SAML or OAuth. The organization must choose which identity provider will manage user authentication before enabling any federation protocols or tokens. SAML and OAuth are protocols enabled after the IdP is selected, and password vaulting is a stopgap solution rather than the proper first step toward federation.

Why The Other Options Are Incorrect

A. SAML cannot be enabled until an IdP is selected and configured.

B. OAuth tokens are created after IdP selection and configuration.

C. Password vaulting is a workaround, not the foundational first step toward proper SSO.

Question #315

A company's online shopping website became unusable shortly after midnight on January 30, 2023.

When a security analyst reviewed the database server, the analyst noticed the following code used for backing up data:

```
IF DATE() = "01/30/2023" THEN BEGIN
  DROP DATABASE WebShopOnline;
END
```

Which of the following should the analyst do next?

A. Check for recently terminated DBAs.
B. Review WAF logs for evidence of command injection.
C. Scan the database server for malware.
D. Search the web server for ransomware notes.

Correct Answer: A — Check for recently terminated DBAs.

The code shown is a SQL time bomb that executes a destructive command (DROP DATABASE) on a specific date and time (January 30, 2023 at midnight). This is a classic

example of insider threat sabotage planted by a database administrator. The website becoming unusable immediately after midnight on that exact date, combined with the discovery of this malicious code in the backup routine, strongly indicates intentional sabotage by a current or recently terminated DBA who had database access and knowledge to embed such code. Checking for recently terminated DBAs is the logical next step to identify the threat actor.

Why The Other Options Are Incorrect

B. While command injection is a valid attack vector, this code is not injected from external sources but rather embedded in database procedures by someone with legitimate access.

C. Traditional malware scanning is not applicable here since the threat is legitimate code (SQL) with malicious intent, not a malware binary.

D. This is a database destruction attack, not a ransomware attack, so searching for ransomware notes on web servers is not the appropriate next step.

Question #316

Which of the following would be the best way to test resiliency in the event of a primary power failure?

A. Parallel processing
B. Tabletop exercise
C. Simulation testing
D. Production failover

Correct Answer: D — Production failover

Production failover is the most effective way to test actual resiliency in the event of power failure because it involves an actual failure scenario with real systems under actual conditions. Parallel processing is an architecture approach, tabletop exercise is theoretical discussion, and simulation testing is less realistic than actual production failover testing. Production failover provides the most authentic test of whether systems will actually recover from a primary power failure.

Why The Other Options Are Incorrect

A. Parallel processing is a system design approach, not a resiliency test method.

B. Tabletop exercises are theoretical discussions without actual system testing.

C. Simulation testing is less realistic than actual production failover testing.

Question #317

Which of the following would be the most appropriate way to protect data in transit?

A. SHA-256
B. SSL3.0
C. TLS 1.3
D. AES-256

Correct Answer: C — TLS 1.3

TLS 1.3 is a cryptographic protocol specifically designed to protect data in transit by encrypting communications between client and server. SHA-256 is a hash function for data integrity, not encryption. SSL 3.0 is outdated and deprecated due to security vulnerabilities. AES-256 is an encryption cipher but operates at the symmetric level and is not a complete protocol for protecting data in transit like TLS 1.3.

Why The Other Options Are Incorrect

A. SHA-256 is a hashing algorithm for integrity verification, not for encrypting data in transit.

B. SSL 3.0 is deprecated and has known security vulnerabilities; TLS 1.3 is the modern standard.

D. AES-256 is a cipher but not a complete protocol; TLS 1.3 wraps encryption with authentication and key exchange.

Question #318

Which of the following is a common, passive reconnaissance technique employed by penetration testers in the early phases of an engagement?

A. Open-source intelligence
B. Port scanning
C. Pivoting
D. Exploit validation

Correct Answer: A — Open-source intelligence

Open-source intelligence (OSINT) is a passive reconnaissance technique that gathers information from publicly available sources without direct interaction with target systems. Port scanning is active reconnaissance as it probes the target. Pivoting is a post-exploitation technique. Exploit validation involves testing exploits against identified vulnerabilities and is not passive reconnaissance.

Why The Other Options Are Incorrect

B. Port scanning is active reconnaissance that directly probes target systems.

C. Pivoting is a lateral movement technique used after initial access, not reconnaissance.

D. Exploit validation requires active testing and interaction with the target system.

Question #319

Which of the following threat actors is the most likely to seek financial gain through the use of ransomware attacks?

A. Organized crime
B. Insider threat
C. Nation-state
D. Hacktivists

✅ Correct Answer: A — Organized crime

Organized crime groups are the primary threat actors seeking financial gain through ransomware attacks, as they operate profit-driven enterprises. Insider threats typically have different motivations (revenge, espionage). Nation-states pursue strategic and political objectives rather than direct financial gain. Hacktivists are ideologically motivated, not financially motivated.

Why The Other Options Are Incorrect

B. Insider threats are motivated by revenge, ideology, or espionage rather than ransom payments.

C. Nation-states pursue strategic objectives and intelligence rather than financial ransoms.

D. Hacktivists are driven by ideological causes, not financial profit motives.

Question #320

Which of the following would a systems administrator follow when upgrading the firmware of an organization’s router?

A. Software development life cycle
B. Risk tolerance
C. Certificate signing request
D. Maintenance window

✅ Correct Answer: D — Maintenance window

A maintenance window is the established time period for performing system updates and firmware upgrades with minimal impact to operations. This is a standard practice in change management. SDLC is a development process, not a specific procedure for firmware updates. Risk tolerance is a framework consideration but not a procedural step. Certificate signing requests relate to cryptography, not firmware upgrades.

Why The Other Options Are Incorrect

A. SDLC is for software development, not the operational procedure for firmware upgrades.

B. Risk tolerance is a policy consideration but not a specific procedure to follow.

C. Certificate signing requests are cryptographic procedures unrelated to firmware upgrades.

Question #321

The security team has been asked to only enable host A (10.2.2.7) and host B (10.3.9.9) to the new isolated network segment (10.9.8.14) that provides access to legacy devices.

Access from all other hosts should be blocked.

Which of the following entries would need to be added on the firewall?

A.
```
Permit 10.2.2.0/24 to 10.9.8.14/27
Permit 10.3.9.0/24 to 10.9.8.14/27
Deny 0.0.0.0/0 to 10.9.8.14/27
```

B.
```
Deny 0.0.0.0/0 to 10.9.8.14/27
Permit 10.2.2.0/24 to 10.9.8.14/27
Permit 10.3.9.0/24 to 10.9.8.14/27
```

C.
```
Permit 10.2.2.7/32 to 10.9.8.14/27
Permit 10.3.9.9/32 to 10.9.8.14/27
Deny 0.0.0.0/0 to 10.9.8.14/27
```

D.
```
Permit 10.2.2.7/32 to 10.9.8.14/27
Permit 10.3.9.0/24 to 10.9.8.14/27
Deny 10.9.8.14/27 to 0.0.0.0/0
```

✅ Correct Answer: C — Permit 10.2.2.7/32 to 10.9.8.14/27
Permit 10.3.9.9/32 to 10.9.8.14/27
Deny 0.0.0.0/0 to 10.9.8.14/27

The requirement is to allow only specific hosts (10.2.2.7 and 10.3.9.9) to access the network segment 10.9.8.14/27, while blocking all others. Option C correctly uses /32 CIDR notation to specify individual host addresses (10.2.2.7/32 and 10.3.9.9/32), followed by a deny rule for all other traffic (0.0.0.0/0). Options A and B use /24 subnet masks which

would allow entire subnets rather than just the specific hosts. Option D has an incorrect deny rule direction. The proper firewall rule order is to permit the specific hosts first, then deny all others.

Why The Other Options Are Incorrect

A. Uses /24 subnets instead of /32 host-specific addresses, allowing unintended hosts to access the network.

B. Uses /24 subnets instead of /32 host-specific addresses, and the rule order (deny before permit) may cause the permit rules to be ineffective.

D. The final deny rule has incorrect source and destination (reversed direction), and uses /24 subnet for one host instead of /32.

Question #322

SIMULATION

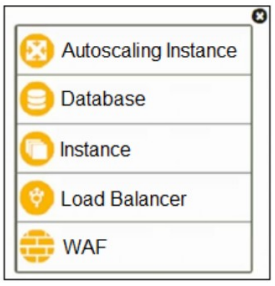
A security analyst is creating the first draft of a network diagram for the company's new customer-facing payment application that will be hosted by a third-party cloud service provider.

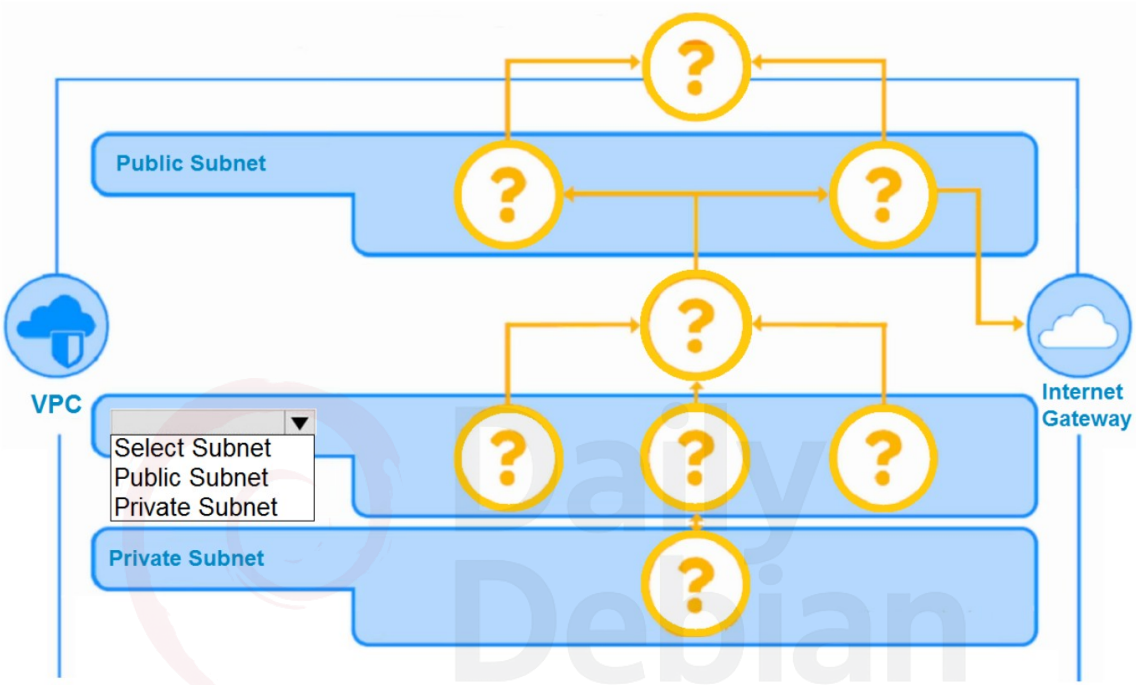
INSTRUCTIONS

Click the ? to select the appropriate icons to create a secure, redundant web application. Then use the dropdown menu to select the appropriate subnet type. Every space in the diagram must be filled.

If at any time you would like to bring back the initial state of the simulation, please click the Reset All button.

Daily Deplan





Completed Answer

Place the correct icon into each ? placeholder of the network diagram and choose the correct subnet type in the dropdown.

Top placeholder (above Public Subnet, facing Internet Gateway) → WAF
Public Subnet - left placeholder → Autoscaling Instance
Public Subnet - right placeholder → Load Balancer
Middle placeholder between the two subnets → Instance
Middle subnet - left placeholder → Database
Middle subnet - center placeholder → Instance
Middle subnet - right placeholder → Autoscaling Instance
Private Subnet placeholder (bottom) → Instance
Subnet type dropdown (middle subnet) → Private Subnet

How To Work It Out

1. Traffic arriving from the Internet Gateway must be inspected first, so the top-most

icon is the WAF, which filters web attacks against the payment application before anything else sees the traffic.

2. Inside the public subnet the internet-facing entry point is the Load Balancer on the right, which spreads sessions across back-end compute for redundancy, while the left position holds an Autoscaling Instance so public-tier capacity grows and shrinks with demand.

3. The compute tiers themselves are filled with Instance icons (between the subnets, in the middle subnet, and in the bottom private subnet) because multiple application servers provide the redundancy the requirement asks for, with a second Autoscaling Instance on the right of the middle subnet.

4. Sensitive payment data belongs in a Database icon placed in the lower, non-public tier so it is never directly reachable from the internet.

5. Because that lower tier holds the database and back-end instances that need no inbound internet exposure, the dropdown is set to Private Subnet.

The diagram models a layered, defense-in-depth cloud deployment. Internet traffic enters through the Internet Gateway and is first screened by the WAF, which protects the customer-facing payment application from injection, cross-site scripting and similar web attacks. Screened traffic is then handed to the Load Balancer in the public subnet, which distributes requests across multiple back-end servers so no single failure takes the site down; the Autoscaling Instances allow that capacity to expand automatically under load, satisfying the redundancy goal. The application workload itself is carried by several Instance icons rather than one, again for fault tolerance. Finally, the Database and the back-end instances that support it sit in the lower tier, which must be set to Private Subnet in the dropdown: private subnets have no direct route to or from the internet, so cardholder data can only be reached through the front-end tier, adding an additional security boundary around the most sensitive component.

Question #323

A systems administrator needs to ensure the secure communication of sensitive data within the organization’s private cloud.

Which of the following is the best choice for the administrator to implement?

A. IPSec
B. SHA-1
C. RSA
D. TGT

Correct Answer: A — IPSec

IPSec is a protocol suite that provides secure end-to-end communication through encryption and authentication at the network layer, making it ideal for protecting data within a private cloud infrastructure. SHA-1 is a deprecated hash function, not an

encryption protocol. RSA is an asymmetric cipher used for key exchange and signatures, not for protecting data streams. TGT (Ticket Granting Ticket) is a Kerberos authentication component, not a data protection mechanism.

Why The Other Options Are Incorrect

B. SHA-1 is a hashing algorithm and is deprecated; it does not encrypt data in transit.

C. RSA is used for asymmetric encryption and key exchange, not for continuous data protection.

D. TGT is part of Kerberos authentication, not a protocol for secure data communication.

Question #324

Which of the following should an internal auditor check for first when conducting an audit of the organization's risk management program?

A. Policies and procedures
B. Asset management
C. Vulnerability assessment
D. Business impact analysis

Correct Answer: A — Policies and procedures

An internal auditor should first check policies and procedures as these establish the framework and foundation of the risk management program. All other activities (asset management, vulnerability assessment, business impact analysis) depend on and relate back to the documented policies and procedures. Starting with policies ensures understanding of what the organization claims to do before assessing actual implementation.

Why The Other Options Are Incorrect

B. Asset management is important but comes after understanding the policies that govern it.

C. Vulnerability assessment is an implementation activity that follows policy review.

D. Business impact analysis is a tactical tool that should align with documented procedures.

Question #325

Which of the following activities are associated with vulnerability management? (Choose two.)

A. Reporting
B. Prioritization

C. Exploiting
D. Correlation
E. Containment
F. Tabletop exercise

Correct Answer: A, B

A. Reporting
B. Prioritization

Reporting and Prioritization are core vulnerability management activities. Reporting communicates vulnerabilities to stakeholders, and prioritization determines which vulnerabilities to remediate first based on risk. Exploiting is a testing technique but not a vulnerability management activity itself. Correlation relates to threat intelligence analysis. Containment is an incident response activity. Tabletop exercises are risk assessment or disaster recovery planning activities, not vulnerability management.

Why The Other Options Are Incorrect

C. Exploiting is a penetration testing technique, not a vulnerability management activity.

D. Correlation is part of threat intelligence and log analysis, not vulnerability management.

E. Containment is an incident response activity, not vulnerability management.

F. Tabletop exercises are disaster recovery or incident response planning, not vulnerability management.

Daily Debian

Question #326

An administrator wants to perform a risk assessment without using proprietary company information.

Which of the following methods should the administrator use to gather information?

A. Network scanning
B. Penetration testing
C. Open-source intelligence
D. Configuration auditing

Correct Answer: C — Open-source intelligence

Open-source intelligence (OSINT) gathers information from publicly available sources without accessing proprietary company information or conducting intrusive testing. Network scanning and penetration testing both interact directly with systems and would require access to company infrastructure. Configuration auditing reviews internal company systems and configurations, which would involve proprietary information.

Why The Other Options Are Incorrect

A. Network scanning requires direct access to and interaction with company systems.

B. Penetration testing requires access to company systems and infrastructure.

D. Configuration auditing reviews internal company systems and proprietary configurations.

Question #327

A systems administrator is concerned about vulnerabilities within cloud computing instances.

Which of the following is most important for the administrator to consider when architecting a cloud computing environment?

A. SQL injection
B. TOC/TOU
C. VM escape
D. Tokenization
E. Password spraying

Correct Answer: C — VM escape

VM escape is the most critical vulnerability to consider when architecting a cloud environment because it allows an attacker to break out of a virtual machine and access the hypervisor or other VMs, compromising the entire cloud infrastructure. This is a cloud-specific threat unique to virtualized environments. While SQL injection, password spraying, and tokenization are important security concerns, they are not specific to cloud architecture decisions. TOC/TOU (Time-of-check/Time-of-use) is a race condition vulnerability but less relevant to cloud architecture planning.

Why The Other Options Are Incorrect

A. SQL injection is a web application vulnerability, not specific to cloud architecture decisions.

B. TOC/TOU is a timing vulnerability, not a primary cloud architecture concern.

D. Tokenization is a data protection technique, not an architectural vulnerability.

E. Password spraying is an attack method, not an architectural vulnerability unique to cloud.

Question #328

A database administrator is updating the company's SQL database, which stores credit card information for pending purchases.

Which of the following is the best method to secure the data against a potential breach?

A. Hashing
B. Obfuscation
C. Tokenization
D. Masking

Correct Answer: C — Tokenization

Tokenization is the best method for securing credit card information because it replaces sensitive card data with a unique token that has no exploitable value if breached. This is specifically designed for payment card data and meets PCI DSS requirements. While hashing is irreversible, it doesn't allow legitimate transactions to use the original card data. Obfuscation and masking provide obscurity but don't eliminate the risk of breach exposure.

Why The Other Options Are Incorrect

A. Hashing is one-way and doesn't allow legitimate use of the credit card data for transactions.

B. Obfuscation only obscures data and doesn't adequately protect against breaches.

D. Masking hides data visually but the underlying sensitive data remains vulnerable.

Question #329

Which of the following is a benefit of vendor diversity?

A. Patch availability
B. Zero-day resiliency
C. Secure configuration guide applicability
D. Load balancing

Correct Answer: B — Zero-day resiliency

Vendor diversity provides zero-day resiliency because if one vendor's product has an undiscovered vulnerability, the organization is not entirely dependent on that single vendor's security posture. By using multiple vendors, if one experiences a zero-day exploit, other vendors' products may not be affected, maintaining business continuity. Patch availability, secure configuration guide applicability, and load balancing are not inherent benefits of vendor diversity.

Why The Other Options Are Incorrect

A. Vendor diversity does not improve patch availability; it may complicate it.

C. Using multiple vendors actually makes it harder to apply a single secure configuration guide.

D. Load balancing is a technical capability, not a benefit of vendor diversity per se.

Question #330

An employee used a company's billing system to issue fraudulent checks. The administrator is looking for evidence of other occurrences of this activity.

Which of the following should the administrator examine?

A. Application logs
B. Vulnerability scanner logs
C. IDS/IPS logs
D. Firewall logs

Correct Answer: A — Application logs

Application logs are the best source to examine because the billing system's application logs will record transactions, account modifications, check issuances, and user actions within the system itself. This directly captures evidence of fraudulent check issuance activity. Vulnerability scanner logs, IDS/IPS logs, and firewall logs operate at network or infrastructure levels and would not capture application-level fraud activities like unauthorized check issuance.

Why The Other Options Are Incorrect

B. Vulnerability scanner logs report security weaknesses, not fraudulent transactions.
C. IDS/IPS logs monitor network intrusions, not application-level fraud.
D. Firewall logs track network traffic, not application-specific fraudulent activities.

Question #331

An organization is looking to optimize its environment and reduce the number of patches necessary for operating systems.

Which of the following will best help to achieve this objective?

A. Microservices
B. Virtualization
C. Real-time operating system
D. Containers

Correct Answer: D — Containers

Containers best optimize the environment and reduce patching overhead because containerized applications bundle their dependencies and run in isolated environments, reducing the attack surface and the number of underlying OS instances requiring patches. Containers require fewer patches than traditional VMs since multiple containers can share a single kernel. Microservices is an architecture pattern, virtualization still requires full OS patches on each VM, and real-time operating systems are specialized and don't reduce

patching requirements.

Why The Other Options Are Incorrect

A. Microservices is an application architecture pattern that doesn't directly reduce OS patching.

B. Virtualization still requires patching each guest OS instance.

C. Real-time operating systems don't reduce the number of patches needed.

Question #332

Which of the following tasks is typically included in the BIA process?

A. Estimating the recovery time of systems
B. Identifying the communication strategy
C. Evaluating the risk management plan
D. Establishing the backup and recovery procedures
E. Developing the incident response plan

Correct Answer: A — Estimating the recovery time of systems

Estimating the recovery time of systems is a core task in the BIA (Business Impact Analysis) process. BIA involves identifying critical systems and determining Recovery Time Objectives (RTO), which directly involves estimating how quickly systems need to be recovered. Identifying communication strategy, evaluating risk management plans, establishing backup procedures, and developing incident response plans are important but belong to other processes like DRP (Disaster Recovery Plan) or incident management, not the BIA itself.

Why The Other Options Are Incorrect

B. Communication strategy is developed in DRP or incident response planning, not BIA.

C. Evaluating risk management plans is a risk assessment task, not BIA.

D. Backup and recovery procedures are DRP tasks, not part of the BIA analysis.

E. Incident response planning is separate from the BIA process.

Question #333

Which of the following is a risk of conducting a vulnerability assessment?

A. A disruption of business operations
B. Unauthorized access to the system
C. Reports of false positives
D. Finding security gaps in the system

Correct Answer: A — A disruption of business operations

A disruption of business operations is a significant risk of conducting vulnerability assessments because active scanning and penetration testing can consume network resources, cause system instability, trigger security alerts, or inadvertently impact running services. Reports of false positives are an outcome, not a risk. Unauthorized access and security gaps found are not risks of the assessment itself—security gaps are the intended finding, and unauthorized access would be a risk if not properly controlled.

Why The Other Options Are Incorrect

B. Unauthorized access would be prevented by proper access controls during the assessment.

C. False positives are a result of assessment, not a risk of conducting it.

D. Finding security gaps is the intended purpose, not a risk of the assessment.

Question #334

Which of the following techniques would attract the attention of a malicious attacker in an insider threat scenario?

A. Creating a false text file in /docs/salaries
B. Setting weak passwords in /etc/shadow
C. Scheduling vulnerable jobs in /etc/crontab
D. Adding a fake account to /etc/passwd

Correct Answer: A — Creating a false text file in /docs/salaries

Creating a false text file in /docs/salaries would attract a malicious attacker's attention in an insider threat scenario because it appears to contain sensitive salary information, which is a high-value target for insider threats seeking to exfiltrate or manipulate financial data. This honey pot-like approach would trigger attacker interest. Weak passwords in /etc/shadow, vulnerable jobs in /etc/crontab, and fake accounts in /etc/passwd are system-level configurations that sophisticated attackers might exploit but wouldn't necessarily 'attract attention' in an insider threat scenario.

Why The Other Options Are Incorrect

B. Weak passwords are a vulnerability to exploit but don't attract attention as bait.

C. Vulnerable cron jobs are exploitation targets but not attention-attracting decoys.

D. Fake accounts might be detected but don't naturally attract insider threat attention like sensitive data.

Question #335

An organization maintains intellectual property that it wants to protect.

Which of the following concepts would be most beneficial to add to the company's security awareness training program?

A. Insider threat detection
B. Simulated threats
C. Phishing awareness
D. Business continuity planning

Correct Answer: A — Insider threat detection

Insider threat detection is the most relevant concept for protecting intellectual property because insiders with legitimate access pose a significant risk to proprietary information. While phishing awareness and business continuity are valuable, they don't directly address the specific threat to IP from employees or trusted personnel. Simulated threats are training tools, not a program concept.

Why The Other Options Are Incorrect

B. Simulated threats are a training delivery method, not a core concept for protecting IP.
C. Phishing awareness protects against external email threats, not insider IP theft.
D. Business continuity planning focuses on operational resilience, not IP protection.

Question #336

An organization plans to expand its operations internationally and needs to keep data at the new location secure. The organization wants to use the most secure architecture model possible.

Which of the following models offers the highest level of security?

A. Cloud-based
B. Peer-to-peer
C. On-premises
D. Hybrid

Correct Answer: C — On-premises

On-premises architecture offers the highest level of security for sensitive intellectual property because the organization maintains complete physical and logical control over data, infrastructure, and access controls. Cloud-based and hybrid models introduce third-party dependencies and shared infrastructure risks. Peer-to-peer architecture lacks centralized security controls.

Why The Other Options Are Incorrect

A. Cloud-based models involve third-party infrastructure and shared resources, reducing direct control.

B. Peer-to-peer architecture lacks centralized security management and control.

D. Hybrid models combine on-premises and cloud, introducing complexity and shared infrastructure risks.

Question #337

Which of the following is the most relevant reason a DPO would develop a data inventory?

A. To manage data storage requirements better
B. To determine the impact in the event of a breach
C. To extend the length of time data can be retained
D. To automate the reduction of duplicated data

Correct Answer: B — To determine the impact in the event of a breach

A DPO develops a data inventory primarily to understand what data the organization holds and where it resides, which is essential for determining the potential impact and scope if a breach occurs. This assessment is critical for GDPR compliance and risk management. The other options relate to storage optimization, retention manipulation, or system administration rather than regulatory compliance.

Why The Other Options Are Incorrect

A. Storage management is an IT operations concern, not a primary DPO responsibility.

C. Data retention periods are legally defined; a DPO doesn't extend them through inventories.

D. Data deduplication is a technical optimization task, not a regulatory compliance function.

Question #338

Which of the following cryptographic solutions protects data at rest?

A. Digital signatures
B. Full disk encryption
C. Private key
D. Steganography

Correct Answer: B — Full disk encryption

Full disk encryption directly protects data at rest by encrypting all data stored on physical drives, making it unreadable without the correct decryption key. Digital signatures provide integrity verification, private keys are cryptographic components, and steganography hides data rather than encrypting it. Only full disk encryption is specifically designed to protect

stored data.

Why The Other Options Are Incorrect

A. Digital signatures verify data integrity and authenticity, not protect data at rest.

C. A private key is a cryptographic component, not a data protection mechanism on its own.

D. Steganography conceals data but doesn't encrypt it, so it doesn't protect against unauthorized access.

Question #339

Which of the following should an organization use to protect its environment from external attacks conducted by an unauthorized hacker?

A. ACL
B. IDS
C. HIDS
D. NIPS

Correct Answer: D — NIPS

NIPS (Network Intrusion Prevention System) is specifically designed to prevent external attacks by actively blocking malicious traffic at the network level in real-time. While IDS detects intrusions and ACLs filter traffic, NIPS combines detection with active prevention. HIDS operates at the host level and is better for internal threats.

Why The Other Options Are Incorrect

A. ACLs filter traffic based on rules but don't actively prevent intrusions.

B. IDS detects intrusions but doesn't prevent them; it only alerts administrators.

C. HIDS monitors individual hosts and is better suited for detecting internal threats.

Question #340

Which of the following would enable a data center to remain operational through a multiday power outage?

A. Generator
B. Uninterruptible power supply
C. Replication
D. Parallel processing

Correct Answer: A — Generator

A generator is the only solution that can sustain operations through a multiday power outage by providing continuous electrical power generation. An UPS provides only temporary backup (minutes to hours), replication is data redundancy, and parallel processing is a computing methodology. Generators are the standard solution for extended power failures.

Why The Other Options Are Incorrect

B. UPS only provides temporary backup power for minutes to hours, insufficient for multiday outages.

C. Replication copies data but doesn't provide power to keep systems running.

D. Parallel processing improves computation efficiency but doesn't address power supply issues.

Question #341

A company installed cameras and added signs to alert visitors that they are being recorded.

Which of the following controls did the company implement? (Choose two.)

A. Directive
B. Deterrent
C. Preventive
D. Detective
E. Corrective
F. Technical

Daily Debian

Correct Answer: B, D

B. Deterrent
D. Detective

Cameras and warning signs implement both detective and deterrent controls. Cameras are detective controls because they record evidence of incidents. Warning signs are deterrent controls because they discourage unauthorized behavior by making people aware they are being monitored. Neither is preventive (blocking access), directive (policies), corrective (fixing incidents), nor technical (technology-based mechanisms).

Why The Other Options Are Incorrect

A. Directive controls establish policies; signage communicates but doesn't establish policy.

C. Preventive controls block unwanted actions; cameras and signs don't prevent access.

E. Corrective controls fix incidents after they occur; these controls monitor and deter instead.

F. Technical controls are technology mechanisms; signs are administrative, cameras are partially technical but classified here as detective.

Question #342

Which of the following is the best way to securely store an encryption key for a data set in a manner that allows multiple entities to access the key when needed?

A. Public key infrastructure
B. Open public ledger
C. Public key encryption
D. Key escrow

Correct Answer: D — Key escrow

Key escrow is the standard solution for securely storing encryption keys with a third party while allowing authorized multiple entities to access them when needed. It enables secure key recovery and management at scale. PKI manages digital certificates, public key encryption requires the recipient's public key, and open ledgers are insecure for sensitive keys.

Why The Other Options Are Incorrect

A. PKI manages certificates and public/private key pairs, not key storage and escrow.

B. Public ledgers are transparent and unsuitable for protecting sensitive encryption keys.

C. Public key encryption encrypts data but doesn't address secure key storage and escrow.

Question #343

For which of the following reasons would a systems administrator leverage a 3DES hash from an installer file that is posted on a vendor’s website?

A. To test the integrity of the file
B. To validate the authenticity of the file
C. To activate the license for the file
D. To calculate the checksum of the file

Correct Answer: A — To test the integrity of the file

A hash posted next to a downloadable installer exists so the administrator can generate a digest of the downloaded file locally and compare it with the vendor's published value. A match proves the file was not corrupted during transfer or tampered with, which is a test of

the file's integrity.

Why The Other Options Are Incorrect

B. Authenticity—proof that the vendor really produced the file—requires a digital signature or certificate, since anyone who alters a file can also alter a posted hash.

C. Hashes have nothing to do with software licensing or product activation keys.

D. Calculating the checksum is merely the mechanical step performed; the purpose behind performing it is to verify integrity.

Question #344

A company is redesigning its infrastructure and wants to reduce the number of physical servers in use.

Which of the following architectures is best suited for this goal?

A. Isolation
B. Segmentation
C. Virtualization
D. Redundancy

Correct Answer: C — Virtualization

Virtualization allows multiple virtual servers to run on fewer physical servers, directly reducing the number of physical machines needed while maintaining the same or greater computing capacity. This is the primary architectural approach for consolidating infrastructure.

Why The Other Options Are Incorrect

A. Isolation refers to security compartmentalization, not infrastructure reduction.

B. Segmentation divides networks or systems for security purposes, not for reducing physical servers.

D. Redundancy adds duplicate systems for fault tolerance, which would typically increase rather than decrease server count.

Question #345

Which of the following security concepts is being followed when implementing a product that offers protection against DDoS attacks?

A. Availability
B. Non-repudiation
C. Integrity
D. Confidentiality

Correct Answer: A — Availability

DDoS (Distributed Denial of Service) attacks target system availability by overwhelming resources. Protection against DDoS attacks directly addresses the availability principle of the CIA triad, ensuring systems remain accessible to legitimate users.

Why The Other Options Are Incorrect

B. Non-repudiation concerns proving who performed an action; DDoS protection does not address this.

C. Integrity protects data from unauthorized modification; DDoS attacks target availability, not data integrity.

D. Confidentiality protects data from unauthorized disclosure; DDoS attacks do not primarily target confidentiality.

Question #346

A security manager created new documentation to use in response to various types of security incidents.

Which of the following is the next step the manager should take?

A. Set the maximum data retention policy.
B. Securely store the documents on an air-gapped network.
C. Review the documents' data classification policy.
D. Conduct a tabletop exercise with the team.

Correct Answer: D — Conduct a tabletop exercise with the team.

After creating incident response documentation, the next logical step is to test it through a tabletop exercise. This validates that the procedures are realistic, feasible, and understood by the team before a real incident occurs. Testing ensures the documentation is effective and identifies gaps.

Why The Other Options Are Incorrect

A. Data retention policy is important but is not the immediate next step after creating incident documentation.

B. Air-gapping is a storage security measure but is not the primary next step in validating incident response procedures.

C. Data classification review should have been completed before or during documentation creation, not after.

Question #347

After failing an audit twice, an organization has been ordered by a government regulatory agency to pay fines.

Which of the following causes this action?

A. Non-compliance
B. Contract violations
C. Government sanctions
D. Rules of engagement

Correct Answer: A — Non-compliance

When an organization fails audits and is ordered to pay fines by a regulatory agency, this directly results from non-compliance—the failure to meet required standards or regulations. Non-compliance is the root cause triggering regulatory action and penalties.

Why The Other Options Are Incorrect

B. Contract violations are specific breaches between parties; regulatory fines stem from violating regulations, not general contracts.

C. Government sanctions are broader punitive measures; regulatory fines are specifically triggered by non-compliance with regulations.

D. Rules of engagement relate to authorized interactions or operational parameters, not regulatory compliance violations.

Daily Debian

Question #348

A company is developing a critical system for the government and storing project information on a fileshare.

Which of the following describes how this data will most likely be classified? (Choose two.)

A. Private
B. Confidential
C. Public
D. Operational
E. Urgent
F. Restricted

Correct Answer: B, F

B. Confidential
F. Restricted

Government project information requiring development for a critical system would be classified as both Confidential (restricted from unauthorized disclosure) and Restricted (highest security level for sensitive government data). These two levels reflect the sensitive nature of government contract development work.

Why The Other Options Are Incorrect

A. Private refers to personal data, not government project information.

C. Public classification is inappropriate for sensitive government project data.

D. Operational is a functional category, not a standard data classification level.

E. Urgent describes priority or timeliness, not a data classification level.

Question #349

Which of the following activities is included in the post-incident review phase?

A. Determining the root cause of the incident
B. Developing steps to mitigate the risks of the incident
C. Validating the accuracy of the evidence collected during the investigation
D. Reestablishing the compromised system's configuration and settings

Correct Answer: A — Determining the root cause of the incident

The post-incident review phase focuses on analysis and lessons learned, with determining the root cause being a primary activity. Root cause analysis helps prevent similar incidents and improves security posture for the future.

Why The Other Options Are Incorrect

B. Developing mitigation steps occurs during response and recovery phases, not post-incident review.

C. Validating evidence accuracy is part of the investigation phase, not post-incident review.

D. Reestablishing system configuration occurs during the recovery phase, not post-incident review.

Question #350

Which of the following attacks exploits a potential vulnerability as a result of using weak cryptographic algorithms?

A. Password cracking
B. On-path
C. Digital signing
D. Side-channel

Correct Answer: A — Password cracking

Password cracking directly exploits weak cryptographic algorithms by using computational power to break inadequate encryption or hashing methods. Weak algorithms like DES or MD5 are vulnerable to brute force or collision attacks, making password cracking a classic example.

Why The Other Options Are Incorrect

B. On-path attacks intercept communications but are not specifically about exploiting weak cryptographic algorithms.

C. Digital signing is a security mechanism, not an attack that exploits weak cryptography.

D. Side-channel attacks exploit implementation details or physical properties, not the cryptographic algorithm strength itself.

Question #351

Which of the following is a preventive physical security control?

A. Video surveillance system
B. Bollards
C. Alarm system
D. Motion sensors

Correct Answer: B — Bollards

Bollards are physical barriers that prevent unauthorized vehicle access to secured areas. They are preventive controls because they actively stop threats before they occur. Video surveillance, alarm systems, and motion sensors are all detective controls that identify threats after they happen, not prevent them.

Why The Other Options Are Incorrect

A. Video surveillance detects incidents after they occur; it does not prevent access.

C. Alarm systems detect and alert to unauthorized activity but do not prevent it.

D. Motion sensors detect movement but do not physically prevent unauthorized access.

Question #352

Which of the following is most likely to be used as a just-in-time reference document within a security operations center?

A. Change management policy
B. Risk profile

C. Playbook
D. SIEM profile

Correct Answer: C — Playbook

A playbook is a documented procedure that provides step-by-step instructions for responding to specific security incidents. It serves as a just-in-time reference during active incident response in the SOC. Change management policies, risk profiles, and SIEM profiles are strategic or configuration documents, not tactical response guides used in real-time during incidents.

Why The Other Options Are Incorrect

A. Change management policy is a governance document, not a tactical reference for incident response.

B. Risk profile is a strategic assessment document, not used for immediate incident response.

D. SIEM profile is a configuration detail, not a just-in-time reference for SOC operations.

Question #353

A security engineer configured a remote access VPN. The remote access VPN allows end users to connect to the network by using an agent that is installed on the endpoint, which establishes an encrypted tunnel.

Which of the following protocols did the engineer most likely implement?

A. GRE
B. IPSec
C. SD-WAN
D. EAP

Correct Answer: B — IPSec

IPSec is the protocol most commonly used for remote access VPNs that require an agent installed on endpoints to establish encrypted tunnels. IPSec operates at the network layer and provides both authentication and encryption. GRE is a tunneling protocol but doesn't provide encryption; SD-WAN is a network architecture, not a VPN protocol; EAP is an authentication framework, not a tunneling protocol.

Why The Other Options Are Incorrect

A. GRE is a tunneling protocol that does not provide encryption on its own.

C. SD-WAN is a network architecture approach, not a VPN protocol.

D. EAP is an authentication protocol, not a VPN tunneling protocol.

Question #354

Executives at a company are concerned about employees accessing systems and information about sensitive company projects unrelated to the employees' normal job duties.

Which of the following enterprise security capabilities will the security team most likely deploy to detect that activity?

A. UBA
B. EDR
C. NAC
D. DLP

Correct Answer: A — UBA

User Behavior Analytics (UBA) detects anomalous user activities by establishing baselines of normal behavior and identifying deviations, such as accessing systems or information unrelated to job duties. This is specifically designed to detect insider threats and unusual access patterns. EDR focuses on endpoint threats; NAC controls network access; DLP prevents data exfiltration but doesn't detect access anomalies.

Why The Other Options Are Incorrect

B. EDR detects endpoint-based threats and malware, not unusual access to unrelated systems.

C. NAC controls which devices connect to the network, not user access behaviors.

D. DLP prevents unauthorized data movement but does not detect unusual access patterns.

Question #355

Several customers want an organization to verify its security controls are operating effectively and have requested an independent opinion.

Which of the following is the most efficient way to address these requests?

A. Hire a vendor to perform a penetration test
B. Perform an annual self-assessment.
C. Allow each client the right to audit
D. Provide a third-party attestation report

Correct Answer: D — Provide a third-party attestation report

A third-party attestation report (such as SOC 2 Type II) provides an independent, credible verification of security controls that satisfies multiple customers' audit requirements simultaneously. This is the most efficient approach as it addresses all customer concerns

with a single engagement rather than individual audits or assessments. Penetration tests validate penetration resilience, not control effectiveness; self-assessments lack independence; individual client audits are inefficient.

Why The Other Options Are Incorrect

A. Penetration tests verify security against attacks, not the effectiveness of existing controls.

B. Self-assessments lack the independent credibility that customers specifically requested.

C. Allowing each client individual audit rights is inefficient and creates significant overhead.

Question #356

A university employee logged on to the academic server and attempted to guess the system administrators' log-in credentials.

Which of the following security measures should the university have implemented to detect the employee's attempts to gain access to the administrators' accounts?

A. Two-factor authentication
B. Firewall
C. Intrusion prevention system
D. User activity logs

Daily Debian

Correct Answer: D — User activity logs

User activity logs record login attempts, including failed authentication attempts against administrator accounts. These logs can be reviewed to detect and investigate suspicious credential guessing activities. Two-factor authentication prevents unauthorized access but wouldn't detect the attempts; a firewall doesn't monitor application-level authentication; an IPS prevents network attacks but wouldn't specifically detect credential guessing.

Why The Other Options Are Incorrect

A. Two-factor authentication prevents unauthorized login but does not detect guessing attempts.

B. A firewall operates at network layer and does not monitor application authentication attempts.

C. An IPS prevents network-based attacks but does not detect credential guessing at the application level.

Question #357

Which of the following consequences would a retail chain most likely face from customers in the event the retailer is non-compliant with PCI DSS?

A. Contractual impacts
B. Sanctions
C. Fines
D. Reputational damage

Correct Answer: D — Reputational damage

Non-compliance with PCI DSS most directly results in reputational damage as customers lose confidence in the retailer's ability to protect their payment card data securely. While a retailer may also face contractual impacts, fines, and sanctions, reputational damage is the most likely and immediate consequence customers would directly experience, affecting their willingness to shop there.

Why The Other Options Are Incorrect

A. Contractual impacts are between the retailer and payment processors, not primarily customer-facing.

B. Sanctions are regulatory actions that may not occur unless breaches happen.

C. Fines are penalties from regulators, not direct customer consequences.

Question #358

A security analyst is reviewing logs and discovers the following:

```
149.32.228.10 - - [28/Jan/2023:16:32:45 -0300] "GET / HTTP/1.0"
User-Agent: ${/bin/sh/ id} 200 397
```

Which of the following should be used to best mitigate this type of attack?

A. Input sanitization
B. Secure cookies
C. Static code analysis
D. Sandboxing

Correct Answer: A — Input sanitization

The log shows a GET request with a User-Agent containing `${/bin/sh/ id}`, which is a command injection attempt. The attacker is trying to execute shell commands through unsanitized input. Input sanitization is the best mitigation as it validates and filters user-supplied input to remove or neutralize malicious content before it's processed by the application. This directly prevents command injection attacks by ensuring that special

characters and command syntax cannot be executed.

Why The Other Options Are Incorrect

B. Secure cookies protect session data in transit/storage but do not prevent command injection through HTTP headers.

C. Static code analysis helps identify vulnerabilities in source code but doesn't prevent attacks at runtime against already-deployed applications.

D. Sandboxing restricts application privileges but doesn't prevent the injection attempt itself from being processed.

Question #359

An administrator is installing an SSL certificate on a new system. During testing, errors indicate that the certificate is not trusted. The administrator has verified with the issuing CA and has validated the private key.

Which of the following should the administrator check for next?

A. If the wildcard certificate is configured
B. If the certificate signing request is valid
C. If the root certificate is installed
D. If the public key is configured

✅ Correct Answer: C — If the root certificate is installed

When an SSL certificate is not trusted despite valid issuance, private key, and CSR, the root certificate of the issuing CA must be installed on the system. The root certificate establishes the chain of trust that clients use to verify the SSL certificate's legitimacy. Without the root certificate in the trust store, clients cannot validate the certificate chain. Wildcard configuration affects domain matching, not trust; CSR validity was already verified; public key configuration is handled automatically.

Why The Other Options Are Incorrect

A. Wildcard certificate configuration affects which domains are covered, not whether the certificate is trusted.

B. The CSR validity has already been verified by the CA issuance process.

D. The public key is embedded in the certificate and configured automatically upon installation.

Question #360

An employee emailed a new systems administrator a malicious web link and convinced the administrator to change the email server’s password.

The employee used this access to remove the mailboxes of key personnel.

Which of the following security awareness concepts would help prevent this threat in the future?

A. Recognizing phishing
B. Providing situational awareness training
C. Using password management
D. Reviewing email policies

Correct Answer: A — Recognizing phishing

The threat involved a malicious web link sent via email that deceived the administrator into performing unauthorized actions. Recognizing phishing attacks—which use social engineering through deceptive emails to trick users into compromising security—is the most direct security awareness concept that would prevent this specific threat. The administrator would have been trained to identify suspicious links and requests rather than act on them.

Why The Other Options Are Incorrect

B. Situational awareness training is helpful but doesn't specifically address the deceptive email tactic used here.

C. Password management tools don't prevent someone from voluntarily changing credentials when socially engineered.

D. Email policies alone cannot stop a determined attacker who has already deceived the administrator into compliance.

Question #361

Which of the following strategies should an organization use to efficiently manage and analyze multiple types of logs?

A. Deploy a SIEM solution
B. Create custom scripts to aggregate and analyze logs.
C. Implement EDR technology.
D. Install a unified threat management appliance.

Correct Answer: A — Deploy a SIEM solution

A SIEM (Security Information and Event Management) solution is specifically designed to efficiently collect, aggregate, normalize, and analyze multiple types of logs from diverse sources across an organization. This is its primary purpose and the industry-standard approach for managing complex log environments at scale.

Why The Other Options Are Incorrect

B. Custom scripts are labor-intensive, difficult to maintain, and lack the advanced

correlation and analysis capabilities of a SIEM.

C. EDR (Endpoint Detection and Response) focuses on endpoint security, not the broader log management and analysis function.

D. A unified threat management appliance provides multiple security functions but is not the optimal solution for efficient log management and analysis across multiple types.

Question #362

A new security regulation was announced that will take effect in the coming year. A company must comply with it to remain in business.

Which of the following activities should the company perform next?

A. Gap analysis
B. Policy review
C. Security procedure evaluation
D. Threat scope reduction

Correct Answer: A — Gap analysis

When facing a new regulatory requirement, the logical first step is to perform a gap analysis. This identifies the difference between the organization's current state (existing controls, policies, and procedures) and the required state mandated by the new regulation. This assessment determines what changes are needed before policy reviews or procedure evaluations can be meaningfully planned.

Why The Other Options Are Incorrect

B. Policy review should follow the gap analysis to understand what needs to be addressed.

C. Security procedure evaluation comes after identifying the gaps, not before.

D. Threat scope reduction is not a compliance activity and doesn't address regulatory requirements.

Question #363

An accountant is transferring information to a bank over FTP.

Which of the following mitigations should the accountant use to protect the confidentiality of the data?

A. Tokenization
B. Data masking
C. Encryption
D. Obfuscation

Correct Answer: C — Encryption

Encryption is the primary mitigation for protecting the confidentiality of data while it is being transmitted over an insecure protocol like FTP. FTP transmits data in cleartext, so encryption (such as using SFTP or FTPS) is necessary to ensure that sensitive financial information cannot be intercepted and read by attackers.

Why The Other Options Are Incorrect

A. Tokenization replaces sensitive data with tokens and is better suited for data at rest, not transmission security.

B. Data masking obscures data for display purposes but does not protect it during transmission.

D. Obfuscation is a weak security measure that does not provide the level of protection needed for confidential data in transit.

Question #364

An organization has recently decided to implement SSO. The requirements are to leverage access tokens and focus on application authorization rather than user authentication.

Which of the following solutions would the engineering team most likely configure?

A. LDAP
B. Federation
C. SAML
D. OAuth

Correct Answer: D — OAuth

OAuth is specifically designed for access token-based authorization and focuses on delegated authorization rather than authentication. It allows applications to request authorization without handling user credentials directly, making it the ideal choice for an SSO implementation that prioritizes application authorization over user authentication using access tokens.

Why The Other Options Are Incorrect

A. LDAP is primarily used for directory services and authentication, not token-based authorization.

B. Federation enables SSO but doesn't specifically emphasize access tokens and application authorization as its primary focus.

C. SAML is primarily an authentication protocol used for asserting user identity, not token-based application authorization.

Question #365

Which of the following would most likely be used by attackers to perform credential harvesting?

A. Social engineering
B. Supply chain compromise
C. Third-party software
D. Rainbow table

Correct Answer: A — Social engineering

Social engineering is the most common and effective method for credential harvesting. Attackers use social engineering tactics—such as phishing emails, pretexting, or manipulation—to trick users into voluntarily divulging their credentials. This human-focused approach is more reliable than technical attacks for obtaining valid login credentials.

Why The Other Options Are Incorrect

B. Supply chain compromise targets systems and software, not typically used for direct credential harvesting.

C. Third-party software compromise may enable attacks but is not the primary method for credential harvesting.

D. Rainbow tables are used to crack hashed passwords offline, not to perform active credential harvesting from users.

Daily Debian

Question #366

A security engineer would like to enhance the use of automation and orchestration within the SIEM.

Which of the following would be the primary benefit of this enhancement?

A. It increases complexity.
B. It removes technical debt.
C. It adds additional guard rails.
D. It acts as a workforce multiplier.

Correct Answer: D — It acts as a workforce multiplier.

Automation and orchestration in a SIEM act as a workforce multiplier by enabling the security team to accomplish more with the same number of personnel. Automated responses to alerts and orchestrated workflows reduce manual work, allowing analysts to focus on more complex investigations and enabling the team to handle higher volumes of security events efficiently.

Why The Other Options Are Incorrect

A. Automation and orchestration reduce complexity, not increase it.

B. Technical debt removal is not the primary benefit of SIEM automation.

C. While guardrails may be part of automation, this is not the primary benefit of the enhancement.

Question #367

A systems administrator receives an alert that a company's internal file server is very slow and is only working intermittently. The systems administrator reviews the server management software and finds the following information about the server:

ServerName	#Connections	CPU%	MEM%	Read/s	Writes/s
FileSev01	12	99.6%	97%	50KB/s	100KB/s

Which of the following indicators most likely triggered this alert?

A. Concurrent session usage
B. Network saturation
C. Account lockout
D. Resource consumption

Correct Answer: D — Resource consumption

The server metrics show critical resource consumption issues: CPU at 99.6% (essentially maxed out) and Memory at 97% (critically high). These extremely high utilization rates directly cause the slow performance and intermittent operation described in the alert. When CPU and memory are nearly exhausted, the server cannot process requests efficiently, leading to sluggish performance and potential service interruptions. This is a classic case of resource exhaustion causing system degradation.

Why The Other Options Are Incorrect

A. While 12 connections exist, this is a normal and low number of concurrent sessions that would not cause the described performance issues.

B. Network saturation would be indicated by high Read/s and Writes/s metrics; the 50KB/s read and 100KB/s write rates show normal network activity, not saturation.

C. Account lockout is a security/authentication issue unrelated to slow performance and intermittent operation, and would not appear in server resource metrics.

Question #368

Which of the following data states applies to data that is being actively processed by a database server?

A. In use
B. At rest
C. In transit
D. Being hashed

✅ Correct Answer: A — In use

Data in use refers to data that is actively being processed, accessed, or manipulated by applications or systems—such as data being actively processed by a database server. This is one of the three main states of data security, alongside data at rest and data in transit.

Why The Other Options Are Incorrect

B. Data at rest refers to stored data, not data being actively processed.

C. Data in transit refers to data being transmitted across networks, not data being processed by a server.

D. Being hashed is a processing operation but does not represent a distinct data state classification.

Question #369

Which of the following architectures is most suitable to provide redundancy for critical business processes?

A. Network-enabled
B. Server-side
C. Cloud-native
D. Multitenant

✅ Correct Answer: C — Cloud-native

Cloud-native architectures are specifically designed to provide redundancy and high availability for critical business processes through distributed systems, auto-scaling, and built-in failover mechanisms. They enable services to remain operational even when individual components fail.

Why The Other Options Are Incorrect

A. Network-enabled describes connectivity capability, not redundancy architecture.

B. Server-side refers to processing location, not a redundancy strategy.

D. Multitenant describes resource sharing among multiple customers, not redundancy design.

Question #370

After a security incident, a systems administrator asks the company to buy a NAC platform.

Which of the following attack surfaces is the systems administrator trying to protect?

A. Bluetooth
B. Wired
C. NFC
D. SCADA

Correct Answer: B — Wired

Network Access Control (NAC) platforms protect the wired network attack surface by controlling which devices can connect to the network, verifying device compliance before allowing access, and preventing unauthorized or compromised devices from connecting to wired infrastructure.

Why The Other Options Are Incorrect

A. Bluetooth protection uses different technologies like pairing mechanisms and signal strength controls, not NAC.

C. NFC is protected through proximity-based security and encryption, not NAC platforms.

D. SCADA requires specialized industrial control security, not standard NAC solutions.

Daily Debian

Question #371

While reviewing logs, a security administrator identifies the following code:

```
<script>function (send_info)</script>
```

Which of the following best describes the vulnerability being exploited?

A. XSS
B. SQLi
C. DDoS
D. CSRF

Correct Answer: A — XSS

The code `<script>function (send_info)</script>` is a classic example of XSS (Cross-Site Scripting) vulnerability. This represents injected JavaScript code that would execute in a

user's browser. XSS vulnerabilities occur when untrusted user input is embedded directly into web pages without proper sanitization or encoding, allowing attackers to inject malicious scripts that execute in the context of the victim's browser session. The presence of raw `<script>` tags in the code demonstrates the injection of executable client-side code.

Why The Other Options Are Incorrect

B. SQL injection (SQLi) involves injecting SQL commands into database queries, not executing JavaScript code in a browser.

C. DDoS (Distributed Denial of Service) is a network-level attack to overwhelm resources, not a code-based vulnerability shown in this example.

D. CSRF (Cross-Site Request Forgery) involves forging requests on behalf of authenticated users, not injecting executable scripts like this code demonstrates.

Question #372

An organization issued new laptops to all employees and wants to provide web filtering both in and out of the office without configuring additional access to the network.

Which of the following types of web filtering should a systems administrator configure?

A. Agent-based
B. Centralized proxy
C. URL scanning
D. Content categorization

Correct Answer: A — Agent-based

Agent-based web filtering installs software on each device to enforce filtering policies regardless of network location. This allows employees to have consistent filtering both in and out of the office without requiring them to connect through corporate network infrastructure.

Why The Other Options Are Incorrect

B. Centralized proxy requires traffic to be routed through the proxy, which is problematic for remote users outside the office.

C. URL scanning is a filtering technique, not a deployment method.

D. Content categorization is a filtering capability, not a deployment architecture.

Question #373

Which of the following should be used to aggregate log data in order to create alerts and detect anomalous activity?

A. SIEM
B. WAF
C. Network taps
D. IDS

Correct Answer: A — SIEM

SIEM (Security Information and Event Management) is specifically designed to aggregate log data from multiple sources, correlate events, create alerts based on patterns, and detect anomalous activity across the enterprise.

Why The Other Options Are Incorrect

B. WAF protects web applications but does not aggregate logs or detect anomalies.

C. Network taps capture traffic but do not aggregate or analyze logs.

D. IDS detects intrusions but does not aggregate logs from multiple sources like SIEM does.

Question #374

Which of the following provides the best protection against unwanted or insecure communications to and from a device?

A. System hardening
B. Host-based firewall
C. Intrusion detection system
D. Anti-malware software

Correct Answer: B — Host-based firewall

A host-based firewall provides the best protection against unwanted or insecure communications by controlling inbound and outbound traffic at the device level, filtering connections based on rules, and preventing unauthorized communication attempts.

Why The Other Options Are Incorrect

A. System hardening reduces vulnerabilities but does not control communications.

C. Intrusion detection detects attacks but does not prevent communications.

D. Anti-malware protects against malicious software but does not filter communications.

Question #375

Which of the following is the primary purpose of a service that tracks log-ins and time spent using the service?

A. Availability
B. Accounting
C. Authentication
D. Authorization

Correct Answer: B — Accounting

Accounting in the AAA model tracks user activities including logins, logout times, and duration of service usage. This creates audit trails and records of resource consumption for billing, compliance, and monitoring purposes.

Why The Other Options Are Incorrect

A. Availability ensures services are accessible, not tracking usage.

C. Authentication verifies identity, not tracks time spent.

D. Authorization determines permissions, not tracks usage patterns.

Question #376

An employee who was working remotely lost a mobile device containing company data.

Which of the following provides the best solution to prevent future data loss?

A. MDM
B. DLP
C. FDE
D. EDR

Correct Answer: A — MDM

Mobile Device Management (MDM) provides comprehensive control over mobile devices including remote wipe capabilities, enforcing encryption, managing app installations, and controlling data access. This prevents future data loss by enabling device tracking, remote lock, and secure data deletion.

Why The Other Options Are Incorrect

B. DLP focuses on data in transit and at rest but lacks the device control and remote wipe capabilities of MDM.

C. FDE protects data on lost devices but cannot remotely wipe or locate devices like MDM can.

D. EDR focuses on endpoint detection and response for threats, not device management or remote wipe.

Question #377

An IT administrator needs to ensure data retention standards are implemented on an enterprise application.

Which of the following describes the administrator's role?

A. Processor
B. Custodian
C. Privacy officer
D. Owner

Correct Answer: B — Custodian

A custodian is the IT role responsible for implementing and maintaining data retention and protection standards. Custodians handle day-to-day management of data, implement policies set by owners, and ensure compliance with retention requirements.

Why The Other Options Are Incorrect

A. Processor is a legal data handling role, typically external to the organization.

C. Privacy officer is a leadership role overseeing privacy strategy, not day-to-day implementation.

D. Owner is the business role responsible for defining retention policies, not implementing them.

Daily Debian

Question #378

A company plans to secure its systems by:

- Preventing users from sending sensitive data over corporate email
- Restricting access to potentially harmful websites

Which of the following features should the company set up? (Choose two.)

A. DLP software
B. DNS filtering
C. File integrity monitoring
D. Stateful firewall
E. Guardrails
F. Antivirus signatures

Correct Answer: A, B

A. DLP software
B. DNS filtering

DLP (Data Loss Prevention) software prevents users from sending sensitive data over

corporate email by monitoring and blocking unauthorized data transfers. DNS filtering restricts access to potentially harmful websites by blocking malicious domains at the DNS level. These two features directly address both security requirements mentioned in the scenario.

Why The Other Options Are Incorrect

C. File integrity monitoring detects unauthorized changes to files but doesn't prevent data transmission or block websites.

D. A stateful firewall manages network connections but doesn't specifically prevent email data loss or filter websites.

E. Guardrails are policy guidelines, not technical controls that enforce the stated requirements.

F. Antivirus signatures protect against malware but don't prevent email data loss or web filtering.

Question #379

A company processes and stores sensitive data on its own systems.

Which of the following steps should the company take first to ensure compliance with privacy regulations?

A. Implement access controls and encryption.
B. Develop and provide training on data protection policies.
C. Create incident response and disaster recovery plans.
D. Purchase and install security software.

Correct Answer: A — Implement access controls and encryption.

Before implementing any privacy compliance measures, an organization must establish the foundational security controls of access controls and encryption to protect sensitive data. These are the prerequisites that enable compliance with privacy regulations; without proper data protection mechanisms in place, compliance efforts are ineffective. Training, incident response, and software are important but secondary to establishing the core technical safeguards.

Why The Other Options Are Incorrect

B. Training is important but comes after establishing the technical controls that protect data.

C. Incident response and disaster recovery plans are part of comprehensive compliance but not the first step.

D. Security software is a tool to implement controls, not the first foundational step.

Question #380

Which of the following cryptographic methods is preferred for securing communications with limited computing resources?

A. Hashing algorithm
B. Public key infrastructure
C. Symmetric encryption
D. Elliptic curve cryptography

✅ Correct Answer: C — Symmetric encryption

Symmetric encryption is the preferred cryptographic method for systems with limited computing resources because it uses a single shared key and requires significantly less computational power compared to public key cryptography. It provides strong security with minimal overhead, making it ideal for devices with constrained processing capabilities.

Why The Other Options Are Incorrect

A. Hashing algorithms are not encryption methods and don't secure communications by themselves.

B. Public key infrastructure requires substantial computational resources, making it unsuitable for limited computing environments.

D. While elliptic curve cryptography is more efficient than RSA, symmetric encryption remains the preferred choice for severely resource-constrained systems.

Daily Debian

Question #381

A network administrator wants to ensure that network traffic is highly secure while in transit.

Which of the following actions best describes the actions the network administrator should take?

A. Ensure that NAC is enforced on all network segments, and confirm that firewalls have updated policies to block unauthorized traffic.
B. Ensure only TLS and other encrypted protocols are selected for use on the network, and only permit authorized traffic via secure protocols.
C. Configure the perimeter IPS to block inbound HTTPS directory traversal traffic, and verify that signatures are updated on a daily basis.
D. Ensure the EDR software monitors for unauthorized applications that could be used by threat actors, and configure alerts for the security team.

✅ Correct Answer: B — Ensure only TLS and other encrypted protocols are selected for use on the network, and only permit authorized traffic via secure

protocols.

To ensure network traffic is highly secure while in transit, the administrator should enforce encrypted protocols like TLS and only permit authorized traffic through those secure channels. This directly addresses the core requirement of securing data in transit by implementing encryption at the protocol level and enforcing strict authorization policies.

Why The Other Options Are Incorrect

A. NAC and firewall policies focus on access control and authorization but don't directly address encryption of data in transit.

C. Configuring IPS to block specific attacks and updating signatures is important but doesn't ensure all traffic is encrypted.

D. EDR software monitors endpoint behavior and threats but doesn't directly secure network traffic in transit.

Question #382

Which of the following definitions best describes the concept of log correlation?

A. Combining relevant logs from multiple sources into one location
B. Searching and processing data to identify patterns of malicious activity
C. Making a record of the events that occur in the system
D. Analyzing the log files of the system components

✅ Correct Answer: B — Searching and processing data to identify patterns of malicious activity

Log correlation is the process of searching, processing, and analyzing log data from multiple sources to identify patterns and indicators of malicious activity. It goes beyond simple aggregation or recording to actively detect security events through pattern recognition and analysis across correlated data.

Why The Other Options Are Incorrect

A. This describes log aggregation or centralization, not correlation.

C. This describes general event logging, not the analytical correlation process.

D. This describes basic log analysis but not the specific concept of correlating data from multiple sources to identify patterns.

Question #383

An enterprise security team is researching a new security architecture to better protect the company’s networks and applications against the latest cyberthreats. The company has a fully remote workforce. The solution should be highly redundant and enable users to connect to a VPN with an integrated, software-based firewall.

Which of the following solutions meets these requirements?

A. IPS
B. SIEM
C. SASE
D. CASB

✅ Correct Answer: C — SASE

SASE (Secure Access Service Edge) is a cloud-based security architecture that combines VPN, firewall, and other security services into a single integrated platform. It is inherently redundant, software-based, and designed specifically to protect remote workforces by providing secure access and integrated security controls at the network edge.

Why The Other Options Are Incorrect

A. IPS (Intrusion Prevention System) is a point security solution, not a comprehensive architecture for remote access.

B. SIEM (Security Information and Event Management) is a monitoring and analytics platform, not an access or firewall solution.

D. CASB (Cloud Access Security Broker) monitors cloud application usage but doesn't provide VPN or integrated firewall capabilities.

Question #384

Which of the following is the best way to validate the integrity and availability of a disaster recovery site?

A. Lead a simulated failover.
B. Conduct a tabletop exercise.
C. Periodically test the generators.
D. Develop requirements for database encryption.

✅ Correct Answer: A — Lead a simulated failover.

A simulated failover (also called a failover test) is the best way to validate both the integrity and availability of a disaster recovery site because it actually activates recovery systems and verifies that data can be restored and services can be brought online, providing real-world validation of the entire recovery process.

Why The Other Options Are Incorrect

B. A tabletop exercise is a discussion-based planning tool, not a validation of actual system functionality and data availability.

C. Testing generators validates power redundancy but doesn't validate data integrity or the actual recovery of systems and applications.

D. Developing encryption requirements addresses one security aspect but doesn't validate recovery site integrity or availability.

Question #385

Which of the following allows an exploit to go undetected by the operating system?

A. Firmware vulnerabilities
B. Side loading
C. Memory injection
D. Encrypted payloads

Correct Answer: C — Memory injection

Memory injection attacks allow exploits to run directly in memory without writing to disk or being properly registered with the operating system, making them difficult to detect by traditional OS-level security mechanisms. This technique bypasses normal process creation and file system monitoring.

Why The Other Options Are Incorrect

A. Firmware vulnerabilities are OS-level exploits but may be detected; they don't inherently avoid OS detection.

B. Side loading is an application installation method that can be detected by the OS through various security controls.

D. Encrypted payloads still execute as detectable processes; encryption doesn't hide execution from the OS.

Daily Debian

Question #386

A malicious insider from the marketing team alters records and transfers company funds to a personal account.

Which of the following methods would be the best way to secure company records in the future?

A. Permission restrictions
B. Hashing
C. Input validation
D. Access control list

Correct Answer: A — Permission restrictions

The insider succeeded because a marketing employee had the ability to modify financial records and initiate transfers. Applying permission restrictions—least privilege, so users

can only access and change data required for their job role, with separation of duties for financial transactions—directly removes that capability and best secures the records going forward.

Why The Other Options Are Incorrect

B. Hashing can reveal that records were altered after the fact but does nothing to prevent an authorized-but-improper user from changing them.

C. Input validation defends against malformed or malicious data entry such as injection attacks, not against a legitimate user misusing legitimate access.

D. An access control list is one technical mechanism, typically applied to network traffic or specific objects; the broader corrective control needed is restricting the user's permissions based on role and least privilege.

Question #387

An organization is required to provide assurance that its controls are properly designed and operating effectively.

Which of the following reports will best achieve the objective?

A. Red teaming
B. Penetration testing
C. Independent audit
D. Vulnerability assessment

Daily Debian

Correct Answer: C — Independent audit

An independent audit provides formal assurance that controls are properly designed and operating effectively. Audits involve third-party evaluation against established standards and requirements, producing documented reports suitable for compliance and stakeholder confidence. Red teaming, penetration testing, and vulnerability assessments are all offensive security activities focused on finding weaknesses, not on providing formal assurance of control effectiveness.

Why The Other Options Are Incorrect

A. Red teaming simulates adversarial attacks but doesn't provide formal assurance documentation.

B. Penetration testing identifies vulnerabilities but isn't designed to formally assess control design and effectiveness.

D. Vulnerability assessment identifies weaknesses but doesn't formally attest to control design and operational effectiveness.

Question #388

A systems administrator successfully configures VPN access to a cloud environment.

Which of the following capabilities should the administrator use to best facilitate remote administration?

A. A jump host in the shared services security zone
B. An SSH server within the corporate LAN
C. A reverse proxy on the firewall
D. An MDM solution with conditional access

Correct Answer: A — A jump host in the shared services security zone

A jump host (bastion host) in the shared services security zone is the best practice for remote administration. It provides a single hardened entry point for administrators to access critical systems, implements additional logging and monitoring, and reduces direct exposure of administrative interfaces. This architecture is specifically designed to facilitate secure remote administration while maintaining security controls.

Why The Other Options Are Incorrect

B. An SSH server on the corporate LAN doesn't provide the same level of centralized security, monitoring, or architecture for remote cloud administration.

C. A reverse proxy on the firewall is designed for inbound traffic distribution, not for facilitating outbound remote administration.

D. MDM with conditional access is for mobile device management, not the primary mechanism for remote system administration.

Question #389

Which of the following best describes the concept of information being stored outside of its country of origin while still being subject to the laws and requirements of the country of origin?

A. Data sovereignty
B. Geolocation
C. Intellectual property
D. Geographic restrictions

Correct Answer: A — Data sovereignty

Data sovereignty refers to the concept that data is subject to the laws and governance of the country where it is located or where the data subject resides, regardless of where the data is physically stored. This directly describes the scenario where information is stored outside its country of origin but remains subject to the laws and requirements of the

country of origin.

Why The Other Options Are Incorrect

B. Geolocation refers to identifying physical or network location, not the legal jurisdiction and compliance requirements of data.

C. Intellectual property concerns ownership of creative works and inventions, not data residency and jurisdiction.

D. Geographic restrictions are limitations on access based on location, not the legal concept of data being subject to foreign laws.

Question #390

An audit reveals that cardholder database logs are exposing account numbers inappropriately.

Which of the following mechanisms would help limit the impact of this error?

A. Segmentation
B. Hashing
C. Journaling
D. Masking

Correct Answer: D — Masking

Data masking is the best mechanism to limit the impact of exposed account numbers in logs. Masking replaces sensitive data with fictitious but realistic-looking data in non-production environments, or obscures portions of account numbers in logs while maintaining usability. This directly addresses the exposure of account numbers by making them unreadable while preserving log functionality.

Why The Other Options Are Incorrect

A. Segmentation separates networks but doesn't prevent account numbers from being visible in logs.

B. Hashing transforms data irreversibly but doesn't prevent exposure in logs; account numbers need to remain readable for legitimate purposes.

C. Journaling records transaction logs but doesn't prevent sensitive data from being exposed within those logs.

Question #391

A security analyst attempts to start a company's database server.

When the server starts, the analyst receives an error message indicating the database server did not pass authentication. After reviewing and testing the system, the analyst

receives confirmation that the server has been compromised and that attackers have redirected all outgoing database traffic to a server under their control.

Which of the following MITRE ATT&CK techniques did the attacker most likely use to redirect database traffic?

A. Browser extension
B. Process injection
C. Valid accounts
D. Escape to host

Correct Answer: B — Process injection

Process injection is the most likely MITRE ATT&CK technique used to redirect database traffic. Process injection allows an attacker to inject malicious code into a legitimate process, which could then intercept or redirect database connections and traffic to attacker-controlled servers. This technique enables the attacker to maintain persistence and redirect traffic from within the compromised system.

Why The Other Options Are Incorrect

A. Browser extension is used to compromise web browsers, not database server processes.

C. Valid accounts would explain initial compromise but not the specific mechanism of redirecting database traffic.

D. Escape to host is a container escape technique, not related to database traffic redirection on a standard database server.

Daily Debian

Question #392

A penetration tester enters an office building at the same time as a group of employees despite not having an access badge.

Which of the following attack types is the penetration tester performing?

A. Tailgating
B. Shoulder surfing
C. RFID cloning
D. Forgery

Correct Answer: A — Tailgating

Tailgating is the practice of following an authorized person through a secured entrance without using credentials. The penetration tester entering the building by following a group of employees without an access badge is the classic definition of tailgating, a common social engineering technique to bypass physical access controls.

Why The Other Options Are Incorrect

B. Shoulder surfing involves observing someone's screen or keypad input from over their shoulder, not entering a building.

C. RFID cloning involves duplicating radio frequency identification cards, not physical following.

D. Forgery involves creating fake credentials or documents, not entering alongside legitimate employees.

Question #393

Which of the following enables the ability to receive a consolidated report from different devices on the network?

A. IPS
B. DLP
C. SIEM
D. Firewall

Correct Answer: C — SIEM

A SIEM (Security Information and Event Management) system is specifically designed to receive, aggregate, and analyze logs and events from different devices across the network, providing consolidated reporting. It collects data from firewalls, IPS/IDS, servers, and other devices to create a unified security view and generate comprehensive reports.

Why The Other Options Are Incorrect

A. An IPS (Intrusion Prevention System) is a single device focused on blocking attacks, not aggregating data from multiple devices.

B. DLP (Data Loss Prevention) focuses on preventing data exfiltration, not consolidating device reports.

D. A firewall is a single device that doesn't consolidate reports from multiple network devices.

Question #394

Which of the following should an organization focus on the most when making decisions about vulnerability prioritization?

A. Exposure factor
B. CVSS
C. CVE
D. Industry impact

Correct Answer: B — CVSS

CVSS (Common Vulnerability Scoring System) provides a standardized, quantifiable method to assess vulnerability severity and prioritize remediation efforts. While exposure factor, CVE, and industry impact are all relevant to vulnerability management, CVSS scores are the most widely adopted metric for making objective prioritization decisions across organizations.

Why The Other Options Are Incorrect

A. Exposure factor is a component of risk calculation but doesn't directly prioritize vulnerabilities on its own.

C. CVE is an identifier/catalog system, not a scoring mechanism for prioritization.

D. Industry impact is contextual but lacks the standardized quantification needed for consistent prioritization.

Question #395

An organization needs to monitor its users' activities in order to prevent insider threats.

Which of the following solutions would help the organization achieve this goal?

A. Behavioral analytics
B. Access control lists
C. Identity and access management
D. Network intrusion detection system

Daily Debian

Correct Answer: A — Behavioral analytics

Behavioral analytics specifically monitors and analyzes user activities to identify anomalous patterns that indicate insider threats. It establishes baselines of normal behavior and alerts on deviations. Access control lists, identity and access management, and network intrusion detection systems are security controls but do not actively monitor user behavior patterns to detect insider threats.

Why The Other Options Are Incorrect

B. ACLs control access permissions but don't monitor or analyze user activities.

C. IAM manages authentication and authorization but doesn't detect suspicious behavioral patterns.

D. NIDS detects network-based attacks but isn't designed to monitor user activity patterns.

Question #396

A customer of a large company receives a phone call from someone claiming to work for the company and asking for the customer's credit card information. The customer sees the caller ID is the same as the company's main phone number.

Which of the following attacks is the customer most likely a target of?

A. Phishing
B. Whaling
C. Smishing
D. Vishing

Correct Answer: D — Vishing

Vishing (voice phishing) is a social engineering attack conducted via phone calls where attackers impersonate legitimate entities. The scenario describes a phone call with spoofed caller ID requesting sensitive information, which is the defining characteristic of vishing. Phishing uses email, smishing uses SMS, and whaling targets high-level executives.

Why The Other Options Are Incorrect

A. Phishing is email-based social engineering, not voice-based.
B. Whaling specifically targets high-level executives, not generic customers.
C. Smishing uses SMS/text messages, not phone calls.

Question #397

A security analyst is reviewing logs to identify the destination of command-and-control traffic originating from a compromised device within the on-premises network.

Which of the following is the best log to review?

A. IDS
B. Antivirus
C. Firewall
D. Application

Correct Answer: C — Firewall

Firewall logs are the best source for identifying command-and-control traffic destinations because firewalls log all network connections including source, destination, port, and protocol information. They specifically track outbound connections to external destinations. While IDS can detect malicious patterns, antivirus logs focus on file-level threats, and application logs track application-specific events, firewall logs provide the clearest visibility

into network traffic destinations.

Why The Other Options Are Incorrect

A. IDS detects suspicious patterns but doesn't directly log destination addresses as clearly as firewalls.

B. Antivirus logs focus on file-based threats, not network traffic destinations.

D. Application logs don't provide network-layer information about external destinations.

Question #398

When trying to access an internal website, an employee reports that a prompt displays, stating that the site is insecure.

Which of the following certificate types is the site most likely using?

A. Wildcard
B. Root of trust
C. Third-party
D. Self-signed

Correct Answer: D — Self-signed

Self-signed certificates are issued by the website owner rather than a trusted certificate authority, causing browsers to display an 'insecure' warning because they cannot be validated against a trusted root. Self-signed certificates are commonly used for internal websites. Wildcard certificates, root of trust, and third-party certificates would not typically trigger insecurity warnings if properly installed.

Why The Other Options Are Incorrect

A. Wildcard certificates are issued by CAs and don't cause insecurity warnings.

B. Root of trust certificates are trusted by default and wouldn't trigger warnings.

C. Third-party CA-issued certificates are trusted and don't generate insecurity prompts.

Question #399

Which of the following would most likely be deployed to obtain and analyze attacker activity and techniques?

A. Firewall
B. IDS
C. Honeypot
D. Layer 3 switch

✅ **Correct Answer: C — Honeypot**

A honeypot is a decoy system specifically designed to attract, detect, and analyze attacker activity and techniques without protecting production systems. It captures detailed information about attack methods, tools, and attacker behavior. Firewalls enforce policy, IDS detects threats, and Layer 3 switches route traffic—none are designed to study attacker techniques in detail.

Why The Other Options Are Incorrect

A. Firewalls block traffic but don't analyze attacker techniques.

B. IDS detects intrusions but doesn't specifically trap attackers to study them.

D. Layer 3 switches are infrastructure devices with no threat analysis capability.

Question #400

Which of the following objectives is best achieved by a tabletop exercise?

A. Familiarizing participants with the incident response process
B. Deciding red and blue team rules of engagement
C. Quickly determining the impact of an actual security breach
D. Conducting multiple security investigations in parallel

✅ **Correct Answer: A — Familiarizing participants with the incident response process**

Tabletop exercises are low-cost, discussion-based simulations that introduce participants to incident response procedures, roles, and processes in a controlled environment. They familiarize teams with the incident response workflow without executing actual systems. Red/blue team rules require formal war games, actual breach impact assessment requires real data analysis, and parallel investigations require full-scale simulations.

Why The Other Options Are Incorrect

B. Red/blue team rules of engagement are determined in structured war games, not tabletops.

C. Determining actual breach impact requires analyzing real events, not tabletop discussions.

D. Parallel investigations require full-scale exercises with actual system execution.

Question #401

The private key for a website was stolen, and a new certificate has been issued.

Which of the following needs to be updated next?

A. SCEP

B. CRL
C. OCSP
D. CSR

Correct Answer: B — CRL

After a private key is compromised and a new certificate is issued, the CRL (Certificate Revocation List) must be updated to mark the old certificate as revoked. This prevents the compromised certificate from being accepted by clients. SCEP is for certificate enrollment, OCSP is a real-time revocation checking protocol (which queries CRL data), and CSR is used to request certificates, not to revoke them.

Why The Other Options Are Incorrect

A. SCEP is for automated certificate enrollment and provisioning, not revocation.

C. OCSP is a protocol for checking revocation status but doesn't update the revocation status itself.

D. CSR (Certificate Signing Request) is used to request new certificates, not revoke old ones.

Question #402

Which of the following organizational documents is most often used to establish and communicate expectations associated with integrity and ethical behavior within an organization?

A. AUP
B. SLA
C. EULA
D. MOA

Correct Answer: A — AUP

An Acceptable Use Policy (AUP) is the primary document used to establish and communicate expectations regarding integrity and ethical behavior, acceptable use of resources, and conduct standards within an organization. It sets clear guidelines for employee behavior and system usage.

Why The Other Options Are Incorrect

B. SLA (Service Level Agreement) defines service performance standards and availability metrics, not ethical behavior expectations.

C. EULA (End User License Agreement) is a legal contract for software licensing, not for establishing organizational ethical standards.

D. MOA (Memorandum of Agreement) documents agreements between parties, typically for external partnerships or specific arrangements.

Question #403

Which of the following explains how to determine the global regulations that data is subject to regardless of the country where the data is stored?

A. Geographic dispersion
B. Data sovereignty
C. Geographic restrictions
D. Data segmentation

Correct Answer: B — Data sovereignty

Data sovereignty refers to the concept that data is subject to the laws and regulations of the country where it is stored or processed, regardless of where the organization is located. It encompasses the legal obligations and restrictions that apply to data based on its geographic location and the regulations governing that jurisdiction.

Why The Other Options Are Incorrect

A. Geographic dispersion refers to the physical distribution of data across multiple locations, not the regulatory determination.

C. Geographic restrictions are limitations on data movement, not an explanation of how to determine applicable regulations.

D. Data segmentation is a technical approach to organizing data, not a method for determining regulatory applicability.

Daily Debian

Question #404

An organization's web servers host an online ordering system. The organization discovers that the servers are vulnerable to a malicious JavaScript injection, which could allow attackers to access customer payment information.

Which of the following mitigation strategies would be most effective for preventing an attack on the organization's web servers? (Choose two.)

A. Regularly updating server software and patches
B. Implementing strong password policies
C. Encrypting sensitive data at rest and in transit
D. Utilizing a web-application firewall
E. Performing regular vulnerability scans
F. Removing payment information from the servers

Correct Answer: A, D

A. Regularly updating server software and patches
D. Utilizing a web-application firewall

Option A (regular patching) prevents known vulnerabilities from being exploited, including JavaScript injection flaws. Option D (web application firewall) specifically detects and blocks malicious JavaScript injection attempts and similar web-based attacks before they reach the application. Together, these address both prevention of the vulnerability and active defense against exploitation.

Why The Other Options Are Incorrect

B. Strong password policies do not prevent JavaScript injection attacks, which don't require compromised credentials.

C. While encryption protects data in transit, it does not prevent the JavaScript injection vulnerability itself from being exploited.

E. Vulnerability scans identify issues but do not prevent attacks; they're detective, not preventive.

F. Removing payment information doesn't address the underlying JavaScript injection vulnerability, which could expose other sensitive data.

Question #405

Which of the following tools is best for logging and monitoring in a cloud environment?

A. IPS
B. FIM
C. NAC
D. SIEM

Correct Answer: D — SIEM

A SIEM (Security Information and Event Management) system is the best tool for comprehensive logging and monitoring in cloud environments, as it collects, correlates, and analyzes security events from multiple sources across the infrastructure, providing centralized visibility and threat detection.

Why The Other Options Are Incorrect

A. IPS (Intrusion Prevention System) is a network security tool that blocks threats but does not provide comprehensive logging and monitoring across cloud environments.

B. FIM (File Integrity Monitoring) focuses only on detecting changes to files, not comprehensive logging and monitoring.

C. NAC (Network Access Control) manages device access to networks but does not provide logging and monitoring capabilities.

Question #406

During a SQL update of a database, a temporary field that was created was replaced by an attacker in order to allow access to the system.

Which of the following best describes this type of vulnerability?

A. Race condition
B. Memory injection
C. Malicious update
D. Side loading

Correct Answer: A — Race condition

A race condition occurs when the timing of operations matters—in this case, an attacker exploited the window between when a temporary field was created during a database update and when it was properly secured or replaced, allowing unauthorized system access. This timing vulnerability is the defining characteristic of a race condition.

Why The Other Options Are Incorrect

B. Memory injection refers to injecting malicious code into memory space, not replacing temporary database fields.

C. While an update was involved, 'malicious update' is not a recognized vulnerability classification; race condition is more precise.

D. Side loading refers to installing applications from unofficial sources, not exploiting database update timing windows.

Daily Debian

Question #407

A group of developers has a shared backup account to access the source code repository.

Which of the following is best way to secure the backup account if there is an SSO failure?

A. RAS
B. EAP
C. SAML
D. PAM

Correct Answer: D — PAM

PAM (Privileged Access Management) is the best solution for securing shared backup accounts during SSO failures because it provides credential management, monitoring, and access controls for privileged accounts, allowing secure access to critical systems without

relying on SSO infrastructure.

Why The Other Options Are Incorrect

A. RAS (Remote Access Service) enables remote connections but does not specifically address credential security for shared accounts.

B. EAP (Extensible Authentication Protocol) is a network authentication framework, not designed for backup account credential management.

C. SAML (Security Assertion Markup Language) is an SSO technology; using it as a backup would not help if SSO itself fails.

Question #408

Which of the following elements of digital forensics should a company use if it needs to ensure the integrity of evidence?

A. Preservation
B. E-discovery
C. Acquisition
D. Containment

Correct Answer: A — Preservation

Preservation is the element of digital forensics that ensures the integrity of evidence by protecting it from alteration, contamination, or loss. This includes proper handling, storage, and documentation to maintain the chain of custody and admissibility of evidence in legal proceedings.

Why The Other Options Are Incorrect

B. E-discovery is the process of identifying and collecting electronic evidence but does not specifically ensure integrity.

C. Acquisition is the process of collecting data from systems but does not inherently ensure the integrity of evidence.

D. Containment involves isolating systems to prevent spread of an incident but does not specifically address evidence integrity.

Question #409

A company suffered a critical incident where 30GB of data was exfiltrated from the corporate network.

Which of the following actions is the most efficient way to identify where the system data was exfiltrated from and what location the attacker sent the data to?

A. Analyze firewall and network logs for large amounts of outbound traffic to external IP addresses or domains.

B. Analyze IPS and IDS logs to find the IP addresses used by the attacker for reconnaissance scans.

C. Analyze endpoint and application logs to see whether file-sharing programs were running on the company systems.

D. Analyze external vulnerability scans and automated reports to identify the systems the attacker could have exploited a remote code vulnerability.

✅ Correct Answer: A — Analyze firewall and network logs for large amounts of outbound traffic to external IP addresses or domains.

Analyzing firewall and network logs for large outbound traffic to external destinations is the most efficient method to identify both the source system where data was exfiltrated and the destination where the attacker sent it. Network logs capture the volume and direction of data flows, external IP addresses, and domains involved in the exfiltration.

Why The Other Options Are Incorrect

B. IPS/IDS logs show reconnaissance and attack attempts but may not clearly identify the 30GB data exfiltration destination.

C. Endpoint and application logs for file-sharing programs only reveal the mechanism used, not necessarily the external destination.

D. External vulnerability scans show potential vulnerabilities but do not directly identify where data was actually exfiltrated to.

Question #410

Which of the following describes the procedures a penetration tester must follow while conducting a test?

A. Rules of engagement

B. Rules of acceptance

C. Rules of understanding

D. Rules of execution

✅ Correct Answer: A — Rules of engagement

Rules of engagement are the formal procedures and guidelines that a penetration tester must follow during an authorized security test. They establish the scope, timeline, methods, systems to test, and contact procedures between the tester and the organization. This is the standard term used in the industry for the documented agreement governing penetration testing activities.

Why The Other Options Are Incorrect

B. Rules of acceptance refer to criteria for accepting systems or services, not testing procedures.

C. Rules of understanding is not a standard penetration testing term.

D. Rules of execution relates to how tests are run, but the formal term is rules of engagement.

Question #411

A security analyst wants to better understand the behavior of users and devices in order to gain visibility into potential malicious activities. The analyst needs a control to detect when actions deviate from a common baseline.

Which of the following should the analyst use?

A. Intrusion prevention system
B. Sandbox
C. Endpoint detection and response
D. Antivirus

Correct Answer: C — Endpoint detection and response

Endpoint Detection and Response (EDR) solutions are specifically designed to monitor user and device behavior, establish behavioral baselines, and detect deviations from normal activity that indicate potential malicious actions. EDR tools provide real-time visibility into endpoint activities and can identify suspicious behavior patterns that traditional tools miss.

Why The Other Options Are Incorrect

A. Intrusion prevention systems focus on network-level threats, not device behavior analysis.

B. Sandboxes execute suspicious files in isolation but don't continuously monitor baseline behavior.

D. Antivirus detects known malware signatures, not behavioral deviations from baselines.

Question #412

A legal department must maintain a backup from all devices that have been shredded and recycled by a third party.

Which of the following best describes this requirement?

A. Data retention
B. Certification

C. Sanitization
D. Destruction

Correct Answer: A — Data retention

Data retention is the requirement to maintain backups and records of data even after physical devices have been destroyed or recycled. In this case, the legal department must keep backup copies of all data from shredded devices for compliance and legal purposes. This ensures data availability even after the original hardware is disposed of.

Why The Other Options Are Incorrect

B. Certification documents that proper procedures were followed, not that data is maintained.

C. Sanitization is the process of securely erasing data from devices before disposal.

D. Destruction refers to the physical destruction of hardware, not maintaining backups.

Question #413

Which of the following can be used to compromise a system that is running an RTOS?

A. Cross-site scripting
B. Memory injection
C. Replay attack
D. Ransomware

Correct Answer: B — Memory injection

Memory injection attacks can compromise Real-Time Operating Systems (RTOS) by directly injecting malicious code into memory at runtime. This attack method works against RTOS because these systems often have limited security controls and operate in constrained environments, making them vulnerable to direct memory manipulation attacks.

Why The Other Options Are Incorrect

A. Cross-site scripting targets web browsers and applications, not RTOS systems.

C. Replay attacks replay captured network traffic but don't specifically target RTOS memory.

D. Ransomware requires file systems and user interaction, which are often minimal in RTOS environments.

Question #414

Which of the following threat actors would most likely deface the website of a high-profile music group?

A. Unskilled attacker
B. Organized crime
C. Nation-state
D. Insider threat

✅ Correct Answer: A — Unskilled attacker

Website defacement of a high-profile music group would most likely be performed by an unskilled attacker (script kiddie) seeking visibility, notoriety, or bragging rights. This type of attack requires relatively low sophistication and the attacker's goal is typically publicity rather than financial gain or espionage, which characterizes other threat actor types.

Why The Other Options Are Incorrect

B. Organized crime typically pursues financial objectives, not publicity through defacement.

C. Nation-states focus on geopolitical objectives and espionage, not celebrity website defacement.

D. Insider threats have direct access and would target more valuable assets within organizations.

Question #415

A security architect wants to prevent employees from receiving malicious attachments by email.

Which of the following functions should the chosen solution do?

A. Apply IP address reputation data.
B. Tap and monitor the email feed.
C. Scan email traffic inline.
D. Check SPF records.

✅ Correct Answer: C — Scan email traffic inline.

Scanning email traffic inline means examining email content and attachments in real-time as they pass through the mail system, before delivery to users. This allows the solution to detect and block malicious attachments before employees receive them. Inline scanning is the active prevention mechanism that stops threats at the gateway.

Why The Other Options Are Incorrect

A. IP reputation data helps filter spam and known malicious senders but doesn't scan attachment content.

B. Tapping and monitoring the email feed is passive observation, not prevention of malicious attachments.

D. SPF records authenticate sender identity but don't prevent malicious attachments from being delivered.

Question #416

Which of the following activities is the first stage in the incident response process?

A. Detection
B. Declaration
C. Containment
D. Verification

Correct Answer: A — Detection

Detection is the first stage of the incident response process, where security teams identify that a security incident has occurred. Before any response actions can be taken (containment, eradication, recovery), the incident must first be detected. This discovery phase initiates the entire incident response workflow.

Why The Other Options Are Incorrect

B. Declaration comes after detection and involves formal notification of the incident.
C. Containment is the third phase, after detection and analysis.
D. Verification occurs during analysis but is not the first stage of incident response.

Question #417

Which of the following is the main consideration when a legacy system that is a critical part of a company's infrastructure cannot be replaced?

A. Resource provisioning
B. Cost
C. Single point of failure
D. Complexity

Correct Answer: C — Single point of failure

Single point of failure is the main security consideration for critical legacy systems that cannot be replaced. When a legacy system cannot be removed from infrastructure due to its critical role, the organization faces significant risk if that system fails, as there is no redundancy or backup alternative. This creates a dangerous dependency that must be actively managed.

Why The Other Options Are Incorrect

A. Resource provisioning is a deployment consideration, not the primary security

concern.

B. While cost may prevent replacement, it's not the main security consideration.

D. Complexity is a technical challenge but not the primary risk concern for legacy critical systems.

Question #418

Which of the following is a compensating control for providing user access to a high-risk website?

A. Enabling threat prevention features on the firewall
B. Configuring a SIEM tool to capture all web traffic
C. Setting firewall rules to allow traffic from any port to that destination
D. Blocking that website on the endpoint protection software

Correct Answer: A — Enabling threat prevention features on the firewall

A compensating control mitigates risk when primary controls cannot be implemented. Enabling threat prevention on the firewall actively reduces the risk of accessing a high-risk website by detecting and blocking malicious content. This is a technical control that compensates for allowing access to a dangerous resource. Options C and D are incorrect because C actually increases risk and D prevents access entirely rather than compensating for it.

Why The Other Options Are Incorrect

B. SIEM monitoring only detects incidents after they occur; it doesn't prevent or compensate for the risk of accessing dangerous sites.

C. Allowing traffic from any port increases risk rather than compensating for it.

D. Blocking the website entirely is a preventive control, not a compensating control for allowing access.

Question #419

An organization is implementing a COPE mobile device management policy.

Which of the following should the organization include in the COPE policy? (Choose two.)

A. Remote wiping of the device
B. Data encryption
C. Requiring passwords with eight characters
D. Data usage caps
E. Employee data ownership

F. Personal application store access

Correct Answer: A, B

A. Remote wiping of the device

B. Data encryption

COPE (Corporate-Owned, Personally-Enabled) policies must include remote wiping capability for lost or stolen devices and data encryption to protect corporate information on mobile devices. These are essential security requirements for managing corporate assets with mixed use. Password requirements (C) are important but not specifically COPE-related. Data usage caps (D) are cost controls, not security. Employee data ownership (E) and personal app store access (F) are not standard COPE security requirements.

Why The Other Options Are Incorrect

C. While password requirements are important, they are basic authentication controls not specific to COPE policies.

D. Data usage caps relate to cost management, not security controls for COPE.

E. Data ownership is an administrative concern, not a core COPE security policy component.

F. Personal app store access is a functionality feature, not a required COPE security control.

Question #420

A security administrator observed the following in a web server log while investigating an incident:

"GET ../../../../etc/passwd"

Which of the following attacks did the security administrator most likely see?

A. Privilege escalation
B. Credential replay
C. Brute force
D. Directory traversal

Correct Answer: D — Directory traversal

The pattern '../../../../etc/passwd' is a classic directory traversal attack, where the attacker uses relative path sequences to navigate up the directory structure and access files outside the intended web root. The 'etc/passwd' file is a common target on Unix/Linux systems. This technique exploits improper input validation to access unauthorized files.

Why The Other Options Are Incorrect

A. Privilege escalation attempts to elevate user permissions, not traverse directories to

access files.

B. Credential replay involves reusing captured authentication credentials, not manipulating file paths.

C. Brute force attacks involve repeated attempts with different passwords or inputs, not directory path manipulation.

Question #421

An organization wants a third-party vendor to do a penetration test that targets a specific device. The organization has provided basic information about the device.

Which of the following best describes this kind of penetration test?

A. Partially known environment
B. Unknown environment
C. Integrated
D. Known environment

✅ Correct Answer: A — Partially known environment

A 'partially known environment' penetration test is conducted when the vendor receives basic information about the target (in this case, basic device information) but not full details about the system. This provides a realistic middle-ground scenario. An unknown environment (B) would provide no information, a known environment (D) would provide full details, and 'integrated' (C) is not a standard penetration test classification.

Why The Other Options Are Incorrect

B. Unknown environment would mean providing the vendor no information about the device at all.

C. Integrated is not a standard penetration test type classification.

D. Known environment would mean providing complete details about the device's configuration and infrastructure.

Question #422

Which of the following should a security team do first before a new web server goes live?

A. Harden the virtual host.
B. Create WAF rules.
C. Enable network intrusion detection.
D. Apply patch management.

Correct Answer: A — Harden the virtual host.

Hardening the virtual host should be done first before deployment because it establishes the secure baseline configuration and removes unnecessary services, accounts, and features. This foundational step must precede other security measures. WAF rules (B) and intrusion detection (C) are applied after hardening, and patch management (D) is part of the ongoing maintenance process, though critical patches should be applied before go-live.

Why The Other Options Are Incorrect

B. WAF rules should be created after the server is hardened and configured.

C. Network intrusion detection is configured after the server is secured and operational.

D. While patching is important, hardening (which includes disabling unnecessary components) is the first step.

Question #423

Which of the following techniques can be used to sanitize the data contained on a hard drive while allowing for the hard drive to be repurposed?

A. Degaussing
B. Drive shredder
C. Retention platform
D. Wipe tool

Daily Debian

Correct Answer: D — Wipe tool

A wipe tool (also called data wiping software) sanitizes a hard drive by securely overwriting all data, making it unrecoverable while preserving the drive's functionality for repurposing. Degaussing (A) uses magnetic fields to erase data but may damage the drive hardware. A drive shredder (B) physically destroys the drive, making it unusable. A retention platform (C) is not a sanitization method.

Why The Other Options Are Incorrect

A. Degaussing can damage the drive hardware and may not allow proper repurposing.

B. Drive shredding physically destroys the drive, making it impossible to repurpose.

C. A retention platform is a storage solution, not a data sanitization technique.

Question #424

An attacker submits a request containing unexpected characters in an attempt to gain unauthorized access to information within the underlying systems.

Which of the following best describes this attack?

A. Side loading
B. Target of evaluation
C. Resource reuse
D. SQL injection

✅ Correct Answer: D — SQL injection

SQL injection is an attack where unexpected characters (typically SQL syntax) are submitted in input fields to manipulate database queries and gain unauthorized access to data. This directly matches the description of submitting unexpected characters to access information in underlying systems. The other options do not describe injection attacks.

Why The Other Options Are Incorrect

A. Side loading refers to installing applications from unofficial sources, not submitting malicious input strings.

B. Target of evaluation is a Common Criteria concept referring to the system being evaluated, not an attack type.

C. Resource reuse is a security concept about controlling how resources are allocated, not an attack vector.

Question #425

A security analyst has determined that a security breach would have a financial impact of $15,000 and is expected to occur twice within a three-year period.

Which of the following is the ALE for this risk?

A. $7,500
B. $10,000
C. $15,000
D. $30,000

✅ Correct Answer: B — $10,000

ALE (Annual Loss Expectancy) is calculated as: Impact × Frequency per year. The impact is $15,000 and the frequency is 2 occurrences per 3 years, which equals 0.67 times per year (2÷3). Therefore: ALE = $15,000 × 0.67 = $10,000 approximately.

Why The Other Options Are Incorrect

A. $7,500 is half the impact, which would only be correct if the event occurred once every two years.

C. $15,000 is the single impact value, not accounting for the annual frequency calculation.

D. $30,000 is double the impact value and does not properly account for the frequency

calculation.

Question #426

A systems administrator discovers a system that is no longer receiving support from the vendor. However, this system and its environment are critical to running the business, cannot be modified, and must stay online.

Which of the following risk treatments is the most appropriate in this situation?

A. Reject
B. Accept
C. Transfer
D. Avoid

Correct Answer: B — Accept

When a critical system cannot be modified, taken offline, or avoided, acceptance is the appropriate risk treatment. The organization acknowledges the risk of running unsupported software and implements compensating controls (monitoring, isolation, security tools) to mitigate the risk while keeping the system operational. This is the only viable option given the constraints that the system is critical and cannot be changed.

Why The Other Options Are Incorrect

A. Reject is not a valid risk treatment option in standard risk management frameworks.

C. Transfer would involve shifting the risk to another party (insurance), but doesn't address the requirement to keep this critical system running.

D. Avoid would mean taking the system offline, which violates the requirement that it must stay online.

Question #427

A company discovered its data was advertised for sale on the dark web. During the initial investigation, the company determined the data was proprietary data.

Which of the following is the next step the company should take?

A. Identify the attacker’s entry methods.
B. Report the breach to the local authorities.
C. Notify the applicable parties of the breach.
D. Implement vulnerability scanning of the company's systems.

Correct Answer: C — Notify the applicable parties of the breach.

According to incident response procedures, notification of affected parties is a critical early

step after discovery of a data breach. This includes notifying customers, regulators, and relevant authorities as required by law (GDPR, HIPAA, state breach notification laws, etc.). While identifying entry methods and implementing scans are important, they are follow-up activities. Notifying applicable parties must happen promptly to meet legal and regulatory obligations.

Why The Other Options Are Incorrect

A. Identifying attacker methods is important but comes after notifying parties, and is part of the investigation phase that follows notification.

B. Reporting to local authorities is typically done after notifying the affected parties and may not always be the immediate next step.

D. Implementing vulnerability scanning is a remediation step that occurs after notification and investigation have begun.

Question #428

Which of the following would be the best solution to deploy a low-cost standby site that includes hardware and internet access?

A. Recovery site
B. Cold site
C. Hot site
D. Warm site

Daily Debian

Correct Answer: B — Cold site

A cold site is a low-cost standby facility that includes hardware and internet connectivity but requires significant time to bring online during a disaster. It provides the basic infrastructure needed but no pre-loaded data or active systems, making it the most cost-effective option. Cold sites are ideal when the organization needs a backup option but has limited budget and can tolerate longer recovery times.

Why The Other Options Are Incorrect

A. A recovery site is a general term but doesn't specifically address the low-cost requirement.

C. A hot site is fully operational with live data replication, making it expensive and not the low-cost solution described.

D. A warm site has some systems and data pre-positioned, making it more expensive than a cold site while offering faster recovery.

Question #429

An organization needs to determine how many employees are accessing the building each day in order to configure the proper access controls.

Which of the following control types best meets this requirement?

A. Detective
B. Preventive
C. Corrective
D. Directive

Correct Answer: A — Detective

Determining how many employees are accessing the building involves monitoring and observing access patterns, which is the purpose of detective controls. Detective controls identify that an event or incident has occurred after it happens, allowing the organization to gather metrics on building access. This information then supports the configuration of proper preventive controls.

Why The Other Options Are Incorrect

B. Preventive controls stop unauthorized access before it happens, rather than determining how many are accessing.

C. Corrective controls remediate incidents after they occur, not measure ongoing access levels.

D. Directive controls guide or influence behavior but don't measure or count building access.

Question #430

An organization wants to implement a secure solution for remote users. The users handle sensitive PHI on a regular basis and need to access an internally developed corporate application.

Which of the following best meet the organization's security requirements? (Choose two.)

A. Local administrative password
B. Perimeter network
C. Jump server
D. WAF
E. MFA
F. VPN

Correct Answer: C, F

C. Jump server

F. VPN

A VPN provides an encrypted tunnel so sensitive PHI traversing the internet cannot be read or modified by an eavesdropper, satisfying the confidentiality requirement for remote users. A jump server then acts as the single hardened, monitored pivot point through which those remote users reach the internally developed corporate application, keeping the internal application off the public network while still allowing controlled access. Together they secure both the transport and the access path.

Why The Other Options Are Incorrect

A. Local administrative passwords concern endpoint privileged account management and do nothing to secure a remote connection to an internal application.

B. A perimeter network (screened subnet) is for hosting public-facing services, but the application here is internal and should not be exposed there.

D. A WAF protects public web applications from application-layer attacks; it does not provide remote users with secure, encrypted access to an internal system.

E. MFA strengthens authentication but by itself neither encrypts the PHI in transit nor provides the controlled gateway into the internal network.

Question #431

A security officer is implementing a security awareness program and is placing security-themed posters around the building and is assigning online user training.

Which of the following would the security officer most likely implement?

A. Password policy
B. Access badges
C. Phishing campaign
D. Risk assessment

Correct Answer: C — Phishing campaign

A phishing campaign is a simulated security test used to measure employee awareness and training effectiveness. When combined with security-themed posters and online training, phishing campaigns are a practical implementation method for security awareness programs that tests whether employees can identify and respond to threats appropriately.

Why The Other Options Are Incorrect

A. Password policy is a technical control, not an awareness program implementation.

B. Access badges are physical security controls, not awareness training measures.

D. Risk assessment is a strategic activity, not part of awareness training implementation.

Question #432

A security consultant is working with a client that wants to physically isolate its secure systems.

Which of the following best describes this architecture?

A. SDN
B. Air gapped
C. Containerized
D. Highly available

Correct Answer: B — Air gapped

An air-gapped system is physically isolated from unsecured networks, especially the internet, with no direct network connections. This architecture best describes the requirement to physically isolate secure systems, as it prevents any network-based attacks or unauthorized access from external sources.

Why The Other Options Are Incorrect

A. SDN (Software Defined Networking) is a network architecture approach that doesn't address physical isolation.

C. Containerized systems are application deployment solutions that don't provide physical isolation.

D. High availability focuses on uptime and redundancy, not physical isolation of secure systems.

Question #433

A company is in the process of migrating to cloud-based services. The company's IT department has limited resources for migration and ongoing support.

Which of the following best meets the company's needs?

A. IPS
B. WAF
C. SASE
D. IAM

Correct Answer: C — SASE

SASE (Secure Access Service Edge) is a cloud-native security architecture that converges networking and security functions into a unified cloud service. For a company with limited IT resources migrating to cloud services, SASE reduces operational overhead by

consolidating firewall, VPN, DLP, and other security functions into a managed cloud service, requiring minimal internal resources for support.

Why The Other Options Are Incorrect

A. IPS (Intrusion Prevention System) is a point security solution that doesn't address the broader needs of cloud migration.

B. WAF (Web Application Firewall) protects web applications but doesn't address overall cloud migration security needs.

D. IAM (Identity Access Management) is important for cloud but doesn't provide the comprehensive security architecture needed for limited-resource migrations.

Question #434

An employee clicks a malicious link in an email that appears to be from the company's Chief Executive Officer. The employee's computer is infected with ransomware that encrypts the company's files.

Which of the following is the most effective way for the company to prevent similar incidents in the future?

A. Security awareness training
B. Database encryption
C. Segmentation
D. Reporting suspicious emails

Daily Debian

Correct Answer: A — Security awareness training

Security awareness training is the most effective long-term preventive measure because it addresses the root cause: human behavior. The attack succeeded because an employee was deceived by a phishing email. Training teaches employees to recognize social engineering tactics, verify sender identities, and avoid clicking malicious links. While other options provide defense-in-depth benefits, they don't prevent the initial click that compromised the system.

Why The Other Options Are Incorrect

B. Database encryption protects data at rest but doesn't prevent malware installation or initial infection.

C. Segmentation limits lateral movement after infection but doesn't prevent the initial compromise from the malicious link.

D. Reporting suspicious emails is reactive; it doesn't prevent employees from clicking malicious links in the first place.

Question #435

Which of the following types of vulnerabilities is primarily caused by improper use and management of cryptographic certificates?

A. Misconfiguration
B. Resource reuse
C. Insecure key storage
D. Weak cipher suites

Correct Answer: C — Insecure key storage

Insecure key storage is the primary vulnerability caused by improper certificate management. When cryptographic certificates and their associated private keys are not stored securely (e.g., hardcoded in code, stored in plaintext, or left in accessible locations), attackers can compromise them. This directly results from poor management practices and is the most common critical failure in certificate-based systems.

Why The Other Options Are Incorrect

A. Misconfiguration is broader and not specifically about certificate management practices.

B. Resource reuse is a different class of vulnerability unrelated to certificate management.

D. Weak cipher suites relate to algorithm choice, not certificate management practices.

Daily Debian

Question #436

Which of the following best describe the benefits of a microservices architecture when compared to a monolithic architecture? (Choose two.)

A. Easier debugging of the system
B. Reduced cost of ownership of the system
C. Improved scalability of the system
D. Increased compartmentalization of the system
E. Stronger authentication of the system
F. Reduced complexity of the system

Correct Answer: C, D

C. Improved scalability of the system
D. Increased compartmentalization of the system

Improved scalability (C) and increased compartmentalization (D) are the primary architectural benefits of microservices. Each service can be independently scaled based on demand, and services are isolated/compartmentalized, improving resilience and

security boundaries. While microservices may improve some aspects, they don't generally make debugging easier, reduce ownership costs, or reduce complexity—in fact, they often increase operational complexity.

Why The Other Options Are Incorrect

A. Debugging is actually more difficult in microservices due to distributed systems complexity and inter-service dependencies.

B. Microservices typically increase operational costs due to infrastructure, monitoring, and deployment complexity requirements.

E. Authentication mechanisms are not inherently stronger in microservices versus monolithic architectures.

F. Microservices increase system complexity through distributed system challenges, network communication, and service coordination.

Question #437

A user's workstation becomes unresponsive and displays a ransom note demanding payment to decrypt files. Before the attack, the user opened a resume they received in a message, browsed the company's website, and installed OS updates.

Which of the following is the most likely vector of this attack?

A. Spear-phishing attachment
B. Watering hole
C. Infected website
D. Typosquatting

Correct Answer: A — Spear-phishing attachment

Spear-phishing attachment is the most likely vector because the user opened a resume received in a message, which is a classic spear-phishing attack. The malicious document (resume) was likely crafted specifically for the user or company and triggered ransomware execution. The other activities (browsing company website, installing OS updates) are routine and wouldn't directly cause infection.

Why The Other Options Are Incorrect

B. Watering hole attacks target websites visited by target groups; the company website would typically be well-maintained and not malicious.

C. Infected websites are possible but less likely than a targeted attachment; OS updates are also from trusted sources.

D. Typosquatting involves visiting mistyped domains and is less probable given the user's activities.

Question #438

A penetration tester finds an unused Ethernet port during an on-site penetration test. Upon plugging a device into the unused port, the penetration tester notices that the machine is assigned an IP address, allowing the tester to enumerate the local network.

Which of the following should an administrator implement in order to prevent this situation from happening in the future?

A. Port security
B. Transport Layer Security
C. Proxy server
D. Security zones

Correct Answer: A — Port security

Port security is the most effective control to prevent unauthorized physical access and device enumeration. It prevents unknown devices from receiving IP addresses and accessing the network by authenticating MAC addresses or limiting port connections to known devices. This directly addresses the vulnerability of unused ports being exploitable for network entry.

Why The Other Options Are Incorrect

B. Transport Layer Security protects data in transit but doesn't prevent physical port access or DHCP assignment.

C. Proxy servers manage application-level traffic but don't prevent initial network access via physical ports.

D. Security zones segment networks but don't prevent unauthorized devices from connecting to and being assigned addresses on unused ports.

Question #439

Which of the following should be used to ensure an attacker is unable to read the contents of a mobile device's drive if the device is lost?

A. TPM
B. ECC
C. FDE
D. HSM

Correct Answer: C — FDE

Full Disk Encryption (FDE) is the standard and most effective method to ensure that an attacker cannot read the contents of a lost mobile device's drive. FDE encrypts all data on the storage medium, making it unreadable without the correct decryption key or password,

regardless of physical access to the device.

Why The Other Options Are Incorrect

A. TPM (Trusted Platform Module) provides cryptographic functions and key storage but is not specifically designed for full drive encryption.

B. ECC (Elliptic Curve Cryptography) is an algorithm used in encryption but not a standalone solution for disk encryption.

D. HSM (Hardware Security Module) manages keys in enterprise settings but is not a mobile device protection mechanism.

Question #440

A security administrator documented the following records during an assessment of network services:

Record	Type	Address	TTL
@	A	192.168.1.1	14400
WWW	CNAME	192.168.1.1	14400

Two weeks later, the administrator performed a log review and noticed the records were changed as follows:

Record	Type	Address	TTL
@	A	233.123.123.23	14400
WWW	CNAME	233.123.123.23	14400

When consulting the service owner, the administrator validated that the new address was not part of the company network.

Which of the following was the company most likely experiencing?

A. DDoS attack
B. DNS poisoning
C. Ransomware compromise
D. Spyware infection

Correct Answer: B — DNS poisoning

DNS poisoning occurs when DNS records are maliciously altered to redirect users to unauthorized IP addresses. The exhibit shows that both the @ (root/apex) and www records changed from 192.168.1.1 to 233.123.123.23, which is not part of the company network. This is a classic DNS poisoning attack where an attacker has compromised the DNS records to redirect legitimate domain queries to a malicious IP address, potentially for

credential harvesting, malware distribution, or phishing purposes.

Why The Other Options Are Incorrect

A. A DDoS attack floods a target with traffic to cause unavailability; it does not involve DNS record modification.

C. Ransomware compromise would encrypt files and demand payment, not modify DNS records to point elsewhere.

D. Spyware infection monitors user activity and steals data locally; it does not change authoritative DNS records.

Question #441

Which of the following is the primary reason why false negatives on a vulnerability scan should be a concern?

A. The system has vulnerabilities that are not being detected.
B. The time to remediate vulnerabilities that do not exist is excessive.
C. Vulnerabilities with a lower severity will be prioritized over critical vulnerabilities.
D. The system has vulnerabilities, and a patch has not yet been released.

✅ **Correct Answer: A — The system has vulnerabilities that are not being detected.**

False negatives on a vulnerability scan are dangerous because the system has vulnerabilities that are not being detected by the scanner. This creates a false sense of security—administrators believe the system is properly assessed and patched when actual vulnerabilities remain undetected and exploitable. This is the primary concern because undetected vulnerabilities pose active security risks.

Why The Other Options Are Incorrect

B. Time spent remediating non-existent vulnerabilities describes the impact of false positives, not false negatives.

C. Prioritization issues are unrelated to false negatives; they concern how detected vulnerabilities are ranked.

D. Lack of available patches is a separate issue from false negatives in scanning.

Question #442

A company is concerned about theft of client data from decommissioned laptops.

Which of the following is the most cost-effective method to decrease this risk?

A. Wiping
B. Recycling

C. Shredding
D. Deletion

Correct Answer: A — Wiping

Wiping is the most cost-effective method to prevent data theft from decommissioned laptops. It uses software-based tools to securely overwrite data, making it irrecoverable without requiring physical destruction. Wiping is significantly cheaper than shredding (physical destruction) while being more effective than simple deletion (which doesn't prevent recovery) and more practical than recycling alone.

Why The Other Options Are Incorrect

B. Recycling doesn't ensure data destruction and may expose drives to data recovery efforts.

C. Shredding is physically destructive and more expensive than wiping while achieving the same security outcome.

D. Deletion only removes file pointers; data remains recoverable with forensic tools and doesn't actually sanitize the drive.

Question #443

A company that has a large IT operation is looking to better control, standardize, and lower the time required to build new servers.

Which of the following architectures will best achieve the company's objectives?

A. IoT
B. IaC
C. IaaS
D. ICS

Correct Answer: B — IaC

Infrastructure as Code (IaC) allows companies to define and provision infrastructure through code, which standardizes server builds, reduces manual errors, speeds up deployment, and enables version control and repeatability. This directly addresses the company's goals of better control, standardization, and reduced build time.

Why The Other Options Are Incorrect

A. IoT (Internet of Things) focuses on connected devices and sensors, not server infrastructure management.

C. IaaS (Infrastructure as a Service) is a cloud service model that doesn't inherently provide the standardization and control benefits of IaC.

D. ICS (Industrial Control Systems) refers to systems that manage physical processes, not IT server infrastructure.

Question #444

A government official receives a blank envelope containing photos and a note instructing the official to wire a large sum of money by midnight to prevent the photos from being leaked on the internet.

Which of the following best describes the threat actor's intent?

A. Organized crime
B. Philosophical beliefs
C. Espionage
D. Blackmail

Correct Answer: D — Blackmail

The scenario describes blackmail: the threat actor is using stolen or compromising information (photos) as leverage to extort money from the victim under threat of public disclosure. This is the textbook definition of blackmail/extortion.

Why The Other Options Are Incorrect

A. Organized crime is a broader category and doesn't specifically describe the extortion method being used.

B. Philosophical beliefs do not apply to this financially motivated extortion scenario.

C. Espionage involves stealing information for a government or competitor, not extorting money from individuals.

Question #445

Which of the following is the best security reason for closing service ports that are not needed?

A. To mitigate risks associated with unencrypted traffic
B. To eliminate false positives from a vulnerability scan
C. To reduce a system's attack surface
D. To improve a system's resource utilization

Correct Answer: C — To reduce a system's attack surface

Closing unnecessary service ports directly reduces a system's attack surface by eliminating potential entry points for attackers. Fewer open ports mean fewer services that could be exploited, which is a fundamental security principle for defense.

Why The Other Options Are Incorrect

A. While encryption helps protect traffic, closing ports addresses availability of services

rather than traffic encryption specifics.

B. Reducing false positives from vulnerability scans is a side effect, not the primary security reason for closing ports.

D. Improving resource utilization is a performance benefit, not a security reason.

Question #446

Which of the following would a security administrator use to comply with a secure baseline during a patch update?

A. Information security policy
B. Service-level expectations
C. Standard operating procedure
D. Test result report

Correct Answer: C — Standard operating procedure

A Standard Operating Procedure (SOP) provides the specific, detailed steps and requirements for executing patch updates while maintaining a secure baseline. SOPs document the exact processes to follow to ensure compliance with security standards during patching.

Why The Other Options Are Incorrect

A. Information security policy sets high-level guidelines but doesn't provide the specific operational procedures for patch updates.

B. Service-level expectations define performance targets, not procedural compliance steps for patching.

D. Test result reports document outcomes after testing, not the procedures to follow during patch updates.

Question #447

A malicious actor conducted a brute-force attack on a company's web servers and eventually gained access to the company's customer information database.

Which of the following is the most effective way to prevent similar attacks?

A. Regular patching of servers
B. Web application firewalls
C. Multifactor authentication
D. Enabling encryption of customer data

Correct Answer: C — Multifactor authentication

Multifactor authentication (MFA) is the most effective defense against brute-force attacks because even if an attacker correctly guesses or cracks a password, they cannot gain access without the second authentication factor. This directly prevents unauthorized access regardless of password strength.

Why The Other Options Are Incorrect

A. Regular patching addresses known vulnerabilities but does not prevent brute-force password attacks.

B. Web application firewalls can help but may not be as effective as MFA at preventing brute-force login attempts.

D. Encrypting customer data protects data at rest but does not prevent the initial brute-force attack or unauthorized access.

Question #448

Which of the following options will provide the lowest RTO and RPO for a database?

A. Snapshots
B. On-site backups
C. Journaling
D. Hot site

Correct Answer: D — Hot site

A hot site provides the lowest RTO (Recovery Time Objective) and RPO (Recovery Point Objective) because it maintains a fully operational backup system that is continuously synchronized with the primary system, allowing for immediate failover with minimal data loss and downtime.

Why The Other Options Are Incorrect

A. Snapshots provide point-in-time recovery but require time to restore, resulting in higher RTO than a hot site.

B. On-site backups require restoration time and may not be continuously synchronized, resulting in higher RTO and RPO than a hot site.

C. Journaling provides transaction logging but still requires recovery processes that take longer than immediate hot site failover.

Question #449

Which of the following is a possible consequence of a VM escape?

A. Malicious instructions can be inserted into memory and give the attacker elevated permissions.
B. An attacker can access the hypervisor and compromise other VMs.

C. Unencrypted data can be read by a user who is in a separate environment.

D. Users can install software that is not on the manufacturer's approved list.

✅ Correct Answer: B — An attacker can access the hypervisor and compromise other VMs.

A VM escape is a vulnerability that allows an attacker to break out of a virtual machine and access the underlying hypervisor. Once the hypervisor is compromised, the attacker can access and compromise other VMs running on the same physical host, making this the most severe consequence.

Why The Other Options Are Incorrect

A. While memory injection is a possible attack technique, it's not specifically the consequence of a VM escape.

C. VM escape does not inherently allow reading unencrypted data across separate environments; it allows hypervisor access.

D. Unauthorized software installation is a separate security control issue unrelated to VM escape consequences.

Question #450

A security team at a large, global company needs to reduce the cost of storing data used for performing investigations.

Which of the following types of data should have its retention length reduced?

A. Packet capture

B. Endpoint logs

C. OS security logs

D. Vulnerability scan

✅ Correct Answer: A — Packet capture

Packet capture data generates very large volumes of storage and is primarily useful for immediate incident response and investigation. It can be safely discarded after a shorter retention period compared to logs, making it the best candidate for retention reduction to lower storage costs.

Why The Other Options Are Incorrect

B. Endpoint logs are essential for long-term security investigations, compliance, and audit trails and should be retained longer.

C. OS security logs provide critical historical records for security investigations and compliance and should be retained longer.

D. Vulnerability scan results are important for compliance and tracking remediation over time and should be retained longer.

Question #451

Which of the following is a type of vulnerability that involves inserting scripts into web-based applications in order to take control of the client's web browser?

A. SQL injection
B. Cross-site scripting
C. Zero-day exploit
D. On-path attack

Correct Answer: B — Cross-site scripting

Cross-site scripting (XSS) is specifically the vulnerability type where an attacker injects malicious scripts into web applications to compromise the client's browser, steal data, or perform actions on behalf of the user. This is the defining characteristic of XSS attacks.

Why The Other Options Are Incorrect

A. SQL injection targets databases through improper input handling, not browser control.

C. Zero-day exploits are previously unknown vulnerabilities, not a specific attack method like script injection.

D. On-path attacks intercept communications between parties but don't involve script injection into web applications.

Daily Debian

Question #452

While investigating a possible incident, a security analyst discovers the following:

```
67.118.34.157 - - [28/Jul/2022:10:26:59 -0300] "GET /query.php?q=wireless%20headphones / HTTP/1.0" 200 12737
132.18.222.103 - - [28/Jul/2022:10:27:10 -0300] "GET /query.php?q=123'';INSERT INTO users VALUES('temp','pass123')# /
HTTP/1.0" 200 935
12.45.101.121 - - [28/Jul/2022:10:27:22 -0300] "GET /query.php?q=mp3%20players / HTTP/1.0" 200 14650
```

Which of the following should the analyst do first?

A. Implement a WAF.
B. Disable the query.php script.
C. Block brute-force attempts on temporary users.
D. Check the users table for new accounts.

Correct Answer: D — Check the users table for new accounts.

The log entries show SQL injection attempts where an attacker is inserting malicious SQL commands through the query.php script, specifically attempting to insert a new user account ('temp', 'pass123') into the users table. When investigating a security incident, the

first priority is to assess the scope and impact of the compromise by determining what damage has already been done. Checking the users table for new/unauthorized accounts is the immediate triage step to understand if the injection was successful and what accounts may have been created. After understanding the current state, then remediation steps like disabling the script, implementing WAF, or blocking attempts would follow.

Why The Other Options Are Incorrect

A. Implementing a WAF is a remediation measure that should come after understanding the scope of the incident, not as the first step.

B. Disabling the script is a containment step but doesn't address the immediate need to assess what unauthorized access may have already occurred.

C. Blocking brute-force attempts assumes the attack is ongoing; the first step is to verify if the injection succeeded in creating accounts.

Question #453

Due to a cyberattack, a company's IT systems were not operational for an extended period of time. The company wants to measure how quickly the systems must be restored in order to minimize business disruption.

Which of the following would the company most likely use?

A. Recovery point objective
B. Risk appetite
C. Risk tolerance
D. Recovery time objective
E. Mean time between failure

Daily Debian

Correct Answer: D — Recovery time objective

Recovery Time Objective (RTO) specifically measures the maximum acceptable downtime for a system and how quickly it must be restored to minimize business disruption. This directly addresses the company's goal of measuring restoration speed after an outage.

Why The Other Options Are Incorrect

A. Recovery Point Objective (RPO) measures acceptable data loss, not restoration speed.

B. Risk appetite is an organization's willingness to accept risk in pursuit of objectives, unrelated to recovery speed.

C. Risk tolerance is similar to risk appetite and doesn't measure system restoration time.

E. Mean Time Between Failure (MTBF) measures reliability/uptime intervals, not recovery speed after failure.

Question #454

Which of the following actors attacking an organization is the most likely to be motivated by personal beliefs?

A. Nation-state
B. Organized crime
C. Hacktivist
D. Insider threat

Correct Answer: C — Hacktivist

Hacktivists are primarily motivated by personal or political beliefs, seeking to promote a cause or ideology through cyber attacks. They attack organizations whose policies or practices conflict with their worldview, making belief-driven motivation their defining characteristic.

Why The Other Options Are Incorrect

A. Nation-states are motivated by geopolitical interests and national security objectives.

B. Organized crime is motivated by financial gain and profit.

D. Insider threats may have various motivations (financial, revenge, coercion) but aren't primarily defined by personal beliefs.

Question #455

Which of the following should a security team use to document persistent vulnerabilities with related recommendations?

A. Audit report
B. Risk register
C. Compliance report
D. Penetration test

Correct Answer: B — Risk register

A risk register is the appropriate tool for documenting persistent vulnerabilities along with associated recommendations, mitigation strategies, and risk ratings. It serves as a central record for tracking and managing identified risks throughout the organization.

Why The Other Options Are Incorrect

A. An audit report documents the results of an audit but is not the primary tool for tracking persistent vulnerabilities and recommendations.

C. A compliance report focuses on adherence to regulatory requirements, not on documenting individual vulnerabilities.

D. A penetration test is a testing activity that may identify vulnerabilities but is not the

documentation mechanism for tracking them with recommendations.

Question #456

An organization purchased a critical business application containing sensitive data. The organization would like to ensure that the application is not exploited by common data exfiltration attacks.

Which of the following approaches would best help to fulfill this requirement?

A. URL scanning
B. WAF
C. Reverse proxy
D. NAC

Correct Answer: B — WAF

A Web Application Firewall (WAF) is specifically designed to protect web applications from common attacks including data exfiltration attempts by filtering malicious requests and responses based on rules that identify attack patterns and suspicious data flows.

Why The Other Options Are Incorrect

A. URL scanning inspects URLs for malware but doesn't prevent data exfiltration attacks.

C. A reverse proxy provides load balancing and can add some security but is not specifically designed to prevent data exfiltration.

D. Network Access Control (NAC) manages device access to the network but doesn't protect against application-level data exfiltration attacks.

Question #457

A company wants to improve the availability of its application with a solution that requires minimal effort in the event a server needs to be replaced or added.

Which of the following would be the best solution to meet these objectives?

A. Load balancing
B. Fault tolerance
C. Proxy servers
D. Replication

Correct Answer: A — Load balancing

Load balancing distributes traffic across multiple servers and automatically handles server replacement or addition with minimal effort, as the load balancer can dynamically adjust to

include new servers or remove failed ones without manual intervention or application downtime.

Why The Other Options Are Incorrect

B. Fault tolerance requires redundant systems and complex configuration, typically requiring more effort than load balancing.

C. Proxy servers improve performance and security but don't directly address the ease of server replacement.

D. Replication copies data but requires significant effort to manage server replacement and failover processes.

Question #458

A company is performing a risk assessment on new software the company plans to use.

Which of the following should the company assess during this process?

A. Software vulnerabilities
B. Cost-benefit analysis
C. Ongoing monitoring strategies
D. Network infrastructure compatibility

Correct Answer: A — Software vulnerabilities

During a risk assessment of new software, the company must assess software vulnerabilities to understand potential security weaknesses and their impact on the organization. This is a core component of evaluating the security risks associated with new applications.

Why The Other Options Are Incorrect

B. Cost-benefit analysis is part of risk response decisions, not the initial risk assessment phase.

C. Ongoing monitoring strategies are developed after risk assessment during the response and implementation phase.

D. Network infrastructure compatibility is a technical fit assessment but not a risk assessment component.

Question #459

A malicious actor is trying to access sensitive financial information from a company's database by intercepting and reusing log-in credentials.

Which of the following attacks is the malicious actor attempting?

A. SQL injection

B. On-path
C. Brute-force
D. Password spraying

Correct Answer: B — On-path

Intercepting credentials as they are transmitted and then reusing them describes an on-path (man-in-the-middle) attack, where the attacker positions themselves between the client and server to capture the authentication traffic and subsequently replay or reuse the captured credentials to reach the database.

Why The Other Options Are Incorrect

A. SQL injection inserts crafted query statements into input fields; it does not involve intercepting credentials in transit.

C. A brute-force attack systematically guesses passwords rather than capturing legitimate ones from the network.

D. Password spraying tries a few common passwords against many accounts, again a guessing technique rather than interception and reuse.

Question #460

A new employee accessed an unauthorized website. An investigation found that the employee violated the company's rules.

Which of the following did the employee violate?

A. MOU
B. AUP
C. NDA
D. MOA

Correct Answer: B — AUP

An Acceptable Use Policy (AUP) defines what employees can and cannot do with company resources and networks. Accessing unauthorized websites violates the AUP, which is the specific policy document that governs employee behavior regarding technology use. The AUP is the most direct match for this scenario.

Why The Other Options Are Incorrect

A. An MOU (Memorandum of Understanding) is a general agreement between parties, not a specific policy governing employee conduct.

C. An NDA (Non-Disclosure Agreement) protects confidential information, not internet usage behavior.

D. An MOA (Memorandum of Agreement) is similar to an MOU and does not address

acceptable technology usage.

Question #461

A systems administrator is reviewing the VPN logs and notices that during non-working hours a user is accessing the company file server and information is being transferred to a suspicious IP address.

Which of the following threats is most likely occurring?

A. Typosquatting
B. Root or trust
C. Data exfiltration
D. Blackmail

Correct Answer: C — Data exfiltration

Data exfiltration is the unauthorized transfer of data from a company's systems to an external location. The scenario describes accessing the file server and transferring information to a suspicious IP address outside of working hours, which is the classic pattern of data exfiltration, likely involving a compromised or malicious user account.

Why The Other Options Are Incorrect

A. Typosquatting involves registering misspelled domain names to trick users; this is not relevant to file server access logs.

B. Root or trust attacks involve exploiting trust relationships or gaining root access, not the lateral movement and data transfer described here.

D. Blackmail would involve threatening the company, not the systematic transfer of data from internal systems.

Question #462

HOTSPOT

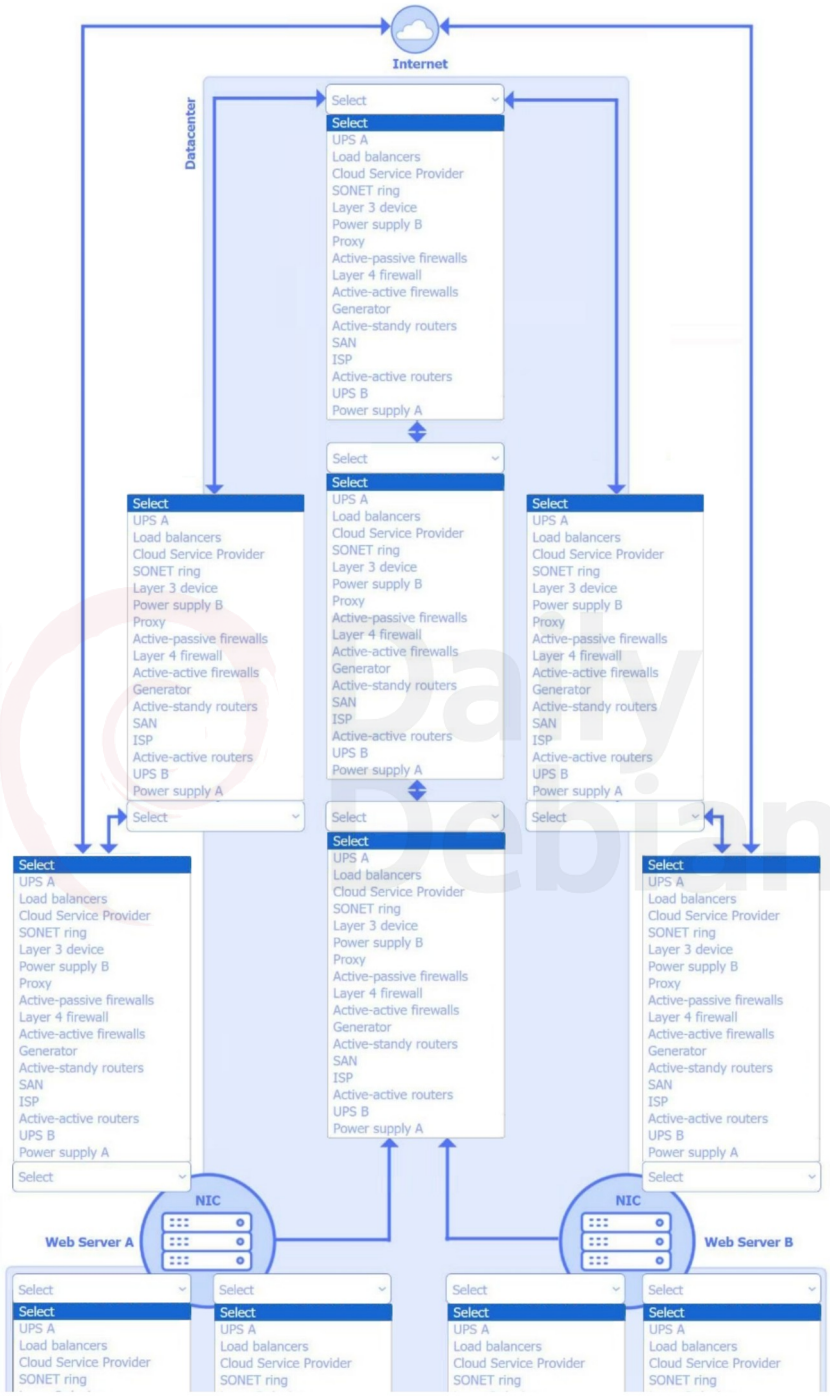
A security architect is tasked with designing a highly resilient, business-critical application. The application SLA is 99.999%.

INSTRUCTIONS

Select the network, power, and server components for the appropriate locations to achieve application resiliency.

A component should be selected for each location, and components may be selected more than once.

If at any time you would like to bring back the initial state of the simulation, please click the Reset All button.



Completed Answer

Choose the redundant network, power, and server components for each dropdown

location in the datacenter diagram so the application can meet a 99.999% SLA.

Top dropdown (Internet edge) → Active-active routers
Middle tier left dropdown → Active-active firewalls
Middle tier center dropdown → Active-active firewalls
Middle tier right dropdown → Active-active routers
Lower tier left dropdown → Load balancers
Lower tier center dropdown → Load balancers
Lower tier right dropdown → Load balancers
Web Server A second power dropdown → Power supply B
Web Server B second power dropdown → Power supply B

How To Work It Out

1. Recognize that a 99.999% SLA allows roughly five minutes of downtime per year, so every layer between the Internet and the web servers must have no single point of failure.

2. At the Internet boundary the diagram shows two ISP feeds converging, so the edge devices must be routers configured active-active so both paths carry traffic and either can fail without an outage.

3. Behind the edge, the redundant paths pass through firewalls deployed active-active (and a second active-active router pair on the alternate path) so security inspection is duplicated rather than failing over with a delay.

4. The tier directly above the two web servers must distribute sessions across Web Server A and Web Server B, which is the job of load balancers, placed on each redundant path.

5. Each web server is dual-fed, so after the first supply is used the second dropdown on each server takes Power supply B, giving both servers two independent power feeds.

Five-nines availability means the design cannot tolerate any single failed device, link, or feed, so each horizontal layer of the drawing is duplicated and both halves are kept in service simultaneously. The Internet edge uses active-active routers so the two ISP connections are both live; the next layer uses active-active firewalls (and a second active-active router pair on the parallel path) so inspection continues instantly if one unit dies instead of waiting for a passive node to take over. Immediately in front of the servers, load balancers spread client sessions over Web Server A and Web Server B and remove a failed server from rotation automatically. Finally, the servers themselves are protected internally: each one is wired to two separate power supplies, so selecting Power supply B for the second feed on each server means the loss of one supply or one power path does not take the application offline.

Question #463

A company discovers suspicious transactions that were entered into the company's database and attached to a user account that was created as a trap for malicious activity.

Which of the following is the user account an example of?

A. Honeytoken
B. Honeynet
C. Honeypot
D. Honeyfile

Correct Answer: A — Honeytoken

A honeytoken is a piece of fake data or a fake user account created as a trap to detect unauthorized access or misuse. When suspicious transactions appear attached to a user account intentionally created to catch malicious activity, that account is functioning as a honeytoken. The fake data triggered an alert when accessed, revealing the attacker's activity.

Why The Other Options Are Incorrect

B. A honeynet is an entire decoy network designed to attract and study attackers, not a single user account.

C. A honeypot is a decoy system or service designed to be compromised, not specifically a database user account with fake transactions.

D. A honeyfile is a decoy file designed to be accessed by attackers; while similar in concept, a user account with transactions is more accurately called a honeytoken.

Question #464

A network engineer is increasing the overall security of network devices and needs to harden the devices.

Which of the following will best accomplish this task?

A. Configuring centralized logging
B. Generating local administrator accounts
C. Replacing Telnet with SSH
D. Enabling HTTP administration

Correct Answer: C — Replacing Telnet with SSH

Replacing Telnet with SSH is a fundamental hardening measure because SSH encrypts the communication channel and provides secure authentication, while Telnet transmits credentials in plain text. This directly improves device security by eliminating a critical

vulnerability. SSH is industry-standard for secure remote device administration.

Why The Other Options Are Incorrect

A. Centralized logging improves monitoring and incident response but does not directly harden devices themselves.

B. Generating local administrator accounts creates additional access points and actually increases security risk rather than hardening devices.

D. Enabling HTTP administration is insecure and reduces hardening; HTTP transmits data unencrypted, making it a security liability.

Question #465

A company's accounting department receives an urgent payment message from the company's bank domain with instructions to wire transfer funds. The sender requests that the transfer be completed as soon as possible.

Which of the following attacks is described?

A. Business email compromise
B. Vishing
C. Spear phishing
D. Impersonation

Correct Answer: A — Business email compromise

Business Email Compromise (BEC) is a specific attack type where attackers impersonate company executives or trusted external parties (like banks) via email to trick employees into transferring funds or revealing sensitive information. The scenario describes receiving an urgent message impersonating the company's bank with wire transfer instructions, which is the classic BEC attack pattern.

Why The Other Options Are Incorrect

B. Vishing is a voice-based phishing attack using phone calls, not email messages.

C. Spear phishing is targeted phishing against specific individuals, but BEC is more specific to financial fraud impersonating trusted business partners.

D. Impersonation is a general category that BEC falls under, but BEC is the specific attack type for business-targeted financial fraud.

Question #466

A company filed a complaint with its IT service provider after the company discovered the service provider's external audit team had access to some of the company's confidential information.

Which of the following is the most likely reason the company filed the complaint?

A. The MOU had basic clauses from a template.
B. A SOW had not been agreed to by the client.
C. A WO had not been mutually approved.
D. A required NDA had not been signed.

Correct Answer: D — A required NDA had not been signed.

An NDA (Non-Disclosure Agreement) is a legal contract that restricts third parties, including service provider audit teams, from accessing or sharing confidential information. The company's complaint about the audit team accessing confidential information indicates that a required NDA was not signed, which would have contractually prohibited such unauthorized access and provided legal recourse.

Why The Other Options Are Incorrect

A. An MOU with basic template clauses might be insufficient but does not specifically address confidential information protection the way an NDA does.

B. A SOW (Statement of Work) defines the scope of services to be performed, not confidentiality restrictions on third-party access.

C. A WO (Work Order) is a specific request for work but does not address confidentiality or third-party access restrictions.

Question #467

Which of the following aspects of the data management life cycle is most directly impacted by local and international regulations?

A. Destruction
B. Certification
C. Retention
D. Sanitization

Correct Answer: C — Retention

Data retention is most directly impacted by local and international regulations because many compliance frameworks (GDPR, HIPAA, SOX, industry-specific regulations) mandate how long different types of data must be kept. These regulations specify retention periods, which directly control this phase of the data lifecycle. Destruction, certification, and sanitization are influenced by retention decisions.

Why The Other Options Are Incorrect

A. Destruction is governed by regulations but is a consequence of retention policies, not the most directly impacted phase.

B. Certification is not a standard phase of the data management lifecycle and is not

primarily driven by regulations.

D. Sanitization is important for security and compliance but is not as directly impacted by regulations as retention requirements are.

Question #468

An analyst is reviewing job postings to ensure sensitive company information is not being shared with the general public.

Which of the following is the analyst most likely looking for?

A. Office addresses
B. Software versions
C. List of board members
D. Government identification numbers

Correct Answer: B — Software versions

Software versions are sensitive technical information that should not be disclosed in job postings because they reveal the company's technology stack, vulnerabilities, and security posture to potential attackers. Disclosing specific software versions helps attackers research known exploits for those versions. This is a common information disclosure mistake in public job postings.

Why The Other Options Are Incorrect

A. Office addresses are generally public information and are often listed in job postings without significant security risk.

C. Board member lists are typically public information available through corporate filings and do not directly impact technical security.

D. Government identification numbers would be extremely sensitive, but they would rarely appear in job postings; software versions are more likely and more commonly disclosed inappropriately.

Question #469

An engineer has ensured that the switches are using the latest OS, the servers have the latest patches, and the endpoints' definitions are up to date.

Which of the following will these actions most effectively prevent?

A. Zero-day attacks
B. Insider threats
C. End-of-life support
D. Known exploits

Correct Answer: D — Known exploits

Latest OS updates, server patches, and endpoint definitions directly address known vulnerabilities and exploits that have been discovered and documented. These actions prevent attackers from using publicly disclosed exploits. Zero-day attacks by definition use unknown vulnerabilities, insider threats are not prevented by patches, and end-of-life support is a separate lifecycle issue.

Why The Other Options Are Incorrect

A. Zero-day attacks use unknown vulnerabilities not covered by patches or updates

B. Insider threats are caused by authorized users and cannot be prevented by OS/patch updates

C. End-of-life support is a vendor lifecycle issue, not prevented by updating current systems

Question #470

Which of the following is most likely a security concern when installing and using low-cost IoT devices in infrastructure environments?

A. Country of origin
B. Device responsiveness
C. Ease of deployment
D. Storage of data

Correct Answer: D — Storage of data

Low-cost IoT devices commonly lack robust security features, secure data handling practices, and encryption capabilities. Insecure storage and transmission of data represents the most significant security concern in infrastructure environments where sensitive operational data may be exposed. Country of origin, device responsiveness, and ease of deployment are not primary security concerns compared to data handling risks.

Why The Other Options Are Incorrect

A. Country of origin is a supply chain consideration but not the primary security concern for IoT devices

B. Device responsiveness is a performance metric, not a security concern

C. Ease of deployment is operational convenience, not a security issue

Question #471

A company captures log-in details and reviews them each week to identify conditions such as excessive log-in attempts and frequent lockouts.

Which of the following should a security analyst recommend to improve security compliance monitoring?

A. Including the date and person who reviewed the information in a report
B. Adding automated alerting when anomalies occur
C. Requiring a statement each week that no exceptions were noted
D. Masking the username in a report to protect privacy

✅ Correct Answer: B — Adding automated alerting when anomalies occur

Automated alerting for anomalies transforms reactive weekly reviews into proactive detection, enabling immediate response to suspicious activities like excessive login attempts or lockouts. This significantly improves security posture by detecting threats in real-time rather than waiting for manual weekly analysis. The other options do not improve the core monitoring capability—they address documentation, completeness statements, or privacy separately.

Why The Other Options Are Incorrect

A. Documenting who reviewed logs is administrative tracking, not an improvement to detection capability

C. Requiring exception statements does not enable faster detection of security anomalies

D. Masking usernames helps with privacy but does not improve the security monitoring process itself

Daily Debian

Question #472

A security team is in the process of hardening the network against externally crafted malicious packets.

Which of the following is the most secure method to protect the internal network?

A. Anti-malware solutions
B. Host-based firewalls
C. Intrusion prevention systems
D. Network access control
E. Network allow list

✅ Correct Answer: C — Intrusion prevention systems

Intrusion Prevention Systems (IPS) actively analyze network traffic in real-time, detecting and blocking malicious packets based on signatures and behavioral analysis before they reach the internal network. This provides the most comprehensive protection against externally crafted malicious packets. Anti-malware is host-based, firewalls focus on access control, NAC addresses device access, and allow lists require prior knowledge of all

legitimate traffic.

Why The Other Options Are Incorrect

A. Anti-malware operates at the host level and primarily addresses malware after execution, not packet filtering

B. Host-based firewalls protect individual systems but do not prevent malicious packets from entering the network

D. Network access control verifies device identity but does not inspect packet content for malicious payloads

E. Allow lists require knowing all legitimate traffic patterns in advance and are difficult to maintain in complex networks

Question #473

Which of the following is the best way to prevent an unauthorized user from plugging a laptop into an employee's phone network port and then using tools to scan for database servers?

A. MAC filtering
B. Segmentation
C. Certification
D. Isolation

Daily Debian

Correct Answer: A — MAC filtering

MAC (Media Access Control) filtering prevents unauthorized devices from connecting to network ports by only allowing known MAC addresses to access the phone network. This directly prevents an unknown laptop from connecting to the employee's port and scanning the network. Segmentation and isolation are broader network controls but do not specifically prevent unauthorized physical connections, and certification is not a port-level access control mechanism.

Why The Other Options Are Incorrect

B. Segmentation separates networks but does not prevent an unauthorized device from plugging into a port within a segment

C. Certification is a credential mechanism, not a method to prevent unauthorized physical port access

D. Isolation is similar to segmentation and does not prevent the initial unauthorized port connection

Question #474

Which of the following should a systems administrator use to decrease the company's hardware attack surface?

A. Replication
B. Isolation
C. Centralization
D. Virtualization

✅ Correct Answer: D — Virtualization

Virtualization decreases hardware attack surface by consolidating multiple physical servers onto fewer physical machines through virtual instances. This reduces the number of physical devices that could be compromised, simplifies hardware management, and centralizes security controls. Replication increases the number of targets, isolation does not reduce physical hardware count, and centralization is a management approach rather than an attack surface reduction technique.

Why The Other Options Are Incorrect

A. Replication creates additional copies of systems, increasing rather than decreasing the attack surface

B. Isolation separates systems but does not reduce the number of physical hardware devices

C. Centralization is a management strategy but does not inherently decrease the physical hardware attack surface

Daily Debian

Question #475

A company wants to add an MFA solution for all employees who access the corporate network remotely. Log-in requirements include something you know, are, and have. The company wants a solution that does not require purchasing third-party applications or specialized hardware.

Which of the following MFA solutions would best meet the company's requirements?

A. Smart card with PIN and password
B. Security questions and a one-time passcode sent via email
C. Voice and fingerprint verification with an SMS one-time passcode
D. Mobile application-generated, one-time passcode with facial recognition

✅ Correct Answer: D — Mobile application-generated, one-time passcode with facial recognition

A mobile application-generated one-time passcode with facial recognition satisfies all three MFA requirements (something you know via the app setup, something you are via facial

recognition, and something you have as the mobile device) without requiring third-party applications to be purchased or specialized hardware. Modern smartphones have built-in facial recognition and can generate OTPs through native or pre-installed apps. Smart cards require specialized hardware, security questions lack strong factors, and voice verification may require additional hardware.

Why The Other Options Are Incorrect

A. Smart card with PIN requires purchasing specialized hardware tokens

B. Security questions are weak factors and email OTPs do not fully satisfy the three requirements effectively

C. Voice verification may require specialized microphone hardware and SMS incurs carrier costs

Question #476

A company is using a legacy FTP server to transfer financial data to a third party. The legacy system does not support SFTP, so a compensating control is needed to protect the sensitive, financial data in transit.

Which of the following would be the most appropriate for the company to use?

A. Telnet connection
B. SSH tunneling
C. Patch installation
D. Full disk encryption

Daily Debian

✅ Correct Answer: B — SSH tunneling

SSH tunneling creates an encrypted tunnel through which the legacy FTP connection can pass, protecting sensitive financial data in transit without modifying the FTP server itself. This is the ideal compensating control when SFTP is unavailable. Telnet is unencrypted, patch installation cannot be applied to unsupported legacy systems, and disk encryption protects data at rest, not in transit.

Why The Other Options Are Incorrect

A. Telnet is unencrypted and provides no protection for data in transit

C. Patches cannot be installed on legacy systems that no longer receive support

D. Full disk encryption protects data at rest on the server, not data in transit across the network

Question #477

A security manager wants to reduce the number of steps required to identify and contain basic threats.

Which of the following will help achieve this goal?

A. SOAR
B. SIEM
C. DMARC
D. NIDS

✅ Correct Answer: A — SOAR

SOAR (Security Orchestration, Automation and Response) is specifically designed to reduce manual steps in threat identification and containment by automating incident response workflows. SIEM collects and analyzes logs but requires manual investigation; DMARC is an email authentication protocol; NIDS is a network detection tool that only identifies threats without automating response.

Why The Other Options Are Incorrect

B. SIEM identifies threats but does not automate response procedures.

C. DMARC is an email authentication protocol unrelated to threat containment.

D. NIDS detects intrusions but does not automate response or containment.

Question #478

The Chief Information Officer (CIO) asked a vendor to provide documentation detailing the specific objectives within the compliance framework that the vendor's services meet. The vendor provided a report and a signed letter stating that the services meet 17 of the 21 objectives.

Which of the following did the vendor provide to the CIO?

A. Penetration test results
B. Self-assessment findings
C. Attestation of compliance
D. Third-party audit report

✅ Correct Answer: C — Attestation of compliance

An attestation of compliance is a signed statement from a vendor certifying that their services meet specific compliance objectives. The vendor's signed letter stating compliance with 17 of 21 objectives is the definition of an attestation. Penetration tests measure security vulnerabilities, self-assessments are internal evaluations, and third-party audits provide independent verification but weren't described here.

Why The Other Options Are Incorrect

A. Penetration test results demonstrate vulnerabilities, not compliance with frameworks.

B. A self-assessment is an internal evaluation, not a vendor's formal signed statement.

D. A third-party audit is an independent verification, which differs from a vendor's self-attestation.

Question #479

Which of the following describes the most effective way to address OS vulnerabilities after they are identified?

A. Endpoint protection
B. Removal of unnecessary software
C. Configuration enforcement
D. Patching

Correct Answer: D — Patching

Patching is the most effective and direct way to address identified OS vulnerabilities by applying vendor-supplied fixes. Endpoint protection provides defense-in-depth but doesn't fix vulnerabilities; removal of unnecessary software reduces attack surface but doesn't fix existing vulnerabilities; configuration enforcement hardens systems but doesn't eliminate known flaws.

Why The Other Options Are Incorrect

A. Endpoint protection defends against exploitation but does not fix the underlying vulnerability.

B. Removing software reduces attack surface but does not address existing OS vulnerabilities.

C. Configuration enforcement hardens the system but does not eliminate identified vulnerabilities.

Daily Debian

Question #480

The management team reports that employees are missing features on company-provided tablets, which is causing productivity issues. The management team directs the IT team to resolve the issue within 48 hours.

Which of the following would be the best solution for the IT team to leverage in this scenario?

A. EDR
B. COPE
C. MDM
D. FDE

Correct Answer: C — MDM

MDM (Mobile Device Management) solutions allow IT teams to quickly manage and configure company tablets, install missing features or applications, and enforce policies across devices. EDR is for endpoint threat detection; COPE is for device provisioning architecture; FDE encrypts disks but does not add features or manage applications.

Why The Other Options Are Incorrect

A. EDR detects threats on endpoints but does not add features or manage device configuration.

B. COPE is a provisioning model, not a management tool for rapidly adding features.

D. FDE encrypts data but does not provide feature management or application installation capabilities.

Question #481

A company is implementing a policy to allow employees to use their personal equipment for work. However, the company wants to ensure that only company-approved applications can be installed.

Which of the following addresses this concern?

A. MDM
B. Containerization
C. DLP
D. FIM

Daily Debian

Correct Answer: A — MDM

MDM (Mobile Device Management) allows enterprises to enforce policies on personal devices, including application whitelisting and approval controls. This ensures only company-approved apps can be installed on BYOD (Bring Your Own Device) equipment. Containerization isolates company data but doesn't restrict applications; DLP prevents data leakage but doesn't control app installation; FIM monitors file integrity but doesn't manage applications.

Why The Other Options Are Incorrect

B. Containerization isolates data compartments but does not enforce application approval policies.

C. DLP prevents sensitive data exfiltration but does not control which applications can be installed.

D. FIM monitors file changes but does not provide application installation controls.

Question #482

An alert references attacks associated with a zero-day exploit. An analyst places a bastion host in the network to reduce the risk of the exploit.

Which of the following types of controls is the analyst implementing?

A. Compensating
B. Detective
C. Operational
D. Physical

Correct Answer: A — Compensating

A compensating control is implemented to reduce risk when a primary control cannot be applied or is ineffective. Placing a bastion host compensates for the inability to patch the zero-day vulnerability immediately, providing an alternative security layer. Detective controls identify threats; operational controls are procedural in nature; physical controls protect physical assets.

Why The Other Options Are Incorrect

B. Detective controls identify threats after they occur, not prevent them proactively.

C. Operational controls relate to procedures and management practices, not technical mitigation.

D. Physical controls protect tangible assets like buildings, not against software exploits.

Question #483

A penetration test has demonstrated that domain administrator accounts were vulnerable to pass-the-hash attacks.

Which of the following would have been the best strategy to prevent the threat actor from using domain administrator accounts?

A. Audit each domain administrator account weekly for password compliance.
B. Implement a privileged access management solution.
C. Create IDS policies to monitor domain controller access.
D. Use Group Policy to enforce password expiration.

Correct Answer: B — Implement a privileged access management solution.

PAM (Privileged Access Management) solutions prevent pass-the-hash attacks by controlling and monitoring privileged account usage, implementing credential management, session recording, and just-in-time access. Auditing credentials does not prevent attacks; IDS policies detect but don't prevent pass-the-hash; password expiration does not stop pass-the-hash attacks which use credential hashes rather than plaintext

passwords.

Why The Other Options Are Incorrect

A. Auditing passwords detects compliance issues but does not prevent pass-the-hash attacks.

C. IDS policies can monitor but do not prevent threat actors from using stolen credential hashes.

D. Password expiration does not prevent pass-the-hash since attackers use cached hashes, not passwords.

Question #484

Which of the following is an example of memory injection?

A. Two processes access the same variable, allowing one to cause a privilege escalation.

B. A process receives an unexpected amount of data, which causes malicious code to be executed.

C. Malicious code is copied to the allocated space of an already running process.

D. An executable is overwritten on the disk, and malicious code runs the next time it is executed.

✅ **Correct Answer: C — Malicious code is copied to the allocated space of an already running process.**

Memory injection is the technique of injecting malicious code into the address space of a running process without modifying the process executable. This allows code execution with the process's privileges while avoiding disk-based detection. Option A describes a race condition; Option B describes buffer overflow; Option D describes file-based malware execution.

Why The Other Options Are Incorrect

A. This describes a race condition or shared memory vulnerability, not memory injection.

B. This describes a buffer overflow attack, which is input validation vulnerability.

D. This describes modifying an executable on disk, which is not memory injection but disk-based malware.

Question #485

A security administrator is implementing encryption on all hard drives in an organization.

Which of the following security concepts is the administrator applying?

A. Integrity

B. Authentication
C. Zero Trust
D. Confidentiality

✅ Correct Answer: D — Confidentiality

Encryption protects data from unauthorized access or disclosure. This is the definition of confidentiality within the CIA triad. While encryption can support integrity through authentication mechanisms, its primary security function when applied to hard drives is to ensure that only authorized parties can read the data, which is confidentiality.

Why The Other Options Are Incorrect

A. Integrity ensures data has not been modified, which is a secondary benefit of some encryption schemes but not the primary purpose here.

B. Authentication verifies identity, not the protection of data from unauthorized reading.

C. Zero Trust is an architectural security model, not a specific security concept that encryption directly implements.

Question #486

An administrator has configured a quarantine subnet for all guest devices that connect to the network.

Which of the following would be best for the security team to perform before allowing access to corporate resources?

A. Device fingerprinting
B. Compliance attestation
C. Penetration test
D. Application vulnerability test

✅ Correct Answer: B — Compliance attestation

Compliance attestation verifies that a guest device meets the organization's security standards and policies before granting access to corporate resources. This is the standard checkpoint for quarantined devices and ensures the device complies with required security configurations, patch levels, and policies before being granted network access.

Why The Other Options Are Incorrect

A. Device fingerprinting identifies devices but does not validate whether they meet security compliance requirements.

C. Penetration testing is too invasive and time-consuming for routine guest device onboarding.

D. Application vulnerability testing is not appropriate for guest devices during initial

access control decisions.

Question #487

A customer has a contract with a CSP and wants to identify which controls should be implemented in the IaaS enclave.

Which of the following is most likely to contain this information?

A. Statement of work
B. Responsibility matrix
C. Service-level agreement
D. Master service agreement

Correct Answer: B — Responsibility matrix

A responsibility matrix clearly delineates which security controls are the responsibility of the CSP versus the customer in an IaaS environment. This document specifically addresses the division of security obligations and identifies which controls should be implemented in the IaaS enclave versus the customer's environment.

Why The Other Options Are Incorrect

A. Statement of work outlines project deliverables but not control responsibilities.

C. Service-level agreement defines performance metrics and uptime guarantees, not control implementation responsibility.

D. Master service agreement covers general terms and conditions but lacks the specific control responsibility detail needed for IaaS.

Question #488

A Chief Information Security Officer is developing procedures to guide detective and corrective activities associated with common threats, including phishing, social engineering, and business email compromise.

Which of the following documents would be most relevant to revise as part of this process?

A. SDLC
B. IRP
C. BCP
D. AUP

Correct Answer: B — IRP

An Incident Response Plan (IRP) is the appropriate document to revise when developing

procedures for detective and corrective activities related to security incidents like phishing, social engineering, and business email compromise. The IRP specifically guides how to detect, respond to, and correct security incidents.

Why The Other Options Are Incorrect

A. SDLC (Software Development Life Cycle) focuses on secure software development, not incident response procedures.

C. BCP (Business Continuity Plan) focuses on maintaining operations during disruptions, not incident response procedures.

D. AUP (Acceptable Use Policy) defines user conduct rules, not procedures for detecting and correcting active incidents.

Question #489

Which of the following testing techniques uses both defensive and offensive testing methodologies with developers to securely build key applications and software?

A. Blue
B. Yellow
C. Red
D. Green

Correct Answer: B — Yellow

Yellow team testing combines defensive (blue) and offensive (red) methodologies with developers to build secure applications. Yellow teams work collaboratively with development teams to integrate security practices throughout the application development process, combining both attack and defense perspectives.

Why The Other Options Are Incorrect

A. Blue team represents purely defensive security testing, not a combination of both methodologies.

C. Red team represents purely offensive security testing, not a combination with developers.

D. Green team is not a recognized security testing methodology in this context.

Question #490

An administrator wants to automate an account permissions update for a large number of accounts.

Which of the following would best accomplish this task?

A. Security groups

B. Federation
C. User provisioning
D. Vertical scaling

Correct Answer: C — User provisioning

User provisioning is the automated process of creating, updating, and managing user accounts and their associated permissions across systems. This directly addresses automating account permissions updates for large numbers of accounts, making it the best solution for this task.

Why The Other Options Are Incorrect

A. Security groups organize accounts but do not automate permission updates across multiple accounts.

B. Federation manages identity across organizations but is not the primary tool for automating permission updates.

D. Vertical scaling refers to increasing system resources, not account permission management.

Question #491

Which of the following is the fastest and most cost-effective way to confirm a third-party supplier's compliance with security obligations?

A. Attestation report
B. Third-party audit
C. Vulnerability assessment
D. Penetration testing

Correct Answer: A — Attestation report

An attestation report is the fastest and most cost-effective method to confirm a supplier's security compliance. The supplier provides a formal statement attesting to their compliance with security obligations, requiring minimal time and expense compared to full audits or testing, while still providing credible evidence.

Why The Other Options Are Incorrect

B. Third-party audits are comprehensive but significantly slower and more expensive than attestation.

C. Vulnerability assessments test technical security but do not comprehensively verify all compliance obligations.

D. Penetration testing is expensive, time-consuming, and focuses on technical vulnerabilities rather than overall compliance verification.

Question #492

Various company stakeholders meet to discuss roles and responsibilities in the event of a security breach that would affect offshore offices.

Which of the following is this an example of?

A. Tabletop exercise
B. Penetration test
C. Geographic dispersion
D. Incident response

Correct Answer: A — Tabletop exercise

A tabletop exercise is a discussion-based scenario where stakeholders meet to review their roles and responsibilities in response to a hypothetical security incident. This format allows teams to discuss procedures and coordination without requiring a full simulation, making it ideal for reviewing incident response plans and responsibility assignments.

Why The Other Options Are Incorrect

B. Penetration testing is a hands-on technical attack simulation, not a discussion of roles and responsibilities.

C. Geographic dispersion refers to physical distribution of resources, not an exercise or meeting format.

D. While this relates to incident response, 'incident response' alone does not describe the specific tabletop exercise format being conducted.

Question #493

Which of the following is an example of a data protection strategy that uses tokenization?

A. Encrypting databases containing sensitive data
B. Replacing sensitive data with surrogate values
C. Removing sensitive data from production systems
D. Hashing sensitive data in critical systems

Correct Answer: B — Replacing sensitive data with surrogate values

Tokenization is a data protection strategy that replaces sensitive data with non-sensitive substitute values called tokens. These tokens have no exploitable value outside their specific system and maintain referential integrity to the original data through a secure token vault. Option B directly describes this core function of tokenization.

Why The Other Options Are Incorrect

A. Encryption is a distinct data protection method that transforms data mathematically,

not through replacement with surrogate values.

C. Removing data from production is data minimization or archival, not tokenization.

D. Hashing is a one-way cryptographic function used for integrity verification, not a tokenization strategy.

Question #494

Which of the following is a type of vulnerability that refers to the unauthorized installation of applications on a device through means other than the official application store?

A. Cross-site scripting
B. Buffer overflow
C. Jailbreaking
D. Side loading

Correct Answer: D — Side loading

Side loading refers to the unauthorized installation of applications on a device through means other than the official application store, such as directly from a developer or third-party source. This bypasses security controls and validation processes of official app stores. Option D is the correct security terminology for this vulnerability vector.

Why The Other Options Are Incorrect

A. Cross-site scripting is a web application vulnerability involving malicious script injection, not application installation.

B. Buffer overflow is a memory corruption vulnerability that occurs during application execution, not installation.

C. Jailbreaking refers to removing OS-level restrictions to gain elevated privileges, not specifically to installing apps outside the store.

Question #495

Which of the following types of identification methods can be performed on a deployed application during runtime?

A. Dynamic analysis
B. Code review
C. Package monitoring
D. Bug bounty

Correct Answer: A — Dynamic analysis

Dynamic analysis is performed on a deployed application during runtime by executing the

code and observing its behavior, inputs, outputs, and responses. This allows identification of vulnerabilities that only manifest during execution. Option A is the standard security testing method performed on running applications.

Why The Other Options Are Incorrect

B. Code review is a static analysis technique performed on source code before deployment, not on deployed applications.

C. Package monitoring is a runtime observation technique but refers to monitoring package dependencies, not vulnerability identification methodology.

D. Bug bounty is a program structure for vulnerability disclosure, not a technical identification method.

Question #496

Which of the following cryptographic solutions is used to hide the fact that communication is occurring?

A. Steganography
B. Data masking
C. Tokenization
D. Private key

Correct Answer: A — Steganography

Steganography is the practice of hiding information within other innocuous data or media so that the very existence of communication is concealed. Unlike encryption which protects data content, steganography prevents detection that communication is occurring at all. Option A is the correct cryptographic solution for this purpose.

Why The Other Options Are Incorrect

B. Data masking obscures sensitive data values but doesn't hide the fact that communication is occurring.

C. Tokenization replaces sensitive data with tokens but doesn't conceal communication itself.

D. A private key is part of asymmetric cryptography used for encryption/decryption, not for hiding communication existence.

Question #497

Which of the following steps should be taken before mitigating a vulnerability in a production server?

A. Escalate the issue to the SDLC team.
B. Use the IR plan to evaluate the changes.

C. Perform a risk assessment to classify the vulnerability.

D. Refer to the change management policy.

Correct Answer: D — Refer to the change management policy.

Before mitigating a vulnerability in a production server, the change management policy must be consulted to ensure proper procedures, approvals, testing, and documentation are followed. This protects against unintended consequences and maintains organizational governance. Option D represents the foundational procedural step that should precede mitigation efforts.

Why The Other Options Are Incorrect

A. Escalating to the SDLC team may occur after following change management policy, not before mitigation.

B. Using the IR plan applies to incident response after a breach occurs, not to proactive vulnerability mitigation.

C. Risk assessment classification helps prioritize which vulnerabilities to address but doesn't precede the change management policy requirement.

Question #498

A security engineer needs to quickly identify a signature from a known malicious file.

Which of the following analysis methods would the security engineer most likely use?

A. Static

B. Sandbox

C. Network traffic

D. Package monitoring

Correct Answer: A — Static

Static analysis involves examining a malicious file without executing it, allowing quick identification of file signatures, hashes, metadata, and structural patterns. This is the fastest method to identify a known malicious file signature without the risks or overhead of sandbox execution. Option A is the most appropriate for rapid signature identification.

Why The Other Options Are Incorrect

B. Sandbox analysis requires executing the file in an isolated environment, which is slower and unnecessary for known signature matching.

C. Network traffic analysis observes communication patterns but doesn't directly identify file signatures.

D. Package monitoring examines dependencies and package integrity but isn't the primary method for known malware signature identification.

Question #499

Which of the following should a company use to provide proof of external network security testing?

A. Business impact analysis
B. Supply chain analysis
C. Vulnerability assessment
D. Third-party attestation

Correct Answer: D — Third-party attestation

Third-party attestation provides formal proof and documentation from independent external auditors or certified security professionals that network security testing has been performed. This creates objective, credible evidence of compliance and security posture to stakeholders and regulatory bodies. Option D is the appropriate documentation for external network security testing proof.

Why The Other Options Are Incorrect

A. Business impact analysis assesses consequences of security incidents but doesn't prove external testing was conducted.

B. Supply chain analysis evaluates vendor security practices but doesn't serve as proof of the company's own network security testing.

C. Vulnerability assessment is a security testing activity itself, not the proof or documentation of having performed such testing.

Daily Debian

Question #500

A security administrator is addressing an issue with a legacy system that communicates data using an unencrypted protocol to transfer sensitive data to a third party. No software updates that use an encrypted protocol are available, so a compensating control is needed.

Which of the following are the most appropriate for the administrator to suggest? (Choose two.)

A. Tokenization
B. Cryptographic downgrade
C. SSH tunneling
D. Segmentation
E. Patch installation
F. Data masking

Correct Answer: C, D

C. SSH tunneling

D. Segmentation

SSH tunneling creates an encrypted tunnel to protect data in transit when the legacy protocol cannot be updated, providing encryption at the transport layer. Network segmentation isolates the legacy system to limit exposure and reduce the impact of potential data interception. Together, these compensating controls address the vulnerability of unencrypted protocol communication without requiring software updates. Options C and D are the most appropriate technical mitigations.

Why The Other Options Are Incorrect

A. Tokenization protects data at rest or during storage but doesn't address the unencrypted transmission protocol problem.

B. Cryptographic downgrade weakens security further and is the opposite of a compensating control.

E. Patch installation is not available according to the scenario, so this cannot be implemented.

F. Data masking obscures sensitive data values but doesn't encrypt the unencrypted protocol transmission itself.

Question #501

Which of the following steps in the risk management process involves establishing the scope and potential risks involved with a project?

A. Risk assessment

B. Risk identification

C. Risk treatment

D. Risk monitoring and review

Correct Answer: B — Risk identification

Risk identification is the step in the risk management process where the scope is established and potential risks involved with a project are identified. This is the foundational step that comes before assessment, treatment, and monitoring.

Why The Other Options Are Incorrect

A. Risk assessment evaluates identified risks for severity and likelihood, not the initial scoping.

C. Risk treatment involves developing responses to risks after they have been identified.

D. Risk monitoring and review tracks risks throughout the project lifecycle after identification.

Question #502

A company's website is www.company.com. Attackers purchased the domain www.c0mpany.com.

Which of the following types of attacks describes this example?

A. Typosquatting
B. Brand impersonation
C. On-path
D. Watering-hole

Correct Answer: A — Typosquatting

Typosquatting is the practice of registering domain names that are misspellings or similar variations of legitimate domains (www.c0mpany.com vs www.company.com) to trick users into visiting malicious sites. This is a classic example of typosquatting.

Why The Other Options Are Incorrect

B. Brand impersonation is broader and would apply if they used the exact brand name, not a domain typo.

C. On-path attacks intercept communications between two parties, not domain registration.

D. Watering-hole attacks compromise legitimate websites to infect visitors, not domain squatting.

Question #503

Which of the following allows a systems administrator to tune permissions for a file?

A. Patching
B. Access control list
C. Configuration enforcement
D. Least privilege

Correct Answer: B — Access control list

An Access Control List (ACL) is the mechanism that allows a systems administrator to granularly tune and modify permissions for a file by specifying which users or groups have what level of access. This directly controls file-level permissions.

Why The Other Options Are Incorrect

A. Patching updates software to fix vulnerabilities, not tune file permissions.

C. Configuration enforcement ensures settings remain compliant but doesn't specifically tune file permissions.

D. Least privilege is a principle guiding permission assignment, not the tool to implement it.

Question #504

Which of the following would be the greatest concern for a company that is aware of the consequences of non-compliance with government regulations?

A. Right to be forgotten
B. Sanctions
C. External compliance reporting
D. Attestation

Correct Answer: B — Sanctions

Sanctions are the greatest concern regarding non-compliance with government regulations, as they represent financial penalties, legal action, and punitive measures imposed by regulatory bodies. This is the most severe consequence of regulatory violations.

Why The Other Options Are Incorrect

A. Right to be forgotten is a data privacy requirement, not a consequence of non-compliance.

C. External compliance reporting is a requirement to demonstrate compliance, not a consequence of violation.

D. Attestation is a process of verifying compliance, not a consequence of non-compliance.

Question #505

Which of the following security concepts is accomplished when granting access after an individual has logged into a computer network?

A. Authorization
B. Identification
C. Non-repudiation
D. Authentication

Correct Answer: A — Authorization

Authorization is the security concept that determines what resources and actions a user can access after they have already logged in and been authenticated. It answers the question 'what can this verified user do?' following successful authentication.

Why The Other Options Are Incorrect

B. Identification is the process of claiming an identity, which happens before login.

C. Non-repudiation ensures users cannot deny their actions, not related to post-login access.

D. Authentication verifies identity at login, but authorization determines access permissions after login.

Question #506

A growing organization, which hosts an externally accessible application, adds multiple virtual servers to improve application performance and decrease the resource usage on individual servers.

Which of the following solutions is the organization most likely to employ to further increase performance and availability?

A. Load balancer
B. Jump server
C. Proxy server
D. SD-WAN

Correct Answer: A — Load balancer

A load balancer distributes incoming traffic across multiple virtual servers to increase performance and availability, which is the natural next step after adding multiple servers. It ensures optimal resource utilization and improves application responsiveness.

Why The Other Options Are Incorrect

B. A jump server provides secure administrative access but doesn't distribute application traffic.

C. A proxy server filters or caches traffic but is not the primary solution for load distribution.

D. SD-WAN optimizes wide-area network performance, not local application server load distribution.

Question #507

A systems administrator is concerned users are accessing emails through a duplicate site that is not run by the company.

Which of the following is used in this scenario?

A. Impersonation
B. Replication

C. Phishing
D. Smishing

Correct Answer: C — Phishing

Phishing is the attack where users are directed to fraudulent websites impersonating legitimate services (a duplicate email site) to steal credentials and sensitive information. This is the most accurate term for users unknowingly accessing a fake site instead of the legitimate one.

Why The Other Options Are Incorrect

A. Impersonation is broader and doesn't specifically refer to duplicate website attacks.

B. Replication refers to data copying or system duplication, not user redirection attacks.

D. Smishing is phishing conducted via SMS text messages, not through duplicate websites.

Question #508

A security engineer at a large company needs to enhance IAM in order to ensure that employees can only access corporate systems during their shifts.

Which of the following access controls should the security engineer implement?

A. Role-based
B. Time-of-day restrictions
C. Least privilege
D. Biometric authentication

Correct Answer: B — Time-of-day restrictions

Time-of-day restrictions is the specific access control that limits user access based on the time of day, ensuring employees can only access corporate systems during their scheduled work shifts. This directly addresses the requirement stated.

Why The Other Options Are Incorrect

A. Role-based access controls determine what resources users can access based on their role, not when they can access them.

C. Least privilege limits access scope but doesn't restrict access based on time of day.

D. Biometric authentication verifies identity but doesn't restrict access based on shift schedules.

Question #509

A company wants to ensure employees are allowed to copy files from a virtual desktop during the workday but are restricted during non-working hours.

Which of the following security measures should the company set up?

A. Digital rights management
B. Role-based access control
C. Time-based access control
D. Network access control

Correct Answer: C — Time-based access control

Time-based access control (TBAC) restricts or allows access to resources based on specific times of day or days of the week. This directly addresses the requirement to allow file copying during work hours but restrict it during non-working hours. The time parameter is the key differentiator for this security policy.

Why The Other Options Are Incorrect

A. Digital rights management controls what users can do with files (print, copy, edit) but doesn't inherently restrict by time of day.

B. Role-based access control grants permissions based on job roles, not time of day.

D. Network access control manages which devices can connect to the network, not when specific file operations are allowed.

Question #510

Employees sign an agreement that restricts specific activities when leaving the company. Violating the agreement can result in legal consequences.

Which of the following agreements does this best describe?

A. SLA
B. BPA
C. NDA
D. MOA

Correct Answer: C — NDA

A Non-Disclosure Agreement (NDA) is a legal contract that restricts employees from disclosing confidential information or engaging in specific activities after leaving a company, with enforceable legal consequences for violations. This matches the description of restricting activities when leaving and having legal repercussions.

Why The Other Options Are Incorrect

A. An SLA (Service Level Agreement) defines performance standards between a service provider and customer, not employee post-employment restrictions.

B. A BPA (Business Partners Agreement) governs relationships between business partners, not employee departures.

D. An MOA (Memorandum of Agreement) is a general understanding between parties but is less formal and legally binding than an NDA for restrictive covenants.

Question #511

A systems administrator just purchased multiple network devices.

Which of the following should the systems administrator perform to prevent attackers from accessing the devices by using publicly available information?

A. Install endpoint protection.
B. Disable ports/protocols.
C. Change default passwords.
D. Remove unnecessary software.

Correct Answer: C — Change default passwords.

Changing default passwords is the most critical immediate security measure because attackers commonly use publicly available default credentials for network devices. This prevents the most direct and well-known attack vector that requires no special tools or techniques.

Why The Other Options Are Incorrect

A. Endpoint protection is designed for computers/endpoints, not network devices like routers and switches.

B. Disabling ports/protocols is important but secondary to changing credentials that could already be known.

D. Removing unnecessary software is relevant for servers but not typically applicable to dedicated network devices.

Question #512

A CVE in a key back-end component of an application has been disclosed. The systems administrator is identifying all of the systems in the environment that are susceptible to this risk.

Which of the following should the systems administrator perform?

A. Packet capture
B. Vulnerability scan

C. Metadata analysis
D. Automated reporting

✅ Correct Answer: B — Vulnerability scan

A vulnerability scan is the appropriate tool to identify all systems susceptible to a known CVE. Vulnerability scanners automatically detect systems running vulnerable versions of the affected component across the environment, providing a comprehensive inventory of at-risk systems.

Why The Other Options Are Incorrect

A. Packet capture analyzes network traffic but doesn't identify systems with specific vulnerabilities.

C. Metadata analysis examines file or system metadata but is not the standard approach for CVE identification.

D. Automated reporting generates reports but doesn't perform the actual identification of vulnerable systems.

Question #513

Which of the following activities uses OSINT?

A. Social engineering testing
B. Data analysis of logs
C. Collecting evidence of malicious activity
D. Producing IOC for malicious artifacts

✅ Correct Answer: A — Social engineering testing

Social engineering testing uses OSINT (Open Source Intelligence) techniques to gather publicly available information about targets, such as employee names, organizational structure, and other data found on public websites, social media, and directories. This information is then used to craft more effective social engineering attacks.

Why The Other Options Are Incorrect

B. Data analysis of logs is performed on internal log data, not open source intelligence.

C. Collecting evidence of malicious activity involves analyzing specific security incidents, not OSINT gathering.

D. Producing IOCs (Indicators of Compromise) is based on malware analysis and threat intelligence, not OSINT.

Question #514

Which of the following are the best security controls for controlling on-premises access? (Choose two.)

A. Swipe card
B. Picture ID
C. Phone authentication application
D. Biometric scanner
E. Camera
F. Memorable question

Correct Answer: A, D

A. Swipe card
D. Biometric scanner

Swipe cards (A) and biometric scanners (D) are both effective physical security controls for on-premises access. Swipe cards provide credential-based access, while biometric scanners provide identity verification based on unique biological characteristics. Both are industry-standard controls for controlling who physically enters secure areas.

Why The Other Options Are Incorrect

B. Picture ID alone is passive identification without active access control capability.

C. Phone authentication applications are for logical access, not physical on-premises access.

E. Cameras provide monitoring and evidence but do not actively control access.

F. Memorable questions are for logical authentication, not physical access control.

Question #515

A company is considering an expansion of access controls for an application that contractors and internal employees use to reduce costs.

Which of the following risk elements should the implementation team understand before granting access to the application?

A. Threshold
B. Appetite
C. Avoidance
D. Register

Correct Answer: B — Appetite

Risk appetite refers to the level of risk an organization is willing to accept in pursuit of its

objectives. Before expanding access to contractors and employees to reduce costs, the team must understand the company's risk appetite to ensure the access expansion aligns with acceptable risk levels and doesn't expose the organization to unacceptable threats.

Why The Other Options Are Incorrect

A. Threshold is a specific limit or boundary value, not a risk management concept related to expansion decisions.

C. Risk avoidance is a strategy to eliminate risk entirely, not the foundational element needed before implementation.

D. A register is a record or list used in risk management but doesn't address the underlying risk tolerance decision.

Question #516

Which of the following is the act of proving to a customer that software developers are trained on secure coding?

A. Assurance
B. Contract
C. Due diligence
D. Attestation

Correct Answer: D — Attestation

Attestation is the act of formally declaring, confirming, or providing evidence that something is true. In this context, attestation means providing proof or certification that software developers have received training on secure coding practices, serving as verification to customers.

Why The Other Options Are Incorrect

A. Assurance refers to confidence or guarantee in a system's security, not the formal declaration of training completion.

B. A contract is an agreement between parties but doesn't specifically refer to proving training credentials.

C. Due diligence is the investigation process itself, not the act of proving training to a customer.

Question #517

An administrator is creating a secure method for a contractor to access a test environment.

Which of the following would provide the contractor with the best access to the test environment?

A. Application server
B. Jump server
C. RDP server
D. Proxy server

✅ Correct Answer: B — Jump server

A jump server (also called a bastion host) is the best practice for providing secure, auditable access to test environments. It acts as an intermediary that allows contractors to connect through a single, hardened, monitored gateway, providing better security controls and audit trails compared to direct access methods.

Why The Other Options Are Incorrect

A. Application servers are not designed as access control points for remote users.

C. RDP servers expose remote desktop protocol directly, which is less secure than a jump server intermediary.

D. Proxy servers are for network traffic filtering, not for providing controlled system access.

Question #518

A security analyst notices unusual behavior on the network. The IDS on the network was not able to detect the activities.

Which of the following should the security analyst use to help the IDS detect such attacks in the future?

A. Signatures
B. Trends
C. Honeypot
D. Reputation

✅ Correct Answer: A — Signatures

Signatures are the rule-based patterns used by IDS systems to detect known attacks. To improve detection of previously missed activities, the IDS signatures must be updated to include new patterns that match the unusual behavior observed. This directly addresses why the IDS failed to detect the attacks.

Why The Other Options Are Incorrect

B. Trends analyze patterns over time but do not directly enable detection; signatures are what enable the actual detection mechanism.

C. Honeypots are decoy systems but do not improve IDS detection capabilities.

D. Reputation filtering relates to threat intelligence but is not the primary mechanism for

improving IDS detection.

Question #519

To which of the following security categories does an EDR solution belong?

A. Physical
B. Operational
C. Managerial
D. Technical

Correct Answer: D — Technical

EDR (Endpoint Detection and Response) is a technical security control that uses software agents and monitoring tools to detect and respond to threats at the endpoint level. It falls under technical controls as it involves technology implementation and endpoint security infrastructure.

Why The Other Options Are Incorrect

A. Physical controls relate to locks, cameras, and physical security measures.

B. Operational controls are processes and procedures like incident response plans or security policies.

C. Managerial controls are policy and governance-level controls like risk assessments and training programs.

Daily Debian

Question #520

A company relies on open-source software libraries to build the software used by its customers.

Which of the following vulnerability types would be the most difficult to remediate due to the company's reliance on open-source libraries?

A. Buffer overflow
B. SQL injection
C. Cross-site scripting
D. Zero-day

Correct Answer: D — Zero-day

Zero-day vulnerabilities are the most difficult to remediate when relying on open-source libraries because, by definition, no patch exists yet. The organization cannot fix a vulnerability that is unknown to the developers. Buffer overflow, SQL injection, and XSS all have known remediation strategies and patches available.

Why The Other Options Are Incorrect

A. Buffer overflows have well-established patches and remediation techniques available in open-source updates.

B. SQL injection vulnerabilities have known coding practices and patches that can be applied.

C. Cross-site scripting has established mitigation strategies and can be patched in open-source libraries.

Question #521

An organization has a new regulatory requirement to implement corrective controls on a financial system.

Which of the following is the most likely reason for the new requirement?

A. To defend against insider threats altering banking details
B. To ensure that errors are not passed to other systems
C. To allow for business insurance to be purchased
D. To prevent unauthorized changes to financial data

✅ Correct Answer: B — To ensure that errors are not passed to other systems

Corrective controls are implemented to detect and fix errors after they occur, preventing propagation. In financial systems, corrective controls ensure errors are caught and corrected before they flow to dependent systems, maintaining data integrity across the organization. This is a core regulatory requirement for financial system reliability.

Why The Other Options Are Incorrect

A. This describes detective controls for insider threats, not corrective controls.

C. Insurance considerations are not the primary regulatory driver for corrective controls.

D. This describes preventive controls, not corrective controls which fix errors after detection.

Question #522

Which of the following is the stage in an investigating when forensic images are obtained?

A. Acquisition
B. Preservation
C. Reporting
D. E-discovery

✅ **Correct Answer: A — Acquisition**

Acquisition is the stage in digital forensics where forensic images (bit-by-bit copies) of storage media are obtained. This is the foundational step before analysis, and it must be done with proper methodology to ensure evidence integrity and legal admissibility.

Why The Other Options Are Incorrect

B. Preservation protects evidence from modification before acquisition takes place.

C. Reporting is the final stage where findings are documented and presented.

D. E-discovery is the legal process of obtaining electronic evidence, not the forensic imaging stage itself.

Question #523

Which of the following describes the difference between encryption and hashing?

A. Encryption protects data in transit, while hashing protects data at rest.

B. Encryption replaces cleartext with ciphertext, while hashing calculates a checksum.

C. Encryption ensures data integrity, while hashing ensures data confidentiality.

D. Encryption uses a public-key exchange, while hashing uses a private key.

✅ **Correct Answer: B — Encryption replaces cleartext with ciphertext, while hashing calculates a checksum.**

Encryption transforms cleartext into ciphertext and can be reversed with the correct key, while hashing calculates a one-way checksum or digest that cannot be reversed. This fundamental difference defines their separate use cases and security properties.

Why The Other Options Are Incorrect

A. Encryption protects data in both transit and at rest; hashing is for integrity verification, not protection.

C. Encryption ensures confidentiality, while hashing ensures integrity; this is backwards in the option.

D. Both encryption types and hashing algorithms vary in their key usage; this is not the key difference.

Question #524

A security report shows that during a two-week test period, 80% of employees unwittingly disclosed their SSO credentials when accessing an external website. The organization purposely created the website to simulate a cost-free password complexity test.

Which of the following would best help reduce the number of visits to similar websites in the future?

A. Block all outbound traffic from the intranet.
B. Introduce a campaign to recognize phishing attempts.
C. Restrict internet access for the employees who disclosed credentials.
D. Implement a deny list of websites.

✅ Correct Answer: B — Introduce a campaign to recognize phishing attempts.

An awareness campaign to recognize phishing attempts directly addresses the root cause of the vulnerability: employee susceptibility to social engineering. Training employees to identify phishing tactics like credential harvesting websites is the most effective long-term solution to prevent similar incidents.

Why The Other Options Are Incorrect

A. Blocking all outbound traffic is overly restrictive and impractical for modern business operations.

C. Restricting internet access for specific employees is punitive and does not educate the broader workforce.

D. A deny list only blocks known sites and cannot address new phishing sites; it does not solve the underlying knowledge gap.

Question #525

A Chief Information Security Officer (CISO) has developed information security policies that relate to the software development methodology.

Which of the following would the CISO most likely include in the organization's documentation?

A. Peer review requirements
B. Multifactor authentication
C. Branch protection tests
D. Secrets management configurations

✅ Correct Answer: A — Peer review requirements

Peer review requirements are a core component of secure software development methodologies. A CISO would include peer review policies in documentation to ensure code quality, security vulnerability detection, and adherence to coding standards. This is a direct control within the SDLC process itself.

Why The Other Options Are Incorrect

B. Multifactor authentication is an authentication control, not specifically a software

development methodology policy.

C. Branch protection tests relate to version control implementation details rather than overall development methodology policies.

D. Secrets management configurations are operational implementation details, not policy-level documentation for development methodology.

Question #526

An organization is developing a security program that conveys the responsibilities associated with the general operation of systems and software within the organization.

Which of the following documents would most likely communicate these expectations?

A. Business continuity plan
B. Change management procedure
C. Acceptable use policy
D. Software development life cycle policy

Correct Answer: C — Acceptable use policy

An Acceptable Use Policy (AUP) explicitly defines the responsibilities, expectations, and permitted behaviors for employees when operating systems and using software within the organization. It is the standard document for communicating general operational security expectations.

Why The Other Options Are Incorrect

A. A business continuity plan addresses disaster recovery and resilience, not general day-to-day operational responsibilities.

B. A change management procedure focuses on the process for requesting and implementing changes, not general operational responsibilities.

D. An SDLC policy applies specifically to development teams, not the general operation of systems for all users.

Question #527

A security analyst created a fake account and saved the password in a non-readily accessible directory in a spreadsheet. An alert was also configured to notify the security team if the spreadsheet is opened.

Which of the following best describes the deception method being deployed?

A. Honeypot
B. Honeyfile
C. Honeytoken

D. Honeynet

✅ Correct Answer: B — Honeyfile

A honeyfile is a deceptive file (in this case a spreadsheet with fake credentials) placed in a non-obvious location with monitoring configured to alert when accessed. This exactly matches the scenario described where a spreadsheet containing a fake account password triggers an alert when opened.

Why The Other Options Are Incorrect

A. A honeypot is an entire decoy system or service, not a single file.

C. A honeytoken is a specific value or piece of data within a system used for detection, but the scenario describes the entire file as the deception.

D. A honeynet is a network of honeypots, much larger in scope than this single monitored file.

Question #528

Which of the following is the best way to provide secure, remote access for employees while minimizing the exposure of a company's internal network?

A. VPN
B. LDAP
C. FTP
D. RADIUS

✅ Correct Answer: A — VPN

A VPN (Virtual Private Network) provides secure, encrypted remote access for employees while keeping the internal network protected through a secure tunnel. It is the standard solution for remote access that minimizes exposure of internal network architecture and data.

Why The Other Options Are Incorrect

B. LDAP is a directory service protocol for authentication and authorization, not a remote access mechanism.

C. FTP is a file transfer protocol that lacks encryption and security controls; it is not suitable for secure remote access.

D. RADIUS is an authentication protocol used for managing user credentials, not a remote access mechanism itself.

Question #529

A company wants to track modifications to the code that is used to build new virtual servers.

Which of the following will the company most likely deploy?

A. Change management ticketing system
B. Behavioral analyzer
C. Collaboration platform
D. Version control tool

Correct Answer: D — Version control tool

A version control tool (such as Git) tracks all modifications to code files, including infrastructure-as-code used to build virtual servers. It provides a complete audit trail of changes, who made them, and when, which is essential for tracking code modifications.

Why The Other Options Are Incorrect

A. A change management ticketing system manages the approval workflow but does not track technical code modifications.

B. A behavioral analyzer monitors system behavior but does not track code modifications.

C. A collaboration platform facilitates team communication but is not designed for tracking technical code changes.

Daily Debian

Question #530

Which of the following documents details how to accomplish a technical security task?

A. Standard
B. Policy
C. Guideline
D. Procedure

Correct Answer: D — Procedure

A procedure is step-by-step documentation that details how to accomplish a specific technical security task. It provides the operational instructions for implementing security controls and processes.

Why The Other Options Are Incorrect

A. A standard defines requirements and specifications but not the detailed how-to steps.

B. A policy establishes organizational rules and expectations but not technical implementation steps.

C. A guideline provides recommendations and best practices but lacks the specific procedural steps of a procedure.

Question #531

While conducting a business continuity tabletop exercise, the security team becomes concerned by potential impact if a generator was to develop a fault during failover.

Which of the following is the team most likely to consider in regard to risk management activities?

A. RPO
B. ARO
C. BIA
D. MTTR

✅ Correct Answer: C — BIA

A Business Impact Analysis (BIA) identifies and prioritizes critical business functions and their impacts if disrupted. The team's concern about generator failure impact during failover directly relates to assessing potential business impacts, which is the purpose of a BIA.

Why The Other Options Are Incorrect

A. RPO (Recovery Point Objective) defines acceptable data loss, not the impact assessment of a specific component failure.

B. ARO (Annualized Rate of Occurrence) measures how often a specific threat is expected to occur annually.

D. MTTR (Mean Time To Repair) measures repair duration but does not assess overall business impact of failures.

Question #532

Which of the following is prevented by proper data sanitization?

A. Hackers' ability to obtain data from used hard drives
B. Devices reaching end-of-life and losing support
C. Disclosure of sensitive data through incorrect classification
D. Incorrect inventory data leading to a laptop shortage

✅ Correct Answer: A — Hackers' ability to obtain data from used hard drives

Proper data sanitization securely erases data from storage media, preventing unauthorized recovery of sensitive information from used hard drives. This directly

prevents attackers from obtaining data from decommissioned equipment through data recovery techniques.

Why The Other Options Are Incorrect

B. End-of-life support loss is a lifecycle management issue unrelated to data sanitization.

C. Incorrect data classification is a governance issue addressed through classification policies, not sanitization.

D. Inventory discrepancies are operational issues unrelated to data sanitization procedures.

Question #533

A certificate authority needs to post information about expired certificates.

Which of the following would accomplish this task?

A. TPM
B. CRL
C. PKI
D. CSR

Correct Answer: B — CRL

A Certificate Revocation List (CRL) is a list published by a certificate authority that contains the serial numbers of certificates that have been revoked before their expiration date. This is the standard mechanism for posting information about expired and revoked certificates. A CRL allows clients to check whether a certificate is still valid.

Why The Other Options Are Incorrect

A. TPM (Trusted Platform Module) is a hardware security chip for storing cryptographic keys, not for publishing certificate status.

C. PKI (Public Key Infrastructure) is the entire framework for managing certificates, not the specific mechanism for posting revocation information.

D. CSR (Certificate Signing Request) is a request to obtain a certificate, not a list of expired certificates.

Question #534

Which of the following can best contribute to prioritizing patch applications?

A. CVSS
B. SCAP
C. OSINT

D. CVE

Correct Answer: A — CVSS

CVSS (Common Vulnerability Scoring System) provides a standardized numerical score (0-10) that reflects the severity of vulnerabilities. This scoring directly helps prioritize which patches to apply first, as higher CVSS scores indicate more critical vulnerabilities that should be patched sooner. It is the primary tool for vulnerability prioritization.

Why The Other Options Are Incorrect

B. SCAP (Security Content Automation Protocol) is a framework for vulnerability management but doesn't directly prioritize patches like CVSS does.

C. OSINT (Open Source Intelligence) is a gathering technique for external information, not a prioritization mechanism for patches.

D. CVE (Common Vulnerabilities and Exposures) is an identifier for vulnerabilities but doesn't provide scoring or prioritization metrics like CVSS does.

Question #535

A systems administrator creates a script that validates OS version, patch levels, and installed applications when users log in.

Which of the following examples best describes the purpose of this script?

A. Resource scaling
B. Policy enumeration
C. Baseline enforcement
D. Guard rails implementation

Correct Answer: C — Baseline enforcement

Baseline enforcement is the practice of ensuring that systems maintain a defined secure configuration standard. A script that validates OS version, patch levels, and installed applications at login is directly enforcing that systems comply with an established baseline configuration. This prevents configuration drift and ensures systems meet security requirements.

Why The Other Options Are Incorrect

A. Resource scaling refers to automatically adjusting computing resources based on demand, not validating configuration compliance.

B. Policy enumeration is the process of identifying and listing policies, not actively enforcing them through validation scripts.

D. Guard rails implementation refers to preventive controls that restrict dangerous actions, while this script validates existing configurations.

Question #536

A security analyst learns that an attack vector, which was used as a part of a recent incident, was a well-known IoT device exploit. The analyst needs to review logs to identify the time of initial exploit.

Which of the following logs should the analyst review first?

A. Endpoint
B. Application
C. Firewall
D. NAC

Correct Answer: C — Firewall

Firewall logs should be reviewed first when investigating an IoT exploit because IoT devices typically communicate over the network using protocols that would be captured and logged by firewalls. The firewall log would show the initial network-based exploit attempt and the time it occurred, making it the best first source for identifying when the exploit happened.

Why The Other Options Are Incorrect

A. Endpoint logs may not capture network-based IoT exploits and are typically found on individual machines.

B. Application logs are relevant only if an application was exploited; the IoT device exploit may bypass application-level logging.

D. NAC (Network Access Control) logs might be helpful but are less likely to capture detailed exploit timing compared to firewall logs.

Question #537

A company's gate access logs show multiple entries from an employee's ID badge within a two-minute period.

Which of the following is this an example of?

A. RFID cloning
B. Side-channel attack
C. Shoulder surfing
D. Tailgating

Correct Answer: A — RFID cloning

Multiple badge entries within a short two-minute period suggests RFID cloning, where an attacker has cloned the employee's RFID badge and is using the clone to gain unauthorized access. The rapid succession of entries is characteristic of testing or using a

cloned badge, as the legitimate employee is unlikely to enter the gate multiple times in two minutes.

Why The Other Options Are Incorrect

B. Side-channel attacks exploit physical properties of systems (like timing or power consumption) rather than creating multiple gate entries.

C. Shoulder surfing involves observing someone entering credentials or access codes, not multiple badge entries.

D. Tailgating occurs when someone follows an authorized person through a gate, but wouldn't show multiple separate badge entries in the logs.

Question #538

Which of the following most accurately describes the order in which a security engineer should implement secure baselines?

A. Deploy, maintain, establish
B. Establish, maintain, deploy
C. Establish, deploy, maintain
D. Deploy, establish, maintain

Correct Answer: C — Establish, deploy, maintain

The correct order for implementing secure baselines is: Establish (define the baseline standards), Deploy (apply those standards to systems), and Maintain (continue monitoring and updating them). You must first establish what the baseline should be, then deploy it across your environment, and finally maintain it over time through monitoring and updates.

Why The Other Options Are Incorrect

A. This order deploys before establishing, which is illogical without first defining what to deploy.

B. This order maintains before deploying, which cannot be done if nothing has been deployed yet.

D. This order deploys before establishing, which lacks the foundational step of defining baselines.

Question #539

A SOC analyst establishes a remote control session on an end user's machine and discovers the following in a file:

gmail.com[ENT]my.name@gmail.com[ENT]NoOneCanGuessThis123! [ENT]Hello Susan, it was great to see you the other day! Let's plan a followup[BACKSPACE]follow-

up meeting soon. Here is the link to register. [RTN][CTRL]c [CTRL]v [RTN]after[BACKSPACE]After you register give me a call on my cellphone.

Which of the following actions should the SOC analyst perform first?

A. Advise the user to change passwords.

B. Reimage the end user's machine.

C. Check the policy on personal email at work.

D. Check host firewall logs.

✅ Correct Answer: A — Advise the user to change passwords.

The file contains a Gmail password in plain text format, indicating credential exposure. The first action should be to advise the user to change passwords immediately to prevent unauthorized access to the Gmail account and any other systems using the same or similar passwords. This mitigates the immediate security risk from exposed credentials before investigating other aspects of the incident.

Why The Other Options Are Incorrect

B. Reimaging is a later step after immediate credential risks are mitigated and investigation is complete.

C. Policy review is important but secondary to addressing the immediate risk of exposed credentials.

D. Firewall logs are relevant for investigation but don't address the immediate credential exposure threat.

Daily Debian

Question #540

Which of the following is a reason environmental variables are a concern when reviewing potential system vulnerabilities?

A. The contents of environmental variables could affect the scope and impact of an exploited vulnerability.

B. In-memory environmental variable values can be overwritten and used by attackers to insert malicious code.

C. Environmental variables define cryptographic standards for the system and could create vulnerabilities if deprecated algorithms are used.

D. Environmental variables will determine when updates are run and could mitigate the likelihood of vulnerability exploitation.

✅ Correct Answer: A — The contents of environmental variables could affect the scope and impact of an exploited vulnerability.

Environmental variables can affect how an application behaves, including security-relevant settings like library paths, configuration directories, and execution parameters. If an

attacker can manipulate environmental variables, they could alter the scope and impact of a vulnerability—for example, redirecting library paths to load malicious code or changing configuration paths. This makes environmental variable values a concern when assessing vulnerability impact.

Why The Other Options Are Incorrect

B. While memory can be overwritten, this is not specifically an environmental variable concern—it applies to all in-memory data.

C. Environmental variables do not define cryptographic standards; those are typically configured in code or configuration files, not environment variables.

D. Environmental variables typically do not control update schedules; that's managed by scheduled tasks or update services.

Question #541

A company evaluates several options that would allow employees to have remote access to the network. The security team wants to ensure the solution includes AAA to comply with internal security policies.

Which of the following should the security team recommend?

A. IPSec with RADIUS
B. RDP connection with LDAPS
C. Web proxy for all remote traffic
D. Jump server with 802.1X

Correct Answer: A — IPSec with RADIUS

IPSec with RADIUS provides complete AAA (Authentication, Authorization, Accounting) functionality required by the security team. IPSec secures the VPN connection while RADIUS handles authentication and accounting. LDAPS provides only authentication/directory services without accounting. Web proxies and 802.1X jump servers don't provide comprehensive AAA for remote VPN access.

Why The Other Options Are Incorrect

B. LDAPS only provides authentication and directory services, not accounting

C. Web proxies don't provide AAA functionality

D. Jump servers with 802.1X don't provide full AAA for remote network access

Question #542

An administrator must replace an expired SSL certificate.

Which of the following does the administrator need to create the new SSL certificate?

A. CSR
B. OCSP
C. Key
D. CRL

Correct Answer: A — CSR

A Certificate Signing Request (CSR) is the primary document needed to request a new SSL certificate from a Certificate Authority. The CSR contains the public key and identifying information. OCSP and CRL are verification mechanisms, not creation tools. While a private key exists, the CSR is the specific request document required.

Why The Other Options Are Incorrect

B. OCSP is for certificate status verification, not certificate creation

C. While a key pair is involved, the CSR itself is what's submitted to the CA

D. CRL is a revocation list, not needed to create new certificates

Question #543

A systems administrator receives a text message from an unknown number claiming to be the Chief Executive Officer of the company. The message states an emergency situation requires a password reset.

Which of the following threat vectors is being used?

A. Typosquatting
B. Smishing
C. Pretexting
D. Impersonation

Correct Answer: B — Smishing

Smishing is phishing conducted via SMS text messages. The scenario describes a text message attempting to manipulate someone into revealing credentials, which is the definition of smishing. Pretexting creates a fabricated scenario, typosquatting involves domain names, and impersonation is a broader category that doesn't specify the delivery method.

Why The Other Options Are Incorrect

A. Typosquatting involves misspelled domains, not SMS messages

C. Pretexting is broader and doesn't specifically describe SMS-based attacks

D. Impersonation is too broad; smishing is the specific technique using SMS

Question #544

A Chief Information Security Officer (CISO) wants to:

- Prevent employees from downloading malicious content.
- Establish controls based on departments and users.
- Map internet access for business applications to specific service accounts.
- Restrict content based on categorization.

Which of the following should the CSO implement?

A. Web application firewall
B. Secure DNS server
C. Jump server
D. Next-generation firewall

Correct Answer: D — Next-generation firewall

A Next-Generation Firewall (NGFW) provides all required capabilities: malware/content blocking, user/department-based controls, application identification with service account mapping, and content categorization. Web application firewalls focus on application-layer attacks. Secure DNS blocks domains but lacks granular user controls. Jump servers provide access control but not content filtering.

Why The Other Options Are Incorrect

A. Web application firewalls focus on application attacks, not content categorization and user-based controls

B. DNS servers can block malicious domains but don't provide user/department controls or content categorization

C. Jump servers provide access control but not content filtering or malware prevention

Question #545

A company is aware of a given security risk related to a specific market segment. The business chooses not to accept responsibility and target their services to a different market segment.

Which of the following describes this risk management strategy?

A. Exemption
B. Exception
C. Avoid
D. Transfer

Correct Answer: C — Avoid

Risk avoidance means the organization chooses not to engage in activities that present the risk, effectively eliminating it by changing business direction. By targeting a different market segment, the company avoids the specific risk altogether. Transfer shifts responsibility to another party, exemption doesn't exist as a standard term, and exception is a temporary deviation.

Why The Other Options Are Incorrect

A. Exemption is not a standard risk management strategy

B. Exception is a temporary deviation, not a strategic avoidance

D. Transfer shifts risk to another party, not eliminating it through market change

Question #546

A security analyst needs to improve the company's authentication policy following a password audit.

Which of the following should be included in the policy? (Choose two.)

A. Length
B. Complexity
C. Least privilege
D. Something you have
E. Security keys
F. Biometrics

Daily Debian

Correct Answer: A, B

A. Length
B. Complexity

Length and complexity are the fundamental password policy parameters that should be included in any authentication policy following a password audit. These directly control password strength. Least privilege is access control, not a password attribute. Something you have, security keys, and biometrics are MFA factors, not password policy components—the question asks about password policy specifically.

Why The Other Options Are Incorrect

C. Least privilege is an access control principle, not a password policy element

D. Something you have is an MFA factor, not a password policy requirement

E. Security keys are hardware authentication factors, not password policies

F. Biometrics are authentication factors, not password policy components

Question #547

Which of the following is an example of a treatment strategy for a continuous risk?

A. Email gateway to block phishing attempts
B. Background checks for new employees
C. Dual control requirements for wire transfers
D. Branch protection as part of the CI/CD pipeline

Correct Answer: A — Email gateway to block phishing attempts

An email gateway blocking phishing attempts is a treatment (mitigation) strategy for the continuous, ongoing risk of phishing attacks. It actively reduces the likelihood and impact of a persistent threat. Background checks and dual control treat one-time/specific risks. CI/CD pipeline branch protection addresses deployment risks but is more incident-prevention than continuous risk treatment.

Why The Other Options Are Incorrect

B. Background checks are a one-time preventive control for hiring, not continuous risk treatment

C. Dual control is a preventive control for specific transactions, not continuous risk treatment

D. CI/CD pipeline controls prevent deployment errors but aren't continuous risk treatment

Daily Debian

Question #548

An organization wants to deploy software in a container environment to increase security.

Which of the following would limit the organization's ability to achieve this goal?

A. Regulatory compliance
B. Patch availability
C. Kernel version
D. Monolithic code

Correct Answer: D — Monolithic code

Monolithic code architecture fundamentally limits containerization benefits because containers work best with microservices and modular architectures. Breaking monolithic code into containers defeats the purpose. Regulatory compliance, patch availability, and kernel version are either manageable constraints or non-blocking issues for container deployment.

Why The Other Options Are Incorrect

A. Regulatory compliance can be addressed through container configurations and policies

B. Patch availability is not a blocker; containerization can improve patching

C. Kernel version is a technical parameter that can be managed in container environments

Question #549

Prior to implementing a design change, the change must go through multiple steps to ensure that it does not cause any security issues.

Which of the following is most likely to be one of those steps?

A. Board review
B. Service restart
C. Backout planning
D. Maintenance

✅ Correct Answer: C — Backout planning

Backout planning is a critical step in the change management process that ensures if a design change causes security issues, there is a documented procedure to revert to the previous secure state. This is a preventive measure taken before implementation to mitigate risk.

Why The Other Options Are Incorrect

A. Board review is a governance step but not specifically about preventing security issues from design changes.

B. Service restart is an operational action, not a pre-implementation security validation step.

D. Maintenance is a general term that occurs after implementation, not a pre-change security verification step.

Question #550

The internal audit team determines a software application is no longer in scope for external reporting requirements.

Which of the following will confirm that the application is no longer applicable?

A. Data inventory and retention
B. Right to be forgotten
C. Due care and due diligence
D. Acknowledgement and attestation

Correct Answer: D — Acknowledgement and attestation

Acknowledgement and attestation from relevant parties formally confirms that an application is no longer in scope for external reporting requirements. This creates the official documentation needed to remove the application from compliance obligations.

Why The Other Options Are Incorrect

A. Data inventory and retention deals with managing data lifecycle, not determining scope status.

B. Right to be forgotten is a data subject right under GDPR, not related to application scope determination.

C. Due care and due diligence are general security principles, not specific confirmation mechanisms for scope changes.

Question #551

Which of the following are the first steps an analyst should perform when developing a heat map? (Choose two.)

A. Methodically walk around the office noting Wi-Fi signal strength.
B. Log in to each access point and check the settings.
C. Create or obtain a layout of the office.
D. Measure cable lengths between access points.
E. Review access logs to determine the most active devices.
F. Remove possible impediments to radio transmissions.

Correct Answer: A, C

A. Methodically walk around the office noting Wi-Fi signal strength.
C. Create or obtain a layout of the office.

Creating or obtaining an office layout (C) is fundamental as it provides the baseline map for the heat map. Methodically walking around and noting Wi-Fi signal strength (A) is the direct data collection method for building the heat map. These two steps establish the foundation before any other analysis.

Why The Other Options Are Incorrect

B. Checking access point settings is configuration review, not part of initial heat map development.

D. Measuring cable lengths between access points is irrelevant to wireless signal strength mapping.

E. Reviewing access logs shows usage patterns but is not a first step for signal strength heat mapping.

F. Removing impediments is a remediation step that comes after heat map analysis, not before.

Question #552

Which of the following is used to improve security and overall functionality without losing critical application data?

A. Reformatting
B. Decommissioning
C. Patching
D. Encryption

Correct Answer: C — Patching

Patching improves security by fixing vulnerabilities and enhances functionality through bug fixes and updates, while preserving all critical application data. It is the standard method for maintaining system integrity and security without data loss.

Why The Other Options Are Incorrect

A. Reformatting erases data and is destructive, not a method to preserve critical application data.

B. Decommissioning removes systems entirely rather than improving their security and functionality.

D. Encryption protects data but does not improve application functionality without separate patching.

Daily Debian

Question #553

An organization is preparing to export proprietary software to a customer.

Which of the following would be the best way to prevent the loss of intellectual property?

A. Code signing
B. Obfuscation
C. Tokenization
D. Blockchain

Correct Answer: B — Obfuscation

Obfuscation is the process of making source code difficult to understand and reverse-engineer, directly protecting proprietary software from intellectual property theft when exported to customers. It maintains functionality while obscuring the underlying logic.

Why The Other Options Are Incorrect

A. Code signing verifies authenticity and integrity but does not prevent intellectual property loss or reverse-engineering.

C. Tokenization replaces sensitive data with tokens and is not designed for source code protection.

D. Blockchain provides distributed ledger functionality but is not a mechanism for preventing intellectual property loss in exported software.

Question #554

After a series of account compromises and credential misuse, a company hires a security manager to develop a security program.

Which of the following steps should the security manager take first to increase security awareness?

A. Evaluate tools that identify risky behavior and distribute reports on the findings.

B. Send quarterly newsletters that explain the importance of password management.

C. Develop phishing campaigns and notify the management team of any successes.

D. Update policies and handbooks to ensure all employees are informed of the new procedures.

✅ Correct Answer: D — Update policies and handbooks to ensure all employees are informed of the new procedures.

Updating policies and handbooks to inform all employees establishes the foundational framework for a security program. Before implementing tools, training, or specific campaigns, employees must understand the baseline expectations and procedures that govern acceptable behavior and security requirements.

Why The Other Options Are Incorrect

A. Using tools to identify risky behavior is an enforcement and monitoring step, not the first step in awareness building.

B. Newsletters are awareness communication but are reactive; policies and procedures must establish baseline expectations first.

C. Phishing campaigns are testing mechanisms that come after awareness and policy education, not as the first step.

Question #555

Which of the following should be used to ensure a device is inaccessible to a network-connected resource?

A. Disablement of unused services

B. Web application firewall
C. Host isolation
D. Network-based IDS

✅ Correct Answer: C — Host isolation

Host isolation physically or logically separates a device from network-connected resources, making it inaccessible regardless of firewall rules or other mechanisms. This is the most direct and reliable method to prevent any network communication.

Why The Other Options Are Incorrect

A. Disabling unused services reduces attack surface but does not guarantee the device remains inaccessible to network resources.

B. Web application firewalls protect web applications but do not isolate devices from network access.

D. Network-based IDS detects intrusions but does not prevent device access to network-connected resources.

Question #556

In which of the following will unencrypted network traffic most likely be found?

A. SDN
B. IoT
C. VPN
D. SCADA

✅ Correct Answer: B — IoT

IoT devices often have resource constraints and lack standardized encryption implementations, resulting in unencrypted network traffic being common. Many IoT deployments prioritize functionality and cost over security encryption measures.

Why The Other Options Are Incorrect

A. SDN (Software-Defined Networking) is an architecture approach that can enforce encryption standards.

C. VPN (Virtual Private Network) specifically encrypts traffic as its primary function.

D. SCADA systems, while industrial and sometimes legacy, are increasingly implementing encryption for critical infrastructure protection.

Question #557

Which of the following is the best reason to perform a tabletop exercise?

A. To address audit findings
B. To collect remediation response times
C. To update the IRP
D. To calculate the ROI

✅ Correct Answer: C — To update the IRP

A tabletop exercise is a discussion-based activity designed to walk through an organization's incident response procedures and identify gaps or areas for improvement. The primary value is validating and refining the Incident Response Plan (IRP) itself. While exercises may inform other activities, updating the IRP based on findings is the core purpose of conducting a tabletop exercise.

Why The Other Options Are Incorrect

A. Addressing audit findings is a separate remediation activity, not the primary purpose of tabletop exercises.

B. Collecting response times is a metric that might be measured but is not the main reason to conduct a tabletop exercise.

D. ROI calculation is a business metric unrelated to the purpose of testing incident response procedures.

Question #558

Which of the following is a use of CVSS?

A. To determine the cost associated with patching systems
B. To identify unused ports and services that should be closed
C. To analyze code for defects that could be exploited
D. To prioritize the remediation of vulnerabilities

✅ Correct Answer: D — To prioritize the remediation of vulnerabilities

CVSS (Common Vulnerability Scoring System) produces a numerical score that quantifies the severity of vulnerabilities. Organizations use this score to prioritize which vulnerabilities to remediate first, focusing resources on the most critical issues. This prioritization is the primary use case for CVSS in vulnerability management.

Why The Other Options Are Incorrect

A. CVSS measures vulnerability severity, not the cost of patches.

B. Port and service discovery is a scanning function, not a use of CVSS scoring.

C. Code defect analysis is performed by static analysis tools, not CVSS.

Question #559

For an upcoming product launch, a company hires a marketing agency whose owner is a close relative of the Chief Executive Officer.

Which of the following did the company violate?

A. Independent assessments
B. Supply chain analysis
C. Right-to-audit clause
D. Conflict of interest policy

Correct Answer: D — Conflict of interest policy

Hiring a marketing agency whose owner is a close relative of the CEO creates a clear conflict of interest. This violates standard conflict of interest policies that require objectivity and independence in vendor selection. The family relationship to an executive compromises the company's ability to make unbiased business decisions.

Why The Other Options Are Incorrect

A. Independent assessments refer to security audits, not vendor selection processes.

B. Supply chain analysis is a broader assessment; the violation here is specifically about conflict of interest.

C. Right-to-audit clauses concern contractual inspection rights, not the conflict created by hiring relatives.

Daily Debian

Question #560

An organization designs an inbound firewall with a fail-open configuration while implementing a website.

Which of the following would the organization consider to be the highest priority?

A. Confidentiality
B. Non-repudiation
C. Availability
D. Integrity

Correct Answer: C — Availability

A fail-open configuration means the firewall allows traffic to pass through when it fails. This creates a direct threat to availability—if the firewall fails, the website remains accessible but potentially unprotected. For a product launch, ensuring the website remains available is critical. Availability becomes the highest priority when operating under a fail-open model.

Why The Other Options Are Incorrect

A. Confidentiality would favor fail-closed (deny by default) to protect data.

B. Non-repudiation is about accountability, not related to firewall failure modes.

D. Integrity protection is important but is secondary to ensuring the service remains available during firewall failures.

Question #561

An engineer needs to ensure that a script has not been modified before it is launched.

Which of the following best provides this functionality?

A. Masking
B. Obfuscation
C. Hashing
D. Encryption

✅ Correct Answer: C — Hashing

Hashing produces a cryptographic fingerprint of a script's contents. Before launching, the engineer can compare the current hash against a known good hash to detect any modification. If even one byte changes, the hash will differ, providing a reliable way to verify the script has not been tampered with.

Why The Other Options Are Incorrect

A. Masking hides data but does not verify integrity.

B. Obfuscation makes code harder to read but does not detect modifications.

D. Encryption protects confidentiality but does not inherently verify that data has not been modified without additional mechanisms.

Question #562

Which of the following is the most important element when defining effective security governance?

A. Discovering and documenting external considerations
B. Developing procedures for employee onboarding and offboarding
C. Assigning roles and responsibilities for owners, controllers, and custodians
D. Defining and monitoring change management procedures

✅ Correct Answer: C — Assigning roles and responsibilities for owners, controllers, and custodians

Assigning clear roles and responsibilities for owners, controllers, and custodians is foundational to effective security governance. Without defined accountability and clear

authority structures, no other governance element can function properly. This creates the organizational framework upon which all security decisions and procedures depend.

Why The Other Options Are Incorrect

A. Discovering external considerations is important but comes after establishing internal governance structures.

B. Onboarding and offboarding procedures are operational security practices, not the foundational element of governance.

D. Change management is a critical procedure but depends first on having clear roles and responsibilities established.

Question #563

A contractor is required to visually inspect the motherboards of all new servers that are purchased to determine whether the servers were tampered with.

Which of the following risks is the contractor attempting to mitigate?

A. Embedded rootkit
B. Supply chain
C. Firmware failure
D. RFID keylogger

✅ Correct Answer: B — Supply chain

Visual inspection of motherboards for tampering addresses supply chain risks—the threat that devices could be compromised before they reach the organization. This is a supply chain security control designed to detect physical modifications or implants that may have been introduced during manufacturing or distribution.

Why The Other Options Are Incorrect

A. Rootkits are software-based and not detectable through visual motherboard inspection.

C. Firmware failure is a reliability issue, not a security tampering risk mitigated by visual inspection.

D. RFID keyloggers are not the primary concern addressed by visual motherboard inspection during supply chain verification.

Question #564

Which of the following could potentially be introduced at the time of side loading?

A. User impersonation
B. Rootkit

C. On-path attack

D. Buffer overflow

Correct Answer: B — Rootkit

Side loading refers to installing applications from sources outside official app stores. This bypasses security controls and verification processes, making it an ideal vector for introducing rootkits and other malware. Attackers can package rootkits into side-loaded applications to gain deep system access.

Why The Other Options Are Incorrect

A. User impersonation is an authentication attack, not specifically related to side loading.

C. On-path attacks are network-based man-in-the-middle attacks, not introduced through side loading.

D. Buffer overflow is a code execution vulnerability, not typically the primary threat from side loading applications.

Question #565

While a school district is performing state testing, a security analyst notices all internet services are unavailable. The analyst discovers that ARP poisoning is occurring on the network and then terminates access for the host.

Which of the following is most likely responsible for this malicious activity?

A. Unskilled attacker

B. Shadow IT

C. Insider threat

D. Nation-state

Correct Answer: C — Insider threat

An ARP poisoning attack occurring during critical state testing on the internal network strongly suggests an insider threat. This type of attack requires network access and technical knowledge, and the timing during a sensitive operational window indicates someone with legitimate access to the network is deliberately disrupting services. An unskilled attacker would be unlikely to execute this attack successfully, shadow IT doesn't fit the malicious context, and nation-states would not typically target a school district's testing infrastructure.

Why The Other Options Are Incorrect

A. Unskilled attackers lack the technical capability to successfully execute ARP poisoning attacks.

B. Shadow IT refers to unauthorized IT systems, not malicious network attacks.

D. Nation-states target high-value government or infrastructure targets, not school district testing.

Question #566

A user needs to complete training at https://comptiatraining.com. After manually entering the URL, the user sees that the accessed website is noticeably different from the standard company website.

Which of the following is the most likely explanation for the difference?

A. Cross-site scripting
B. Pretexting
C. Typosquatting
D. Vishing

Correct Answer: C — Typosquatting

Typosquatting occurs when an attacker registers a domain name similar to a legitimate one, exploiting users who manually mistype URLs. When the user manually enters the URL, they may have made a small typo that directed them to an attacker-controlled domain with a similar appearance. This explains why the website looks noticeably different despite visiting what they thought was the correct address.

Why The Other Options Are Incorrect

A. Cross-site scripting is an injection attack affecting website code, not domain registration.

B. Pretexting involves creating a fabricated scenario to extract information, not website spoofing.

D. Vishing is voice-based social engineering, not website spoofing.

Question #567

A company has yearly engagements with a service provider. The general terms and conditions are the same for all engagements. The company wants to simplify the process and revisit the general terms every three years.

Which of the following documents would provide the best way to set the general terms?

A. MSA
B. NDA
C. MOU
D. SLA

Correct Answer: A — MSA

A Master Service Agreement (MSA) is the appropriate document for establishing general terms and conditions that apply across multiple engagements with the same service provider. An MSA provides a framework that covers standard terms which can be reused for yearly engagements, allowing the company to revisit and renegotiate every three years without recreating the entire agreement each time.

Why The Other Options Are Incorrect

B. An NDA (Non-Disclosure Agreement) only addresses confidentiality, not general service terms.

C. An MOU (Memorandum of Understanding) is informal and not suitable for establishing binding general terms.

D. An SLA (Service Level Agreement) defines specific performance metrics, not general terms and conditions.

Question #568

While updating the security awareness training, a security analyst wants to address issues created if vendors' email accounts are compromised.

Which of the following recommendations should the security analyst include in the training?

A. Refrain from clicking on images included in emails from new vendors
B. Delete emails from unknown service provider partners.
C. Require that invoices be sent as attachments
D. Be alert to unexpected requests from familiar email addresses

Correct Answer: D — Be alert to unexpected requests from familiar email addresses

When a vendor's email account is compromised, attackers send fraudulent requests from legitimate email addresses. Teaching staff to be alert to unexpected requests from familiar email addresses is the best defense, as it encourages verification of unusual requests even when they appear to come from trusted contacts. This directly addresses the risk of compromised vendor accounts being used to send fraudulent communications.

Why The Other Options Are Incorrect

A. Refusing to click images is too broad and doesn't specifically address compromised vendor accounts.

B. Deleting all unknown vendor emails may cause legitimate business communications to be missed.

C. Requiring invoice attachments doesn't prevent exploitation of compromised vendor email accounts.

Question #569

A new corporate policy requires all staff to use multifactor authentication to access company resources.

Which of the following can be utilized to set up this form of identity and access management? (Choose two.)

A. Authentication tokens
B. Least privilege
C. Biometrics
D. LDAP
E. Password vaulting
F. SAML

Correct Answer: A, C

A. Authentication tokens
C. Biometrics

Authentication tokens (something you have, such as hardware tokens or software token generators) and biometrics (something you are, such as fingerprints or facial recognition) are both valid MFA factors. These represent different authentication categories and can be used to implement multifactor authentication. Least privilege and LDAP are access control mechanisms, not authentication factors. Password vaulting stores passwords but doesn't add a second factor. SAML is a federation protocol, not an MFA method.

Why The Other Options Are Incorrect

B. Least privilege is an access control principle, not an MFA authentication factor.

D. LDAP is a directory protocol for user management, not an authentication factor.

E. Password vaulting stores credentials but does not constitute a second authentication factor.

F. SAML is a single sign-on protocol, not an MFA mechanism.

Question #570

A help desk employee receives a call from someone impersonating the Chief Executive Officer. The caller asks for assistance with resetting a password.

Which of the following best describes this event?

A. Vishing
B. Hacktivism
C. Blackmail

D. Misinformation

Correct Answer: A — Vishing

Vishing (voice phishing) is a social engineering attack conducted via telephone where an attacker impersonates someone with authority or trust to manipulate victims into revealing sensitive information or performing actions like password resets. This scenario perfectly matches the vishing definition: an attacker impersonating an executive and using social engineering over voice to gain access.

Why The Other Options Are Incorrect

B. Hacktivism involves attacking systems to make a political statement, not impersonation for access.

C. Blackmail involves extortion through threats, not impersonation for password reset assistance.

D. Misinformation is the spread of false information, not a targeted impersonation attack.

Question #571

The number of tickets the help desk has been receiving has increased recently due to numerous false-positive phishing reports.

Which of the following would be best to help to reduce the false positives?

A. Performing more phishing simulation campaigns
B. Improving security awareness training
C. Hiring more help desk staff
D. Implementing an incident reporting web page

Correct Answer: B — Improving security awareness training

Improving security awareness training directly addresses the root cause of false-positive phishing reports by educating employees on what constitutes actual phishing attempts versus legitimate communications. Better training reduces confusion and decreases unnecessary tickets to the help desk. While phishing simulations are beneficial, general awareness training is the most effective solution for reducing false positives systematically.

Why The Other Options Are Incorrect

A. More phishing simulations may increase false reports temporarily if awareness is not concurrently improved.

C. Hiring more help desk staff only increases capacity; it doesn't solve the underlying problem.

D. An incident reporting webpage doesn't prevent false positives; it only changes where they are reported.

Question #572

An organization that handles sensitive information wants to protect the information by using a reversible technology.

Which of the following best satisfies this requirement?

A. Hardware security module
B. Hashing algorithm
C. Tokenization
D. Steganography

Correct Answer: C — Tokenization

Tokenization is a reversible technology that replaces sensitive data with non-sensitive tokens while maintaining the ability to recover the original data through a mapping process. This allows the organization to protect sensitive information while retaining the ability to retrieve it when needed. Hardware security modules protect keys but aren't reversible protection methods. Hashing is irreversible by design. Steganography hides data but isn't designed for protection.

Why The Other Options Are Incorrect

A. Hardware security modules protect cryptographic keys but are not reversible data protection technologies.

B. Hashing algorithms are intentionally one-way and irreversible, not suitable for this requirement.

D. Steganography hides data within other data but doesn't protect it and isn't reversible in a practical sense.

Question #573

A systems administrator needs to encrypt all data on employee laptops.

Which of the following encryption levels should be implemented?

A. Volume
B. Partition
C. Full disk
D. File

Correct Answer: C — Full disk

Full disk encryption (FDE) encrypts the entire storage device including the operating system, boot sector, and all data, providing the most comprehensive protection for all data

on employee laptops. While volume and partition encryption are more granular options, full disk encryption is the standard requirement for encrypting ALL data on a device, and file-level encryption only protects individual files rather than the entire system.

Why The Other Options Are Incorrect

A. Volume encryption only protects specific volumes, not the entire disk.

B. Partition encryption only protects individual partitions, not all data.

D. File encryption only protects individual files, not all data on the laptop.

Question #574

Which of the following actions best addresses a vulnerability found on a company's web server?

A. Patching
B. Segmentation
C. Decommissioning
D. Monitoring

Correct Answer: A — Patching

Patching is the primary and most direct method to address a known vulnerability on a web server. Patches close the specific security gaps that vulnerabilities represent. While monitoring, segmentation, and decommissioning may play supporting roles in security strategies, patching is the definitive action that actually fixes the vulnerability itself.

Why The Other Options Are Incorrect

B. Segmentation limits damage but does not fix the vulnerability.

C. Decommissioning is excessive and not practical for a server with a fixable vulnerability.

D. Monitoring detects exploitation but does not remediate the vulnerability.

Question #575

A company is changing its mobile device policy. The company has the following requirements:

- Company-owned devices
- Ability to harden the devices
- Reduced security risk
- Compatibility with company resources

Which of the following would best meet these requirements?

A. BYOD
B. CYOD
C. COPE
D. COBO

Correct Answer: D — COBO

COBO (Corporate-Owned, Business-Only) best meets all requirements: the company owns the devices, can fully harden them according to corporate standards, reduces security risk through complete organizational control, and ensures full compatibility with company resources. BYOD involves personal devices with limited control, CYOD provides limited choice, and COPE adds personal use which increases risk and complexity.

Why The Other Options Are Incorrect

A. BYOD means personal devices with minimal company control and hardening capability.

B. CYOD provides limited device choices but still involves employee selection rather than company control.

C. COPE allows personal use which contradicts the reduced security risk requirement.

Question #576

A company is concerned about employees unintentionally introducing malware into the network. The company identified fifty employees who clicked on a link embedded in an email sent by the internal IT department.

Which of the following should the company implement to best improve its security posture?

A. Social engineering training
B. SPF configuration
C. Simulated phishing campaign
D. Insider threat awareness

Correct Answer: A — Social engineering training

Social engineering training directly addresses the root cause of the identified vulnerability: employees clicking malicious links. Training educates employees to recognize and avoid phishing and social engineering attacks. SPF configuration helps prevent email spoofing but doesn't educate users, simulated phishing campaigns test awareness but don't provide the remedial training needed, and insider threat awareness focuses on malicious intent rather than accidental mistakes.

Why The Other Options Are Incorrect

B. SPF configuration prevents email spoofing but does not train employees to recognize

phishing.

C. Simulated campaigns test vulnerability but do not provide the training needed to improve.

D. Insider threat awareness addresses malicious intent, not unintentional mistakes from poor security awareness.

Question #577

A penetration test identifies that an SMBv1 is enabled on multiple servers across an organization. The organization wants to remediate this vulnerability in the most efficient way possible.

Which of the following should the organization use for this purpose?

A. GPO
B. ACL
C. SFTP
D. DLP

Correct Answer: A — GPO

Group Policy Objects (GPO) is the most efficient method to disable SMBv1 across multiple servers in a domain environment. GPO allows centralized configuration management that can be applied organization-wide simultaneously. ACLs manage access permissions but not protocol settings, SFTP is a file transfer protocol unrelated to this issue, and DLP protects data but does not address protocol vulnerabilities.

Why The Other Options Are Incorrect

B. ACLs control access permissions but do not disable protocols.

C. SFTP is a file transfer protocol and does not address SMB vulnerabilities.

D. DLP protects data loss but does not remediate protocol vulnerabilities.

Question #578

Which of the following best protects sensitive data in transit across a geographically dispersed infrastructure?

A. Encryption
B. Masking
C. Tokenization
D. Obfuscation

Correct Answer: A — Encryption

Encryption is the best protection for sensitive data in transit across networks and geographic distances, using protocols like TLS/SSL to render data unreadable to unauthorized parties. Masking, tokenization, and obfuscation are data protection techniques for data at rest or in storage, not for protecting data actively moving across networks.

Why The Other Options Are Incorrect

B. Masking is typically used for data at rest, not in transit.

C. Tokenization is primarily used for stored data, not data in transit.

D. Obfuscation is not a reliable security control for protecting data in transit across networks.

Question #579

As part of new compliance audit requirements, multiple servers need to be segmented on different networks and should be reachable only from authorized internal systems.

Which of the following would meet the requirements?

A. Configure firewall rules to block external access to Internal resources.
B. Set up a WAP to allow internal access from public networks.
C. Implement a new IPSec tunnel from internal resources.
D. Deploy an internal jump server to access resources.

Correct Answer: D — Deploy an internal jump server to access resources.

A jump server (bastion host) provides secure, controlled access to segmented servers by requiring authorized users to first authenticate to the jump server before accessing internal resources. This method enforces access control, provides audit trails, and ensures only authorized systems can reach the segmented infrastructure. Firewall rules alone don't provide controlled access, WAPs enable public access, and IPSec tunnels facilitate connectivity without the required access control and authorization layer.

Why The Other Options Are Incorrect

A. Blocking external access is basic but does not provide the controlled authorization mechanism required.

B. WAPs allow public network access, contradicting the requirement for internal-only access.

C. IPSec tunnels facilitate connectivity but do not provide the required authorization and access control.

Question #580

Which of the following activities should be performed first to compile a list of vulnerabilities in an environment?

A. Automated scanning
B. Penetration testing
C. Threat hunting
D. Log aggregation
E. Adversarial emulation

Correct Answer: A — Automated scanning

Automated scanning should be performed first to efficiently compile a comprehensive list of vulnerabilities in an environment. Scanning is the baseline activity that identifies potential weaknesses. Penetration testing builds on scan results with manual testing, threat hunting investigates suspicious activity, log aggregation collects data for analysis, and adversarial emulation simulates attacks—all require vulnerability data to be identified first.

Why The Other Options Are Incorrect

B. Penetration testing is more complex and should follow initial scanning.
C. Threat hunting investigates existing threats, not initial vulnerability discovery.
D. Log aggregation collects data but does not identify vulnerabilities.
E. Adversarial emulation simulates attacks but is not the first step in vulnerability identification.

Question #581

Which of the following can be used to mitigate attacks from high-risk regions?

A. Obfuscation
B. Data sovereignty
C. IP geolocation
D. Encryption

Correct Answer: C — IP geolocation

IP geolocation allows organizations to identify the geographic origin of traffic and block or restrict access from high-risk regions. This directly addresses attacks originating from specific geographic locations by enabling location-based access controls.

Why The Other Options Are Incorrect

A. Obfuscation hides code or data but doesn't prevent attacks from specific regions.
B. Data sovereignty is about regulatory compliance for data location, not attack

mitigation.

D. Encryption protects data in transit but doesn't prevent access from high-risk regions.

Question #582

A program manager wants to ensure contract employees can only access the company's computers Monday through Friday from 9 a m. to 5 p.m.

Which of the following would best enforce this access control?

A. Creating a GPO for all contract employees and setting time-of-day log-in restrictions

B. Creating a discretionary access policy and setting rule-based access for contract employees

C. Implementing an OAuth server and then setting least privilege for contract employees

D. Implementing SAML with federation to the contract employees' authentication server

✅ Correct Answer: A — Creating a GPO for all contract employees and setting time-of-day log-in restrictions

Group Policy Objects (GPOs) in Windows environments can enforce time-of-day login restrictions at the OS level, allowing administrators to restrict access to specific hours and days. This is the most direct and effective method for implementing time-based access controls for contract employees.

Why The Other Options Are Incorrect

B. Discretionary access control policies don't inherently provide time-of-day restrictions.

C. OAuth is primarily for authorization and delegated access, not time-based restrictions.

D. SAML with federation handles authentication but not time-of-day access limitations.

Question #583

A recent power outage halted operations at a company's only data center.

Which of the following solutions would best prevent an event like this one in the future?

A. Platform diversity

B. Generator

C. Snapshots

D. Load balancing

Correct Answer: B — Generator

A generator provides backup power during outages, directly preventing operations from halting when power is lost. This is the most appropriate solution for mitigating the impact of power outages at a data center.

Why The Other Options Are Incorrect

A. Platform diversity addresses software/system failures, not power outages.

C. Snapshots are backup mechanisms but don't prevent the operational halt caused by power loss.

D. Load balancing distributes traffic but doesn't provide power redundancy.

Question #584

Which of the following analysis methods allows an organization to measure the exposure factor associated with organizational assets?

A. Heuristic
B. Quantitative
C. User-driven
D. Trend-based

Correct Answer: B — Quantitative

Quantitative analysis uses numerical values and formulas to measure risk factors, including exposure factor (EF), which represents the percentage of asset value that would be lost if a threat occurred. This method provides measurable, numeric assessment of organizational asset exposure.

Why The Other Options Are Incorrect

A. Heuristic analysis uses rules of thumb and experience-based reasoning, not numerical measurement.

C. User-driven analysis is not a standard risk analysis methodology.

D. Trend-based analysis examines patterns over time but doesn't specifically measure exposure factors.

Question #585

A security analyst notices an increase in port scans on the edge of the corporate network.

Which of the following logs should the analyst check to obtain the attacker’s source IP address?

A. OS security

B. Firewall
C. Application
D. Endpoint

Correct Answer: B — Firewall

Firewall logs record all traffic passing through the firewall, including port scan attempts, and contain the source IP addresses of incoming traffic. This is the most appropriate log source for identifying the attacker's origin during port scans on the network edge.

Why The Other Options Are Incorrect

A. OS security logs track local system events, not network-level attacks.

C. Application logs record application-specific events, not network traffic.

D. Endpoint logs track individual system activity, not inbound network scans.

Question #586

A security team receives reports about high latency and complete network unavailability throughout most of the office building. Flow logs from the campus switches show high traffic on TCP 445.

Which of the following is most likely the root cause of this incident?

A. Buffer overflow
B. NTP amplification attack
C. Worm
D. DoS attack

Correct Answer: C — Worm

A worm spreads rapidly across networks using high-volume traffic on common file-sharing protocols like SMB (TCP 445), causing widespread network degradation and unavailability. The symptom of high TCP 445 traffic combined with building-wide network problems strongly indicates worm propagation.

Why The Other Options Are Incorrect

A. Buffer overflow attacks target specific processes, not widespread network traffic.

B. NTP amplification uses UDP port 123, not TCP 445.

D. DoS attacks typically don't generate internal network traffic patterns like this.

Question #587

A security analyst is examining a penetration test report and notices that the tester pivoted to critical internal systems with the same local user ID and password.

Which of the following would help prevent this in the future?

A. Implement centralized authentication with proper password policies
B. Add password complexity rules and increase password history limits
C. Connect the systems to an external authentication server
D. Limit the ability of user accounts to change passwords

✅ **Correct Answer: A — Implement centralized authentication with proper password policies**

Centralized authentication (such as Active Directory or LDAP) with proper password policies prevents reusing the same credentials across multiple systems. This eliminates the vulnerability where compromising one local account grants access to all systems using identical credentials.

Why The Other Options Are Incorrect

B. Complexity rules and password history don't prevent reuse of the same password across systems.

C. External authentication servers alone don't prevent use of identical passwords on multiple systems.

D. Restricting password changes doesn't address the fundamental problem of credential reuse.

Question #588

When used with an access control vestibule which of the following would provide the best prevention against tailgating?

A. PIN
B. Access card
C. Security guard
D. CCTV

✅ **Correct Answer: C — Security guard**

A security guard can actively monitor access control vestibules and prevent unauthorized individuals from following authorized personnel through the door, physically stopping tailgating attempts in real-time.

Why The Other Options Are Incorrect

A. A PIN only authenticates the person entering; it doesn't prevent a second person from entering during the same door opening.

B. An access card has the same limitation as PIN—it doesn't prevent tailgating by unauthorized individuals.

D. CCTV only records tailgating incidents after they occur; it doesn't actively prevent them.

Question #589

A security professional discovers a folder that contains an employee's personal information located on the enterprise's shared drive.

Which of the following best describes the data type the security professional should use to identify organizational policies and standards concerning the storage of employees' personal information?

A. Legal
B. Financial
C. Privacy
D. Intellectual property

Correct Answer: C — Privacy

Privacy data classification relates to personal information about employees and how it should be stored, handled, and protected according to organizational policies. This classification type directly addresses regulatory and policy requirements for protecting personally identifiable information (PII) in the workplace.

Why The Other Options Are Incorrect

A. Legal data classification pertains to data with legal implications or litigation holds, not personal information storage policies.

B. Financial data classification concerns monetary and accounting information, not employee personal data storage.

D. Intellectual property classification relates to company proprietary assets and trade secrets, not employee personal information.

Question #590

A site reliability engineer is designing a recovery strategy that requires quick failover to an identical site if the primary facility goes down.

Which of the following types of sites should the engineer consider?

A. Recovery site
B. Hot site
C. Cold site
D. Warm site

Correct Answer: B — Hot site

A hot site is a fully operational and identical backup facility that can provide quick failover with minimal data loss and downtime. It has all systems running and synchronized with the primary site, enabling immediate recovery when needed.

Why The Other Options Are Incorrect

A. Recovery site is a generic term that doesn't specify the level of readiness required for quick failover.

C. A cold site requires significant time to set up and become operational, unsuitable for quick failover requirements.

D. A warm site has some systems running but requires additional configuration and time to fully activate, slower than a hot site.

Question #591

Which of the following would an organization most likely use to minimize the loss of data on a file server in the event data needs to be restored?

A. Snapshots
B. Journaling
C. Obfuscation
D. Tokenization

Correct Answer: A — Snapshots

Snapshots capture point-in-time copies of file server data, allowing quick restoration to a previous state if data loss occurs. This is the primary mechanism for minimizing data loss and enabling rapid recovery in file server environments.

Why The Other Options Are Incorrect

B. Journaling records transaction logs but is not the primary tool for file server data restoration and loss minimization.

C. Obfuscation masks data for security purposes but doesn't help with data recovery or loss prevention.

D. Tokenization replaces sensitive data with tokens for security but is not used for file server backup and recovery.

Question #592

Which of the following solutions would most likely be used in the financial industry to mask sensitive data?

A. Tokenization

B. Hashing
C. Salting
D. Steganography

✅ Correct Answer: A — Tokenization

Tokenization replaces sensitive financial data (such as credit card numbers) with non-sensitive tokens while maintaining referential integrity. This is the industry standard in finance for protecting sensitive payment and account information while preserving functionality.

Why The Other Options Are Incorrect

B. Hashing is one-way and irreversible, unsuitable for masking data that needs to be recovered for transactions.

C. Salting is used with hashing to prevent rainbow table attacks, not for masking financial sensitive data.

D. Steganography hides data within other data but is not a practical masking solution for financial data protection.

Question #593

Which of the following is a type of vulnerability that may result from outdated algorithms or keys?

A. Hash collision
B. Cryptographic
C. Buffer overflow
D. Input validation

✅ Correct Answer: B — Cryptographic

Cryptographic vulnerabilities specifically result from weaknesses in cryptographic algorithms or encryption keys, including outdated algorithms that are no longer secure and weak keys that can be broken. This directly addresses the question about outdated algorithms or keys.

Why The Other Options Are Incorrect

A. Hash collision is a specific weakness where different inputs produce the same hash output, not related to outdated algorithms or keys.

C. Buffer overflow is a memory management vulnerability unrelated to cryptographic algorithms or key management.

D. Input validation vulnerabilities relate to improper handling of user inputs, not cryptographic algorithm or key obsolescence.

Question #594

A company wants to prevent proprietary and confidential company information from being shared to outsiders.

Which of the following would this best describe?

A. MOA
B. SLA
C. MSA
D. NDA

Correct Answer: D — NDA

A Non-Disclosure Agreement (NDA) is a legal contract specifically designed to prevent sharing of proprietary and confidential information with outsiders. It legally binds parties to maintain confidentiality of sensitive company information.

Why The Other Options Are Incorrect

A. MOA (Memorandum of Agreement) is a general agreement document but doesn't specifically address preventing information disclosure.

B. SLA (Service Level Agreement) defines service performance standards and remedies, not confidentiality protection.

C. MSA (Master Service Agreement) outlines overall service terms but is not specifically designed to prevent proprietary information sharing.

Question #595

A security administrator needs to reduce the attack surface in the company's data centers.

Which of the following should the security administrator do to complete this task?

A. Implement a honeynet.
B. Define Group Policy on the servers.
C. Configure the servers for high availability.
D. Upgrade end-of-support operating systems.

Correct Answer: D — Upgrade end-of-support operating systems.

Upgrading end-of-support operating systems removes security vulnerabilities that exist in outdated systems no longer receiving patches. This directly reduces the attack surface by eliminating known exploitable weaknesses that attackers can leverage.

Why The Other Options Are Incorrect

A. A honeynet is a security monitoring tool for detecting attacks, not for reducing the

actual attack surface.

B. Group Policy defines access controls and configurations but doesn't inherently reduce the underlying attack surface of outdated systems.

C. High availability improves resilience and uptime but doesn't reduce the attack surface or vulnerability footprint.

Question #596

Which of the following is a prerequisite for a DLP solution?

A. Data destruction
B. Data sanitization
C. Data classification
D. Data masking

Correct Answer: C — Data classification

Data classification is a prerequisite for DLP (Data Loss Prevention) solutions because the system must know what data is sensitive or confidential before it can identify and prevent its unauthorized disclosure. DLP rules are built on classification levels.

Why The Other Options Are Incorrect

A. Data destruction is a data lifecycle action but not a prerequisite for implementing DLP functionality.

B. Data sanitization removes data from systems but is not required before implementing DLP controls.

D. Data masking is a protection technique that may be used alongside DLP but is not a prerequisite for DLP implementation.

Question #597

A business provides long-term cold storage services to banks that are required to follow regulator-imposed data retention guidelines. Banks that use these services require that data is disposed of in a specific manner at the conclusion of the regulatory threshold for data retention.

Which of the following aspects of data management is the most important to the bank in the destruction of this data?

A. Encryption
B. Classification
C. Certification
D. Procurement

Correct Answer: C — Certification

Certification is the most critical aspect for banks requiring regulated data disposal. Certification provides documented proof that data has been destroyed according to regulatory requirements and retention guidelines, which is essential for compliance audits and legal liability protection. While encryption and classification support data management, certification specifically demonstrates that destruction was performed correctly and can be audited.

Why The Other Options Are Incorrect

A. Encryption protects data during storage but does not address disposal requirements.

B. Classification helps organize data but is not required to prove proper destruction.

D. Procurement relates to acquiring services, not disposing of data.

Question #598

The physical security team at a company receives reports that employees are not displaying their badges. The team also observes employees tailgating at controlled entrances.

Which of the following topics will the security team most likely emphasize in upcoming security training?

A. Social engineering
B. Situational awareness
C. Phishing
D. Acceptable use policy

Correct Answer: B — Situational awareness

Situational awareness is the most relevant topic for employees not displaying badges and tailgating at controlled entrances. These behaviors indicate a lack of awareness regarding physical security protocols and environmental observations. Security training should emphasize paying attention to security procedures, monitoring surroundings, and maintaining proper access controls.

Why The Other Options Are Incorrect

A. Social engineering is about psychological manipulation, not physical security enforcement.

C. Phishing relates to email and digital attacks, not physical badge display.

D. Acceptable use policy covers appropriate system usage, not physical security practices.

Question #599

Which of the following would most likely be a hacktivist's motive?

A. Financial gain
B. Espionage
C. Philosophical beliefs
D. Revenge

Correct Answer: C — Philosophical beliefs

Hacktivists are motivated by philosophical beliefs, ideological causes, or social justice rather than financial or personal gain. They attack targets to promote their beliefs, protest policies, or raise awareness about causes they support. This distinguishes them from other threat actors who target systems for profit, espionage, or personal revenge.

Why The Other Options Are Incorrect

A. Financial gain motivates cybercriminals, not hacktivists.

B. Espionage is the motive of state-sponsored or corporate threat actors.

D. Revenge is a personal motive; hacktivists are driven by broader ideological goals.

Question #600

During a recent log review, an analyst discovers evidence of successful injection attacks.

Which of the following will best address this issue?

A. Authentication
B. Secure cookies
C. Static code analysis
D. Input validation

Correct Answer: D — Input validation

Input validation is the best control to address injection attacks by ensuring that user-supplied data is properly verified, filtered, and sanitized before being used in code execution. This prevents malicious input from being interpreted as commands. Input validation stops injection attacks at their source before they can be processed by the application.

Why The Other Options Are Incorrect

A. Authentication verifies user identity but does not prevent injection attacks.

B. Secure cookies protect session data but do not prevent code injection.

C. Static code analysis is a development tool but does not provide runtime protection against successful injection attacks.

Question #601

Which of the following is the first step to secure a newly deployed server?

A. Close unnecessary service ports.
B. Update the current version of the software.
C. Add the device to the ACL.
D. Upgrade the OS version.

✅ Correct Answer: B — Update the current version of the software.

Updating the current version of software should be the first step after deployment to patch known vulnerabilities and security issues. This establishes a secure baseline foundation before performing other hardening tasks. Applying security updates immediately after deployment addresses critical vulnerabilities that could be exploited before additional controls are implemented.

Why The Other Options Are Incorrect

A. Closing ports is important but should follow patching to address the most critical vulnerabilities first.

C. Adding to ACLs is a network control that comes after the system itself is secured.

D. OS upgrades may be necessary but updates to the current version should be applied first.

Daily Debian

Question #602

A security analyst receives an alert that there was an attempt to download known malware.

Which of the following actions would allow the best chance to analyze the malware?

A. Review the IPS logs and determine which command-and-control IPs were blocked.
B. Analyze application logs to see how the malware attempted to maintain persistence.
C. Run vulnerability scans to check for systems and applications that are vulnerable to the malware
D. Obtain and execute the malware in a sandbox environment and perform packet captures.

✅ Correct Answer: D — Obtain and execute the malware in a sandbox environment and perform packet captures.

Executing the malware in a sandbox environment with packet captures provides the best opportunity for comprehensive malware analysis. A sandbox allows safe execution and monitoring of malware behavior, communications, and persistence mechanisms without risk to production systems. Packet captures reveal network indicators of compromise and command-and-control communications that are critical for threat intelligence.

Why The Other Options Are Incorrect

A. IPS logs only show blocked communications, not the malware's actual behavior or capabilities.

B. Application logs may not capture all malware activity and persistence techniques.

C. Vulnerability scanning identifies potential weaknesses but does not analyze the malware itself.

Question #603

Which of the following should be used to ensure a user has the permissions needed to effectively do an assigned job role?

A. Changing default passwords
B. Implementing least privilege
C. Enforcing baseline configurations
D. Applying network segmentation

Correct Answer: B — Implementing least privilege

Implementing least privilege ensures users receive only the minimum permissions necessary to perform their assigned job functions. This principle balances providing necessary access for job effectiveness while minimizing security risk from excessive permissions. Least privilege directly addresses the requirement to grant appropriate permissions for job role effectiveness.

Why The Other Options Are Incorrect

A. Changing default passwords improves authentication security but does not establish appropriate permission levels.

C. Baseline configurations set security standards but do not specifically address individual permission requirements.

D. Network segmentation isolates systems but does not determine individual user permissions.

Question #604

An employee receives a text message from an unrecognized number claiming to be the Chief Executive Officer and asking the employee to purchase gift cards.

Which of the following types of attacks describes this example?

A. Watering-hole
B. Disinformation
C. Phishing
D. Impersonation

Correct Answer: D — Impersonation

This is an impersonation attack where the attacker pretends to be the Chief Executive Officer to deceive the employee. Impersonation involves fraudulently assuming the identity of a trusted person or authority to manipulate victims into taking actions. The attack relies on the victim believing they are communicating with someone in a position of authority.

Why The Other Options Are Incorrect

A. Watering-hole attacks compromise legitimate websites to infect visitors, not direct messaging.

B. Disinformation involves spreading false information, not impersonating a specific individual.

C. Phishing typically uses emails and fake websites; while this could be considered a phishing variant, impersonation is more specific to the fraudulent identity assumption.

Question #605

An unexpected and out-of-character email message from a Chief Executive Officer's corporate account asked an employee to provide financial information and to change the recipient's contact number.

Which of the following attack vectors is most likely being used?

A. Business email compromise
B. Phishing
C. Brand impersonation
D. Pretexting

Correct Answer: A — Business email compromise

Business email compromise (BEC) is a sophisticated attack where threat actors gain unauthorized access to or impersonate a legitimate business email account, typically a high-level executive like a CEO. The attacker then sends requests to employees asking for sensitive information or unusual actions (like changing contact numbers), exploiting the trust and authority associated with the executive's account. This matches the scenario perfectly: an unexpected out-of-character email from the CEO's account requesting financial data and a contact change.

Why The Other Options Are Incorrect

B. Phishing is a broader attack using fraudulent emails to trick recipients, but doesn't necessarily involve compromising a legitimate account.

C. Brand impersonation typically involves creating fake accounts or websites mimicking a brand, not compromising a legitimate executive account.

D. Pretexting involves creating a fabricated scenario to manipulate someone, but doesn't specifically describe account compromise and impersonation.

Question #606

Which of the following should an organization use to ensure that it can review the controls and performance of a service provider or vendor?

A. Service-level agreement
B. Memorandum of agreement
C. Right-to-audit clause
D. Supply chain analysis

Correct Answer: C — Right-to-audit clause

A right-to-audit clause is a contractual provision that gives an organization explicit permission to audit, inspect, and review a service provider's or vendor's controls, processes, and performance. This ensures the organization can independently verify that the vendor is meeting contractual obligations and maintaining appropriate security and operational standards. This is the most direct mechanism for reviewing vendor controls and performance.

Why The Other Options Are Incorrect

A. A service-level agreement defines expected performance metrics but doesn't grant the organization the right to audit the vendor's internal controls and operations.

B. A memorandum of agreement documents mutual understanding but typically lacks specific audit rights and enforcement mechanisms.

D. Supply chain analysis is a risk assessment practice that doesn't directly provide contractual review rights over vendor operations.

Question #607

Which of the following is used to calculate the impact to an organization per cybersecurity incident?

A. SLE
B. ALE
C. ARO

D. SLA

Correct Answer: B — ALE

Annual Loss Expectancy (ALE) is the metric used to calculate the expected financial impact to an organization from a cybersecurity incident over one year. ALE is calculated as: ALE = Single Loss Expectancy (SLE) × Annual Rate of Occurrence (ARO). While SLE represents the impact of a single incident, ALE projects the annualized financial impact, which is what organizations use to understand total per-incident economic impact when annualized. The community consensus of 100% for B indicates this is the standard answer in modern risk management frameworks.

Why The Other Options Are Incorrect

A. SLE (Single Loss Expectancy) measures the impact of one incident, not the total impact per year that an organization uses for budgeting.

C. ARO (Annual Rate of Occurrence) is a frequency metric multiplied by SLE to create ALE, not the impact calculation itself.

D. SLA (Service Level Agreement) is a contractual commitment unrelated to incident impact calculation.

Question #608

A retail company receives a request to remove a customer's data.

Which of the following is the retail company considered under GDPR legislation?

A. Data processor
B. Data controller
C. Data subject
D. Data custodian

Correct Answer: B — Data controller

Under GDPR, the data controller is the organization that determines the purposes and means of processing personal data. A retail company that receives a deletion request from a customer is acting as the data controller because it decides how and why customer data is processed, and it is the entity responsible for fulfilling data subject rights requests, including the right to erasure. The data controller has the legal obligation to respond to and implement such requests.

Why The Other Options Are Incorrect

A. A data processor processes data on behalf of a controller but doesn't directly determine purposes or directly respond to subject requests.

C. A data subject is the individual whose data is being processed, not the company receiving the deletion request.

D. Data custodian is not an official GDPR role and typically refers to IT personnel maintaining data, not the legally responsible entity.

Question #609

An administrator implements web-filtering products but still sees that users are visiting malicious links.

Which of the following configuration items does the security administrator need to review?

A. Intrusion prevention system
B. Content categorization
C. Encryption
D. DNS service

Correct Answer: B — Content categorization

Content categorization is the feature within web-filtering products that classifies websites and URLs into categories (malicious, phishing, adult content, etc.). If users are still accessing malicious links despite web filtering being implemented, the problem likely lies in improper or incomplete content categorization—either the malicious sites aren't being properly identified and categorized, or the categories aren't configured to block appropriately. Reviewing and updating content categorization databases and rules would directly address this gap.

Why The Other Options Are Incorrect

A. An IPS (Intrusion Prevention System) detects network attacks but is separate from web-filtering and wouldn't directly filter malicious links at the application layer.

C. Encryption protects data in transit but doesn't filter or block access to malicious websites.

D. While DNS filtering could help block malicious domains, content categorization within the web filter itself is the primary mechanism that should be reviewed when the web filter itself is deployed but ineffective.

Question #610

A security analyst is reviewing the following logs about a suspicious activity alert for a user's VPN log-ins:

Date	Time	Action	SourceIP	City-State-Country
2023-01-23	08:21:41	Success	207.414.201.19	Chicago-IL-USA
2023-01-24	08:23:41	Success	207.414.201.19	Chicago-IL-USA
2023-01-25	08:29:39	Success	207.414.201.19	Chicago-IL-USA
2023-01-26	08:27:44	Success	207.414.201.19	Chicago-IL-USA
2023-01-27	08:22:24	Success	207.414.201.19	Chicago-IL-USA
2023-01-27	09:45:35	Success	185.17.106.237	Rome-Italy
2023-01-27	09:47:55	Success	188.17.105.137	Rome-Italy
2023-01-27	09:55:36	Success	207.414.201.19	Chicago-IL-USA
2023-01-27	16:28:15	Success	207.414.201.19	Chicago-IL-USA

Which of the following malicious activity indicators triggered the alert?

A. Impossible travel
B. Account lockout
C. Blocked content
D. Concurrent session usage

Correct Answer: A — Impossible travel

The logs show successful VPN logins from geographically distant locations within an impossibly short timeframe. On 2023-01-27, there are successful logins from Chicago, IL, USA at 08:22:24 and 08:27:44, followed by logins from Rome, Italy at 09:45:35 and 09:47:55, then back to Chicago at 09:55:36. It is physically impossible for a user to travel from Chicago to Rome (approximately 5,000+ miles) in roughly 1 hour and 20 minutes, making this a classic impossible travel scenario that triggers security alerts.

Why The Other Options Are Incorrect

B. Account lockout would typically appear as 'Failed' or 'Locked' actions in the logs, not multiple 'Success' entries.

C. Blocked content would show blocked or denied actions, not successful VPN authentications across multiple entries.

D. While concurrent sessions from different locations could be suspicious, impossible travel is the more specific and primary indicator demonstrated by the extreme geographic distance covered in minimal time.

Question #611

Which of the following phases of the incident response process attempts to minimize disruption?

A. Recovery
B. Containment
C. Preparation
D. Analysis

Correct Answer: B — Containment

Containment is the incident response phase focused on stopping the attack and limiting its scope and impact. The primary goal of containment is to minimize disruption by preventing further damage, isolating affected systems, and stopping the attacker's access or movement within the network. This phase occurs after detection and analysis and before recovery, and it directly addresses the objective of reducing negative impact to the organization.

Why The Other Options Are Incorrect

A. Recovery focuses on restoring systems to normal operations after containment, not on minimizing disruption during the active incident.

C. Preparation involves setting up tools and procedures before an incident occurs, not addressing disruption during an active incident.

D. Analysis investigates what happened but doesn't take action to minimize ongoing disruption.

Daily Debian

Daily Debian

Thank You

for purchasing CompTIA Security+ SY0-701 Exam Practice Questions

We hope these questions serve you well in your exam preparation.

Any questions, or a problem with this PDF? Get in touch. We reply to every message.

Telegram	**@DailyDebian**
Email	**support@dailydebian.com**
YouTube	**www.youtube.com/@DailyDebian**
Instagram	**www.instagram.com/dailydebian**

More PDFs at **www.dailydebian.com**